République du Cameroun

Chaire UNESCO d'Afrique Centrale Accès TIC

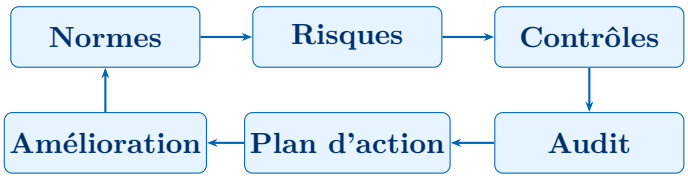
Sous la tutelle académique de l'École Nationale Supérieure Polytechnique de l'Université de Yaoundé I

Master Professionnel en Sécurité des Systèmes Numériques

Normes, Gestion des Risques et Audit de Cybersécurité

Du référentiel à la preuve :
piloter, mesurer et auditer la sécurité

NRAC - UE MSN-2S3-SEC08



oui / non / nek $\longrightarrow$ μ (conformité) · U (incertitude) · H (entropie)

MINKA MI NGUIDJOÏ Thierry Emmanuel

Enseignant Chercheur | LIMSI | ENSPY

Chaire UNESCO d'Afrique Centrale Accès TIC

maletyon@proton.me

Année académique 2026–2027

Version 1.0 | Document pédagogique de l'UE MSN-2S3-SEC08

AVANT-PROPOS

Une banque peut être certifiée et compromise la même année. Ce paradoxe apparent, qui ouvre ce livre, n'a rien d'exceptionnel : il naît chaque fois qu'une organisation confond ce qu'elle a fait vérifier avec ce qu'elle est réellement, et ce qu'elle a regardé avec ce qui existe. Les normes, les méthodes de gestion des risques et l'audit sont les outils dont on dispose pour réduire cet écart ; ils peuvent aussi le masquer, quand on les emploie pour rassurer plutôt que pour savoir.

Ce cours s'adresse aux étudiants du master professionnel en management des systèmes numériques, spécialité sécurité des systèmes numériques, de la Chaire UNESCO d'Afrique centrale, et aux praticiens qui exercent ou exerceront les métiers de responsable de la sécurité des systèmes d'information, d'auditeur en cybersécurité, de gestionnaire des risques cyber, de responsable GRC ou de consultant en mise en œuvre de systèmes de management. Il suppose les bases de la cybersécurité ; il ne suppose aucune connaissance préalable des normes, de la gestion des risques ni de l'audit.

Il a trois partis pris. Le premier est de relier, plutôt que de juxtaposer, les normes, le risque et l'audit : une même organisation les vit ensemble, et les échecs naissent souvent entre eux. Le deuxième est d'ancrer chaque notion dans le contexte camerounais et africain : le droit de la cybersécurité, la régulation bancaire de la CEMAC, les organismes publics et leurs contrôleurs, au côté des normes internationales. Le troisième est de mesurer ce que l'on ne sait pas : chaque cote, chaque conclusion, chaque chiffre du livre dit sur quoi il repose, et l'instrument OUI / NON / NEK, issu du programme de recherche de l'auditologie, donne à cette exigence une forme mesurable.

Les trois organisations qui accompagnent le lecteur, la BANQUE SANAGA, LiZbiZ et l'ANPP, sont fictives, comme leurs dirigeants, leurs prestataires, les dates et les montants. Les mécanismes, les normes et les textes cités sont exacts, avec, pour chaque texte, le degré de vérification indiqué à l'annexe D. Les normes sous licence sont paraphrasées, jamais citées.

Le livre est accompagné d'un livret des corrigés, qui explique et annote chaque exercice, et de NDAP SUKULU, sur lequel les fiches d'auto-évaluation et les ateliers du cours permettent de pratiquer chaque chapitre.

Minka Mi Nguidjoi Thierry Emmanuel
Enseignant & Chercheur en Cryptographie et Sécurité de l'Information

Yaoundé, novembre 2026

© *MaletYon*

MODE D'EMPLOI DU COURS

Structure générale

Le cours compte un prologue et six parties, soit 16 chapitres, pour 30 heures en présentiel réparties en quinze séances de deux heures, qui couvrent l'ensemble des parties. Les fiches de questions-réponses par chapitre et les dix laboratoires de 60 minutes de NDAP SUKULU sont des travaux à faire à la maison, hors de ces 30 heures. Les corrigés des exercices sont réunis dans un livret séparé.

Partie	Thème	Chap.	Niveau
0	Prologue : certifiée, et pourtant compromise	P	introductif
I	Fondements : gouvernance, risque et incertitude	1–2	fondamental
II	Méthodes : gérer les risques, conduire l'audit	3–7	fondamental à intermédiaire
III	Cadre normatif et juridique	8–10	fondamental
IV	Pratique : SMSI, audit technique et GRC	11–14	intermédiaire à expert
V	Défis avancés	15	expert
VI	Recherche : mesurer ce que l'on ne sait pas	16	recherche

Les quinze séances

© *MaletYon*

Séance	Contenu	Travail à la maison
1	Prologue : le certificat, le périmètre, l'inconnu	Fiche P
2	Chap. 1 : gouverner la cybersécurité	Fiche 1
3	Chap. 2 : le risque cyber et sa cote	Fiche 2, atelier TD01
4	Chap. 3 : ISO 31000 et ISO/IEC 27005	Fiche 3
5	Chap. 4 : EBIOS Risk Manager	Fiche 4, ateliers TD02 et TD03
6	Chap. 5 : quantifier avec FAIR	Fiche 5, atelier TD04
7	Chap. 6 : conduire un audit	Fiche 6
8	Chap. 7 : décomposer, coter, conclure	Fiche 7, atelier TD05
9	Chap. 8 : la famille ISO/IEC 27000	Fiche 8, atelier TD06
10	Chap. 9 : référentiels et correspondances	Fiche 9, atelier TD07
11	Chap. 10 : droit et déontologie	Fiche 10
12	Chap. 11 : mettre en œuvre et auditer un SMSI	Fiche 11, atelier TD08
13	Chap. 12 : l'audit technique	Fiche 12, atelier TD09
14	Chap. 13 et 14 : la GRC en pratique, les cas intégrateurs	Fiches 13 et 14, atelier TD10
15	Chap. 15 et 16 : risques émergents, mesurer l'inconnu	Fiches 15 et 16

Cette répartition est indicative ; l'enseignant l'adapte au calendrier et au rythme du groupe.

Les dix laboratoires de NDAP SUKULU

Les dix laboratoires, NRAC-LAB-01 à NRAC-LAB-10, sont présentés dans la section « NDAP SUKULU, la salle de classe compagnon », qui suit ce mode d'emploi.

Le gabarit des chapitres

Chaque chapitre suit le même plan : une épigraphe, le niveau et les prérequis, les objectifs, une situation d'ouverture tirée de l'un des trois cas, cinq à huit sections, ce qu'il faut retenir, des points de contrôle, trois à quatre exercices gradués, des lectures, et une transition.

Les encadrés

Encadré	Rôle
Objectifs	Ce que l'on doit savoir faire à la fin du chapitre
Définition	Les notions, en gras dans le texte et indexées
Violation typique	Une erreur fréquente, et la règle qui l'évite
Information	Un complément, un renvoi, une nuance
Opération (SANAGA, LIZBIZ, ANPP)	Le cas : les constatations, puis l'analyse, avec un niveau de confiance
Lecture	Un calcul de μ, U et H, et sa lecture
Fiche de risque	Un risque décrit, coté et décidé
Papier de travail	Ce que le dossier doit contenir pour être refait par un autre
Métier	Ce que la notion change pour chacun des cinq métiers du cours
Texte juridique	Un article cité dans son texte officiel, et sa portée
Ce qu'il faut retenir	La synthèse du chapitre
Exercice	Trois niveaux de difficulté : ★☆☆, ★★☆, ★★★

Les conventions

- **Les cotes** : OUI (établi par une preuve), NON (absent ou contredit par une preuve), NEK (connaissance insuffisante). Aucun barème ne donne de demi-point à NEK.
- **Les mesures** : le taux de conformité μ, le taux d'incertitude U et l'entropie H, en bits, se lisent toujours ensemble ; règle de décision : U d'abord, μ ensuite, H pour contrôler (Chapitre 7).
- **L'échelle de cotation** des risques est celle du Chapitre 2 (quatre niveaux de vraisemblance et d'impact, criticité de 1 à 16).
- **Constatation et analyse** sont toujours séparées ; l'analyse porte un niveau de confiance.
- **Les textes** : seuls les articles lus dans leur version officielle sont cités entre guillemets ; les normes sous licence sont paraphrasées ; le degré de vérification figure à l'annexe D.
- **Les travaux de recherche** sont cités avec leur statut : prépublication déposée, ou travail en préparation (Chapitre 16).
- **Les cas** sont fictifs : noms en majuscules, montants en francs CFA, villes réelles.

NDAP SUKULU, LA SALLE DE CLASSE COMPAGNON



Un nom venu du pays bassa

> *Le soir tombe sur Éséka. Un enfant revient des champs avec son grand-père et lui demande pourquoi il doit marcher si loin, chaque matin, pour aller à l'école. Le vieil homme s'arrête au bord du chemin et répond, en bassa : «* Ndap sukulu*, la salle de classe, ce ne sont pas les murs. Ce sont les murs qui viennent après. La salle de classe, c'est l'endroit où quelqu'un t'attend pour t'apprendre ce qu'il sait. » L'enfant insiste : « Et qui m'attend ? » Le grand-père sourit : «* Malet yon*. Ton enseignant. »*

En bassa, la langue paternelle de l'auteur, ***ndap sukulu*** désigne la salle de classe et ***malet yon*** signifie « ton enseignant ». L'environnement compagnon de ce cours porte ce nom parce qu'il prolonge la salle de classe au-delà des heures de cours : il attend l'étudiant le soir, le week-end, à distance, avec des questions, des pièces à examiner et une correction immédiate. Il est édité par **MaletYon**, « ton enseignant », et mis à la disposition des étudiants et des praticiens qui souhaitent se perfectionner (maletyon@proton.me).

Ce que l'on y trouve

- **Une fiche d'auto-évaluation par chapitre.** Chaque fiche puise vingt questions dans une banque de quarante (QCM, vrai ou faux, textes à trous). Elle dure trente minutes ; la copie validée est verrouillée et notée aussitôt. Le seuil de réussite est de 60 %.
- **Des laboratoires pratiques.** Chaque lab place l'étudiant devant les pièces d'une affaire du fil rouge (tableurs, journaux, contrats, procès-verbaux) dans un bureau d'analyste virtuel, ouvert dans le navigateur. Il dure soixante minutes, se termine par des points de contrôle notés automatiquement et renvoie aux sections du livre qu'il mobilise.

© *MaletYon*

➢ **Un suivi pour l'enseignant** : rapport de classe, notes par fiche et par lab, journal d'activité.

Les fiches et les labs sont des travaux à faire hors des heures de cours. Ils ne remplacent ni le livre ni les exercices de fin de chapitre : ils en vérifient la maîtrise.

Comment y travailler

1. Se connecter au portail NDAP SUKULU avec ses identifiants et le code de cours **MSN-2S3-SEC08**.
2. Pour un lab, commencer par vérifier l'empreinte SHA-256 des pièces (`sha256sum -c MANIFESTE_SHA256.txt`), puis travailler sur la copie du dossier `travail` : les pièces originales sont en lecture seule et l'activité est journalisée, comme dans une vraie mission.
3. Lire le rappel de cours affiché par le lab et relire les sections citées avant de répondre.

Note

Si le portail n'est pas encore ouvert. En attendant le déploiement de NDAP SUKULU, les fiches de questions sont fournies au format texte dans le dossier `fiches` du cours, prêtes à être distribuées. Les corrections des fiches figurent dans le livret de correction, à la suite des corrigés des exercices de chaque chapitre.

Les laboratoires du cours

Le cours compte dix laboratoires, disponibles sous le code MSN-2S3-SEC08. Le dernier rassemble le dispositif de GRC de la BANQUE SANAGA et sert de synthèse.

Lab	Sujet	Chapitre	Opération
NRAC-LAB-01	Coter le registre des risques et sa base de preuve	2	SANAGA
NRAC-LAB-02	EBIOS Risk Manager : cadrage et sources de risque	4	LIZBIZ
NRAC-LAB-03	EBIOS Risk Manager : écosystème et scénario opérationnel	4	LIZBIZ
NRAC-LAB-04	Quantifier un risque cyber avec FAIR	5	SANAGA
NRAC-LAB-05	Décomposer, coter, conclure	7	SANAGA
NRAC-LAB-06	Confronter une déclaration d'applicabilité aux preuves	8	SANAGA
NRAC-LAB-07	Une base commune, plusieurs référentiels	9	ANPP
NRAC-LAB-08	Auditer un SMSI	11	SANAGA
NRAC-LAB-09	Audit technique sur exports figés	12	LIZBIZ
NRAC-LAB-10	Synthèse GRC : obligations, matrice, indicateurs	13	SANAGA

Les laboratoires du cours dans NDAP SUKULU

TABLE DES MATIÈRES

Avant-propos iii

Mode d'emploi du cours v

NDAP SUKULU, la salle de classe compagnon ix

Prologue Opérationnel 3

0 Certifiée, et pourtant Compromise 3

0.1 Ce qui s'est passé . . . 4
0.1.1 La chronologie . . . 4
0.1.2 Constater, puis analyser . . . 5
0.2 Certificat, conformité, sécurité . . . 6
0.2.1 Trois choses différentes . . . 6
0.2.2 Le périmètre, première décision de sécurité . . . 6
0.3 Un Risque jamais Apprécié n'est pas un Risque Faible . . . 7
0.3.1 Le trou dans le registre . . . 7
0.3.2 Une fiche de risque . . . 7
0.4 Lire la Sécurité par Trois Mesures . . . 8
0.4.1 Deux colonnes, un certificat . . . 8
0.4.2 Trois mesures . . . 9
0.5 Cinq Réflexes . . . 9
0.5.1 Ce que l'incident dit à chaque métier . . . 10
0.6 Le Cours et son Fil Rouge . . . 11
0.6.1 Une discipline, une mesure . . . 11
0.6.2 Trois cas . . . 12
0.6.3 Le parcours . . . 12

I Fondements : Gouvernance, Risque et Incertitude 17

1 Gouverner la Cybersécurité : du Contrôle à la GRC 19

1.1 Du Contrôle à la GRC . . . 20
1.1.1 Trois âges de la sécurité . . . 20
1.1.2 Gouvernance, risque, conformité . . . 21
1.2 Gouverner n'est pas Gérer . . . 22

1.2.1 Deux niveaux de décision . . . 22
1.2.2 Ce que la norme attend de la direction . . . 22
1.2.3 Le cadre NIST : gouverner d'abord . . . 23
1.3 Le Modèle des Trois Lignes appliqué à la Sécurité . . . 23
1.3.1 Le modèle . . . 23
1.3.2 Où placer le RSSI ? . . . 24
1.3.3 Ce que le modèle ne dit pas . . . 24
1.4 Les Acteurs et leurs Responsabilités . . . 25
1.4.1 Huit acteurs . . . 25
1.4.2 Le propriétaire du risque R-AG-01 . . . 26
1.4.3 Rattacher le RSSI . . . 26
1.5 La Matrice RACI de la Sécurité . . . 27
1.5.1 Quatre lettres . . . 27
1.5.2 La matrice de la BANQUE SANAGA, après l'incident . . . 28
1.6 Mesurer la Gouvernance . . . 29
1.6.1 Huit questions . . . 29
1.6.2 Ce que la mesure ajoute . . . 30
1.7 Le Cadre Camerounais . . . 30
1.8 Ce que la Gouvernance demande à chaque Métier . . . 31
2 Le Risque Cyber : Notions, Mesure, Incertitude 35
2.1 Définir le Risque Cyber . . . 36
2.1.1 L'effet de l'incertitude sur les objectifs . . . 36
2.1.2 Les deux portes d'entrée de l'ISO/IEC 27005 . . . 36
2.2 Les Composantes d'un Risque . . . 37
2.2.1 Huit notions . . . 37
2.2.2 Le scénario R-AG-01, décomposé . . . 38
2.3 Ce qui rend le Risque Cyber Particulier . . . 38
2.4 Coter un Risque . . . 39
2.4.1 Une échelle commune . . . 39
2.4.2 L'appétence, traduite sur l'échelle . . . 40
2.4.3 Ce que la matrice cache . . . 40
2.5 Inhérent, Résiduel, Appétence . . . 41
2.5.1 Trois niveaux . . . 41
2.5.2 Une convention de réduction . . . 41
2.5.3 R-AG-01, coté . . . 42
2.6 Une Cote sans Preuve est une Incertitude . . . 42
2.6.1 Deux incertitudes . . . 42
2.6.2 Coter la cote . . . 43
2.6.3 Quand la cote est un intervalle . . . 45
2.6.4 La fiche de risque, avec sa base de preuve . . . 45
2.7 Le Cadre de Référence . . . 45

2.8 Ce que la Cote demande à chaque Métier 46

II Méthodes : Gérer les Risques, Conduire l'Audit 51

3 Gérer les Risques : ISO 31000 et ISO/IEC 27005 53

3.1 L'ISO 31000 : Principes, Cadre, Processus 54
3.1.1 Une norme générale 54
3.1.2 Le processus 55
3.1.3 L'ISO/IEC 27005, déclinaison pour la sécurité de l'information 55
3.2 Établir le Contexte 55
3.2.1 Périmètre et parties intéressées 55
3.2.2 Critères de risque, critères d'acceptation 56
3.3 Apprécier : Deux Approches qui se Complètent 57
3.3.1 Identifier 57
3.3.2 Analyser et évaluer 58
3.4 Traiter 58
3.4.1 Les options 58
3.4.2 Les options pour R-AG-01 58
3.4.3 Le plan de traitement 59
3.5 Accepter le Risque Résiduel 60
3.5.1 Une décision, pas un constat 60
3.5.2 Le cas de DIGICORE 60
3.6 Suivre et Revoir 61
3.6.1 Le programme 2027, neuf mois plus tard 61
3.6.2 Quand revoir 62
3.7 Le Cadre Camerounais 63
3.8 Ce que le Processus demande à chaque Métier 63

4 EBIOS Risk Manager 69

4.1 La Méthode 70
4.1.1 Origine et logique 70
4.1.2 Cinq ateliers 71
4.2 Atelier 1 : Cadrage et Socle de Sécurité 71
4.2.1 Périmètre, valeurs métier, biens supports 71
4.2.2 Événements redoutés et gravité 72
4.2.3 Le socle de sécurité 72
4.3 Atelier 2 : Sources de Risque 72
4.3.1 Des couples, pas des menaces 72
4.4 Atelier 3 : Scénarios Stratégiques 73
4.4.1 L'écosystème 73
4.4.2 Trois scénarios stratégiques 74

4.4.3 Ce que valent les cotes de l'écosystème . . . 75
4.5 Atelier 4 : Scénarios Opérationnels . . . 76
4.5.1 Du chemin au mode opératoire . . . 76
4.5.2 Le mode opératoire de SS1 . . . 76
4.6 Atelier 5 : Traitement du Risque . . . 77
4.7 Situer EBIOS parmi les Méthodes . . . 77
4.8 Ce que la Méthode demande à chaque Métier . . . 78

5 Quantifier le Risque Cyber : FAIR 83

5.1 Pourquoi Quantifier . . . 84
5.2 La Taxonomie FAIR . . . 84
5.2.1 Une décomposition . . . 84
5.2.2 Six formes de pertes . . . 86
5.3 Estimer . . . 86
5.3.1 Des estimations calibrées . . . 86
5.3.2 Les estimations de R-AG-01 . . . 86
5.3.3 La base de preuve des estimations . . . 87
5.4 La Simulation de Monte-Carlo . . . 87
5.4.1 Le principe . . . 87
5.4.2 Dix années, à la main . . . 88
5.4.3 Cent mille années . . . 89
5.5 Interpréter et Décider . . . 89
5.5.1 Lire la distribution . . . 89
5.5.2 L'appétence en francs CFA . . . 90
5.5.3 L'assurance, chiffrée . . . 90
5.6 Ce que la Quantification Masque . . . 90
5.6.1 Des chiffres faits d'opinions . . . 90
5.6.2 Cinq angles morts . . . 91
5.7 Ce que la Quantification demande à chaque Métier . . . 92

6 Conduire un Audit de Cybersécurité 97

6.1 Ce qu'est un Audit . . . 98
6.1.1 Cinq notions . . . 98
6.1.2 Sept principes . . . 99
6.1.3 Quatre familles d'audit . . . 99
6.2 Le Cycle de la Mission . . . 100
6.2.1 Programme et mission . . . 100
6.2.2 Le mandat . . . 100
6.2.3 La préparation . . . 101
6.3 Collecter et Apprécier la Preuve . . . 101
6.3.1 Trois techniques, et leurs variantes . . . 101
6.3.2 La fiabilité de la preuve . . . 102

6.3.3 Échantillonner . . . 102
6.4 Coter les Tests . . . 103
6.4.1 Les résultats de terrain . . . 103
6.4.2 Le cas du NEK . . . 104
6.4.3 Le papier de travail . . . 104
6.5 Le Contradictoire et le Rapport . . . 104
6.5.1 La réunion de clôture . . . 104
6.5.2 Le rapport et le suivi . . . 105
6.6 Le Cadre Camerounais . . . 106
6.7 Ce que l'Audit demande à chaque Métier . . . 106

7 Décomposer, Coter, Conclure 111

7.1 Décomposer . . . 112
7.1.1 Pourquoi décomposer . . . 112
7.1.2 Le gabarit canonique . . . 112
7.1.3 Trois conditions de qualité . . . 113
7.1.4 Le réseau d'agences, décomposé . . . 113
7.2 Coter un Contrôle . . . 113
7.2.1 La fiche d'assertion . . . 114
7.2.2 Un contrôle, trois critères . . . 114
7.2.3 De la cote des critères à celle du contrôle . . . 115
7.3 Mesurer et Localiser l'Incertitude . . . 115
7.3.1 Trois mesures . . . 115
7.3.2 Par sous-domaine . . . 116
7.4 Conclure . . . 117
7.4.1 Le quadrant conformité × incertitude . . . 117
7.4.2 La règle de décision . . . 118
7.4.3 Pas de niveau de maturité pour un domaine opaque . . . 119
7.5 Rédiger l'Observation . . . 119
7.5.1 Sept éléments . . . 119
7.5.2 Le nouveau risque . . . 120
7.6 Ce que la Conclusion demande à chaque Métier . . . 120

III Cadre Normatif et Juridique 125

8 La Famille ISO/IEC 27000 127

8.1 Une Famille de Normes . . . 128
8.2 L'ISO/IEC 27001:2022 . . . 129
8.2.1 Une structure commune . . . 129
8.2.2 Ce qui a changé en 2022 . . . 129
8.2.3 Le cycle de certification . . . 130

8.3 L'ISO/IEC 27002:2022 . . . 130
8.3.1 93 mesures, quatre thèmes . . . 130
8.3.2 Les attributs . . . 131
8.4 La Déclaration d'Applicabilité . . . 132
8.4.1 Ce qu'elle contient . . . 132
8.4.2 Un extrait . . . 132
8.4.3 Confronter la déclaration aux preuves . . . 133
8.4.4 L'exclusion de 8.28 . . . 133
8.5 Mesurer et Auditer le SMSI . . . 134
8.6 Ce que la Norme demande à chaque Métier . . . 134

9 Les Autres Référentiels et leurs Correspondances 139

9.1 Le Cadre de Cybersécurité du NIST . . . 140
9.1.1 Six fonctions, vingt-deux catégories . . . 140
9.1.2 Profils et niveaux . . . 140
9.2 Catalogues de Mesures . . . 141
9.2.1 NIST SP 800-53 . . . 141
9.2.2 Les CIS Controls . . . 141
9.2.3 PCI DSS . . . 142
9.3 Rapports d'Assurance et Gouvernance . . . 142
9.3.1 SOC 2 et ISAE 3402 . . . 142
9.3.2 COBIT 2019 . . . 143
9.4 Les Tables de Correspondance . . . 143
9.4.1 Ce qu'est une correspondance . . . 143
9.4.2 La base commune de l'ANPP . . . 143
9.4.3 Tester une fois, rendre compte trois fois . . . 144
9.5 Choisir ses Référentiels . . . 145
9.6 Ce que les Référentiels demandent à chaque Métier . . . 146

10 Le Cadre Camerounais et Africain, la Déontologie 149

10.1 Panorama des Textes . . . 150
10.2 La Loi sur la Cybersécurité . . . 150
10.2.1 L'audit de sécurité et l'ANTIC . . . 151
10.2.2 L'ANPP est-elle soumise ? . . . 151
10.2.3 Des obligations qui deviennent des critères . . . 151
10.2.4 Le secret, et l'obstruction . . . 153
10.3 La Réglementation Bancaire . . . 153
10.4 Le Cadre Africain et les Données Personnelles . . . 154
10.4.1 La Convention de Malabo . . . 154
10.4.2 Les données personnelles pendant l'audit . . . 154
10.5 La Déontologie de l'Auditeur . . . 154
10.5.1 Cinq principes . . . 154

10.5.2 Les menaces sur l'indépendance . . . 155
10.5.3 Constater n'est pas qualifier . . . 156
10.5.4 Une obligation de moyens . . . 156
10.6 Ce que la Loi et la Déontologie demandent à chaque Métier . . . 156

IV Pratique : SMSI, Audit Technique et GRC 161

11 Mettre en Œuvre et Auditer un SMSI 163

11.1 Mettre en Œuvre : un Projet, puis un Système . . . 164
11.1.1 Les étapes . . . 164
11.1.2 Un périmètre défendable . . . 165
11.1.3 Les informations documentées . . . 165
11.2 Mesurer : les Indicateurs du SMSI . . . 166
11.2.1 Deux familles de mesures . . . 166
11.2.2 Les six indicateurs de la RSSI . . . 167
11.2.3 Un indicateur vaut ce que vaut sa source . . . 167
11.3 Auditer le SMSI . . . 168
11.3.1 Deux objets . . . 168
11.3.2 La revue de direction . . . 168
11.4 L'Audit de Certification et ses Constats . . . 169
11.4.1 Majeure, mineure . . . 169
11.4.2 Les constats de CERTIQUAL AFRIQUE . . . 170
11.4.3 Ce qui suit . . . 170
11.5 Ce que le SMSI demande à chaque Métier . . . 171

12 L'Audit Technique de Sécurité 175

12.1 Trois Activités Techniques . . . 176
12.1.1 Le droit de tester . . . 176
12.2 Travailler sur des Exports Figés . . . 177
12.2.1 Pourquoi figer . . . 177
12.2.2 L'exhaustivité . . . 178
12.3 Auditer la Configuration . . . 178
12.3.1 Une référence écrite . . . 178
12.3.2 Lire un export . . . 179
12.4 Auditer la Segmentation . . . 179
12.5 Auditer les Comptes et la Journalisation . . . 180
12.5.1 Les comptes . . . 180
12.5.2 La journalisation . . . 180
12.6 Auditer la Gestion des Vulnérabilités . . . 180
12.6.1 Le processus avant le scan . . . 180
12.6.2 Prioriser . . . 181

12.7 Deux Passages, Quatre Centres . . . 181
12.8 Ce que l'Audit Technique demande à chaque Métier . . . 182

13 La GRC en Pratique 187

13.1 Un Dispositif Unique . . . 188
13.2 Les Deux Registres . . . 188
13.2.1 Le registre des risques . . . 188
13.2.2 Le registre des obligations . . . 189
13.3 La Matrice Risques-Contrôles . . . 190
13.3.1 Croiser . . . 191
13.3.2 Lire la matrice . . . 191
13.4 Les Indicateurs de Risque . . . 192
13.4.1 Risque ou performance . . . 192
13.5 Le Tableau de Bord GRC . . . 192
13.5.1 Une page pour la gouvernance . . . 192
13.6 Le Contrôle Continu de la Conformité . . . 193
13.6.1 Des contrôles qui se vérifient seuls . . . 193
13.6.2 Les limites . . . 194
13.7 Ce que la GRC demande à chaque Métier . . . 194

14 Études de Cas Intégratrices 199

14.1 Une Méthode en Dix Questions . . . 200
14.2 BANQUE SANAGA : du Rançongiciel au Certificat . . . 200
14.2.1 Le fil . . . 201
14.2.2 Ce que les mesures racontent . . . 201
14.2.3 Ce que le cas enseigne . . . 202
14.3 LiZbiZ : de la Fraude au Client Exigeant . . . 202
14.3.1 Le fil . . . 203
14.3.2 Ce que le cas enseigne . . . 203
14.4 ANPP : un Organisme Public sous Trois Regards . . . 203
14.4.1 Le fil . . . 204
14.4.2 Ce que le cas enseigne . . . 204
14.5 Dix Erreurs à ne pas Commettre . . . 205
14.6 Préparer l'Épreuve de Synthèse . . . 205
14.7 Le Parcours de chaque Métier . . . 206

V Défis Avancés 209

15 Risques Émergents et Nouveaux Objets d'Audit 211

15.1 Les Tiers et la Chaîne d'Approvisionnement . . . 212
15.1.1 Un risque qui vient de l'extérieur . . . 212

15.1.2 Le cycle de vie d'un tiers . . . 212
15.2 Auditer un Service en Nuage . . . 213
15.2.1 La responsabilité partagée . . . 213
15.2.2 Les référentiels du nuage . . . 214
15.3 L'Intelligence Artificielle . . . 214
15.3.1 Des risques nouveaux . . . 214
15.3.2 Deux cadres . . . 215
15.3.3 Deux usages à la BANQUE SANAGA . . . 215
15.4 L'Audit Continu . . . 216
15.4.1 De l'échantillon à la population . . . 216
15.4.2 Les conditions et les limites . . . 217
15.5 Ce que les Nouveaux Objets demandent à chaque Métier . . . 218

VI Recherche : Mesurer ce que l'on ne Sait pas 221

16 Mesurer ce que l'on ne Sait pas 223

16.1 L'Auditologie . . . 224
16.1.1 L'objet . . . 224
16.1.2 Six axiomes . . . 224
16.1.3 Cinq piliers et une méthode . . . 226
16.2 L'Instrument et ses Métriques . . . 226
16.2.1 Quatre conditions pour NEK . . . 226
16.2.2 Décomposer l'entropie . . . 226
16.2.3 Comparer deux cycles . . . 227
16.3 L'Usage Stratégique de NEK . . . 228
16.4 Établi, Déposé, en Préparation . . . 228
16.4.1 Les travaux en préparation . . . 229
16.4.2 Questions ouvertes pour le risque cyber . . . 229
16.5 Formuler un Sujet de Recherche . . . 230

A Glossaire 233

B Référentiel des Outils 239

C Modèles de Documents Opérationnels 241

D Textes et Normes de Référence 245

E Bibliographie Commentée 249

F Contacts et Ressources 251

Références bibliographiques 253

TABLE DES FIGURES

1.1 L'articulation de la gouvernance, du risque et de la conformité 21

2.1 Les composantes du scénario R-AG-01 38

3.1 Le processus de management du risque (d'après l'ISO 31000:2018) 55

5.1 La taxonomie FAIR (d'après Freund et Jones, 2015) 85

6.1 Le cycle d'une mission d'audit 100

7.1 Le quadrant diagnostique (d'après l'article sur l'incertitude épistémique ; seuils du cours) 117

13.1 Le référentiel commun de la GRC 188

© *MaletYon*

LISTE DES TABLEAUX

© *MaletYon*

Prologue Opérationnel

© *MaletYon*

0

PROLOGUE : CERTIFIÉE, ET POURTANT COMPROMISE

« Un certificat dit ce qui a été audité.
Il ne dit rien de ce qui ne l'a pas été. »

Principe du cours

Niveau : *Introductif* • Aucun prérequis de gestion des risques ni d'audit. Les notions de base de la cybersécurité (MSN-1S1-SEC01) suffisent.

✦ Objectifs du chapitre

- ➢ Reconstituer, à partir de ses traces, la compromission d'une banque certifiée ISO/IEC 27001.
- ➢ Distinguer un certificat, la conformité à une norme et la sécurité effective.
- ➢ Lire le périmètre d'un système de management de la sécurité et repérer un périmètre de complaisance.
- ➢ Reconnaître qu'un risque jamais apprécié n'est pas un risque faible, mais une inconnue.
- ➢ Lire un ensemble de contrôles par trois mesures : μ, U et H.
- ➢ Énoncer les cinq réflexes du cours et situer ses parties, ses ateliers et ses cas.

Avant de commencer : un certificat au mur, des guichets fermés

Douala, jeudi 17 septembre 2026. Dans le hall du siège de la BANQUE SANAGA[1], un cadre doré présente le certificat ISO/IEC 27001 obtenu quinze mois plus tôt. Dans les étages, la cellule de crise en est à sa troisième nuit. Neuf agences sur trente-huit ont gardé leurs guichets fermés pendant trois jours ; 180 postes de travail ont été chiffrés par un rançongiciel ; les attaquants réclament 90 millions de francs CFA.

Le directeur général, M. FOTSO, pose la question que tout le monde se pose : « Nous

[1] La BANQUE SANAGA, ses dirigeants, ses prestataires, l'organisme certificateur, les dates et les montants de ce cas sont fictifs. Les mécanismes d'attaque, les normes et les textes cités sont exacts.

© MaletYon

sommes certifiés. Comment est-ce possible ? » La responsable de la sécurité des systèmes d'information, Mme ABENA, répond par une seule phrase : « Le certificat porte sur le centre de données. L'attaque est passée par une agence. »

Ce prologue reconstitue l'incident, montre pourquoi il ne contredit pas le certificat, et en tire les réflexes qui structurent tout le cours. Il ne suppose aucune connaissance préalable des normes ni de l'audit : les notions sont nommées ici et définies dans les chapitres qui suivent.

★ Attention

Violation typique. Présenter un certificat ISO/IEC 27001 comme la preuve que « la banque est sécurisée ».

Règle : un certificat atteste qu'un système de management, sur un périmètre donné, satisfait les exigences d'une norme à la date de l'audit. On lit toujours le périmètre avant de lire le certificat.

0.1 Ce qui s'est passé

0.1.1 La chronologie

La RSSI a reconstitué l'incident à partir des journaux des postes, de la messagerie et du partage de fichiers, puis l'a présenté au comité des risques. Chaque ligne du Tableau P.1 renvoie à une trace.

Date	Événement	Trace
Juin 2025	Certificat ISO/IEC 27001:2022 délivré par CERTIQUAL AFRIQUE pour trois ans. Périmètre : le centre de données principal de Douala	Certificat et rapport d'audit de certification
Novembre 2025	Revue annuelle des risques : aucun scénario ne porte sur le réseau des agences, hors périmètre	Registre des risques 2025
Lundi 14 sept. 2026, 10 h 12	Un agent de l'agence de Ngaoundéré ouvre la pièce jointe d'un faux avis de virement	Journal de la messagerie
14 sept., 10 h 14	Un programme malveillant s'installe sur le poste ; il récupère les identifiants enregistrés dans le navigateur	Journal du poste
14 – 15 sept.	Avec ces identifiants, l'attaquant accède au partage de fichiers commun aux agences et s'y déplace	Journal du serveur de fichiers
Mardi 15 sept., 2 h 40	Chiffrement simultané de 180 postes dans 9 agences ; message de rançon	Journaux des postes
15 – 17 sept.	Guichets fermés dans les 9 agences ; reconstruction des postes à partir d'images propres	Rapport de la cellule de crise
18 sept.	Réouverture des agences ; la rançon n'est pas payée	Décision du directeur général

Tableau P.1. Chronologie de l'incident (reconstitution de la RSSI)

Le centre de données certifié n'a pas été atteint : il n'était pas relié au partage de fichiers des agences. Les comptes, les opérations et le système central sont restés intacts. Le coût de l'incident, chiffré par la direction financière, atteint pourtant **410 millions de francs CFA** : arrêt des guichets, reconstruction des postes, prestataire de réponse à incident, communication auprès de la clientèle.

0.1.2 Constater, puis analyser

Comme dans toute investigation, on sépare ce qui est établi de ce que l'on en déduit.

Scénario Opérationnel · Opération SANAGA. Le rançongiciel

Constatations.

- Le certificat couvre le seul centre de données principal de Douala ; les 38 agences, la messagerie et les postes de travail sont hors périmètre.
- Le registre des risques 2025 ne contient aucun scénario sur les agences.
- L'attaque est entrée par un courriel ouvert en agence, puis s'est propagée par un partage de fichiers commun aux agences.

➢ Les identifiants volés n'étaient protégés par aucun second facteur d'authentification.

Analyse (confiance élevée). Le certificat n'est pas faux : le système de management certifié couvre bien le centre de données, et celui-ci n'a pas été touché. Ce qui a échoué, c'est le choix du périmètre et l'appréciation des risques, qui s'arrêtait à ses frontières. La banque a protégé ce qu'elle avait décidé d'auditer, et laissé dans l'ombre ce qu'elle n'avait pas regardé.

0.2 Certificat, conformité, sécurité

0.2.1 Trois choses différentes

Définition

Système de management de la sécurité de l'information (SMSI) : ensemble de politiques, de processus, de rôles et de contrôles par lequel une organisation pilote la sécurité de son information sur un périmètre défini, selon un cycle d'amélioration continue. L'ISO/IEC 27001 en fixe les exigences [40].

Certificat : attestation délivrée par un organisme tiers accrédité, après un audit, qu'un système de management satisfait les exigences d'une norme, sur un périmètre et pour une durée donnés.

Conformité : satisfaction d'une exigence précise (d'une norme, d'une loi, d'un contrat), établie par une preuve.

Sécurité effective : capacité réelle de l'organisation à résister aux attaques qu'elle subit, et à s'en relever.

Notion	Ce qu'elle établit	Ce qu'elle n'établit pas
Certificat	Un SMSI conforme à la norme sur le périmètre, à la date de l'audit	La sécurité hors périmètre ; la sécurité après l'audit
Conformité	Qu'une exigence précise est satisfaite	Que l'exigence suffit à couvrir le risque
Sécurité effective	Que les attaques réelles échouent ou sont contenues	Rien sans mesure : elle se démontre par des tests et des incidents

Tableau P.2. Trois notions à ne pas confondre

0.2.2 Le périmètre, première décision de sécurité

L'ISO/IEC 27001 demande à l'organisation de fixer les limites de son SMSI en tenant compte de son contexte, des attentes des parties intéressées, et des interfaces et dépendances entre ses propres activités et celles des autres [40]. Le périmètre n'est donc pas

libre : il doit être défendable. Celui de la BANQUE SANAGA avait été choisi pour obtenir rapidement le certificat, en excluant ce qui était difficile à maîtriser.

Définition

Périmètre de complaisance : périmètre de SMSI choisi pour faciliter la certification plutôt que pour couvrir les risques de l'organisation, au point d'exclure des activités ou des actifs dont dépend le périmètre retenu.

Les agences de la banque n'étaient pas un sujet à part : elles reçoivent les clients, saisissent les opérations et sont reliées au système central. Un attaquant installé en agence se trouve à quelques pas de ce que le certificat protège. Le Chapitre 11 montrera comment construire un périmètre défendable, et comment l'auditeur le conteste.

Note

Et le régulateur ? Le règlement COBAC R-2016/04 impose aux établissements de crédit un dispositif de contrôle interne qui couvre l'ensemble de leurs risques, y compris les risques opérationnels liés aux systèmes d'information [8]. Un certificat sur une partie du système ne dispense pas la banque de maîtriser l'autre. Le Chapitre 10 présente ces obligations.

0.3 Un Risque jamais Apprécié n'est pas un Risque Faible

0.3.1 Le trou dans le registre

Le registre des risques de 2025 recensait des scénarios sur le centre de données : panne électrique, défaillance du prestataire d'hébergement, intrusion par Internet. Aucun ne portait sur les agences. Lors de la revue, le comité des risques a lu le registre et conclu qu'aucun risque intolérable n'était ouvert.

Le raisonnement est faux, et c'est l'erreur la plus répandue en gestion des risques : un risque absent du registre a été lu comme un risque nul. Il n'était pas nul ; il était *inconnu*. La bonne cote n'était pas « faible », mais « non évalué », et cette cote aurait dû déclencher une appréciation.

Attention

Violation typique. Lire l'absence d'un scénario dans le registre comme la preuve que le risque est maîtrisé.

Règle : ce qui n'a pas été apprécié est coté NEK (connaissance insuffisante), pas « faible ». Une cote de vraisemblance sans preuve est une opinion ; elle se signale comme telle.

0.3.2 Une fiche de risque

Voici ce qu'aurait dû contenir le registre. Le Chapitre 2 en définira chaque rubrique, et le Chapitre 4 montrera comment construire le scénario avec la méthode EBIOS Risk Manager.

Fiche de risque · R-AG-01 · Rançongiciel en agence

Actif essentiel : le service au guichet des agences (versements, retraits, ouvertures de compte).
Actifs supports : postes de travail des agences, messagerie, partage de fichiers commun, comptes des agents.
Source de risque : groupe cybercriminel motivé par le gain.
Événement redouté : indisponibilité des guichets pendant plusieurs jours dans plusieurs agences.
Scénario : courriel piégé ouvert en agence, vol d'identifiants, déplacement par le partage commun, chiffrement des postes.
Vraisemblance : NEK en 2025 (scénario jamais apprécié) ; après l'incident, élevée.
Impact : perte d'exploitation, coûts de reconstruction, atteinte à la réputation, compte rendu au régulateur.
Mesures existantes : antivirus sur les postes ; aucun second facteur ; partage de fichiers ouvert à toutes les agences ; sauvegardes des postes non testées.
Risque résiduel : intolérable, tant que le partage n'est pas cloisonné et que l'authentification n'est pas renforcée.

0.4 Lire la Sécurité par Trois Mesures

0.4.1 Deux colonnes, un certificat

Après l'incident, la direction de l'audit interne, dirigée par Mme EKAMBI, évalue dix contrôles clés de sécurité de deux façons : sur le centre de données certifié, puis sur le réseau des agences. Chaque contrôle est coté OUI (en place et prouvé), NON (absent ou défaillant) ou NEK (impossible à établir faute de preuve).

Contrôle	Centre de données	Agences
Second facteur d'authentification pour les accès à distance	OUI	NON
Correctifs de sécurité appliqués dans le délai fixé	OUI	NEK
Sauvegardes hors ligne testées	OUI	NON
Cloisonnement du réseau	OUI	NON
Comptes d'administration nominatifs et revus	OUI	NEK
Journalisation centralisée et revue	OUI	NEK
Filtrage des pièces jointes de la messagerie	OUI	OUI
Sensibilisation des agents dans l'année	NEK	NEK
Plan de réponse aux incidents testé	NON	NON
Protection des postes (antivirus)	OUI	OUI
Total (oui / non / nek)	**8 / 1 / 1**	**2 / 4 / 4**

Tableau P.3. Dix contrôles clés, deux périmètres

0.4.2 Trois mesures

Le cours lit un ensemble de cotes par trois mesures, définies au Chapitre 7 :

- le **taux de conformité** μ, la part des OUI ;
- le **taux d'incertitude** U, la part des NEK ;
- l'**entropie** H, la dispersion des réponses, en bits, de 0 à $\log_2 3 \approx 1{,}585$: $H = -\sum_m p(m) \log_2 p(m)$.

Lecture auditologique · Deux périmètres de la BANQUE SANAGA

Constatation.

- Centre de données (8/1/1) : $\mu = 0{,}80$, $U = 0{,}10$, $H = -(0{,}8 \log_2 0{,}8 + 2 \times 0{,}1 \log_2 0{,}1) \approx 0{,}92$ bit.
- Agences (2/4/4) : $\mu = 0{,}20$, $U = 0{,}40$, $H = -(0{,}2 \log_2 0{,}2 + 2 \times 0{,}4 \log_2 0{,}4) \approx 1{,}52$ bit.
- Ensemble (10/5/5) : $\mu = 0{,}50$, $U = 0{,}25$, $H = 1{,}50$ bit.

Analyse (confiance élevée sur le calcul, moyenne sur la lecture). Le certificat décrit la première ligne seulement : un périmètre largement conforme et bien connu. Les agences combinent une conformité faible et une forte incertitude : quatre contrôles sur dix ne peuvent pas même être évalués, faute de trace. C'est l'endroit où l'attaque est entrée. Lue d'un bloc, la banque paraît « à moitié conforme » ; lue par périmètre, elle montre un îlot maîtrisé dans une zone inconnue.

Une cote mérite enfin d'être relue : le filtrage des pièces jointes est coté OUI en agence, alors que l'attaque est entrée par une pièce jointe. Il n'y a pas de contradiction : OUI dit que le contrôle est en place et prouvé, pas qu'il est infaillible. Un filtre arrête les pièces jointes connues comme malveillantes ; celle du 14 septembre ne l'était pas encore. C'est le troisième réflexe du cours : une mesure se juge à son fonctionnement face aux attaques réelles.

$\mu = 0{,}20$ · $U = 0{,}40$ · $H = 1{,}52$ **bit**

Note

Une règle à retenir dès maintenant. On ne conclut jamais sur une seule mesure. Un taux de conformité de 0,50 ne dit pas si la moitié du système est solide et l'autre fragile, ou si l'on ignore l'état de la moitié du système : U et H le disent. Le Chapitre 7 en tirera la règle de décision : U d'abord, μ ensuite, H pour contrôler.

0.5 Cinq Réflexes

L'incident se résume en cinq réflexes. Chacun fait l'objet d'au moins un chapitre.

N°	Réflexe	Ce qu'il évite	Chapitre
1	Lire le périmètre avant le certificat	Croire protégé ce qui n'a jamais été audité	11
2	Ce qui n'est pas apprécié est inconnu, pas faible	Un registre qui rassure parce qu'il est incomplet	2
3	Une mesure se prouve en fonctionnement	Des contrôles qui existent sur le papier	6
4	Mesurer l'incertitude	Une conformité moyenne qui cache des zones inconnues	7
5	Relier norme, risque et audit	Trois exercices séparés qui ne se parlent pas	1

Tableau P.4. Les cinq réflexes du cours

Papier de travail

Le minimum d'une cote documentée. Pour qu'une cote de contrôle ou de risque puisse être défendue devant un comité, un auditeur ou le régulateur, le papier de travail qui la porte indique au moins :

- le contrôle ou le scénario concerné, et son périmètre ;
- le critère (la norme, la politique ou la loi qui fixe l'attendu) ;
- la cote (OUI, NON ou NEK) et la preuve qui l'appuie ;
- pour un NEK, la raison pour laquelle on ne peut pas savoir ;
- la date, l'auteur et le réviseur.

0.5.1 Ce que l'incident dit à chaque métier

Application RSSI

Ce que Mme ABENA retient

Le périmètre du SMSI était une décision de sécurité, et non une formalité de certification. Elle propose au comité d'étendre le SMSI aux agences en deux ans, de cloisonner le partage de fichiers et d'imposer un second facteur pour tous les accès. Elle sait que le prochain audit de surveillance de l'organisme certificateur ne lui sera d'aucun secours sur ces sujets, puisqu'ils sont hors périmètre.

Application Auditeur en cybersécurité

Contester le périmètre

L'auditeur ne se contente pas de vérifier ce qui est inclus : il examine ce qui est exclu, et la justification de l'exclusion. Un périmètre qui exclut une activité dont dépend le périmètre retenu est une constatation d'audit en soi (Chapitre 11).

Application Gestionnaire des risques cyber

Apprécier hors des frontières

L'appréciation des risques ne s'arrête pas au périmètre du certificat : elle porte sur les activités de l'organisation. Le gestionnaire des risques ajoute le scénario R-AG-01, le chiffre (Chapitre 5) et le présente au comité avec ses options de traitement.

Application Responsable GRC

Un seul dispositif

Le registre des risques, la déclaration d'applicabilité du SMSI et le programme d'audit doivent couvrir le même univers. Le responsable GRC vérifie qu'aucun pan de l'activité n'échappe aux trois à la fois (Chapitre 13).

Application Consultant en mise en œuvre de SMSI

Conseiller un périmètre défendable

Le consultant qui a accompagné la certification a proposé le périmètre le plus facile à certifier. Son rôle était aussi de dire ce que ce choix laissait sans protection. Un périmètre étroit peut être une étape ; il doit alors être présenté comme tel, avec un calendrier d'extension.

0.6 Le Cours et son Fil Rouge

0.6.1 Une discipline, une mesure

Ce cours enseigne à appliquer les normes de sécurité, à gérer les risques et à auditer la cybersécurité. Il les relie par un même fil rouge : la mesure de ce que l'on sait et de ce que l'on ignore. L'instrument de réponse OUI / NON / NEK et les mesures μ, U et H viennent du programme de recherche de l'auditologie [56], [57]. Le cours les applique à l'audit, comme les autres cours du corpus, et aussi à l'appréciation des risques, où une vraisemblance cotée sans preuve est un NEK déguisé.

Note

Ce que dit la recherche. L'article *Vers l'auditologie* pose l'*observabilité partielle* comme premier axiome : l'auditeur ne voit jamais tout le système, il en voit des traces. Le périmètre d'un certificat en est une illustration : il délimite ce qui a été observé. L'article sur l'incertitude épistémique en tire l'instrument trichotomique et ses mesures. Les travaux sur la décomposition, le suivi dans le temps et le jeu entre auditeur et audité sont en préparation ; le Chapitre 16 les présente comme tels.

0.6.2 Trois cas

Cas	Situation	Thèmes dans ce cours
BANQUE SANAGA (Douala)	Banque de 38 agences, certifiée ISO/IEC 27001 sur son centre de données, compromise en agence	SMSI, périmètre, quantification, régulation bancaire
LiZbiZ (Douala)	Logistique, quatre centres de données, douze agences, écart de stock et fraude	EBIOS Risk Manager, audit technique, décomposition
ANPP (Yaoundé)	Agence publique de paiement	Audit de sécurité réglementaire, correspondances de référentiels

Tableau P.5. Les trois cas fil rouge

0.6.3 Le parcours

Partie	Chapitres	Question traitée
I. Fondements	1 à 2	Qu'est-ce que gouverner la sécurité ? Qu'est-ce qu'un risque cyber, et que sait-on de lui ?
II. Méthodes	3 à 7	Comment apprécier, traiter et chiffrer un risque ? Comment conduire un audit et conclure ?
III. Cadre normatif	8 à 10	Quelles normes, quels référentiels, quel droit, quelle déontologie ?
IV. Pratique	11 à 14	Comment mettre en œuvre et auditer un SMSI, auditer la technique, faire vivre la GRC ?
V. Défis avancés	15	Tiers, nuage, intelligence artificielle, audit continu
VI. Recherche	16	Mesurer ce que l'on ne sait pas

Tableau P.6. Les six parties du cours

Le cours compte 30 heures en présentiel, réparties en quinze séances de deux heures qui couvrent le prologue et les six parties. Les fiches de questions-réponses de chaque chapitre et les dix ateliers d'environ 90 minutes de NDAP SUKULU, sous le code MSN-2S3-SEC08 (registre des risques, EBIOS Risk Manager en deux séances, quantification FAIR, décomposition et cotation, déclaration d'applicabilité, table de correspondance des référentiels, audit d'un SMSI, audit technique, synthèse), sont des travaux à faire à la maison, hors de ces 30 heures. Les corrigés des exercices de fin de chapitre sont réunis dans un livret séparé.

Note

Ce que le cours ne fait pas. Il ne refait pas les autres enseignements du master : le test d'intrusion relève de l'UE MSN-2S3-SEC03, la forensique de l'UE MSN-2S3-SEC07, le droit du numérique et des données personnelles de l'UE MSN-2S3-JUR01, l'audit de protection des données de l'UE MSN-2S4-SEC02. Il y renvoie chaque fois que nécessaire.

★ À retenir

Ce qu'il faut retenir de ce prologue :

- **Un certificat dit ce qui a été audité** : un SMSI conforme, sur un périmètre, à une date. Il ne dit rien du reste.
- **Certificat, conformité, sécurité effective** sont trois notions distinctes ; seule la dernière se mesure aux attaques.
- **Le périmètre est une décision de sécurité** : un périmètre de complaisance exclut ce dont dépend ce qu'il protège.
- **Un risque jamais apprécié est inconnu, pas faible** : il se cote NEK et appelle une appréciation.
- **Trois mesures**, μ, U et H, lisent un ensemble de contrôles ; lues par périmètre, elles montrent où se cache l'incertitude.
- **Cinq réflexes** : lire le périmètre, coter l'inconnu, prouver le fonctionnement, mesurer l'incertitude, relier norme, risque et audit.

Note

Points de contrôle. Vous avez compris ce prologue si vous savez :

- expliquer pourquoi l'incident ne contredit pas le certificat ;
- dire ce qu'est un périmètre de complaisance, sur un exemple ;
- justifier la cote NEK d'un scénario jamais apprécié ;
- calculer μ, U et H pour 2, 4 et 4 réponses.

Exercices

✍ Exercice P.1. Certificat, conformité ou sécurité ? ★☆☆

Pour chacune des phrases suivantes, dites si elle porte sur le certificat, la conformité ou la sécurité effective, et si elle est exacte.

(a) « Notre certificat ISO/IEC 27001 prouve que nos agences sont protégées. »

(b) « L'audit de certification a constaté que la politique de sauvegarde du centre de données était appliquée. »

(c) « Aucun des trois exercices de simulation d'attaque de l'année n'a permis d'atteindre le système central. »

(d) « La politique de mots de passe satisfait l'exigence de longueur de la politique de sécurité du groupe. »

✍ Exercice P.2. Lire un périmètre ★★☆

Le périmètre d'un SMSI est ainsi rédigé : « La gestion du système d'information du centre de données principal de Douala, à l'exclusion des postes de travail et de la messagerie. »

(a) Citez trois activités de la banque dont dépend ce périmètre et qui en sont exclues.

(b) Pour chacune, décrivez un scénario d'attaque qui, partant de l'activité exclue, atteindrait le périmètre.

(c) Proposez une rédaction plus défendable, et un calendrier d'extension réaliste.

✍ Exercice P.3. Mesurer deux périmètres ★★☆

Six mois après l'incident, la même évaluation des dix contrôles donne, pour les agences, 6 OUI, 3 NON et 1 NEK.

(a) Calculez μ, U et H pour les agences.

(b) Comparez avec la situation de septembre (2/4/4). Qu'est-ce qui a le plus changé : la conformité ou la connaissance ?

(c) Le nombre de NON est passé de 4 à 3 seulement. Est-ce une mauvaise nouvelle ? Justifiez.

✍ Exercice P.4. La note au conseil d'administration ★★★

Le conseil d'administration demande à Mme ABENA une note d'une page.

(a) Expliquez, sans jargon, pourquoi le certificat n'a pas empêché l'incident, et pourquoi il reste valable.

(b) Rédigez une fiche de risque complète pour le scénario « vol d'identifiants de

messagerie d'un dirigeant », sur le modèle de R-AG-01.

(c) Proposez trois décisions au conseil, avec leur coût approximatif en ordre de grandeur et le risque qu'elles traitent.

(d) Indiquez ce que le prochain audit devra vérifier pour que le conseil sache si ces décisions ont été appliquées.

Note

Pour aller plus loin.

- L'ISO/IEC 27001:2022 [40], articles 4.1 à 4.3 : le contexte de l'organisation et le périmètre du SMSI.
- L'article *Vers l'auditologie* [57], sur l'observabilité partielle.
- L'article sur l'incertitude épistémique [56], qui définit la réponse NEK et les mesures μ, U, H.

Note

Transition. Le prologue a montré une banque qui gérait la sécurité de son centre de données et ignorait celle de ses agences. Avant d'apprendre les méthodes, il faut définir ce que signifie gouverner la cybersécurité, et qui en porte la responsabilité. C'est l'objet du Chapitre 1.

partie I

Fondements : Gouvernance, Risque et Incertitude

© MaletYon

1

GOUVERNER LA CYBERSÉCURITÉ : DU CONTRÔLE À LA GRC

« La sécurité se décide au conseil,
elle s'exécute dans les services,
elle se vérifie ailleurs. »

Principe du cours

Niveau : *Fondamental* • Maîtrise du Chapitre 0

✦ Objectifs du chapitre

- ➢ Définir gouvernance, gestion des risques et conformité, et leur articulation.
- ➢ Distinguer la gouvernance de la sécurité de sa gestion opérationnelle.
- ➢ Appliquer le modèle des trois lignes à la sécurité.
- ➢ Situer les rôles du conseil, de la direction, du comité de sécurité, du RSSI, du propriétaire de risque et du délégué à la protection des données.
- ➢ Choisir et justifier le rattachement d'un RSSI.
- ➢ Construire et vérifier une matrice RACI de la sécurité.
- ➢ Évaluer un dispositif de gouvernance par μ, U et H.

Avant de commencer : qui a décidé du périmètre ?

Douala, 6 octobre 2026. Trois semaines après le rançongiciel, le comité des risques du conseil d'administration de la BANQUE SANAGA[1] se réunit en séance extraordinaire. Le président du comité ne demande pas comment l'attaque s'est produite : la RSSI l'a déjà expliqué. Il pose une autre question : « Qui a décidé que les agences resteraient hors du périmètre du certificat ? »

Personne ne répond tout de suite. On reconstitue : en 2024, le consultant qui a accompagné la certification a proposé le centre de données seul ; le directeur des systèmes

[1] Comme dans tout le cours, la BANQUE SANAGA, ses dirigeants, les dates et les montants sont fictifs ; les normes et les textes cités sont exacts.

© MaletYon

d'information l'a accepté, parce que le calendrier était serré ; le directeur général a signé la déclaration de périmètre, au milieu d'autres documents. Le conseil d'administration ne l'a jamais vue. Une décision qui engageait la sécurité de trente-huit agences a été prise sans que l'organe qui répond des risques de la banque en soit informé.

Ce chapitre explique ce qu'est gouverner la cybersécurité, qui en porte la responsabilité et comment on le vérifie. Il pose le cinquième réflexe du prologue : relier norme, risque et audit au lieu de les mener comme trois exercices séparés.

★ Attention

Violation typique. Traiter une décision de sécurité structurante (périmètre, acceptation d'un risque, budget) comme une décision technique, prise et signée sans que l'instance qui répond des risques en soit saisie.

Règle : toute décision qui fixe le niveau de risque accepté par l'organisation remonte à l'instance qui en répond. Le technicien propose, la direction arbitre, le conseil approuve et surveille.

1.1 Du Contrôle à la GRC

1.1.1 Trois âges de la sécurité

La sécurité des systèmes d'information n'a pas toujours été une affaire de gouvernance. On peut distinguer trois âges, qui coexistent encore dans beaucoup d'organisations.

Âge	Question posée	Limite
Technique	Quels outils installer (pare-feu, antivirus, sauvegardes) ?	Personne ne dit quels risques ces outils traitent, ni lesquels ils laissent
Contrôle	Les contrôles prévus sont-ils appliqués ?	On vérifie ce qui est prévu, pas ce qui manque
Gouvernance	Quels risques l'organisation accepte-t-elle, qui en répond, et comment le sait-on ?	Exige que la direction s'en saisisse réellement

Tableau 1.1. Trois âges de la sécurité des systèmes d'information

La BANQUE SANAGA était à l'âge du contrôle : ses contrôles du centre de données étaient documentés et appliqués, et l'audit de certification l'a confirmé. Elle n'était pas à l'âge de la gouvernance : personne, au niveau du conseil, n'avait décidé quels risques la banque acceptait de laisser hors du périmètre.

1.1.2 Gouvernance, risque, conformité

Définition

Gouvernance de la sécurité : ensemble des responsabilités et des pratiques par lesquelles l'organe de direction fixe les objectifs de sécurité de l'organisation, décide du niveau de risque acceptable, attribue les rôles et surveille les résultats [39].

Gestion des risques : activités coordonnées pour identifier, analyser, évaluer et traiter les risques, puis en suivre l'évolution. Le Chapitre 2 en définit le vocabulaire.

Conformité : au sens du prologue, satisfaction prouvée d'une exigence ; appliquée ici à l'ensemble des obligations qui s'imposent à l'organisation (lois, règlements, contrats, normes auxquelles elle s'engage) et à ses propres politiques.

Gouvernance, risque et conformité (GRC) : approche qui pilote la gouvernance, la gestion des risques et la conformité comme un seul dispositif, avec un référentiel commun d'objectifs, de risques, de contrôles et de preuves.

Les trois termes ne désignent pas trois services. Ils désignent trois questions, qui se posent sur le même objet :

- la **gouvernance** répond à « que voulons-nous, et jusqu'où acceptons-nous le risque ? » ;
- la **gestion des risques** répond à « qu'est-ce qui peut nous empêcher d'y parvenir, et que faisons-nous ? » ;
- la **conformité** répond à « respectons-nous ce qui nous est imposé et ce que nous nous sommes imposé ? ».

L'**audit** n'est pas une quatrième lettre : il donne une assurance indépendante sur les trois. C'est pourquoi le cours l'étudie à part (Chapitre 6).

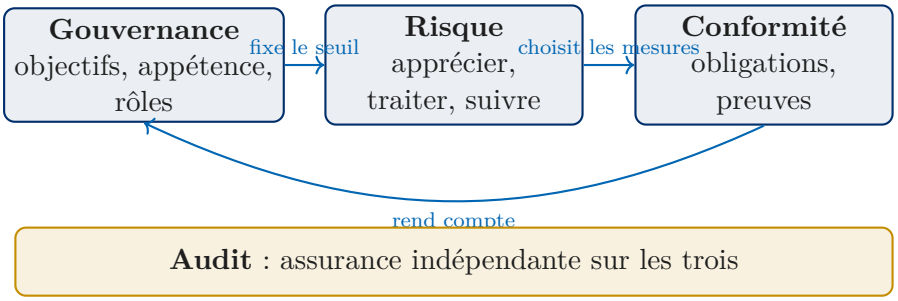


Figure 1.1: L'articulation de la gouvernance, du risque et de la conformité

Note

GRC n'est pas un logiciel. Le marché vend des « outils GRC ». Ils peuvent aider à tenir les registres, mais un outil ne remplace ni une décision du conseil sur l'appétence, ni un propriétaire de risque qui signe. Une organisation qui achète l'outil sans définir les rôles obtient des registres mieux présentés, et aussi incomplets. Le

Chapitre 13 montre comment faire vivre la GRC au quotidien.

1.2 Gouverner n'est pas Gérer

1.2.1 Deux niveaux de décision

La distinction entre gouvernance et gestion vient de la gouvernance des entreprises ; les référentiels du numérique l'ont reprise. COBIT sépare ainsi les objectifs de gouvernance, réunis dans le domaine *évaluer, diriger, surveiller*, des objectifs de gestion, qui planifient, construisent, exploitent et contrôlent [27]. L'ISO/IEC 27014 applique la même logique à la sécurité de l'information : l'organe de direction *évalue* la situation et les risques, *dirige* en fixant objectifs et politiques, *surveille* les résultats, et *communique* avec les parties prenantes [39].

Processus	Ce que fait l'organe de direction	À la BANQUE SANAGA, avant l'incident
Évaluer	Apprécie la situation de sécurité et les risques au regard de la stratégie	Le conseil ne recevait aucun rapport de sécurité
Diriger	Fixe les objectifs, l'appétence, les politiques et les moyens	La politique existait ; l'appétence au risque cyber n'était pas fixée
Surveiller	Vérifie que les objectifs sont atteints, par des indicateurs et par l'audit	Le seul retour était le certificat
Communiquer	Rend compte aux actionnaires, au régulateur, aux clients	Communication de crise improvisée en septembre 2026

Tableau 1.2. Les processus de gouvernance de la sécurité (d'après l'ISO/IEC 27014)

Définition

Organe de direction : personne ou groupe qui répond, en dernier ressort, de la performance et de la conformité de l'organisation : le conseil d'administration dans une société anonyme, le conseil d'administration ou l'autorité de tutelle dans un établissement public.

Direction (ou management) : personnes qui dirigent l'organisation au quotidien, sous l'autorité de l'organe de direction : le directeur général et ses directeurs.

1.2.2 Ce que la norme attend de la direction

L'ISO/IEC 27001 consacre son article 5 au *leadership*. En substance, la direction doit démontrer qu'elle s'implique dans le système de management : elle établit une politique de sécurité compatible avec la stratégie, intègre ses exigences dans les processus de

l'organisation, fournit les ressources, et attribue les responsabilités et les autorités des rôles de sécurité [40]. L'article 6.1.2 ajoute que chaque risque identifié doit avoir un *propriétaire*.

La norme n'exige pas que le conseil d'administration approuve le périmètre. Elle exige que la direction s'implique ; elle ne dit pas comment l'organe de direction la surveille. C'est là que la gouvernance d'entreprise prend le relais : pour une banque, le règlement COBAC R-2016/04 confie à l'organe délibérant la responsabilité du dispositif de contrôle interne et de maîtrise des risques, et à l'organe exécutif sa mise en œuvre [8]. Le Chapitre 10 précisera ces obligations.

1.2.3 Le cadre NIST : gouverner d'abord

Dans sa version 2.0, publiée en 2024, le cadre de cybersécurité du NIST a ajouté une sixième fonction, *Gouverner*, aux cinq fonctions historiques (identifier, protéger, détecter, répondre, rétablir) [60]. Elle couvre six catégories : le contexte de l'organisation ; la stratégie de gestion des risques ; les rôles, les responsabilités et les autorités ; la politique ; la supervision ; la gestion des risques de la chaîne d'approvisionnement. Le cadre la place au centre des cinq autres : sans elle, elles n'ont pas d'objectif. Le Chapitre 9 étudie ce cadre et ses correspondances avec l'ISO/IEC 27001.

Scénario Opérationnel · Opération SANAGA. Une décision orpheline

Constatations.

- La déclaration de périmètre du SMSI porte la seule signature du directeur général.
- Les procès-verbaux du conseil et de son comité des risques de 2024 et 2025 ne mentionnent ni le périmètre ni le certificat, sauf pour annoncer son obtention.
- Aucun document ne fixe l'appétence de la banque au risque cyber.

Analyse (confiance élevée). La direction a satisfait l'exigence de la norme : elle s'est impliquée et a signé. Mais l'organe de direction n'a ni évalué, ni dirigé, ni surveillé cette décision. On peut discuter, comme le prologue, de la prise en compte des interfaces et des dépendances du périmètre ; mais le défaut premier n'est pas de conformité à l'ISO/IEC 27001, il est de gouvernance. Un audit de certification pouvait contester le périmètre ; il ne pouvait pas corriger le silence du conseil, puisqu'il ne porte pas sur son fonctionnement.

1.3 Le Modèle des Trois Lignes appliqué à la Sécurité

1.3.1 Le modèle

L'Institut des auditeurs internes (IIA) a publié en 2020 le **modèle des trois lignes** [69]. Il remplace l'ancien modèle des « trois lignes de défense » : le mot *défense* a disparu,

parce que la gestion des risques sert aussi à saisir des opportunités, et parce que les lignes doivent coopérer, pas seulement se protéger les unes des autres. Le modèle distingue des *rôles*, pas des services : une même direction peut tenir un rôle de première ligne pour une activité et de deuxième ligne pour une autre.

Rôle	Ce qu'il fait en sécurité	À la BANQUE SANAGA
Organe de gouvernance	Fixe l'appétence, approuve la stratégie de sécurité, surveille	Conseil d'administration, comité des risques du conseil
Première ligne	Exploite les systèmes et applique les mesures de sécurité au quotidien	DSI (exploitation, réseau, postes), directeurs métier, chefs d'agence
Deuxième ligne	Fixe le cadre, conseille, surveille et remet en cause la première ligne	RSSI, direction des risques, conformité, DPD
Troisième ligne	Donne une assurance indépendante à l'organe de gouvernance	Direction de l'audit interne (Mme EKAMBI)
Prestataires d'assurance externes	Assurance complémentaire	CERTIQUAL AFRIQUE, commissaires aux comptes

Tableau 1.3. Le modèle des trois lignes appliqué à la sécurité de la BANQUE SANAGA

Le superviseur, la COBAC, n'apparaît pas dans le tableau : il n'est pas un prestataire au service de la banque, mais une autorité extérieure qui contrôle l'ensemble du dispositif, les trois lignes comprises.

1.3.2 Où placer le RSSI ?

Le RSSI est l'acteur le plus difficile à placer, parce qu'on lui confie souvent des tâches des deux premières lignes à la fois. S'il fixe la politique, surveille les indicateurs et rend compte à la direction, il tient un rôle de deuxième ligne. S'il administre lui-même le pare-feu, il tient un rôle de première ligne. S'il fait les deux, il surveille son propre travail.

★ Attention

Violation typique. Le RSSI administre les équipements de sécurité, puis rédige le rapport qui dit au comité qu'ils fonctionnent.

Règle : celui qui exploite une mesure n'en atteste pas l'efficacité. Si l'organisation est trop petite pour séparer les rôles, elle compense par une revue indépendante (audit interne, auditeur externe) et le dit dans son rapport.

1.3.3 Ce que le modèle ne dit pas

Le modèle des trois lignes est un modèle de rôles. Il ne dit pas si les lignes couvrent tout l'univers des risques. À la BANQUE SANAGA, les trois lignes existaient et fonction-

naient ; mais aucune ne regardait les agences sous l'angle de la cybersécurité : la DSI les exploitait sans appréciation des risques, la RSSI concentrait ses efforts sur le périmètre certifié, et l'audit interne n'avait pas inscrit la sécurité des agences à son programme. Trois lignes bien rangées peuvent laisser le même trou. C'est ce que mesure l'évaluation de la Section 1.6.

1.4 Les Acteurs et leurs Responsabilités

1.4.1 Huit acteurs

Acteur	Responsabilité principale
Conseil et comité des risques	Fixe l'appétence au risque cyber, approuve la stratégie et les décisions structurantes (périmètre, risques acceptés au-delà d'un seuil), reçoit les rapports du RSSI et de l'audit interne
Direction générale	Met en œuvre la stratégie, fournit les ressources, arbitre entre les directions, signe la politique de sécurité
Comité de sécurité	Instance de direction qui réunit les directeurs métier, la DSI, le RSSI et les risques ; suit les projets de sécurité, les incidents et les indicateurs, et prépare les décisions
RSSI	Propose la politique, coordonne l'appréciation des risques, surveille les mesures, conseille, rend compte
DSI	Exploite les systèmes et les mesures techniques, applique la politique dans les projets et l'exploitation
Propriétaire de risque	Directeur qui a l'autorité et les moyens de traiter un risque ; décide du traitement et accepte le risque résiduel dans la limite de l'appétence
Audit interne	Évalue le dispositif de façon indépendante et rend compte au conseil
DPD	Veille à la conformité des traitements de données personnelles, conseille, sert de point de contact avec l'autorité de protection

Tableau 1.4. Les acteurs de la gouvernance de la sécurité

Définition

Propriétaire de risque : personne qui a la responsabilité et l'autorité de gérer un risque [36]. Ce n'est pas le RSSI : c'est en général le directeur dont l'activité est exposée, parce que c'est lui qui peut dégager les moyens de traitement et qui supporte les conséquences.

Appétence au risque : niveau de risque qu'une organisation est prête à accepter pour atteindre ses objectifs. Elle est fixée par l'organe de direction [10] ; le Chapitre 2 montre comment l'exprimer.

1.4.2 Le propriétaire du risque R-AG-01

La fiche du prologue décrivait le risque. Il lui manquait les rubriques de gouvernance : qui en répond, qui peut l'accepter, qui le surveille.

Fiche de risque · R-AG-01 · Rubriques de gouvernance

Propriétaire du risque : le directeur du réseau d'agences. C'est lui qui dirige les agences, arbitre leur budget et supporte la fermeture des guichets.
Contributeurs : DSI (postes, messagerie, partage de fichiers), RSSI (analyse et mesures), direction de la communication (crise).
Instance d'acceptation : le comité des risques du conseil. Tant que le conseil n'a pas fixé l'appétence, aucun directeur ne peut accepter seul un risque de cette ampleur ; une fois l'appétence fixée, le comité reste compétent pour tout résiduel qui la dépasse.
Surveillance : la RSSI suit trois indicateurs (part des comptes d'agence avec second facteur, délai d'application des correctifs, succès des tests de restauration) et les présente chaque trimestre au comité de sécurité.
Assurance : la direction de l'audit interne inscrit le réseau d'agences à son programme 2027.

1.4.3 Rattacher le RSSI

Le rattachement du RSSI n'est pas un détail d'organigramme : il détermine ce qu'il peut dire, et à qui. Aucune norme n'impose un rattachement unique ; chaque option a ses forces et ses risques.

Rattachement	Force	Risque
DSI	Proximité technique, mise en œuvre rapide	Le RSSI surveille son propre supérieur ; la sécurité passe après les délais des projets
Direction des risques	Intégration au dispositif de maîtrise des risques ; deuxième ligne naturelle	Distance avec la technique ; risque d'une sécurité réduite à des registres
Direction générale	Autorité, accès direct aux arbitrages	Charge de la direction générale ; peut isoler le RSSI des autres directions
Conformité	Lien avec les obligations légales	Une sécurité réduite à la conformité, aveugle aux menaces non réglementées

Tableau 1.5. Les options de rattachement du RSSI

À la BANQUE SANAGA, la RSSI est rattachée au directeur des risques. C'est un choix défendable : il place la sécurité en deuxième ligne, à distance de la DSI. Mais

ce rattachement ne valait rien sans un accès au comité des risques du conseil : les rapports de la RSSI s'arrêtaient au directeur des risques. Le critère décisif n'est pas l'organigramme, c'est le *droit d'être entendu* par l'instance qui décide.

Note

Le délégué à la protection des données. Le DPD et le RSSI travaillent sur des objets voisins : les données personnelles sont aussi des informations à protéger. Leurs missions diffèrent pourtant : le RSSI protège l'information de l'organisation contre les menaces ; le DPD veille aux droits des personnes dont les données sont traitées. Confondre les deux fonctions crée un conflit d'intérêts, car le RSSI peut avoir à défendre un traitement que le DPD devrait contester. La place du DPD dans la loi n° 2024/017 relative à la protection des données à caractère personnel est étudiée dans l'UE MSN-2S3-JUR01 ; le cours n'y revient que pour situer les rôles.

1.5 La Matrice RACI de la Sécurité

1.5.1 Quatre lettres

Définition

Matrice RACI : tableau qui croise des activités et des acteurs, et indique pour chaque case le rôle de l'acteur :

- **R** (*Responsible*, réalise) : exécute l'activité ;
- **A** (*Accountable*, répond) : rend compte du résultat, approuve, et ne peut pas déléguer cette responsabilité ;
- **C** (*Consulted*, consulté) : donne un avis avant la décision ;
- **I** (*Informed*, informé) : est tenu au courant après.

Papier de travail

Vérifier une matrice RACI. Le papier de travail qui examine une matrice contrôle, ligne par ligne :

- **un seul A** par activité : deux personnes qui répondent, c'est personne ;
- **au moins un R** : une activité sans exécutant n'est pas faite ;
- **un A qui a l'autorité** : celui qui répond doit pouvoir décider et dégager les moyens ;
- **pas de R et de A d'attestation sur la même tête** : celui qui exécute une mesure n'atteste pas son efficacité ;
- **les décisions de risque au bon niveau** : l'acceptation d'un risque au-delà de l'appétence remonte à l'organe de gouvernance ;

➢ **la preuve** : pour chaque A, un document signé (procès-verbal, décision, rapport) montre que le rôle a été tenu.

1.5.2 La matrice de la BANQUE SANAGA, après l'incident

La RSSI propose au comité de sécurité la matrice du Tableau 1.6. Les colonnes sont : CA (conseil d'administration et son comité des risques), DG, CS (comité de sécurité), RSSI, DSI, PR (propriétaire de risque, ici le directeur métier concerné), AI (audit interne) et DPD.

Activité	CA	DG	CS	RSSI	DSI	PR	AI	DPD
Fixer l'appétence au risque cyber	A	R	C	C	–	C	I	–
Approuver la politique de sécurité	I	A	C	R	C	C	I	C
Fixer le périmètre du SMSI	A	R	C	R	C	C	I	I
Apprécier les risques d'une activité	–	I	I	R	C	A	I	C
Accepter un risque résiduel sous le seuil	–	I	I	C	–	A/R	I	–
Accepter un risque résiduel au-delà du seuil	A	R	C	C	–	C	I	–
Exploiter les mesures techniques	–	–	I	C	A/R	–	–	–
Surveiller l'efficacité des mesures	I	I	I	A/R	C	I	–	–
Notifier un incident majeur au régulateur	I	A	I	R	C	C	I	C
Auditer le dispositif de sécurité	I	I	I	C	C	C	A/R	–

Tableau 1.6. Matrice RACI de la sécurité de la BANQUE SANAGA (proposition de la RSSI)

Deux lignes demandent une explication. Pour « fixer le périmètre du SMSI », le DG et la RSSI réalisent (R) et le conseil répond (A) : c'est précisément la décision qui avait échappé au conseil. Pour « auditer le dispositif », l'audit interne répond seul ; la RSSI n'est que consultée, parce qu'elle ne peut pas auditer ce qu'elle surveille. La mention « A/R » signale un acteur qui répond de l'activité et la réalise par ses propres équipes : elle est normale pour l'exploitation (DSI) ou l'audit (audit interne), à condition que l'attestation d'efficacité vienne d'un autre acteur.

● Note

Une matrice se lit aussi par colonne. Une colonne sans aucun A désigne un acteur qui ne répond de rien ; une colonne chargée de A désigne un goulet d'étranglement. Dans le Tableau 1.6, la colonne CA porte trois A, tous sur des

décisions de niveau de risque : c'est le signe que le conseil gouverne. Un conseil sans A en sécurité ne gouverne pas la sécurité.

1.6 Mesurer la Gouvernance

1.6.1 Huit questions

Une gouvernance se décrit dans des documents ; elle se vérifie dans leur usage. Après l'incident, Mme EKAMBI évalue la gouvernance de la sécurité telle qu'elle fonctionnait en 2025, par huit questions. Chaque réponse est cotée OUI (prouvé), NON (absent ou contredit par les pièces) ou NEK (impossible à établir faute de pièce).

N°	Question	Cote	Pièce
G1	Une politique de sécurité est-elle approuvée par la direction générale ?	OUI	Politique signée, 2024
G2	Le périmètre du SMSI a-t-il été approuvé par le conseil ou son comité des risques ?	NON	Procès-verbaux 2024–2025
G3	L'appétence au risque cyber est-elle fixée par le conseil ?	NON	Aucun document
G4	Chaque risque du registre a-t-il un propriétaire désigné ?	NON	Registre 2025, sans colonne propriétaire
G5	Le RSSI est-il indépendant de la DSI ?	OUI	Organigramme, fiche de poste
G6	Le comité de sécurité s'est-il réuni au moins deux fois en 2025 ?	NEK	Aucun procès-verbal retrouvé
G7	Un rapport de sécurité a-t-il été présenté au comité des risques du conseil en 2025 ?	NEK	Ordre du jour sans annexe
G8	L'audit interne a-t-il couvert la sécurité dans son programme 2024–2025 ?	NON	Programmes d'audit

Tableau 1.7. Évaluation de la gouvernance de la sécurité en 2025

⚖ Lecture auditologique · Gouvernance de la sécurité de la BANQUE SANAGA en 2025

Constatation. 2 OUI, 4 NON, 2 NEK sur 8 questions :

$$\mu = \tfrac{2}{8} = 0{,}25\,; \quad U = \tfrac{2}{8} = 0{,}25\,; \quad H = -\left(2 \times 0{,}25 \log_2 0{,}25 + 0{,}5 \log_2 0{,}5\right) = 0{,}5{+}0{,}5{+}0{,}5 = 1{,}50 \text{ bit}$$

Analyse (confiance élevée sur le calcul et sur les NON, moyenne sur la lecture des NEK). La gouvernance existait sur le papier (politique, RSSI indépendant) et manquait dans les décisions : périmètre, appétence, propriétaires, assurance. Les deux NEK portent sur la *surveillance* : rien ne prouve que l'organe de direction ait

été informé. Un NEK sur la surveillance n'est pas neutre : un conseil qui ne peut pas prouver qu'il a été informé ne peut pas prouver qu'il a gouverné.

$\mu = 0{,}25$ · $U = 0{,}25$ · $H = 1{,}50$ **bit**

1.6.2 Ce que la mesure ajoute

Dans l'évaluation des dix contrôles clés, le centre de données certifié obtenait une conformité de 0,80 (prologue, Tableau P.3). La gouvernance qui l'encadrait obtient 0,25. Les deux chiffres ne se contredisent pas : ils ne mesurent pas le même objet. Le premier dit que les contrôles du périmètre sont appliqués ; le second dit que personne, au niveau qui décide, n'a choisi ce périmètre en connaissance de cause. Le cinquième réflexe du cours, relier norme, risque et audit, consiste à lire ces deux niveaux ensemble.

1.7 Le Cadre Camerounais

Deux textes donnent à la gouvernance de la sécurité une assise juridique au Cameroun. Le Chapitre 10 les étudie en détail.

Jurisprudence & Droit applicable

Loi n° 2010/012, article 26, alinéa 1 [53] :

« Les exploitants des systèmes d'information prennent toutes les mesures techniques et administratives afin de garantir la sécurité des services offerts. A cet effet, ils se dotent de systèmes normalisés leur permettant d'identifier, d'évaluer, de traiter et de gérer continûment les risques liés à la sécurité des systèmes d'information dans le cadre des services offerts directement ou indirectement. »

Portée pour la gouvernance. La loi impose aux exploitants de systèmes d'information un dispositif *normalisé* et *permanent* de gestion des risques de sécurité, pour les services fournis « directement ou indirectement ».

Analyse (lecture du cours, confiance moyenne en l'absence de jurisprudence connue). Le texte ne prévoit pas de restreindre ce dispositif à une partie des services. Un dispositif qui n'apprécie les risques que sur le centre de données répond donc mal à cette obligation, quel que soit le certificat.

Pour les établissements de crédit, le règlement COBAC R-2016/04 organise le contrôle interne et la maîtrise des risques, y compris les risques liés aux systèmes d'information, et en répartit la responsabilité entre l'organe délibérant et l'organe exécutif [8]. Le défaut de gouvernance de la BANQUE SANAGA n'est donc pas seulement une faiblesse de bonne pratique : il expose la banque à une observation du superviseur.

1.8 Ce que la Gouvernance demande à chaque Métier

Application RSSI

Obtenir le droit d'être entendu

1. Demander un point permanent à l'ordre du jour du comité des risques du conseil, au moins deux fois par an.
2. Présenter peu d'indicateurs, reliés aux risques et à l'appétence, et dire ce qu'on ignore (les NEK) autant que ce qu'on sait.
3. Se dégager de l'exploitation des outils de sécurité, ou faire revoir par un tiers ce qu'on exploite soi-même.

Application Responsable GRC

Un seul référentiel

1. Tenir à jour la matrice RACI et la faire approuver par le comité de sécurité.
2. Vérifier que chaque risque du registre a un propriétaire, et que chaque acceptation au-delà du seuil porte la décision de l'instance compétente.
3. Relier registre des risques, déclaration d'applicabilité et programme d'audit, pour qu'aucun pan de l'activité n'échappe aux trois (Chapitre 13).

Application Auditeur en cybersécurité

Auditer la gouvernance, pas seulement les contrôles

L'auditeur ne s'arrête pas aux mesures techniques. Il demande qui a décidé du périmètre, qui a accepté chaque risque résiduel, et quelle pièce le prouve. Une décision structurante sans instance compétente est une constatation d'audit, même si chaque contrôle est en place.

Application Gestionnaire des risques cyber

Faire signer les propriétaires

Le gestionnaire des risques anime l'appréciation, mais ne possède pas les risques. Il obtient de chaque directeur concerné qu'il reconnaisse son risque, choisisse un traitement et signe l'acceptation du résiduel. Un risque que personne n'a signé reste, en pratique, à la charge du RSSI, qui n'a pas les moyens de le traiter.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

➢ **GRC** : trois questions sur un même objet : ce que l'on veut et jusqu'où l'on

accepte le risque, ce qui peut l'empêcher, ce que l'on doit respecter. L'audit donne une assurance indépendante sur les trois.

- **Gouverner n'est pas gérer** : l'organe de direction évalue, dirige, surveille et communique ; la direction met en œuvre.
- **Trois lignes** : l'exploitation, la surveillance et l'assurance indépendante sont des rôles distincts ; celui qui exploite une mesure n'en atteste pas l'efficacité.
- **Le propriétaire de risque** est le directeur qui a l'autorité de le traiter, pas le RSSI.
- **Le rattachement du RSSI** compte moins que son droit d'être entendu par l'instance qui décide.
- **RACI** : un seul A par activité, des décisions de risque au bon niveau, une preuve pour chaque A.
- **La gouvernance se mesure** : à la BANQUE SANAGA, 0,25 de conformité et 0,25 d'incertitude en 2025, alors que les contrôles du périmètre certifié obtenaient 0,80.

Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- dire, sur un exemple, ce qui relève de la gouvernance, de la gestion des risques et de la conformité ;
- placer les acteurs de la sécurité d'une organisation dans le modèle des trois lignes ;
- repérer les défauts d'une matrice RACI ;
- expliquer pourquoi un défaut de gouvernance échappe à un audit de certification.

Exercices

✍ Exercice 1.1. Gouvernance, risque ou conformité ? ★☆☆

Classez chacune des activités suivantes dans la gouvernance, la gestion des risques ou la conformité, et indiquez l'acteur qui en répond à la BANQUE SANAGA.

(a) Le conseil décide qu'aucune agence ne doit rester fermée plus de 24 heures pour une cause informatique.

(b) La RSSI anime un atelier qui identifie les scénarios de rançongiciel sur le réseau des agences.

(c) La direction juridique vérifie que la banque a bien transmis à la COBAC le rapport demandé après la bascule de mars 2026.

(d) Le directeur du réseau d'agences choisit de cloisonner le partage de fichiers plutôt que d'accepter le risque.

(e) Le comité des risques du conseil reçoit le rapport trimestriel de sécurité.

✍ Exercice 1.2. Les trois lignes de LiZbiZ ★★☆

Chez LiZbiZ, M. KOUNOU, responsable informatique, détient tous les droits de l'application intégrée ; il administre aussi le pare-feu et rédige chaque année le rapport de sécurité présenté au directeur général, M. ETEME. Mme NKENG est contrôleuse interne. Il n'y a pas d'audit interne.

(a) Placez chaque acteur dans le modèle des trois lignes, en distinguant les rôles qu'il tient effectivement.

(b) Identifiez les deux conflits de rôles les plus graves et expliquez le risque que chacun fait courir.

(c) Proposez une organisation réaliste pour une entreprise de cette taille, sans créer de direction de l'audit interne.

✍ Exercice 1.3. Corriger une matrice RACI ★★☆

Une première version de la matrice de la BANQUE SANAGA contenait les lignes suivantes (colonnes : CA, DG, CS, RSSI, DSI, PR, AI) :

- ➢ Fixer le périmètre du SMSI : –, A, –, R, A, –, – ;
- ➢ Accepter un risque résiduel au-delà du seuil : –, I, –, A, –, C, – ;
- ➢ Exploiter les mesures techniques : –, –, –, R, R, –, – ;
- ➢ Surveiller l'efficacité des mesures : –, –, I, A, R, –, – ;
- ➢ Auditer le dispositif de sécurité : –, I, –, A, –, –, R.

(a) Pour chaque ligne, relevez les règles de vérification violées.

(b) Proposez une version corrigée de chaque ligne.

(c) Quelle ligne, si elle était restée en l'état, aurait reproduit le défaut à l'origine de l'incident de septembre 2026 ?

✍ Exercice 1.4. Un an après ★★★

En octobre 2027, Mme EKAMBI reprend les huit questions du Tableau 1.7. Le conseil a approuvé un périmètre étendu aux agences et fixé une appétence ; le registre a une colonne propriétaire, mais trois risques sur vingt n'ont pas de propriétaire désigné ; le comité de sécurité s'est réuni trois fois, procès-verbaux à l'appui ; deux

rapports ont été présentés au comité des risques ; l'audit interne a programmé une mission sur les agences pour 2028. La politique et le rattachement du RSSI n'ont pas changé.

(a) Cotez les huit questions et justifiez chaque cote.

(b) Calculez μ, U et H, et comparez avec 2025.

(c) La question G4 est-elle bien posée ? Proposez une formulation qui permette une cote plus informative, et dites ce qu'elle changerait.

(d) Rédigez, en une demi-page, le mandat du comité de sécurité : composition, fréquence, attributions, ce qu'il décide et ce qu'il remonte au conseil.

Note

Pour aller plus loin.

- Le modèle des trois lignes de l'IIA [69].
- L'ISO/IEC 27014:2020 [39], sur la gouvernance de la sécurité de l'information.
- Le cadre de cybersécurité du NIST, version 2.0 [60], et sa fonction *Gouverner*.
- L'ISO/IEC 27001:2022 [40], article 5 (leadership).

Note

Transition. Gouverner, c'est décider du niveau de risque que l'on accepte. Encore faut-il savoir ce qu'est un risque cyber, comment on le décrit et comment on le cote, et reconnaître quand une cote n'est qu'une opinion. C'est l'objet du Chapitre 2.

2

LE RISQUE CYBER : NOTIONS, MESURE, INCERTITUDE

« Une cote sans preuve est une opinion
qui a pris l'apparence d'un chiffre. »

Principe du cours

Niveau : *Fondamental* • Maîtrise du Chapitre 1

✦ Objectifs du chapitre

- ➢ Définir risque, actif, menace, vulnérabilité, source de risque, objectif visé, événement redouté et scénario.
- ➢ Expliquer ce qui distingue le risque cyber des autres risques opérationnels.
- ➢ Coter vraisemblance, impact et criticité sur une échelle commune, et en connaître les limites.
- ➢ Distinguer risque inhérent, risque résiduel et appétence, et ne réduire un risque que par des mesures testées.
- ➢ Distinguer l'incertitude aléatoire de l'incertitude épistémique.
- ➢ Reconnaître une cote sans preuve comme une incertitude (NEK) et mesurer la base de preuve d'un registre par μ, U et H.

Avant de commencer : sur quoi repose ce « 1 » ?

Douala, novembre 2026. Mme ABENA relit le registre des risques que le comité des risques avait approuvé un an plus tôt[1]. Il compte six scénarios, tous sur le centre de données. L'un d'eux, « intrusion par Internet », porte une vraisemblance de 1 sur 4 : rare. La RSSI demande au responsable de l'exploitation d'où vient ce chiffre.

« Nous n'avons jamais été attaqués », répond-il. Elle lui demande alors qui lit les journaux du pare-feu d'accès à Internet. Personne : installé au siège, hors du périmètre

[1] Comme dans tout le cours, la BANQUE SANAGA, ses dirigeants, les dates et les montants sont fictifs ; les normes et les méthodes citées sont exactes.

© MaletYon

certifié, il conserve ses journaux trente jours, puis les efface ; la journalisation du centre de données ne voit que ce qui a franchi ce pare-feu. La banque ne savait pas si elle avait été attaquée. Le « 1 » ne mesurait pas une fréquence d'attaques ; il mesurait l'absence de regard.

Le prologue a montré qu'un risque jamais apprécié n'est pas faible, mais inconnu. Ce chapitre va plus loin : même un risque apprécié et coté peut reposer sur une inconnue. Il définit le vocabulaire du risque cyber, montre comment on le cote, puis apprend à coter la cote elle-même.

★ Attention

Violation typique. Coter la vraisemblance d'une attaque à partir de l'absence d'incident connu, alors que rien n'aurait permis de détecter l'incident.

Règle : l'absence de preuve d'attaque n'est une preuve d'absence que si l'on regardait. Une cote fondée sur un silence non surveillé est NEK.

2.1 Définir le Risque Cyber

2.1.1 L'effet de l'incertitude sur les objectifs

■ Définition

Risque : effet de l'incertitude sur les objectifs. L'effet est un écart, positif ou négatif, par rapport à ce qui est attendu. On décrit un risque par ses sources, les événements possibles, leurs conséquences et leur vraisemblance [31].

Définition reformulée d'après l'ISO 31000:2018.

Un risque se rattache toujours à un *objectif*. « Les postes de Ngaoundéré sont chiffrés » n'est un risque qu'au regard d'un objectif, par exemple « servir les clients au guichet tous les jours ouvrés ». C'est pourquoi le conseil, qui fixe les objectifs, fixe aussi le niveau de risque acceptable (Chapitre 1).

■ Définition

Risque cyber : risque dont la source est une action, malveillante ou accidentelle, sur les systèmes d'information ou les données, et dont les conséquences touchent les activités de l'organisation : interruption, perte financière, fuite d'information, sanction, atteinte à la réputation.

2.1.2 Les deux portes d'entrée de l'ISO/IEC 27005

L'ISO/IEC 27005:2022, guide de la gestion des risques de sécurité de l'information, admet deux manières d'identifier les risques [42] : à partir des *actifs* (on recense ce qui a de la valeur, puis les menaces et les vulnérabilités qui le concernent), ou à partir

des *événements* (on part des scénarios stratégiques, des sources de risque et de leurs conséquences sur l'activité). La première est exhaustive mais lourde ; la seconde va droit aux scénarios qui comptent, au risque d'en oublier. Le Chapitre 3 les met en œuvre ; ce chapitre en pose le vocabulaire commun.

2.2 Les Composantes d'un Risque

2.2.1 Huit notions

Définition

Valeur métier (ou actif essentiel) : activité, processus ou information qui a de la valeur pour l'organisation (le service au guichet, le fichier des clients).

Bien support (ou actif support) : composant sur lequel repose une valeur métier : matériel, logiciel, réseau, local, personne, prestataire.

Menace : cause potentielle d'un incident (un rançongiciel, une erreur d'administration, une coupure électrique).

Vulnérabilité : faiblesse d'un bien support qu'une menace peut exploiter (un partage de fichiers ouvert à tous, un compte sans second facteur).

Source de risque : élément, personne ou groupe susceptible d'engendrer le risque ; pour une attaque, l'attaquant et ses capacités.

Objectif visé : ce que la source de risque cherche à obtenir (un gain financier, de l'information, une nuisance).

Événement redouté : atteinte à une valeur métier, exprimée du point de vue de l'organisation (indisponibilité des guichets pendant plusieurs jours).

Scénario : enchaînement qui mène une source de risque, par des biens supports et leurs vulnérabilités, jusqu'à l'événement redouté.

Les notions de valeur métier, bien support, source de risque, objectif visé et événement redouté sont celles de la méthode EBIOS Risk Manager, publiée par l'Agence nationale de la sécurité des systèmes d'information (ANSSI, France) [2]. Le cours les retient parce qu'elles séparent nettement ce que l'on protège (la valeur métier) de ce par quoi on est attaqué (les biens supports). D'autres textes emploient d'autres mots pour les mêmes idées ; le Tableau 2.1 donne les plus courants.

Ce cours	EBIOS Risk Manager	Autres formulations courantes
Valeur métier	Valeur métier	Actif essentiel, actif primaire
Bien support	Bien support	Actif support
Source de risque	Source de risque (SR)	Attaquant, menace au sens large
Objectif visé	Objectif visé (OV)	Motivation de l'attaquant
Événement redouté	Événement redouté	Événement, conséquence
Scénario	Scénario stratégique, puis opérationnel	Scénario de risque, scénario d'incident
Impact	Gravité	Conséquence

Tableau 2.1. Correspondance des vocabulaires (simplifiée)

2.2.2 Le scénario R-AG-01, décomposé

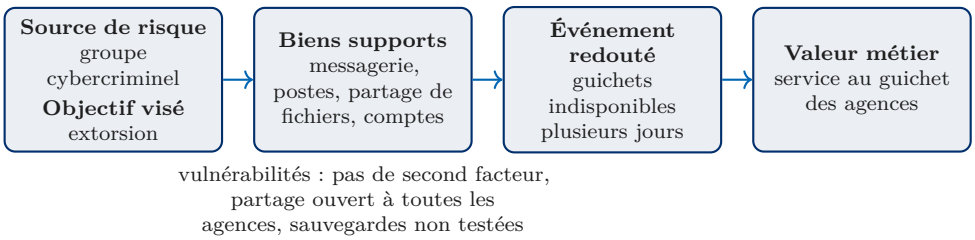


Figure 2.1: Les composantes du scénario R-AG-01

La décomposition dit où agir. On peut viser la source (on ne la contrôle pas), les vulnérabilités des biens supports (second facteur, cloisonnement), ou les conséquences sur la valeur métier (sauvegardes restaurables, procédure de guichet en mode dégradé). Les mesures se classent ainsi par *étape du scénario* : entrée, propagation, récupération. Cette classification servira à coter le risque résiduel (Section 2.5).

2.3 Ce qui rend le Risque Cyber Particulier

Le risque cyber se gère avec les outils des risques opérationnels, mais il en déjoue plusieurs hypothèses. Chacune a une conséquence sur la manière de le coter.

Particularité	Ce qu'elle signifie	Conséquence pour la cote
Un adversaire qui s'adapte	L'attaquant choisit sa cible et contourne les mesures connues ; la fréquence dépend de la défense	Une fréquence passée ne prédit pas la fréquence future
Peu d'historique	Les incidents sont rares, mal déclarés, et changent de forme chaque année	Les cotes reposent souvent sur l'avis d'expert
Des incidents invisibles	Un attaquant peut rester des semaines dans un réseau sans être détecté	L'absence d'incident connu ne vaut que si l'on surveillait
Des effets simultanés	Un même scénario touche d'un coup de nombreux sites (9 agences en une nuit)	L'impact se cote sur le scénario entier, pas par site
Des pertes très dispersées	La plupart des incidents coûtent peu ; quelques-uns coûtent énormément	Une moyenne trompe ; il faut un intervalle (Chapitre 5)

Tableau 2.2. Cinq particularités du risque cyber

Note

Un risque qui dépend de la défense. Une coupure électrique ne devient pas plus fréquente parce que la banque a installé un groupe électrogène. Une attaque, si : quand une cible se protège, l'attaquant en cherche une autre, ou une autre porte. La vraisemblance d'un scénario cyber n'est donc jamais une donnée de la nature ; c'est une hypothèse sur un adversaire, qui se révise.

2.4 Coter un Risque

2.4.1 Une échelle commune

Pour comparer des risques de natures différentes, et pour que le conseil puisse arbitrer, on les cote sur une même échelle. Le cours reprend la convention à quatre niveaux du corpus, et la précise par des bornes de fréquence ; chaque organisation fixe la sienne.

Niv.	Vraisemblance	Impact (le critère le plus défavorable l'emporte)
1	Rare : moins d'une fois en 10 ans	Mineur : perte inférieure à 5 millions FCFA, interruption de moins de 4 heures
2	Possible : une fois en 3 à 10 ans	Modéré : de 5 à 50 millions FCFA, interruption de moins de 24 heures
3	Probable : une fois en 1 à 3 ans	Majeur : de 50 à 500 millions FCFA, interruption de 1 à 3 jours, réserve du commissaire aux comptes ou compte rendu exigé par le régulateur
4	Quasi certain : au moins une fois par an	Critique : plus de 500 millions FCFA, interruption de plus de 3 jours, sanction d'un régulateur

Tableau 2.3. Échelles de cotation (convention du cours)

Définition

Criticité (ou score) : produit vraisemblance × impact, de 1 à 16. Elle sert à classer les risques et à les situer par rapport à l'appétence.

L'incident de septembre 2026 a coûté 410 millions FCFA et fermé les guichets trois jours : il se situe au niveau 3 d'impact. Le scénario redouté de R-AG-01 va plus loin : une propagation à l'ensemble du réseau, au-delà de trois jours. Son impact se cote 4. On cote le scénario que l'on redoute, pas seulement celui que l'on a vécu.

2.4.2 L'appétence, traduite sur l'échelle

En novembre 2026, le comité des risques du conseil adopte, à titre provisoire, la règle d'appétence commune au corpus :

- une criticité résiduelle de **9 ou plus** est *intolérable* et doit être traitée sans délai ;
- de **5 à 8**, le risque est *traité dans l'année* ;
- de **1 à 4**, il est *accepté sous surveillance*, par une décision écrite du propriétaire ;
- tout risque d'impact 4 est présenté au comité, quelle que soit sa criticité.

La dernière règle n'est pas un détail. Elle corrige le principal défaut des matrices, qu'il faut maintenant examiner.

2.4.3 Ce que la matrice cache

La matrice vraisemblance × impact est l'outil le plus répandu de la gestion des risques. Elle est aussi l'un des plus critiqués. Cox a montré qu'elle peut classer deux risques dans le mauvais ordre, et donner la même couleur à des risques dont les pertes attendues diffèrent de plusieurs ordres de grandeur [14]. Trois raisons :

- **des échelles ordinales** : le niveau 4 n'est pas « deux fois » le niveau 2 ; leurs bornes (une fois par an, une fois en trois ans) sont dans un rapport de 1 à 3 au moins, et les bornes d'impact dans un rapport de 1 à 10 ;
- **un produit qui écrase** : un risque fréquent et mineur (4×1) et un risque rare et critique (1×4) ont la même criticité, 4 ;
- **des frontières arbitraires** : une fréquence de 0,32 par an et une de 0,34 tombent dans deux niveaux différents, une fréquence de 0,34 et une de 0,99 dans le même.

★ Attention

Violation typique. Accepter un risque rare et critique parce que sa criticité tombe en zone verte.

Règle : la criticité classe, elle ne décide pas. Un risque d'impact critique se présente toujours à l'instance qui répond des risques, avec son scénario. Quand la décision dépend de l'ordre de grandeur des pertes, on quantifie (Chapitre 5).

2.5 Inhérent, Résiduel, Appétence

2.5.1 Trois niveaux

■ Définition

Risque inhérent : niveau du risque avant la prise en compte des mesures de sécurité.

Risque résiduel : niveau du risque qui subsiste compte tenu des mesures réellement en place *et dont l'efficacité a été établie.*

Appétence au risque : niveau de risque que l'organisation accepte pour atteindre ses objectifs, fixé par l'organe de gouvernance (Chapitre 1).

2.5.2 Une convention de réduction

Pour que deux analystes obtiennent le même résiduel, il faut une règle de réduction écrite. Le cours retient la suivante, fondée sur les étapes du scénario.

☑ Papier de travail

Réduire un risque, étape par étape.

- On classe les mesures selon l'étape du scénario sur laquelle elles agissent : *entrée* (empêcher l'accès initial), *propagation* (empêcher l'extension), *récupération* (limiter les conséquences).
- Une étape couverte par au moins une mesure **testée et efficace** abaisse d'un niveau : la vraisemblance pour l'entrée et la propagation, l'impact pour la récupération.
- Une étape ne compte qu'une fois, quel que soit le nombre de mesures qui la couvrent ; aucun niveau ne descend sous 1.

- Une mesure non testée, ou cotée NEK, n'abaisse rien.
- Le papier de travail cite, pour chaque réduction, la mesure et la preuve de son test.

2.5.3 R-AG-01, coté

Scénario Opérationnel · Opération SANAGA. R-AG-01, inhérent et résiduel

Inhérent. Une banque de 38 agences qui reçoit chaque jour des courriels de l'extérieur sera visée au moins une fois par an : vraisemblance 4. Le scénario redouté touche tout le réseau plus de trois jours : impact 4. Criticité inhérente : $4 \times 4 = 16$.

Mesures de 2025, avec les cotes de l'audit interne (prologue, Tableau P.3) :

- entrée : filtrage des pièces jointes et antivirus, OUI ; second facteur, NON ⇒ étape couverte, -1 en vraisemblance ;
- propagation : cloisonnement, NON ⇒ aucune réduction ;
- récupération : sauvegardes hors ligne testées, NON ; plan de réponse testé, NON ⇒ aucune réduction.

Résiduel. Vraisemblance 3, impact 4 : criticité $3 \times 4 = 12$, intolérable.

Analyse (confiance moyenne). Le registre de 2025 aurait dû porter un risque intolérable sur les agences. Il n'en portait aucun, parce que le scénario n'y figurait pas. La cote résiduelle de 12 n'est pas une prédiction : elle dit que, faute de mesures sur deux étapes sur trois, la banque dépendait d'une seule barrière, et que cette barrière arrête les attaques connues, pas les nouvelles.

2.6 Une Cote sans Preuve est une Incertitude

2.6.1 Deux incertitudes

Le mot « incertitude » figure dans la définition du risque. Il recouvre deux choses que la gestion des risques confond souvent.

Définition

Incertitude aléatoire : part de l'incertitude qui tient au hasard des événements : même parfaitement informé, on ne sait pas si l'attaque aura lieu cette année. Elle ne se réduit pas ; elle se décrit par une probabilité.

Incertitude épistémique : part de l'incertitude qui tient à ce que l'on ne sait pas de l'état du système ou de la menace : on ignore si les journaux contiennent des traces d'intrusion. Elle se réduit en collectant des preuves.

	Aléatoire	Épistémique
Porte sur	Les événements futurs	L'état présent du système et de la menace
Se réduit ?	Non	Oui, par des preuves
Se mesure par	Une probabilité, un intervalle de pertes	Le taux d'incertitude U et l'entropie H des réponses
À la BANQUE SANAGA	Le groupe attaquera-t-il en 2027 ?	Les journaux du pare-feu contiennent-ils des traces d'intrusion ?

Tableau 2.4. Incertitude aléatoire et incertitude épistémique

Une vraisemblance cotée « 1 » sans base de preuve mélange les deux : elle prétend décrire le hasard (l'aléatoire), alors qu'elle traduit une ignorance (l'épistémique). Le programme de l'auditologie fait de cette distinction l'une de ses thèses [56], [57] : avant de mesurer un risque, on mesure ce que l'on sait de lui.

2.6.2 Coter la cote

Chaque cote d'un registre repose sur une **base de preuve** : des mesures internes (journaux, incidents recensés, tests), des données externes (statistiques du secteur, alertes des autorités), un avis d'expert motivé, ou rien. On cote donc la cote elle-même :

- OUI : la base de preuve existe et soutient la cote (un avis d'expert motivé et écrit compte, et se signale comme tel) ;
- NON : la base de preuve existe et contredit la cote ;
- NEK : aucune base de preuve, ou une base qui ne permet pas de conclure (une déclaration, un silence non surveillé).

Scénario Opérationnel · Opération SANAGA. Le registre de 2025, revu

Mme ABENA revoit les douze cotes (six vraisemblances, six impacts) des six scénarios du registre approuvé en novembre 2025.

Réf.	Scénario	V	I	Base de la vraisemblance	V	I
DC-01	Coupure électrique prolongée	2	4	Journal des coupures sur cinq ans	OUI	OUI
DC-02	Défaillance du prestataire DIGICORE	2	3	« Prestataire fiable » ; aucune revue, pas de droit d'audit	NEK	OUI
DC-03	Intrusion par Internet	1	4	« Jamais attaqués » ; journaux du pare-feu d'accès non lus	NEK	OUI
DC-04	Erreur lors d'un changement	1	3	Sept incidents liés à des changements en 2025	NON	OUI
DC-05	Copie de données par un administrateur	1	4	« Confiance dans les équipes »	NEK	NEK
DC-06	Déni de service des services en ligne	1	3	Quatre attaques signalées par le fournisseur d'accès en 2025	NON	OUI

Colonnes : V et I cotés (1 à 4) ; puis cote de la base de preuve de la vraisemblance (V) et de l'impact (I). Les impacts reposent sur l'analyse d'impact sur l'activité de 2024, sauf pour DC-05 : personne n'a établi quelles données un administrateur pouvait copier.

Lecture auditologique · Base de preuve du registre de 2025

Constatation. Sur douze cotes : 6 OUI, 2 NON, 4 NEK.

$\mu = 0{,}50\,; \quad U = \frac{4}{12} \approx 0{,}33\,; \quad H = -\left(\frac{1}{2}\log_2\frac{1}{2} + \frac{1}{6}\log_2\frac{1}{6} + \frac{1}{3}\log_2\frac{1}{3}\right) \approx 0{,}50{+}0{,}43{+}0{,}53 \approx 1{,}46$ bit.

Par colonne : impacts 5/0/1 ($\mu \approx 0{,}83$, $U \approx 0{,}17$, $H \approx 0{,}65$) ; vraisemblances 1/2/3 ($\mu \approx 0{,}17$, $U = 0{,}50$, $H \approx 1{,}46$).

Analyse (confiance élevée). Le registre est solide sur les conséquences et fragile sur les fréquences : une seule vraisemblance sur six est fondée. Les deux NON sont les plus graves : DC-04 et DC-06 étaient contredits par des pièces que la banque détenait. DC-04 annonçait la bascule ratée de mars 2026. Enfin, ce tableau ne mesure que ce que le registre contient : le scénario des agences, absent, échappe même à cette revue. C'est le NEK du prologue, au niveau du périmètre.

$\mu = 0{,}50$ · $U = 0{,}33$ · $H = 1{,}46$ **bit**

2.6.3 Quand la cote est un intervalle

Une estimation honnête de la vraisemblance prend souvent la forme d'un intervalle. L'atelier de quantification du cours estime la fréquence de R-AG-01 entre 0,2 et 0,6 événement par an (Chapitre 5). Sur l'échelle du Tableau 2.3, cet intervalle chevauche deux niveaux : de 0,2 à 0,33, niveau 2 ; de 0,33 à 0,6, niveau 3. Le résiduel vaut donc 8 ou 12 selon le niveau retenu : « à traiter dans l'année » ou « intolérable ».

Note

Une décision qui dépend de l'incertitude. Quand l'intervalle d'une cote traverse un seuil d'appétence, la décision dépend de ce que l'on ignore. Deux réponses sont légitimes : retenir le niveau le plus défavorable en le signalant, ou réduire l'incertitude avant de décider (une revue des journaux, une simulation d'attaque, une quantification). Choisir silencieusement le niveau favorable ne l'est pas.

2.6.4 La fiche de risque, avec sa base de preuve

Fiche de risque · R-DC-03 · Intrusion par Internet (fiche révisée)

Valeur métier : les opérations du système central (comptes, virements).
Biens supports : pare-feu, serveurs exposés, comptes d'administration à distance.
Source de risque et objectif visé : groupe cybercriminel, fraude ou extorsion.
Événement redouté : prise de contrôle du système central.
Vraisemblance : 1 en 2025. Base : absence d'incident connu, journaux du pare-feu d'accès effacés à trente jours sans lecture. Cote de la base : NEK.
Impact : 4. Base : analyse d'impact sur l'activité de 2024. Cote de la base : OUI.
Pour réduire l'incertitude : centraliser et conserver les journaux un an ; faire analyser trois mois de journaux par un tiers ; commander un test d'intrusion externe (UE MSN-2S3-SEC03).
Décision provisoire : faute de fréquence observée, la vraisemblance est recalculée par la convention de réduction : inhérent 4 (serveurs exposés à Internet), entrée couverte par des mesures testées au centre (second facteur, correctifs : prologue, Tableau P.3), −1 ; propagation couverte (cloisonnement testé), −1. Vraisemblance 2, impact 4 : criticité 8, à traiter dans l'année, et présentée au comité en raison de l'impact 4. À confirmer par la revue des journaux.

2.7 Le Cadre de Référence

L'article 26 de la loi n° 2010/012, cité au Chapitre 1, impose aux exploitants de systèmes d'information des dispositifs normalisés pour *identifier* et *évaluer* en permanence les risques de sécurité [53]. Pour une banque, le règlement COBAC R-2016/04 range les risques liés aux systèmes d'information parmi les risques que le dispositif de contrôle interne doit couvrir [8].

Note

Analyse (lecture du cours). Ni la loi ni le règlement ne disent comment coter. Mais une évaluation que l'on ne peut pas justifier n'en est pas une : devant le superviseur comme devant un juge, une cote se défend par sa base de preuve. Le registre qui distingue ce qu'il sait de ce qu'il suppose est plus défendable que celui qui affiche des chiffres sans source. Le Chapitre 10 revient sur ces obligations.

2.8 Ce que la Cote demande à chaque Métier

Application Gestionnaire des risques cyber

Documenter chaque cote

1. Écrire, pour chaque vraisemblance et chaque impact, la base de preuve et sa date.
2. Coter la base : OUI, NON ou NEK ; ne jamais transformer un NEK en « faible ».
3. Donner un intervalle quand l'estimation le justifie, et signaler tout intervalle qui traverse un seuil d'appétence.
4. Ne réduire le résiduel que par des mesures testées, selon la convention écrite.

Application Auditeur en cybersécurité

Auditer le registre, pas seulement les mesures

L'auditeur prélève des cotes et demande leur base. Une vraisemblance sans base est une constatation ; une vraisemblance contredite par une pièce détenue par l'organisation est une constatation grave, parce qu'elle montre que l'information existait et n'a pas été utilisée.

Application RSSI

Transformer les nek en travaux

Chaque NEK du registre appelle une action qui produit une preuve : lecture de journaux, test de restauration, revue d'un prestataire, test d'intrusion. Le RSSI les classe par l'importance de la décision qu'ils débloquent : d'abord les cotes dont l'intervalle traverse un seuil.

Application Responsable GRC

Une échelle, une convention

Le responsable GRC fait approuver par le conseil l'échelle, l'appétence et la convention de réduction, puis veille à ce que tous les registres de l'organisation les appliquent. Deux registres qui cotent différemment ne peuvent pas être comparés, donc pas arbitrés.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Un risque** est l'effet de l'incertitude sur un objectif ; un scénario relie une source de risque, par des biens supports vulnérables, à un événement redouté sur une valeur métier.
- **Le risque cyber** dépend d'un adversaire qui s'adapte, a peu d'historique, peut rester invisible, frappe plusieurs sites à la fois et produit des pertes très dispersées.
- **La criticité classe, elle ne décide pas** : les matrices écrasent les écarts ; tout impact critique remonte à l'instance qui répond des risques.
- **Le résiduel** ne se réduit que par des mesures testées, selon une convention écrite : une étape du scénario couverte abaisse d'un niveau.
- **Deux incertitudes** : l'aléatoire se décrit, l'épistémique se réduit par des preuves.
- **On cote la cote** : OUI, NON ou NEK selon sa base de preuve. Le registre 2025 de la SANAGA : $\mu = 0{,}50$, $U \approx 0{,}33$, et une seule vraisemblance fondée sur six.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- décomposer un scénario en source, objectif visé, biens supports, vulnérabilités, événement redouté et valeur métier ;
- calculer une criticité inhérente et résiduelle avec la convention de réduction ;
- montrer, sur un exemple, ce qu'une matrice de risques cache ;
- coter la base de preuve d'une vraisemblance, et dire ce qu'il faudrait pour la rendre OUI.

Exercices

✍ Exercice 2.1. Le vocabulaire du scénario ★☆☆

Associez chacun des éléments suivants, tirés de l'incident de septembre 2026, à l'une des notions du chapitre (valeur métier, bien support, menace, vulnérabilité, source de risque, objectif visé, événement redouté, scénario).

(a) Un groupe cybercriminel organisé.

(b) Obtenir le paiement d'une rançon.

(c) Le partage de fichiers ouvert à toutes les agences.

(d) Les postes de travail des agences.

(e) Le service au guichet.

(f) La fermeture des guichets pendant plusieurs jours.

(g) Un rançongiciel.

(h) Courriel piégé, vol d'identifiants, déplacement par le partage, chiffrement des postes.

✍ Exercice 2.2. Six mois après ★★☆

En mars 2027, la situation de R-AG-01 est la suivante : le second facteur est déployé et testé sur tous les comptes ; le partage de fichiers est cloisonné par agence, mais le cloisonnement n'a pas encore été testé ; les sauvegardes hors ligne ont été restaurées avec succès lors d'un test.

(a) Calculez la criticité résiduelle avec la convention du chapitre (inhérent : 4×4). Quelle décision l'appétence impose-t-elle ?

(b) Que deviendrait le résiduel si le cloisonnement était testé avec succès ?

(c) Le second facteur n'a rien changé au calcul. Expliquez pourquoi, et dites si c'est un défaut de la convention ou une qualité.

✍ Exercice 2.3. Ce que cache la matrice ★★☆

Le registre de la banque contient deux risques :

- A : erreurs de saisie au guichet, vraisemblance 4, impact 1 ;
- B : fraude massive au virement par compromission du système de paiement, vraisemblance 1, impact 4.

(a) Calculez leur criticité. Que conclurait un comité qui lit seulement la criticité ?

(b) Les erreurs A se produisent douze fois par an et coûtent 1 million FCFA chacune ; la fraude B a une chance sur vingt de se produire chaque année et coûterait 2 milliards FCFA. Calculez la perte annuelle attendue de chacun.

(c) Expliquez l'écart entre (a) et (b) à l'aide des trois défauts des matrices vus dans le chapitre.

(d) Quelle règle de l'appétence de la banque évite la mauvaise décision ?

✍ Exercice 2.4. La base de preuve du registre de LiZbiZ ★★★

Mme NKENG reprend le registre R1 à R8 de LiZbiZ (cotes de probabilité inchangées) et recherche la base de chaque probabilité :

- R1, ajustement frauduleux du stock : écart de 186 millions FCFA constaté, ajustements identifiés ;
- R2, fournisseurs fictifs : fraude TRANSLOG établie ;
- R3, compte d'un agent parti : « on désactive les comptes au départ », déclaration du responsable informatique, sans extraction ;
- R4, arrêt prolongé du centre de Garoua : journal des coupures sur trois ans, un arrêt de plus d'un jour ;
- R5, perte de données faute de sauvegarde restaurable : « les sauvegardes tournent chaque nuit », aucun test de restauration ;
- R6, fuite de données des clients : aucune information ;
- R7, erreurs de facturation : trois erreurs par mois relevées par le contrôle de gestion ;
- R8, rançongiciel (probabilité 2) : « nous n'avons jamais été touchés » ; l'audit des quatre centres a pourtant relevé des comptes par défaut, des services en clair et des flux non autorisés.

(a) Cotez chaque base OUI, NON ou NEK, en justifiant.

(b) Calculez μ, U et H.

(c) Proposez une nouvelle cote de probabilité pour R8, recalculez sa criticité résiduelle (impact 4, aucune mesure testée) et dites ce que l'appétence impose.

(d) Rédigez pour Mme NKENG une note de dix lignes : quelles cotes rétablir en priorité, par quelles preuves, et pourquoi dans cet ordre.

● Note

Pour aller plus loin.

- L'ISO 31000:2018 [31] et l'ISO/IEC 27005:2022 [42], pour le vocabulaire et le processus.
- Le guide EBIOS Risk Manager [2], pour les notions de valeur métier, bien support et source de risque.
- L'article de Cox sur les matrices de risque [14].
- L'article sur l'incertitude épistémique [56], qui fonde la cote NEK.

Note

Transition. La Partie I a posé qui décide (Chapitre 1) et ce que l'on décide (ce chapitre). La Partie II passe aux méthodes : comment conduire une appréciation des risques complète, de l'établissement du contexte à l'acceptation du résiduel. C'est l'objet du Chapitre 3.

partie II

Méthodes : Gérer les Risques, Conduire l'Audit

© *MaletYon*

3

GÉRER LES RISQUES : ISO 31000 ET ISO/IEC 27005

« Un registre est une photographie.
La gestion des risques est un processus. »

Principe du cours

Niveau : *Fondamental* • Maîtrise du Chapitre 2

✦ Objectifs du chapitre

- ➢ Situer les principes, le cadre et le processus de l'ISO 31000.
- ➢ Établir le contexte d'une appréciation : périmètre, parties intéressées, critères de risque et critères d'acceptation.
- ➢ Appliquer les deux approches d'identification de l'ISO/IEC 27005:2022 et montrer qu'elles se complètent.
- ➢ Choisir une option de traitement et rédiger un plan de traitement.
- ➢ Faire accepter formellement le risque résiduel, et refuser une acceptation fondée sur une cote NEK.
- ➢ Suivre l'avancement d'un plan de traitement par μ, U et H.

Avant de commencer : « Donnez-nous un plan »

Douala, décembre 2026. Le comité des risques du conseil de la BANQUE SANAGA[1] a reçu en novembre la cotation de R-AG-01 : 12, intolérable. Il ne demande plus une cote ; il demande un plan. Que fait-on, qui le fait, pour quand, à quel coût, et que restera-t-il ensuite ?

Mme ABENA mesure l'écart. Le registre de 2025 était une liste de six scénarios, revue une fois par an. Il n'avait ni critères d'acceptation, ni plan de traitement, ni suivi. La banque avait un registre ; elle n'avait pas de processus. La RSSI propose de reprendre

[1] Comme dans tout le cours, la BANQUE SANAGA, ses dirigeants, ses prestataires, les dates et les montants sont fictifs ; les normes et les textes cités sont exacts.

© MaletYon

la démarche depuis le début, selon l'ISO 31000 et l'ISO/IEC 27005, sur toute la banque cette fois.

Ce chapitre ouvre la Partie II, consacrée aux méthodes. Il présente le processus général de gestion des risques, puis la manière dont l'ISO/IEC 27005 l'applique à la sécurité de l'information, jusqu'à l'acceptation formelle de ce qui reste.

★ Attention

Violation typique. Tenir un registre des risques sans plan de traitement ni décision d'acceptation : les risques sont décrits, cotés, et laissés en l'état.

Règle : chaque risque d'un registre aboutit à une décision écrite : un traitement, avec un responsable et une échéance, ou une acceptation, signée par l'instance compétente. Un risque coté sans décision n'est pas géré.

3.1 L'ISO 31000 : Principes, Cadre, Processus

3.1.1 Une norme générale

L'ISO 31000:2018 donne des lignes directrices pour le management du risque, quel qu'il soit : financier, industriel, juridique, cyber [31]. Elle n'est pas certifiable et ne prescrit pas de méthode. Elle s'articule en trois ensembles : des *principes*, qui disent ce qu'est un management du risque efficace ; un *cadre organisationnel*, qui l'intègre dans la gouvernance ; un *processus*, qui en décrit les étapes.

Ensemble	Contenu (d'après l'ISO 31000:2018)
Principes	Intégré ; structuré et global ; adapté ; inclusif ; dynamique ; fondé sur la meilleure information disponible ; attentif aux facteurs humains et culturels ; en amélioration continue
Cadre	Leadership et engagement de la direction ; intégration dans les activités ; conception ; mise en œuvre ; évaluation ; amélioration
Processus	Communication et consultation ; domaine d'application, contexte et critères ; appréciation (identification, analyse, évaluation) ; traitement ; suivi et revue ; enregistrement et rapports

Tableau 3.1. Les trois ensembles de l'ISO 31000

Le cadre fait le lien avec le Chapitre 1 : sans leadership de la direction ni intégration dans la gouvernance, le processus tourne à vide. Le principe de « meilleure information disponible » fait le lien avec le Chapitre 2 : la norme demande que l'information soit disponible, et elle ajoute qu'il faut tenir compte de ses limites et de ses incertitudes. C'est exactement ce que fait la cote de la base de preuve.

3.1.2 Le processus

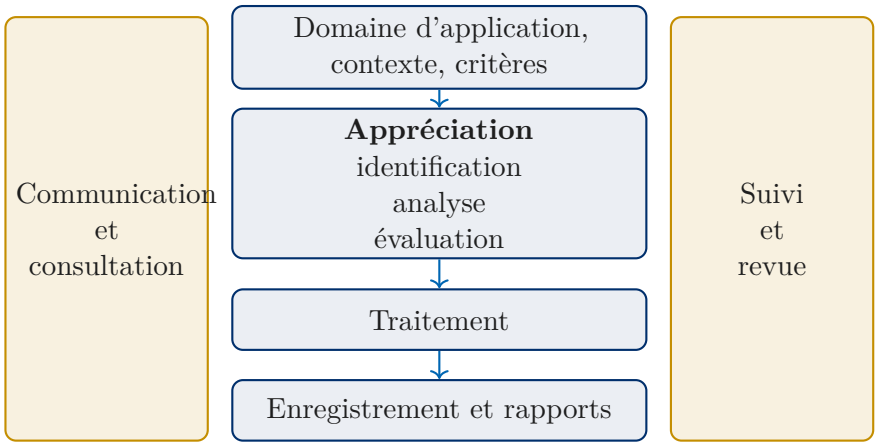


Figure 3.1: Le processus de management du risque (d'après l'ISO 31000:2018)

Deux activités encadrent les autres et durent tout le processus : la *communication et consultation*, qui associe les parties intéressées à chaque étape, et le *suivi et revue*, qui vérifie que les décisions sont appliquées et que les cotes restent valables. À la BANQUE SANAGA, ce sont précisément les deux activités qui manquaient : le registre était rédigé par la DSI seule, et revu une fois par an.

3.1.3 L'ISO/IEC 27005, déclinaison pour la sécurité de l'information

L'ISO/IEC 27005:2022 applique ce processus à la sécurité de l'information et le relie aux exigences de l'ISO/IEC 27001 [42]. Elle n'impose pas non plus de méthode : EBIOS Risk Manager (Chapitre 4) ou une méthode maison peuvent la mettre en œuvre. Sa version de 2022 a refondu le texte de 2018 ; elle insiste sur l'identification des risques à partir des événements, et non plus seulement des actifs.

3.2 Établir le Contexte

3.2.1 Périmètre et parties intéressées

Le premier livrable fixe le périmètre de l'appréciation et les parties intéressées. La RSSI retient cette fois toute la banque : le siège, le centre de données, le site de secours de Bonabéri et les 38 agences. Elle recense les parties intéressées et ce qu'elles attendent.

Partie intéressée	Attente en matière de sécurité
Clients	Guichets ouverts, comptes exacts, données protégées
Actionnaires et conseil	Pertes contenues dans l'appétence, réputation préservée
COBAC	Dispositif de maîtrise des risques couvrant les systèmes d'information ; comptes rendus après incident
DIGICORE et autres prestataires	Engagements contractuels clairs, accès encadrés
Agents des agences	Outils disponibles, consignes simples

Tableau 3.2. Les parties intéressées de l'appréciation

3.2.2 Critères de risque, critères d'acceptation

L'ISO/IEC 27005 demande d'établir, avant toute appréciation, deux familles de critères : ceux qui servent à apprécier (les échelles de vraisemblance et d'impact) et ceux qui servent à accepter [42]. La banque dispose des premiers depuis novembre 2026 (Chapitre 2, Tableau 2.3). Il lui manque les seconds : la règle d'appétence dit quels risques traiter, elle ne dit pas qui peut accepter quoi.

Définition

Critères d'acceptation du risque : règles, fixées à l'avance par l'organe de direction, qui disent quel niveau de risque résiduel peut être accepté, par qui, à quelles conditions et pour combien de temps.

En décembre 2026, le comité des risques complète l'appétence par les critères suivants.

Résiduel	Qui peut accepter	Conditions
1 à 4	Le propriétaire du risque	Décision écrite ; revue annuelle
5 à 8	Le comité de sécurité, sur proposition du propriétaire	Aucune mesure supplémentaire proportionnée ; revue semestrielle ; sinon, traitement dans l'année
9 et plus	Personne, sauf le comité des risques du conseil, à titre temporaire	Plan de traitement daté ; durée de six mois au plus, renouvelable une fois
Toute cote	–	Pas d'acceptation si une cote de vraisemblance ou d'impact a une base NEK ou NON, sauf acceptation « en l'état des connaissances » avec une date de revue

Tableau 3.3. Critères d'acceptation de la BANQUE SANAGA (décembre 2026)

Note

Pourquoi la dernière ligne ? Accepter un risque, c'est décider en connaissance de cause de ne pas le traiter davantage. Si la cote repose sur une ignorance, la décision ne porte pas sur le risque, mais sur une supposition. La règle n'interdit pas d'accepter ; elle oblige à dire ce que l'on accepte d'ignorer, et jusqu'à quand.

3.3 Apprécier : Deux Approches qui se Complètent

3.3.1 Identifier

L'ISO/IEC 27005:2022 propose deux approches d'identification : par les *événements* et par les *actifs* [42].

	Par les événements	Par les actifs
Point de départ	Les sources de risque, leurs objectifs, et les événements redoutés sur les valeurs métier	L'inventaire des biens supports, puis leurs menaces et vulnérabilités
Niveau	Stratégique : on raisonne en scénarios	Détaillé : on raisonne composant par composant
Force	Rapide, centrée sur ce qui compte pour la direction	Exhaustive, fait apparaître des faiblesses précises
Faiblesse	Peut oublier un composant que personne n'a imaginé	Lourde ; peut noyer l'essentiel dans des centaines de lignes

Tableau 3.4. Les deux approches d'identification

Scénario Opérationnel · Opération SANAGA. Ce que chaque approche a trouvé

Par les événements. Un atelier réunit la direction du réseau d'agences, la DSI, la direction des risques et la direction financière. Il retient quatre scénarios stratégiques : le rançongiciel en agence (R-AG-01) ; la fraude au virement par compromission d'un poste du siège ; la défaillance de DIGICORE ; la fuite du fichier des clients.

Par les actifs. L'inventaire des biens supports des 38 agences, mené en parallèle, fait apparaître deux faiblesses qu'aucun scénario n'avait imaginées :

- les automates de retrait (GAB) de 14 agences fonctionnent sous un système d'exploitation qui ne reçoit plus de correctifs ;
- dans 31 agences, le chef d'agence dispose des droits d'administration locale sur tous les postes, pour « dépanner ».

Analyse (confiance élevée). Les deux approches ne se recouvrent pas. Les scénarios ont donné les priorités de la direction ; l'inventaire a donné des faiblesses concrètes,

dont la seconde alimente directement R-AG-01 (elle facilite la propagation). On ne choisit pas entre les deux : on part des événements pour savoir ce qui compte, et l'on vérifie par les actifs que rien d'important n'échappe.

3.3.2 Analyser et évaluer

L'*analyse* cote chaque risque : vraisemblance, impact, criticité, avec leur base de preuve (Chapitre 2). L'*évaluation* compare le résultat aux critères et en tire une priorité : traiter sans délai, traiter dans l'année, ou proposer à l'acceptation. Les deux faiblesses de l'inventaire ne sont pas des risques à part entière ; ce sont des vulnérabilités qui modifient la cote d'un scénario existant, ou qui en appellent un nouveau (« compromission d'un GAB »).

3.4 Traiter

3.4.1 Les options

L'ISO 31000 énumère les options de traitement : éviter le risque en renonçant à l'activité ; prendre ou augmenter un risque pour saisir une opportunité ; supprimer la source de risque ; modifier la vraisemblance ; modifier les conséquences ; partager le risque ; maintenir le risque par une décision argumentée [31]. En sécurité de l'information, on les regroupe souvent en quatre familles.

Famille	Principe	Limite
Réduire	Modifier la vraisemblance ou les conséquences par des mesures	Ne réduit le résiduel que si les mesures sont testées
Partager	Transférer une partie des conséquences financières (assurance, contrat)	Ne transfère ni la responsabilité, ni l'atteinte à la réputation
Éviter	Renoncer à l'activité ou au composant qui crée le risque	Supprime aussi la valeur que l'activité apportait
Maintenir	Accepter le résiduel, selon les critères	Exige une décision écrite et une base de preuve

Tableau 3.5. Les quatre familles de traitement

3.4.2 Les options pour R-AG-01

Scénario Opérationnel · Opération SANAGA. Choisir un traitement pour R-AG-01

Maintenir : impossible. La criticité résiduelle est de 12 ; seul le comité des risques du conseil pourrait l'accepter, pour six mois, et avec un plan.

Éviter : supprimer le partage de fichiers commun aux agences. Option retenue en partie : le partage commun est remplacé par un espace par agence. Supprimer

la messagerie externe en agence, en revanche, priverait les agences d'un outil indispensable.

Partager : une assurance contre les risques cyber, si le marché le permet. Ordre de grandeur obtenu d'un courtier : prime de 35 millions FCFA par an, franchise de 100 millions, plafond de 1 milliard. Les assureurs exigent en général, avant de couvrir, un second facteur et des sauvegardes hors ligne testées : l'assurance vient *après* la réduction, pas à sa place.

Réduire : couvrir les trois étapes du scénario par des mesures testées (plan ci-dessous).

Analyse (confiance moyenne). La combinaison retenue est « réduire, éviter en partie, puis partager ». Le résiduel visé, selon la convention de réduction, est de vraisemblance 2 (entrée et propagation couvertes) et d'impact 3 (récupération couverte) : criticité 6. La convention ne permet pas de descendre plus bas ; un résiduel de 6 relève du comité de sécurité.

3.4.3 Le plan de traitement

L'ISO/IEC 27001 demande, en substance, que l'organisation choisisse ses options de traitement, détermine les mesures nécessaires, les compare à celles de son annexe A, établisse une déclaration d'applicabilité, formule un plan de traitement, et obtienne des propriétaires des risques l'approbation de ce plan et l'acceptation des risques résiduels [40]. La déclaration d'applicabilité est étudiée au Chapitre 8 ; voici le plan.

Réf.	Action	Étape	Responsable	Échéance	M FCFA
A1	Second facteur sur tous les comptes	Entrée	DSI	mars 2027	25
A2	Cloisonnement du partage, un espace par agence	Propag.	DSI	fév. 2027	40
A3	Test d'intrusion interne vérifiant le cloisonnement	Propag.	RSSI	juin 2027	15
A4	Sauvegardes hors ligne des serveurs d'agence, test trimestriel	Récup.	DSI	mars 2027	60
A5	Procédure de guichet en mode dégradé, exercée	Récup.	Dir. réseau d'agences	avril 2027	5
A6	Sensibilisation des agents des 38 agences	Entrée	RSSI	juin 2027	10
A7	Plan de réponse aux incidents testé par un exercice	Récup.	RSSI	sept. 2027	8
A8	Journalisation centralisée des postes et du partage	Détection	DSI	juin 2027	30
Total					**193**

Tableau 3.6. Plan de traitement de R-AG-01 (décembre 2026)

Deux remarques. L'action A3 n'ajoute aucune mesure : elle produit la preuve sans laquelle A2 n'abaisserait rien. Et l'action A8 ne correspond à aucune étape de la convention : elle ne réduit pas la cote, mais elle réduit l'incertitude, puisque la banque saura désormais si elle est attaquée.

Papier de travail

Le contenu minimal d'un plan de traitement. Pour chaque action :

- le risque traité et l'étape du scénario visée ;
- le responsable (une personne, pas un service) et l'échéance ;
- le coût estimé et la source du financement ;
- la **preuve attendue** qui permettra de la déclarer réalisée (procès-verbal de test, extraction, rapport) ;
- l'effet attendu sur la cote, selon la convention écrite.

Le plan entier porte l'approbation du propriétaire du risque, et sa date de revue.

3.5 Accepter le Risque Résiduel

3.5.1 Une décision, pas un constat

Définition

Acceptation du risque : décision argumentée, prise par une personne ou une instance qui en a l'autorité, de ne pas traiter davantage un risque résiduel, pour une durée donnée et à des conditions données.

L'acceptation est la décision que les registres oublient le plus souvent. Un risque qui reste dans le registre d'une année sur l'autre, sans traitement ni signature, est accepté de fait : personne ne l'a décidé, et personne n'en répond. C'est la forme la plus discrète du défaut de gouvernance étudié au Chapitre 1.

3.5.2 Le cas de DIGICORE

Le scénario DC-02, défaillance du prestataire d'hébergement DIGICORE, était coté $2 \times 3 = 6$ en 2025, avec une vraisemblance sans base (NEK). Le contrat ne contient pas de clause de droit d'audit ; la banque ne sait pas comment le prestataire gère ses propres risques.

Fiche de risque · R-DC-02 · Décision d'acceptation (janvier 2027)

Risque : défaillance prolongée de DIGICORE, prestataire d'hébergement du centre de données.

Propriétaire : le directeur des opérations.
Résiduel : vraisemblance 2, impact 3, criticité 6. Base de la vraisemblance : NEK (aucune revue du prestataire, pas de droit d'audit). Base de l'impact : OUI (analyse d'impact sur l'activité).
Mesures en place : site de secours de Bonabéri ; plan de continuité approuvé en 2022, jamais testé (aucune réduction retenue).
Décision : accepté par le comité de sécurité *en l'état des connaissances*, pour six mois. Conditions : avenant au contrat introduisant un droit d'audit et un rapport annuel d'assurance du prestataire (A10) ; test du plan de continuité avant la revue.
Revue : juillet 2027. Si l'avenant est refusé, le risque est présenté au comité des risques du conseil.
Signatures : directeur des opérations (propriétaire) ; président du comité de sécurité ; RSSI (avis).

★ Attention

Violation typique. Faire signer l'acceptation par le RSSI ou par le DSI parce qu'ils « connaissent le sujet ».

Règle : accepte celui qui a l'autorité et supporte les conséquences, selon les critères d'acceptation. Le RSSI donne un avis ; il ne signe pas à la place du propriétaire.

3.6 Suivre et Revoir

3.6.1 Le programme 2027, neuf mois plus tard

Le programme de traitement de 2027 compte les huit actions de R-AG-01 et deux autres : A9, conservation et lecture des journaux du pare-feu d'accès (pour R-DC-03), et A10, avenant au contrat de DIGICORE (pour R-DC-02). Fin septembre 2027, le comité de sécurité fait le point. Une action est cotée OUI si elle est réalisée *et* que la preuve attendue est au dossier, NON si elle n'est pas réalisée, NEK si elle est déclarée réalisée sans la preuve attendue.

Réf.	Action	Cote	Pièce
A1	Second facteur	OUI	Extraction de la configuration
A2	Cloisonnement	OUI	Rapport du test A3
A3	Test d'intrusion interne	OUI	Rapport du prestataire
A4	Sauvegardes hors ligne testées	OUI	Procès-verbaux de restauration
A5	Mode dégradé exercé	NEK	Procédure rédigée ; aucun exercice tracé
A6	Sensibilisation	NEK	Listes de présence de 22 agences sur 38
A7	Exercice de réponse aux incidents	NON	Reporté à 2028
A8	Journalisation centralisée	NEK	« 20 agences raccordées », sans extraction
A9	Journaux du pare-feu d'accès	OUI	Configuration, rapports de revue mensuels
A10	Avenant DIGICORE	NON	Refus du prestataire

Tableau 3.7. Avancement du programme de traitement (septembre 2027)

Lecture auditologique · Programme de traitement 2027

Constatation. 5 OUI, 2 NON, 3 NEK sur 10 actions :

$$\mu = 0{,}50\,; \quad U = 0{,}30\,; \quad H = -(0{,}5\log_2 0{,}5 + 0{,}2\log_2 0{,}2 + 0{,}3\log_2 0{,}3) \approx 0{,}500 + 0{,}464 + 0{,}521 \approx 1{,}49 \text{ bi}$$

Analyse (confiance élevée). Les actions techniques sont faites et prouvées ; les actions humaines et organisationnelles (mode dégradé, sensibilisation, exercice) sont en retard ou sans preuve. Pour R-AG-01, l'entrée et la propagation sont couvertes : vraisemblance 2. La récupération l'est aussi grâce à A4 : impact 3. Le résiduel visé, 6, est atteint. Mais deux NEK portent sur la récupération (A5) et la détection (A8) : le jour d'une attaque, la banque ne sait pas encore si ses agences sauront servir en mode dégradé. Le refus de DIGICORE (A10) déclenche, selon la décision de janvier, la présentation de R-DC-02 au conseil.

$\mu = 0{,}50$ · $U = 0{,}30$ · $H = 1{,}49$ **bit**

3.6.2 Quand revoir

Une appréciation se revoit à date fixe (au moins une fois par an), et aussi chaque fois que le contexte change : incident significatif, nouveau système, nouveau prestataire, nouvelle menace signalée par les autorités, changement de réglementation. Le Chapitre 13 montre comment des indicateurs de risque déclenchent ces revues sans attendre la date anniversaire.

3.7 Le Cadre Camerounais

Jurisprudence & Droit applicable

Loi n° 2010/012, article 26, alinéa 1 [53] :

« Les exploitants des systèmes d'information prennent toutes les mesures techniques et administratives afin de garantir la sécurité des services offerts. A cet effet, ils se dotent de systèmes normalisés leur permettant d'identifier, d'évaluer, de traiter et de gérer continûment les risques liés à la sécurité des systèmes d'information dans le cadre des services offerts directement ou indirectement. »

Article 29, alinéa 1 :

« Les exploitants des systèmes d'information ont l'obligation de conserver les données de connexion et de trafic de leurs systèmes d'information pendant une période de dix (10) ans. »

Portée. Les quatre verbes de l'article 26 (identifier, évaluer, traiter, gérer continûment) recouvrent les étapes du processus de l'ISO 31000 : identification, analyse et évaluation, traitement, suivi et revue. Une démarche conforme à l'ISO/IEC 27005 est donc une manière de satisfaire cette obligation, sans être la seule.

Analyse (confiance moyenne : la portée exacte des « données de connexion et de trafic » est étudiée au Chapitre 10). Des journaux de pare-feu effacés au bout de trente jours, comme ceux de la BANQUE SANAGA en 2025, se concilient mal avec l'article 29. L'action A9 ne traite donc pas seulement un risque : elle répond aussi à une obligation.

3.8 Ce que le Processus demande à chaque Métier

Application Gestionnaire des risques cyber

Faire tourner le processus

1. Faire approuver les critères d'acceptation avant toute appréciation.
2. Combiner l'approche par les événements et l'approche par les actifs.
3. Pour chaque risque, obtenir une décision écrite : un plan, ou une acceptation signée.
4. Suivre le plan par ses preuves, pas par les déclarations.

Application RSSI

Un plan qui produit des preuves

Chaque action du plan prévoit la preuve qui la clôturera. Le RSSI inscrit au plan les tests eux-mêmes (comme A3), car une mesure non testée n'abaisse rien, et refuse

de déclarer réalisée une action sans sa pièce.

Application Consultant en mise en œuvre de SMSI

Livrer un processus, pas un registre

Le consultant qui accompagne une organisation laisse derrière lui des critères approuvés, une méthode écrite, un plan avec des responsables et une première revue datée. Un registre bien présenté, livré seul, sera obsolète à la première réorganisation.

Application Auditeur en cybersécurité

Auditer les décisions

L'auditeur prélève des risques du registre et demande, pour chacun, la décision : le plan approuvé ou l'acceptation signée. Il vérifie que le signataire avait l'autorité selon les critères, et qu'aucune acceptation ne repose sur une cote sans base, sauf acceptation datée en l'état des connaissances.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **L'ISO 31000** donne des principes, un cadre et un processus ; la communication et le suivi encadrent toutes les étapes.
- **Le contexte** fixe le périmètre, les parties intéressées et deux familles de critères : pour apprécier, et pour accepter.
- **Deux approches d'identification** : par les événements pour savoir ce qui compte, par les actifs pour vérifier que rien n'échappe.
- **Quatre familles de traitement** : réduire, partager, éviter, maintenir ; l'assurance vient après la réduction.
- **Un plan de traitement** donne, pour chaque action, un responsable, une échéance, un coût et la preuve attendue.
- **L'acceptation** est une décision écrite, par l'instance compétente, à durée limitée ; sur une cote NEK, elle se fait « en l'état des connaissances », avec une date de revue.
- **Le suivi** cote les actions par leurs preuves : en septembre 2027, $\mu = 0{,}50$, $U = 0{,}30$ à la BANQUE SANAGA.

Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- ➢ placer une activité dans le processus de l'ISO 31000 ;
- ➢ dire ce que l'approche par les actifs apporte à l'approche par les événements, sur un exemple ;
- ➢ rédiger une ligne de plan de traitement complète ;
- ➢ dire qui peut accepter un résiduel donné, et à quelles conditions.

Exercices

✍ Exercice 3.1. Où en est-on dans le processus ? ★☆☆

Placez chacune des activités suivantes dans le processus de l'ISO 31000 (Figure 3.1).

(a) Le comité des risques fixe qui peut accepter un résiduel de 5 à 8.

(b) L'inventaire des postes des 38 agences.

(c) La RSSI cote la vraisemblance de la fraude au virement.

(d) Le comité compare les criticités aux critères et classe les risques.

(e) La DSI déploie le second facteur.

(f) Le comité de sécurité fait le point sur le programme 2027.

(g) La direction du réseau d'agences participe à l'atelier des scénarios.

(h) Le rapport annuel des risques est transmis au conseil.

✍ Exercice 3.2. Choisir un traitement ★★☆

Pour chacun des risques suivants de LiZbiZ (appétence : 9 et plus intolérable, 5 à 8 traité dans l'année, 1 à 4 accepté), proposez une famille de traitement et une mesure, et justifiez.

(a) R1, ajustement frauduleux du stock, résiduel 12.

(b) R4, arrêt prolongé du centre de Garoua, résiduel 4, base de probabilité OUI.

(c) R6, fuite de données des clients, résiduel 3, base de probabilité NEK (Exercice 2.4).

(d) R8, rançongiciel, résiduel 12 après nouvelle cote.

Indiquez, pour (d), pourquoi une assurance seule ne suffit pas.

✍ Exercice 3.3. Une acceptation contestable ★★☆

En février 2027, le dossier de R-DC-06 (déni de service des services en ligne, coté $1 \times 3 = 3$ en 2025) contient la décision suivante : « Risque accepté. Signé : le DSI. » Aucune date de revue n'est indiquée.

(a) Relevez tous les défauts de cette décision au regard des critères d'acceptation (Tableau 3.3).

(b) La base de la vraisemblance était cotée NON (quatre attaques signalées en 2025). Proposez une nouvelle vraisemblance, recalculez la criticité et dites qui peut désormais accepter le risque.

(c) Rédigez la décision corrigée sur le modèle de R-DC-02.

✍ Exercice 3.4. Le plan de traitement de R8 ★★★

LiZbiZ décide de traiter R8 (rançongiciel, probabilité 3, impact 4, criticité 12, aucune mesure testée). L'audit des quatre centres a relevé des comptes par défaut, des services en clair et des flux non autorisés.

(a) Décomposez le scénario en étapes (entrée, propagation, récupération) et reliez chaque constat de l'audit à une étape.

(b) Rédigez un plan de traitement de six actions au plus, au format du Tableau 3.6, en indiquant pour chacune la preuve attendue.

(c) Calculez le résiduel visé avec la convention de réduction, en partant d'un inhérent de 4×4, et dites qui pourra l'accepter selon des critères identiques à ceux de la BANQUE SANAGA.

(d) Un an plus tard, quatre actions sont prouvées, une est déclarée faite sans preuve, une n'est pas faite. Calculez μ, U et H, et dites si le résiduel visé est atteint.

● Note

Pour aller plus loin.

- ➢ L'ISO 31000:2018 [31], pour les principes, le cadre et le processus.
- ➢ L'ISO/IEC 27005:2022 [42], pour l'application à la sécurité de l'information.
- ➢ L'ISO/IEC 27001:2022 [40], article 6.1.3, sur le traitement des risques et la déclaration d'applicabilité.

Note

Transition. Le processus dit quoi faire ; il ne dit pas comment imaginer les scénarios. L'atelier de décembre 2026 a trouvé quatre scénarios stratégiques : comment les construire avec méthode, à partir des sources de risque et de leurs objectifs, puis les détailler en modes opératoires ? C'est l'objet de la méthode EBIOS Risk Manager, au Chapitre 4.

4

EBIOS RISK MANAGER

« On ne se protège pas d'une menace
que l'on n'a pas pris la peine d'imaginer. »

Principe du cours

Niveau : *Intermédiaire* • Maîtrise du Chapitre 3

✦ Objectifs du chapitre

- Situer EBIOS Risk Manager : son origine, sa logique « conformité et scénarios », ses cinq ateliers.
- Cadrer une étude : valeurs métier, biens supports, événements redoutés, gravité, socle de sécurité.
- Identifier et retenir des couples source de risque et objectif visé.
- Cartographier l'écosystème et construire des scénarios stratégiques.
- Détailler un scénario opérationnel et en coter la vraisemblance.
- Coter la base de preuve d'une étude EBIOS, et en tirer les priorités de connaissance.
- Situer MEHARI et le NIST SP 800-30 par rapport à EBIOS.

Avant de commencer : le client demande une preuve

Douala, janvier 2027. PHARMACAM[1], distributeur de médicaments et premier client de LiZbiZ, prépare le renouvellement de son contrat de transport. Sa direction des achats a ajouté une clause : le prestataire devra remettre « une analyse des risques de cybersécurité conduite selon une méthode reconnue ». Les médicaments voyagent sous chaîne du froid ; un arrêt du suivi des expéditions de plusieurs jours, et ce sont des lots entiers qu'il faut détruire.

M. ETEME, directeur général de LiZbiZ, appelle d'abord M. BEYALA, d'AUDIX CONSEIL, qui connaît l'entreprise. Celui-ci refuse d'animer l'étude : son cabinet a audité

[1] LiZbiZ, PHARMACAM, leurs dirigeants, les dates et les montants sont fictifs ; la méthode et les textes cités sont exacts.

© MaletYon

LiZbiZ et l'auditera encore ; il ne peut pas auditer demain une analyse qu'il aurait conduite aujourd'hui. Il conseille de confier l'animation à Mme NKENG, contrôleuse interne, et de choisir EBIOS Risk Manager.

Ce chapitre présente cette méthode et la déroule sur LiZbiZ, atelier par atelier. Les rançongiciels, la fraude au stock et les faux fournisseurs, que le registre R1 à R8 décrivait séparément, y deviennent des scénarios reliés à des attaquants, à leurs objectifs et à l'écosystème de l'entreprise.

★ Attention

Violation typique. Faire animer l'analyse des risques par le cabinet qui en auditera ensuite les résultats.

Règle : on n'audite pas son propre travail. Un auditeur peut conseiller sur la méthode ; il ne construit pas l'analyse qu'il devra évaluer. Le Chapitre 10 revient sur ces règles d'indépendance.

4.1 La Méthode

4.1.1 Origine et logique

EBIOS Risk Manager est la méthode d'appréciation et de traitement du risque numérique publiée en 2018 par l'Agence nationale de la sécurité des systèmes d'information (ANSSI, France), avec le soutien du Club EBIOS [2]. Elle succède aux versions d'EBIOS de 1995, 2004 et 2010. Elle est compatible avec l'ISO 31000 et l'ISO/IEC 27005 : elle en est une mise en œuvre, pas une alternative.

Sa logique tient en une phrase, que l'ANSSI formule comme une *synthèse entre conformité et scénarios* :

- la **conformité** construit un *socle de sécurité* : l'organisation applique les mesures d'un référentiel (hygiène informatique, ISO/IEC 27002) et mesure ses écarts ;
- les **scénarios** mettent ce socle à l'épreuve de menaces *intentionnelles et ciblées* : un attaquant précis, avec un objectif précis, qui passe éventuellement par l'écosystème de l'organisation.

● Note

Pourquoi cette division du travail ? Les menaces courantes (maliciel opportuniste, erreur, panne) se traitent par le socle : il serait inutile de construire un scénario pour chacune. L'effort d'imagination est réservé aux attaques qui visent l'organisation et peuvent contourner le socle. C'est l'inverse d'un registre qui énumère cent menaces au même niveau de détail.

4.1.2 Cinq ateliers

Atelier	Question	Principaux livrables
1. Cadrage et socle de sécurité	Que protège-t-on, de quoi a-t-on peur, où en est-on de la conformité ?	Périmètre, valeurs métier, biens supports, événements redoutés et gravité, écarts au socle
2. Sources de risque	Qui pourrait nous attaquer, et pour quoi faire ?	Couples source de risque et objectif visé, retenus ou écartés
3. Scénarios stratégiques	Par où passerait l'attaquant, y compris par nos partenaires ?	Cartographie de l'écosystème, scénarios stratégiques, mesures sur l'écosystème
4. Scénarios opérationnels	Comment s'y prendrait-il, techniquement ?	Modes opératoires, vraisemblance
5. Traitement du risque	Que décide-t-on, et comment le suit-on ?	Stratégie de traitement, mesures, risques résiduels, cadre de suivi

Tableau 4.1. Les cinq ateliers d'EBIOS Risk Manager

Les ateliers 1 à 3 relèvent de la direction et des métiers : ils raisonnent en enjeux et en attaquants. L'atelier 4 relève des techniciens : il raisonne en vulnérabilités et en chemins d'attaque. L'atelier 5 revient à la direction, qui décide. Les ateliers stratégiques se revoient rarement, les ateliers opérationnels plus souvent, au rythme des systèmes et des menaces.

Note

Échelles. Le guide propose des échelles de gravité et de vraisemblance que chaque organisation adapte. Le cours emploie la sienne (Chapitre 2, Tableau 2.3), en appelant *gravité* l'impact d'un événement redouté, comme le fait la méthode. On note G1 à G4 et V1 à V4 les niveaux de cette échelle.

4.2 Atelier 1 : Cadrage et Socle de Sécurité

4.2.1 Périmètre, valeurs métier, biens supports

Mme NKENG réunit M. ETEME, le directeur des opérations, le directeur financier, M. KOUNOU et un chef d'agence. Le périmètre retenu est le système d'information logistique : les quatre centres de données de Douala, Yaoundé, Garoua et Bafoussam, les douze agences et l'application intégrée. L'atelier retient trois valeurs métier : le *suivi des expéditions*, la *facturation* et la *gestion des stocks*, et une quatrième, ajoutée à la demande de PHARMACAM : les *données des clients*.

4.2.2 Événements redoutés et gravité

Réf.	Événement redouté	Conséquences	Grav.
ER1	Indisponibilité du suivi des expéditions pendant plus de trois jours	Lots sous chaîne du froid perdus, pénalités, perte du client	G4
ER2	Altération des données de stock par des ajustements non autorisés	Écarts de stock, réserve du commissaire aux comptes	G3
ER3	Paiement de factures à un fournisseur fictif	Perte financière directe	G3
ER4	Divulgation des données des clients	Rupture de contrat, sanction de l'autorité de protection	G3

Tableau 4.2. Événements redoutés de LiZbiZ

Les gravités s'appuient sur des faits : l'écart de stock de 186 millions FCFA (ER2) et la fraude TRANSLOG de 112,7 millions (ER3) se situent au niveau majeur de l'échelle ; pour ER1, PHARMACAM a chiffré la valeur d'un seul camion de vaccins à plus de 500 millions.

4.2.3 Le socle de sécurité

L'atelier compare ensuite l'existant à un référentiel. Faute de mieux, LiZbiZ reprend les constats de l'audit de ses quatre centres : des comptes par défaut actifs, des services d'administration en clair, des flux non autorisés entre centres. Ces écarts ne sont pas des scénarios ; ils constituent un socle troué, que les scénarios des ateliers suivants vont exploiter. Un écart au socle se corrige, en principe, sans attendre la fin de l'étude.

4.3 Atelier 2 : Sources de Risque

4.3.1 Des couples, pas des menaces

Définition

Couple SR/OV : association d'une source de risque (qui ?) et d'un objectif visé (pour quoi faire ?). Un même attaquant peut poursuivre plusieurs objectifs ; chaque couple se traite à part.

L'atelier recense les couples plausibles, puis les apprécie selon la *motivation* de la source à atteindre l'objectif, ses *ressources*, et son *activité* connue dans le secteur. Il en retient quelques-uns, jugés pertinents.

Réf.	Source de risque	Objectif visé	Appréciation	Retenu
SR1	Groupe cybercriminel	Extorsion par rançongiciel	Très motivé, outillé, très actif contre les entreprises de transport	Oui
SR2	Employé malveillant, seul ou avec un complice	Détourner du stock et masquer l'écart	Précédent connu (ajustements de Douala)	Oui
SR3	Fournisseur indélicat ou faux fournisseur	Se faire payer des factures fictives	Précédent connu (TRANSLOG)	Oui
SR4	Concurrent	Obtenir les tarifs et la liste des clients	Motivé, mais peu d'activité connue	Non
SR5	Militant	Nuire à l'image	Peu motivé par une entreprise de logistique	Non

Tableau 4.3. Couples source de risque et objectif visé

Scénario Opérationnel · Opération LIZBIZ. Deux fraudes devenues des sources de risque

Constatation. Les couples SR2 et SR3 ne sont pas imaginés : ils reprennent les deux fraudes établies par AUDIX CONSEIL, les ajustements de stock de FOUDA et le fournisseur fictif TRANSLOG (112,7 millions FCFA).

Analyse (confiance élevée). Le registre de 2026 traitait ces fraudes comme des risques de contrôle interne (R1, R2), et le rançongiciel comme un risque informatique (R8). EBIOS les met sur le même plan : trois attaquants, trois objectifs, qui exploitent souvent les mêmes faiblesses. Les droits illimités de M. KOUNOU servent aussi bien un fraudeur interne qu'un cybercriminel qui aurait volé son compte.

4.4 Atelier 3 : Scénarios Stratégiques

4.4.1 L'écosystème

Un attaquant ciblé passe souvent par un partenaire, moins protégé que sa cible. L'atelier 3 cartographie donc les *parties prenantes* : prestataires, sous-traitants, fournisseurs, clients reliés au système. Le guide de l'ANSSI les évalue selon quatre critères : la *dépendance* de l'organisation envers la partie prenante, la *pénétration* de celle-ci dans le système, sa *maturité* en cybersécurité, et la *confiance* qu'on peut lui accorder. Il en déduit un niveau de menace, d'autant plus élevé que la partie prenante est indispensable et présente dans le système, et d'autant plus faible qu'elle est mûre et fiable :

$$\text{Menace} = \frac{\text{Dépendance} \times \text{Pénétration}}{\text{Maturité} \times \text{Confiance}}$$

Chaque critère se cote de 1 à 4. L'atelier fixe lui-même les seuils : une menace de 3 ou plus place la partie prenante en zone de *danger*, de 1 à 3 en zone de *contrôle*, sous 1 en zone de *veille*.

Réf.	Partie prenante	Dép.	Pén.	Mat.	Conf.	Menace
P1	Éditeur de l'application intégrée (maintenance à distance)	4	4	2	2	4,00
P2	Transporteurs sous-traitants (portail de suivi)	3	2	1	2	3,00
P3	Opérateur de télécommunications	4	1	3	3	0,44
P4	Cabinet comptable externe	2	2	2	3	0,67
P5	Fournisseurs (portail de dépôt des factures)	2	1	1	1	2,00

Tableau 4.4. Les parties prenantes de LiZbiZ

L'éditeur de l'application (P1) et les transporteurs (P2) sont en zone de danger ; les fournisseurs (P5) en zone de contrôle ; l'opérateur et le cabinet comptable en zone de veille.

4.4.2 Trois scénarios stratégiques

Définition

Scénario stratégique : chemin d'attaque de haut niveau, qui relie un couple SR/OV à un événement redouté, en passant éventuellement par une ou plusieurs parties prenantes. Il se décrit sans détail technique et prend la gravité de l'événement redouté.

Réf.	Chemin d'attaque	ER	Grav.
SS1	SR1 compromet l'accès de maintenance de l'éditeur (P1), atteint les centres de données et chiffre l'application et ses sauvegardes	ER1	G4
SS2	SR2, magasinier de Douala, obtient l'aide d'un détenteur de droits d'administration et passe des ajustements de stock sans contrôle	ER2	G3
SS3	SR3 s'enregistre comme fournisseur sur le portail (P5) et fait valider des factures fictives par un complice interne	ER3	G3

Tableau 4.5. Scénarios stratégiques de LiZbiZ

L'atelier propose aussi des mesures sur l'écosystème, qui ne dépendent pas du détail technique : imposer à l'éditeur un second facteur et une journalisation de ses connexions de maintenance ; limiter l'accès des transporteurs aux seules expéditions qui les concernent ; vérifier l'existence de tout nouveau fournisseur avant son premier paiement.

4.4.3 Ce que valent les cotes de l'écosystème

Les vingt cotes du Tableau 4.4 n'ont pas toutes la même solidité. La dépendance et la pénétration se lisent dans les contrats et dans les droits d'accès ; la maturité et la confiance se devinent.

⚖ Lecture auditologique · Base de preuve des cotes de l'écosystème

Constatation. Mme NKENG cote la base de chacune des vingt cotes :

- dépendance : 5 OUI (contrats, chiffre d'affaires concerné) ;
- pénétration : 4 OUI et 1 NON : P2 était coté 2, mais les droits du portail montrent que chaque transporteur voit toutes les expéditions ;
- maturité : 1 OUI (l'opérateur est certifié ISO/IEC 27001), 4 NEK ;
- confiance : 3 OUI (historique de la relation), 2 NEK (P1, P2).

Sur vingt cotes : 13 OUI, 1 NON, 6 NEK :

$$\mu = 0{,}65\,; \quad U = 0{,}30\,; \quad H = -(0{,}65\log_2 0{,}65 + 0{,}05\log_2 0{,}05 + 0{,}30\log_2 0{,}30) \approx 0{,}404 + 0{,}216 + 0{,}521$$

Analyse (confiance élevée sur le calcul, moyenne sur la lecture). L'incertitude se concentre au dénominateur de la formule : la maturité et la confiance. Or ce sont elles qui font baisser la menace. Une maturité cotée 2 sans preuve peut cacher un 1, ce qui doublerait la menace de P1. Les zones de danger sont donc probablement sous-estimées, et non surestimées. Pour P2, le NON se corrige tout de suite : avec une pénétration de 3, sa menace passe de 3,00 à 4,50.

$\mu = 0{,}65$ · $U = 0{,}30$ · $H = 1{,}14$ **bit**

☑ Papier de travail

Réduire l'incertitude sur l'écosystème. Pour chaque partie prenante en zone de danger ou de contrôle, le papier de travail prévoit :

- un questionnaire de maturité, signé par la partie prenante, et les attestations qu'elle peut fournir (certification, rapport d'assurance) ;
- l'extraction des droits d'accès dont elle dispose réellement ;
- une clause contractuelle de droit d'audit et de notification des incidents ;

➢ la date de la dernière revue, et la cote de base de chaque critère.

4.5 Atelier 4 : Scénarios Opérationnels

4.5.1 Du chemin au mode opératoire

Définition

Scénario opérationnel : suite d'actions élémentaires, sur les biens supports, par lesquelles une source de risque réalise un scénario stratégique. On le décompose en quatre phases : *connaître* la cible, y *rentrer*, y *trouver* ce qui permet d'atteindre l'objectif, puis l'*exploiter*.

4.5.2 Le mode opératoire de SS1

M. KOUNOU et deux techniciens de l'éditeur détaillent SS1. Pour chaque phase, ils cotent la vraisemblance que l'attaquant y réussisse, au vu des constats de l'audit.

Phase	Action élémentaire	V	Base
Connaître	Repérer sur Internet l'éditeur et son outil de maintenance à distance	V4	Sources publiques
Rentrer	Voler l'identifiant d'un technicien de l'éditeur par hameçonnage, ou utiliser un compte par défaut du serveur de maintenance	V3	Constat d'audit (comptes par défaut)
Trouver	Se déplacer d'un centre à l'autre par les flux non autorisés, capter des mots de passe sur les services en clair	V4	Constats d'audit
Exploiter	Chiffrer l'application dans les quatre centres et effacer les sauvegardes accessibles	V3	Sauvegardes en ligne, jamais restaurées

Tableau 4.6. Le scénario opérationnel SO1

Note

Une règle de chaîne. Un mode opératoire ne réussit que si toutes ses phases réussissent. Le cours retient donc, pour vraisemblance du scénario, celle de la phase la plus difficile pour l'attaquant : ici V3. C'est une convention prudente ; le guide décrit aussi des manières plus fines de combiner les actions élémentaires.

SO1 obtient une vraisemblance V3 et hérite de la gravité G4 de ER1 : criticité $3 \times 4 = 12$, intolérable. On retrouve la cote de R8 après sa révision (Exercice 2.4) : EBIOS ne la contredit pas, il l'explique. Et il montre où agir : la phase « rentrer » est la seule cotée V3 au lieu de V4 ; la fermer (second facteur pour l'éditeur, suppression des comptes par défaut) ferait tomber la vraisemblance de tout le scénario.

4.6 Atelier 5 : Traitement du Risque

L'atelier 5 rejoint le processus du Chapitre 3 : options de traitement, plan, risques résiduels, acceptation. EBIOS y ajoute deux apports : les mesures se rattachent aux *phases* des scénarios et aux *parties prenantes*, et le plan s'inscrit dans un cadre de suivi qui fait revenir l'étude à intervalles réguliers. Le guide parle d'un plan d'amélioration continue de la sécurité.

Scénario	Mesures principales	Phase ou partie prenante	Résiduel visé
SO1 (SS1)	Second facteur et journalisation pour l'éditeur ; suppression des comptes par défaut ; filtrage entre centres ; sauvegardes hors ligne testées	Rentrer, trouver, exploiter ; P1	$2 \times 3 = 6$
SS2	Séparation des tâches de réception et d'ajustement ; revue des ajustements par la contrôleuse interne ; comptes d'administration nominatifs	Exploiter	$2 \times 3 = 6$
SS3	Vérification de tout nouveau fournisseur avant paiement ; double validation des factures	P5	$1 \times 3 = 3$

Tableau 4.7. Synthèse du traitement

Fiche de risque · SO1 · Rançongiciel par l'accès de maintenance

Valeur métier : suivi des expéditions.
Événement redouté : ER1, indisponibilité de plus de trois jours (G4).
Source de risque et objectif visé : SR1, groupe cybercriminel, extorsion.
Partie prenante : P1, éditeur de l'application (menace 4,00, maturité et confiance NEK).
Mode opératoire : connaître (V4), rentrer (V3), trouver (V4), exploiter (V3) ; vraisemblance retenue V3.
Criticité : 12, intolérable. Base : constats de l'audit des quatre centres (OUI) pour les phases rentrer, trouver et exploiter.
Traitement : réduire (Tableau 4.7), puis envisager une assurance.
Propriétaire : le directeur des opérations.
Revue : après le test des sauvegardes et la signature de l'avenant avec l'éditeur, et au plus tard dans un an.

4.7 Situer EBIOS parmi les Méthodes

EBIOS Risk Manager n'est pas la seule méthode. Deux autres sont souvent citées : MEHARI, développée par le CLUSIF, l'association française des professionnels de la

sécurité, et le guide d'appréciation des risques du NIST, la publication spéciale 800-30 [48].

	EBIOS RM	MEHARI	NIST SP 800-30
Origine	ANSSI, 2018	CLUSIF	NIST, révision 1 de 2012
Point de départ	Sources de risque, objectifs, écosystème	Bases de connaissances, diagnostic des services de sécurité	Sources de menace, événements de menace, vulnérabilités
Force	Scénarios lisibles par la direction ; écosystème	Questionnaires détaillés, utiles à l'audit	Démarche à trois niveaux (organisation, mission, système)
Limite	Demande des animateurs formés	Lourde sans outil	Pensée pour l'administration américaine ; à adapter

Tableau 4.8. Trois méthodes d'appréciation des risques

Pour une organisation camerounaise, le choix n'est pas dicté par la loi : l'article 26 de la loi n° 2010/012 exige des « systèmes normalisés » d'identification et d'évaluation des risques (Chapitre 3), sans désigner de méthode [53]. EBIOS a l'avantage d'être gratuite, publiée en français et compatible avec l'ISO/IEC 27005 ; elle reste une méthode étrangère, que l'on adapte aux échelles, au droit et aux menaces du pays.

4.8 Ce que la Méthode demande à chaque Métier

Application Gestionnaire des risques cyber

Animer, pas rédiger seul

1. Réunir les bons participants à chaque atelier : la direction et les métiers pour les ateliers 1 à 3, les techniciens pour le 4.
2. Partir des faits connus (fraudes, incidents, constats d'audit) pour les couples SR/OV.
3. Coter la base de preuve des critères de l'écosystème, et programmer les questionnaires et les extractions qui manquent.
4. Relier chaque mesure à une phase ou à une partie prenante.

Application Auditeur en cybersécurité

Rester de l'autre côté

M. BEYALA a eu raison de refuser l'animation. L'auditeur peut évaluer une étude EBIOS : il vérifie que les couples écartés l'ont été pour de bonnes raisons, que les cotes de l'écosystème ont une base, et que les mesures annoncées existent. Il ne l'écrit pas.

Application Responsable GRC

Ramener l'étude dans le registre

Une étude EBIOS produit des scénarios ; le registre doit les recevoir. Le responsable GRC remplace les lignes R1, R2 et R8 par les scénarios SS2, SS3 et SO1, avec leurs propriétaires, et veille à ce que l'étude soit revue quand un nouveau partenaire entre dans l'écosystème.

Application Consultant en mise en œuvre de SMSI

Transmettre la méthode

Quand un consultant anime l'étude, il forme en même temps un animateur interne. La demande de PHARMACAM se répétera chaque année ; LiZbiZ doit pouvoir refaire l'étude sans lui.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **EBIOS Risk Manager** (ANSSI, 2018) réalise une synthèse entre conformité (un socle de sécurité) et scénarios (des menaces intentionnelles et ciblées).
- **Cinq ateliers** : cadrage et socle, sources de risque, scénarios stratégiques, scénarios opérationnels, traitement.
- **Un couple SR/OV** relie un attaquant à un objectif ; on part des faits connus pour les retenir.
- **L'écosystème** se cote par la dépendance, la pénétration, la maturité et la confiance ; les deux derniers critères sont souvent NEK, et ce sont eux qui font baisser la menace.
- **Un scénario opérationnel** se décompose en connaître, rentrer, trouver, exploiter ; sa vraisemblance est celle de la phase la plus difficile.
- **Indépendance** : celui qui auditera l'étude ne l'anime pas.

Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- dire à quel atelier appartient un livrable donné ;
- calculer le niveau de menace d'une partie prenante et la placer dans une zone ;
- décomposer un scénario opérationnel en quatre phases et en coter la vraisemblance ;
- expliquer pourquoi une maturité cotée sans preuve sous-estime probablement la menace.

Exercices

Exercice 4.1. À quel atelier ? ★☆☆

Indiquez l'atelier d'EBIOS Risk Manager auquel appartient chacun des éléments suivants.

(a) La liste des écarts de LiZbiZ au guide d'hygiène informatique.

(b) Le couple « concurrent, obtenir la liste des clients », écarté.

(c) La cote de pénétration du cabinet comptable.

(d) L'action « capter des mots de passe sur les services en clair ».

(e) La gravité G4 de l'indisponibilité du suivi des expéditions.

(f) La décision de faire signer un avenant à l'éditeur.

(g) Le chemin « faux fournisseur, portail, complice interne ».

Exercice 4.2. Trois nouvelles parties prenantes ★★☆

LiZbiZ envisage trois nouveaux partenaires :

- Q1, un hébergeur en nuage pour le portail de suivi : dépendance 4, pénétration 3, maturité 3, confiance 2 ;
- Q2, une société de maintenance des chambres froides, reliée au réseau pour la télésurveillance : dépendance 3, pénétration 2, maturité 1, confiance 2 ;
- Q3, un prestataire de paie : dépendance 2, pénétration 1, maturité 2, confiance 3.

(a) Calculez leur niveau de menace et placez-les dans les zones du chapitre.

(b) Les maturités ont été cotées sur la base d'une plaquette commerciale. Quelle cote de base leur donnez-vous ? Recalculez la menace de Q1 si sa maturité réelle est de 2.

(c) Proposez, pour Q2, deux mesures sur l'écosystème et la preuve qui permettrait de relever sa confiance.

✍ Exercice 4.3. Le mode opératoire de SS2 ★★☆

Détaillez SS2 (le magasinier de Douala et son complice) en scénario opérationnel.

(a) Décrivez une action élémentaire pour chacune des quatre phases.

(b) Cotez la vraisemblance de chaque phase et justifiez par un fait du cas. Déduisez la vraisemblance du scénario selon la règle de chaîne.

(c) Quelle phase faut-il fermer en priorité ? Montrez l'effet sur la criticité.

✍ Exercice 4.4. EBIOS à la BANQUE SANAGA ★★★

L'atelier de décembre 2026 de la BANQUE SANAGA a retenu le scénario « fraude au virement par compromission d'un poste du siège » (Chapitre 3).

(a) Atelier 1 : nommez la valeur métier, deux biens supports et l'événement redouté, et cotez sa gravité avec l'échelle du cours.

(b) Atelier 2 : proposez deux couples SR/OV, dont un que vous écarterez, en justifiant par la motivation, les ressources et l'activité.

(c) Atelier 3 : identifiez une partie prenante qui pourrait servir de point d'entrée, cotez ses quatre critères, et indiquez pour chacun la base de preuve dont vous disposez.

(d) Atelier 4 : rédigez le mode opératoire en quatre phases et déduisez la vraisemblance.

(e) Comparez la démarche avec la fiche R-AG-01 : qu'apporte EBIOS que la fiche de risque ne donnait pas ?

Note

Pour aller plus loin.

➢ Le guide EBIOS Risk Manager de l'ANSSI [2] et ses fiches méthodes, sur le site de l'ANSSI.

➢ Le guide NIST SP 800-30, révision 1 [48].

➢ L'ISO/IEC 27005:2022 [42], pour l'articulation avec le processus.

Note

Transition. EBIOS a coté SO1 à 12 : intolérable. Mais combien LiZbiZ ou la BANQUE SANAGA perdraient-elles, en francs CFA, si le scénario se réalisait ? Et combien faut-il dépenser pour le traiter ? Les échelles qualitatives ne répondent pas à ces questions. Le Chapitre 5 apprend à quantifier.

5

QUANTIFIER LE RISQUE CYBER : FAIR

« Un conseil ne vote pas une couleur.
Il vote un budget. »

Principe du cours

Niveau : *Intermédiaire* • Maîtrise du Chapitre 3

✦ Objectifs du chapitre

- Expliquer pourquoi et quand quantifier un risque cyber.
- Décomposer un risque selon la taxonomie FAIR : fréquence des événements de perte et ampleur des pertes.
- Produire des estimations calibrées (minimum, plus probable, maximum) et en coter la base de preuve.
- Conduire une simulation de Monte-Carlo pas à pas.
- Interpréter une distribution de pertes annuelles : moyenne, quantiles, probabilité de dépassement.
- Comparer des traitements en francs CFA, y compris une assurance.
- Dire ce que la quantification apporte et ce qu'elle masque.

Avant de commencer : 193 millions, est-ce trop ?

Douala, janvier 2027. Le comité des risques du conseil de la BANQUE SANAGA[1] examine le plan de traitement de R-AG-01 : huit actions, 193 millions FCFA (Chapitre 3). Le directeur financier pose la question que les échelles ne savent pas traiter : « Vous me dites que le risque est coté 12. Combien nous coûte-t-il ? Et combien nous coûtera-t-il après ces 193 millions ? »

La RSSI n'a pas de réponse en francs CFA. La cote 12 classe le risque parmi les intolérables ; elle ne dit pas si 193 millions sont une bonne affaire, une dépense insuffisante ou un luxe. Le comité lui demande de revenir en mars avec une quantification.

[1] Comme dans tout le cours, la BANQUE SANAGA, ses dirigeants, les dates et les montants sont fictifs ; la méthode et les normes citées sont exactes.

© MaletYon

Ce chapitre présente la méthode qu'elle emploie, FAIR, et la déroule sur R-AG-01. Tous les résultats numériques ont été obtenus par une simulation réelle de 100 000 années, dont le chapitre explique chaque étape.

★ Attention

Violation typique. Présenter au conseil une perte « attendue » de 143,5 millions, obtenue en multipliant une fréquence par une perte, comme si c'était ce qui allait arriver.

Règle : une quantification se présente comme une distribution : la plupart des années ne coûtent rien, quelques-unes coûtent très cher. On donne au moins la moyenne, la probabilité d'une perte et un quantile élevé, avec les hypothèses et leur base de preuve.

5.1 Pourquoi Quantifier

Les échelles qualitatives ont deux mérites : elles sont rapides, et chacun les comprend. Le Chapitre 2 en a montré les limites : niveaux ordinaux, produit qui écrase les écarts, frontières arbitraires. Ces limites deviennent bloquantes dans trois situations :

- **comparer un risque à une dépense** : un plan de 193 millions, une prime d'assurance, un recrutement ;
- **comparer des risques de nature différente** : un risque cyber et un risque de crédit, que le conseil arbitre avec le même budget ;
- **une cote qui chevauche un seuil** : la fréquence de R-AG-01, estimée entre 0,2 et 0,6 par an, traverse les niveaux 2 et 3 de l'échelle, donc la frontière entre « à traiter dans l'année » et « intolérable » (Chapitre 2).

On ne quantifie pas tout. La quantification coûte du temps et des compétences ; on la réserve aux risques qui pèsent sur une décision importante, typiquement ceux d'impact critique ou dont la cote traverse un seuil.

5.2 La Taxonomie FAIR

5.2.1 Une décomposition

FAIR (*Factor Analysis of Information Risk*) est un modèle de quantification du risque d'information. Il est normalisé par The Open Group sous le nom d'Open FAIR, en deux normes : la taxonomie du risque (O-RT, version 3.0.1) et l'analyse du risque (O-RA, version 2.0.1) [71]. Le cours présente la taxonomie d'après l'ouvrage de référence de Freund et Jones [17].

Définition

Risque (au sens de FAIR) : fréquence et ampleur probables des pertes futures. Il se décompose en deux branches :

- la **fréquence des événements de perte** : combien de fois par an un événement de menace aboutit à une perte ;
- l'**ampleur des pertes** : combien coûte chaque événement.

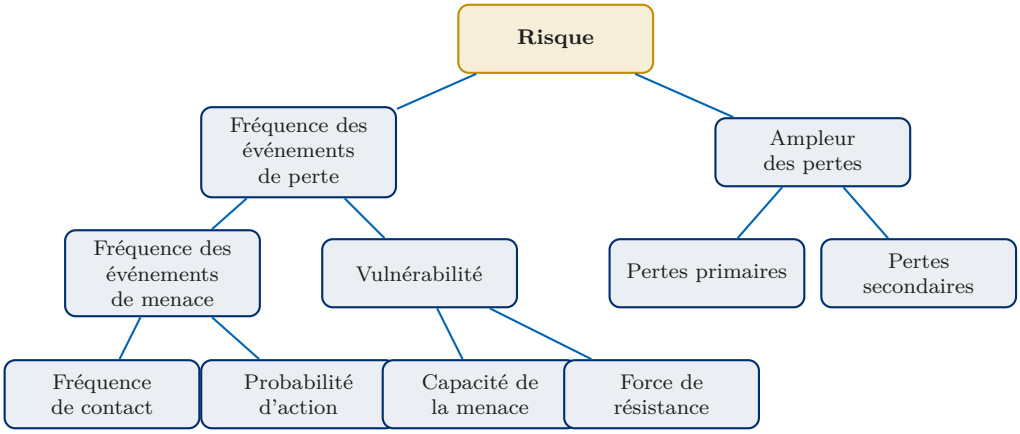


Figure 5.1: La taxonomie FAIR (d'après Freund et Jones, 2015)

Facteur	Définition
Fréquence des événements de menace	Nombre de fois par an où une source de menace agit contre l'actif : produit de la fréquence de contact et de la probabilité qu'elle passe à l'action
Vulnérabilité	Probabilité qu'un événement de menace devienne un événement de perte : elle dépend de la capacité de la menace comparée à la force de résistance des mesures
Pertes primaires	Pertes subies directement par l'organisation du fait de l'événement
Pertes secondaires	Pertes qui viennent des réactions de tiers : clients, régulateur, tribunaux, presse ; elles ont leur propre fréquence et leur propre ampleur

Tableau 5.1. Les facteurs de la taxonomie

Note

À vérifier dans la norme. La version 3 de la taxonomie Open FAIR a révisé certains termes ; on y lit notamment *susceptibilité* là où les textes antérieurs parlent de *vulnérabilité*. Le cours garde le vocabulaire de Freund et Jones, plus répandu, et signale l'écart.

5.2.2 Six formes de pertes

FAIR ventile l'ampleur en six formes de pertes : la *productivité* (activité perdue), la *réponse* (gestion de l'incident, communication, conseils), le *remplacement* (actifs à reconstruire ou racheter), les *amendes et jugements*, l'*avantage concurrentiel* perdu, et la *réputation* [17].

Scénario Opérationnel · Opération SANAGA. Les 410 millions, ventilés

Constatation. La direction financière ventile le coût de l'incident de septembre 2026 :

- productivité : 190 millions (neuf agences fermées trois jours, opérations perdues ou reportées) ;
- réponse : 140 millions (prestataire de réponse à incident, cellule de crise, communication auprès de la clientèle) ;
- remplacement : 80 millions (reconstruction de 180 postes) ;
- amendes et jugements, avantage concurrentiel : néant ;
- réputation : non chiffrée.

Analyse (confiance élevée sur les pertes primaires, faible sur les secondaires). Les 410 millions sont presque entièrement des pertes primaires. La perte de clients qui ont changé de banque n'est pas mesurée : elle est NEK. Le coût réel de l'incident est donc d'au moins 410 millions, pas de 410 millions.

5.3 Estimer

5.3.1 Des estimations calibrées

FAIR ne demande pas des valeurs exactes, que personne n'a, mais des **estimations calibrées** : pour chaque facteur, un minimum, une valeur la plus probable et un maximum, choisis de sorte que l'expert soit confiant, à 90 % environ, que la vraie valeur se trouve entre le minimum et le maximum. Hubbard et Seiersen montrent que cette confiance s'apprend, par des exercices de calibrage, et que la plupart des experts non entraînés donnent des intervalles trop étroits [20].

5.3.2 Les estimations de R-AG-01

En février 2027, la RSSI anime un atelier avec la direction financière, la direction du réseau d'agences et le prestataire de réponse à incident.

Facteur	Min.	Plus prob.	Max.	Justification
Fréquence des événements de perte (par an)	0,2	0,35	0,6	Un incident réussi en 2026 ; tentatives fréquentes dans le secteur ; défenses de 2025
Ampleur par événement (M FCFA)	150	410	900	Minimum : trois agences touchées ; plus probable : l'incident vécu ; maximum : propagation à tout le réseau et pertes secondaires

Tableau 5.2. Estimations calibrées pour R-AG-01 (défenses de 2025)

Pour la fréquence, l'atelier estime directement la fréquence des événements de perte, sans descendre jusqu'à la fréquence de contact et à la vulnérabilité : la taxonomie permet de s'arrêter au niveau où l'on dispose de la meilleure information.

5.3.3 La base de preuve des estimations

Lecture auditologique · Base de preuve des six valeurs

Constatation. La RSSI cote la base de chacune des six valeurs du Tableau 5.2 :

- fréquence : minimum NEK (avis non motivé), plus probable OUI (incident de 2026, données sectorielles d'un assureur), maximum NEK ;
- ampleur : minimum OUI (devis de reconstruction pour trois agences), plus probable OUI (coût de l'incident), maximum NEK (pertes secondaires non chiffrées).

3 OUI, 0 NON, 3 NEK : $\mu = 0{,}50$; $U = 0{,}50$; $H = -(2 \times 0{,}5 \log_2 0{,}5) = 1{,}00$ bit.

Analyse (confiance élevée). La quantification est solide en son centre et incertaine dans ses queues. Or ce sont les queues qui intéressent le conseil : le maximum d'ampleur décide du quantile à 99 %, et le maximum de fréquence de la probabilité d'avoir deux incidents la même année. La Section 5.6 mesure ce que pèse cette incertitude.

$\mu = 0{,}50$ · $U = 0{,}50$ · $H = 1{,}00$ **bit**

5.4 La Simulation de Monte-Carlo

5.4.1 Le principe

Multiplier la fréquence la plus probable par l'ampleur la plus probable donne $0{,}35 \times 410 = 143{,}5$ millions. Ce chiffre n'est ni ce qui arrivera une année donnée (le plus souvent, rien), ni même la moyenne, parce qu'il ignore la forme des distributions. La **simulation de**

Monte-Carlo remplace ce calcul par un grand nombre d'années tirées au hasard, selon les estimations.

Papier de travail

Simuler une année.

1. Tirer une fréquence λ dans la distribution de fréquence (ici une loi PERT, qui suit le minimum, le plus probable et le maximum).
2. Tirer un nombre d'événements dans l'année, selon une loi de Poisson de paramètre λ : le plus souvent 0, parfois 1, rarement 2 ou plus.
3. Pour chaque événement, tirer une ampleur dans la distribution d'ampleur (loi PERT).
4. La perte de l'année est la somme des ampleurs.

On répète l'opération un grand nombre de fois (ici 100 000), puis on lit la distribution des pertes annuelles obtenues. Le papier de travail conserve le programme, la graine du générateur aléatoire et les estimations, pour que le résultat puisse être reproduit.

Note

La loi PERT. Elle se construit à partir d'un minimum a, d'une valeur la plus probable m et d'un maximum b. Sa moyenne vaut $\frac{a+4m+b}{6}$: pour la fréquence, $\frac{0{,}2+1{,}4+0{,}6}{6} \approx 0{,}367$; pour l'ampleur, $\frac{150+1\,640+900}{6} \approx 448$ millions. La moyenne de l'ampleur dépasse la valeur la plus probable, parce que le maximum est plus éloigné du mode que le minimum.

5.4.2 Dix années, à la main

Pour comprendre la mécanique, voici les dix premières années d'une simulation.

Année	λ tirée	Événements	Ampleurs (M FCFA)	Perte
1	0,38	0	–	0
2	0,26	0	–	0
3	0,39	0	–	0
4	0,43	1	385	385
5	0,38	0	–	0
6	0,26	0	–	0
7	0,43	0	–	0
8	0,35	0	–	0
9	0,40	1	521	521
10	0,35	0	–	0
Moyenne				**90,6**

Tableau 5.3. Dix années simulées

Huit années sur dix ne coûtent rien ; deux coûtent 385 et 521 millions. La moyenne de ces dix années, 90,6 millions, est loin de la moyenne obtenue sur 100 000 années (164,6 millions) : dix tirages ne suffisent pas. C'est la leçon de la simulation, et aussi celle de l'expérience : une banque qui n'a pas eu d'incident pendant huit ans n'en déduit rien sur la neuvième.

5.4.3 Cent mille années

Indicateur (M FCFA, par an)	Défenses 2025	Après traitement
Perte annuelle moyenne	164,6	18,6
Probabilité d'une perte dans l'année	30,5 %	10,1 %
Médiane (une année sur deux)	0	0
Quantile à 90 % (une année sur dix au-delà)	579	60
Quantile à 95 % (une année sur vingt)	734	174
Quantile à 99 % (une année sur cent)	1 170	283
Probabilité d'une perte supérieure à 500 M	14,3 %	0,06 %

Tableau 5.4. Distribution des pertes annuelles dues à R-AG-01 (100 000 années simulées)

La colonne « après traitement » reprend la simulation avec les estimations de l'atelier pour la situation visée par le plan : fréquence entre 0,05 et 0,20 (plus probable 0,10), grâce au second facteur et au cloisonnement ; ampleur entre 50 et 400 millions (plus probable 150), grâce aux sauvegardes testées et au mode dégradé.

Perte supérieure à (M)	0	250	500	750	1 000
Défenses 2025	30,5 %	28,8 %	14,3 %	4,7 %	2,1 %
Après traitement	10,1 %	1,8 %	0,06 %	0 %	0 %

Tableau 5.5. Probabilités de dépassement (courbe de dépassement, en points)

5.5 Interpréter et Décider

5.5.1 Lire la distribution

⚖ Lecture auditologique · Ce que la RSSI présente au comité, en mars 2027

Constatation.

- Avec les défenses de 2025, une année sur trois environ connaît un incident ; la perte moyenne est de 165 millions par an, et une année sur sept dépasse 500 millions.
- Après traitement, une année sur dix connaît un incident ; la perte moyenne

tombe à 19 millions, et une perte de plus de 500 millions devient exceptionnelle (moins d'une année sur mille).

Analyse (confiance moyenne : voir la base de preuve des estimations). Le plan réduit la perte moyenne d'environ 146 millions par an. Il coûte 193 millions la première année, puis environ 30 millions par an (licences, tests trimestriels, exercices). Le gain net annuel, de l'ordre de 116 millions, rembourse l'investissement en moins de deux ans. Sur ce seul risque, 193 millions ne sont pas un luxe.

5.5.2 L'appétence en francs CFA

La quantification permet aussi d'exprimer l'appétence autrement qu'en couleurs. La RSSI propose au comité une formulation : « la probabilité qu'un même risque cyber cause, une année donnée, une perte supérieure à 500 millions FCFA ne dépasse pas 5 % ». Avec les défenses de 2025, R-AG-01 la viole largement (14,3 %) ; après traitement, il la respecte (0,06 %).

La simulation tranche aussi la question laissée ouverte au Chapitre 2 : la fréquence tirée dépasse 1/3 par an dans 64 % des années simulées. Le niveau 3 de vraisemblance est donc plus probable que le niveau 2 ; la cote prudente de 12 était justifiée.

5.5.3 L'assurance, chiffrée

L'offre du courtier (prime de 35 millions par an, franchise de 100 millions par événement, plafond de 1 milliard) se juge maintenant sur les mêmes simulations.

M FCFA par an	Défenses 2025	Après traitement
Perte moyenne sans assurance	164,6	18,6
Remboursement moyen de l'assureur	126,6	8,2
Coût moyen avec assurance (perte − remboursement + prime)	73,0	45,4

Tableau 5.6. L'assurance, avant et après traitement

Avant traitement, l'assurance divise le coût moyen par plus de deux. Après traitement, elle coûte en moyenne plus qu'elle ne rapporte (45,4 contre 18,6). Deux conclusions : l'assurance est utile comme protection temporaire, pendant la mise en œuvre du plan ; ensuite, elle ne se justifie que si la prime baisse, ou pour protéger la banque contre les années extrêmes que la simulation estime mal. Et l'on ne pourra pas l'obtenir sans les mesures, que les assureurs exigent : la réduction vient d'abord.

5.6 Ce que la Quantification Masque

5.6.1 Des chiffres faits d'opinions

Une simulation transforme des estimations en distribution ; elle ne les rend pas plus vraies. Trois des six valeurs d'entrée sont NEK. Pour mesurer ce que cela pèse, la RSSI

relance la simulation en portant le maximum d'ampleur de 900 à 1 500 millions, pour tenir compte des pertes secondaires non chiffrées.

Indicateur (M FCFA)	Max. 900	Max. 1 500
Perte annuelle moyenne	164,6	200,9
Quantile à 99 %	1 170	1 507
Probabilité d'une perte supérieure à 500 M	14,3 %	18,4 %

Tableau 5.7. Sensibilité au maximum d'ampleur

Une seule valeur NEK, modifiée, déplace la moyenne de 22 % et le quantile à 99 % de 29 %. La décision de traiter ne change pas ; mais le montant de couverture d'assurance, lui, en dépend. C'est le rôle de l'analyse de sensibilité : identifier les NEK dont la décision dépend, et y consacrer l'effort de collecte de preuves.

5.6.2 Cinq angles morts

- **Le scénario absent.** On ne simule que ce que l'on a imaginé. En 2025, R-AG-01 n'existait pas dans le registre : aucune simulation ne l'aurait chiffré.
- **La fausse précision.** « 164,6 millions » suggère une exactitude que les estimations n'ont pas. On présente des ordres de grandeur arrondis (« environ 165 millions »).
- **L'indépendance supposée.** Le modèle tire les événements indépendamment. Une même faiblesse peut provoquer plusieurs incidents corrélés, et une crise du secteur toucher plusieurs banques à la fois.
- **L'adversaire qui s'adapte.** Les estimations décrivent la menace de 2027 ; un attaquant qui change de méthode les rend caduques (Chapitre 2, Tableau 2.2).
- **L'incertitude de connaissance.** La distribution mêle l'aléa (l'attaque aura-t-elle lieu ?) et l'ignorance (la vraie fréquence) ; elle ne dit pas quelle part vient de chacun. La cote de la base de preuve des estimations le dit.

Note

La quantification et l'auditologie. Le cours tient les deux ensemble : la simulation décrit l'incertitude *aléatoire* sur les pertes, sous des hypothèses ; la cote OUI / NON / NEK des hypothèses décrit l'incertitude *épistémique* sur ces hypothèses. Une quantification présentée sans la seconde est incomplète ; le Chapitre 16 montre comment les combiner.

Note

Et le cadre juridique ? Aucun texte camerounais n'impose de quantifier les risques cyber. L'article 26 de la loi n° 2010/012 demande de les *évaluer* (Chapitre 3) [53] ; la

quantification est une manière de le faire, que le conseil, le superviseur et l'assureur comprennent, parce qu'elle parle leur langue : l'argent.

5.7 Ce que la Quantification demande à chaque Métier

Application Gestionnaire des risques cyber

Quantifier ce qui décide

1. Réserver la quantification aux risques dont dépend une décision importante.
2. Faire produire des estimations calibrées, par des experts entraînés, et coter leur base de preuve.
3. Présenter une distribution (moyenne, probabilité, quantile élevé), jamais un seul chiffre.
4. Tester la sensibilité aux valeurs NEK.

Application RSSI

Défendre un budget

La RSSI ne demande plus 193 millions pour « réduire un risque coté 12 ». Elle montre une réduction de perte moyenne de l'ordre de 146 millions par an, et le passage de la probabilité d'une année à plus de 500 millions de 14 % à moins de 0,1 %. Le conseil vote un budget, avec ses hypothèses.

Application Auditeur en cybersécurité

Auditer les entrées, pas le logiciel

L'auditeur ne refait pas les 100 000 tirages ; il vérifie que le programme et la graine sont conservés, que chaque estimation a une justification écrite, que les auteurs ont été calibrés, et que la sensibilité aux valeurs non fondées a été testée.

Application Responsable GRC

Une même monnaie

Le responsable GRC propose au conseil une appétence exprimée en francs CFA, applicable à tous les risques quantifiés, cyber ou non. Les risques deviennent comparables, et les arbitrages budgétaires, explicables.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Quantifier** sert à comparer un risque à une dépense, des risques entre eux, ou à trancher une cote qui chevauche un seuil.
- **FAIR** décompose le risque en fréquence des événements de perte et ampleur des pertes ; l'ampleur se ventile en six formes de pertes, primaires et secondaires.
- **Des estimations calibrées** (minimum, plus probable, maximum) remplacent les valeurs exactes que personne n'a ; leur base de preuve se cote.
- **La simulation de Monte-Carlo** tire des années ; on lit la moyenne, la probabilité d'une perte et les quantiles élevés.
- **R-AG-01** : environ 165 millions de perte moyenne par an avant traitement, 19 après ; le plan de 193 millions se rembourse en moins de deux ans.
- **La quantification masque** le scénario absent, la fausse précision, les corrélations, l'adversaire qui s'adapte, et l'incertitude de connaissance.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- placer un facteur dans la taxonomie FAIR ;
- ventiler un coût d'incident en formes de pertes ;
- simuler quelques années à la main et dire pourquoi elles ne suffisent pas ;
- lire une distribution et en tirer une décision de traitement ou d'assurance.

Exercices

✍ Exercice 5.1. Six formes de pertes ★☆☆

Classez chacun des coûts suivants dans l'une des six formes de pertes de FAIR, et dites s'il s'agit d'une perte primaire ou secondaire.

(a) Les heures supplémentaires des agents pour ressaisir les opérations.

(b) Le rachat de vingt postes de travail.

(c) L'amende infligée par le superviseur pour notification tardive.

(d) Les honoraires du prestataire de réponse à incident.

(e) Les clients qui ferment leur compte après l'incident.

(f) Le contrat d'une grande entreprise remporté par une banque concurrente pendant la fermeture des guichets.

✍ Exercice 5.2. Le chiffre trompeur ★★☆

(a) Calculez les moyennes PERT de la fréquence et de l'ampleur pour la situation après traitement (Section 5.4), et leur produit. Comparez au résultat de la simulation (18,6).

(b) Pourquoi la médiane de la perte annuelle est-elle nulle, avant comme après traitement ?

(c) Un administrateur propose de provisionner chaque année 165 millions « pour couvrir le risque ». Expliquez ce que cette provision couvre et ce qu'elle ne couvre pas, à l'aide du Tableau 5.4.

✍ Exercice 5.3. Une autre offre d'assurance ★★☆

Un second assureur propose, après traitement, une prime de 12 millions par an, une franchise de 200 millions par événement et un plafond de 500 millions. On admet qu'après traitement il rembourserait en moyenne 1,5 million par an.

(a) Calculez le coût moyen annuel avec cette assurance et comparez-le à l'absence d'assurance et à la première offre.

(b) À l'aide du Tableau 5.5, dites dans quelles années cette assurance joue, et ce qu'elle protège réellement.

(c) Recommandez une décision au comité, en deux phrases.

✍ Exercice 5.4. Quantifier SO1 pour PHARMACAM ★★★

LiZbiZ veut présenter à PHARMACAM une quantification simple du scénario SO1 (Chapitre 4). L'atelier retient : un événement au plus par an, avec une probabilité de 0,25 ; une ampleur triangulaire de minimum 100, plus probable 300, maximum 800 millions FCFA (moyenne : le tiers de la somme des trois valeurs).

(a) Calculez la perte annuelle moyenne.

(b) Simulez dix années à la main avec les nombres aléatoires suivants (un événement survient si le nombre est inférieur à 0,25) : 0,81 ; 0,12 ; 0,55 ; 0,37 ; 0,09 ; 0,66 ; 0,93 ; 0,21 ; 0,48 ; 0,70. Les ampleurs tirées pour les événements sont, dans l'ordre, 320, 610 et 180 millions. Calculez la moyenne des dix années et commentez.

(c) Cotez la base de preuve des quatre valeurs d'entrée, sachant que LiZbiZ n'a jamais subi de rançongiciel et que l'ampleur maximale correspond à l'estimation de PHARMACAM pour un camion de vaccins perdu.

(d) Rédigez le paragraphe destiné à PHARMACAM : ce que la quantification dit, ce qu'elle suppose, ce qu'elle ne dit pas.

Note

Pour aller plus loin.

- Freund et Jones, *Measuring and Managing Information Risk* [17], l'exposé de référence de FAIR.
- Les normes Open FAIR de The Open Group [71].
- Hubbard et Seiersen, *How to Measure Anything in Cybersecurity Risk* [20], sur le calibrage des experts.

Note

Transition. La Partie II a jusqu'ici appris à apprécier, traiter et chiffrer les risques. Reste à vérifier que les mesures annoncées existent et fonctionnent : c'est le travail de l'auditeur. Le Chapitre 6 présente la conduite d'un audit de cybersécurité, du mandat au rapport.

6

CONDUIRE UN AUDIT DE CYBERSÉCURITÉ

« L'auditeur ne croit pas.
Il vérifie, ou il dit qu'il n'a pas pu. »

Principe du cours

Niveau : *Fondamental* • Maîtrise du Chapitre 1

✦ Objectifs du chapitre

- ➢ Définir l'audit, ses critères, ses preuves, ses constats et ses conclusions.
- ➢ Appliquer les sept principes de l'ISO 19011 et situer l'ISO/IEC 27007.
- ➢ Distinguer audit interne, audit de certification, audit contractuel et audit réglementaire.
- ➢ Décrire le cycle d'une mission, du mandat au suivi, et organiser le contradictoire.
- ➢ Choisir une technique de collecte et apprécier la fiabilité d'une preuve.
- ➢ Échantillonner, et dire ce qu'un échantillon permet de conclure.
- ➢ Coter un test OUI, NON ou NEK, et traiter une limitation de l'étendue.

Avant de commencer : « Les actions sont faites »

Douala, février 2028. Le plan de traitement de R-AG-01 est déclaré achevé. Le rapport de la RSSI au comité des risques l'affirme : second facteur, cloisonnement, sauvegardes, mode dégradé, sensibilisation, journalisation, tout est en place[1]. Le comité ne doute pas de la bonne foi de Mme ABENA. Mais il a appris, en 2026, ce que vaut une assurance qu'on ne vérifie pas. Il confirme donc la mission inscrite au programme de l'audit interne : la sécurité du réseau d'agences.

Mme EKAMBI, directrice de l'audit interne, sait que la mission sera regardée de près. Si elle conclut que tout va bien, le comité réduira la surveillance ; si elle se trompe, la

[1] Comme dans tout le cours, la BANQUE SANAGA, ses dirigeants, ses prestataires, les dates et les montants sont fictifs ; les normes et les textes cités sont exacts.

prochaine attaque le dira. Elle doit donc pouvoir montrer, pour chaque conclusion, la preuve qui la fonde, ou dire clairement qu'elle ne l'a pas obtenue.

Ce chapitre décrit la conduite d'un audit de cybersécurité, de l'audit interne à l'audit réglementaire. Le Chapitre 7 apprendra ensuite à décomposer l'objet audité et à conclure.

★ Attention

Violation typique. Conclure qu'une mesure est en place sur la foi d'un rapport de l'audité, d'une capture d'écran qu'il a fournie, ou d'un entretien.

Règle : une déclaration n'est pas une preuve de fonctionnement. L'auditeur obtient lui-même la preuve, ou une preuve produite par le système sous ses yeux ; à défaut, il cote NEK et le dit.

6.1 Ce qu'est un Audit

6.1.1 Cinq notions

■ Définition

Audit : processus méthodique, indépendant et documenté, qui consiste à obtenir des preuves objectives et à les évaluer de manière objective pour déterminer dans quelle mesure des critères sont satisfaits [30].

Critère d'audit : ensemble d'exigences qui sert de référence : une norme, une politique, une loi, un contrat, un plan de traitement.

Preuve d'audit : enregistrement, énoncé de fait ou autre information, vérifiable et pertinent au regard des critères.

Constat d'audit : résultat de l'évaluation des preuves au regard des critères : conformité, non-conformité, ou impossibilité de conclure.

Conclusion d'audit : résultat de l'audit, tiré de l'ensemble des constats, au regard des objectifs de la mission.

Définitions reformulées d'après l'ISO 19011:2018 ; la troisième issue du constat est propre au cours.

L'ISO 19011 envisage deux issues pour un constat : conforme ou non conforme. Le cours en ajoute une troisième, NEK : la preuve n'a pas pu être obtenue, ou ne permet pas de trancher. Ce n'est pas une complaisance ; c'est une information, souvent la plus importante du rapport (Chapitre 7).

6.1.2 Sept principes

L'ISO 19011:2018 pose sept principes, qui s'appliquent à tout audit de système de management [30].

Principe	Ce qu'il signifie pour l'auditeur en cybersécurité
Intégrité	Honnêteté, diligence, compétence ; refus de toute pression sur les constats
Présentation impartiale	Rapporter fidèlement, y compris les obstacles rencontrés et les divergences non résolues
Conscience professionnelle	Le soin qu'exige l'importance de la mission et la confiance des commanditaires
Confidentialité	Protéger les informations obtenues, en particulier les faiblesses découvertes
Indépendance	Ne pas auditer son propre travail ; rester objectif
Approche fondée sur la preuve	Conclure sur des preuves vérifiables, obtenues sur un échantillon raisonné
Approche fondée sur le risque	Concentrer l'effort là où le risque, pour la mission et pour l'audité, est le plus grand

Tableau 6.1. Les sept principes de l'audit (d'après l'ISO 19011:2018)

Note

Les autres référentiels. L'ISO/IEC 27007:2020 complète l'ISO 19011 pour l'audit des systèmes de management de la sécurité de l'information [38] ; le Chapitre 11 l'emploie. Les auditeurs internes appliquent en outre les normes mondiales d'audit interne de l'IIA, publiées en 2024 [70], et les auditeurs des systèmes d'information le cadre ITAF de l'ISACA [28].

6.1.3 Quatre familles d'audit

Famille	Commanditaire	Critères	Exemple du cours
Interne (première partie)	L'organisation elle-même, par son audit interne	Ses politiques, ses plans, les normes qu'elle applique	Mission de Mme EKAMBI sur les agences
Contractuel (seconde partie)	Un client ou un partenaire	Le contrat	PHARMACAM chez LiZbiZ
Certification (tierce partie)	L'organisation, auprès d'un organisme accrédité	La norme certifiable	CERTIQUAL AFRIQUE, ISO/IEC 27001
Réglementaire	La loi, par une autorité	Les textes	L'audit de sécurité obligatoire de l'ANPP

Tableau 6.2. Les familles d'audit

Un test d'intrusion n'est pas un audit au sens strict : il cherche des chemins d'attaque, sans évaluer l'ensemble des critères. Il peut fournir des preuves à un audit, comme le test A3 du plan de la banque. Il est enseigné dans l'UE MSN-2S3-SEC03.

6.2 Le Cycle de la Mission

6.2.1 Programme et mission

L'ISO 19011 distingue le *programme d'audit*, qui organise les audits sur plusieurs années selon les risques, et la *mission*, qui en réalise un. Le programme de l'audit interne de la BANQUE SANAGA n'avait pas couvert la sécurité en 2024 et 2025 (Chapitre 1, Tableau 1.7) ; celui de 2028 l'inscrit en tête, parce que le risque résiduel de R-AG-01 repose sur des mesures nouvelles.

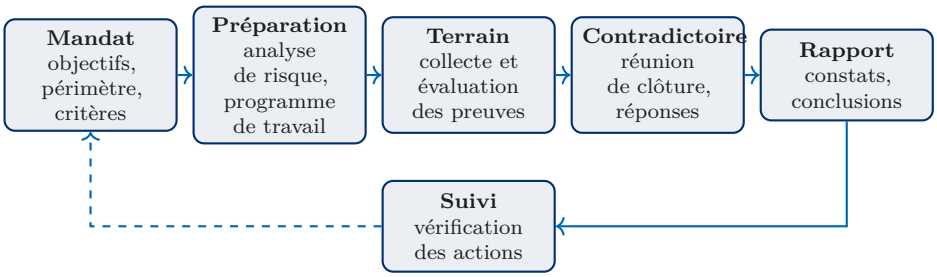


Figure 6.1: Le cycle d'une mission d'audit

6.2.2 Le mandat

Scénario Opérationnel · Opération SANAGA. La lettre de mission

Commanditaire : le comité des risques du conseil, auquel l'audit interne rend compte.

Objectif : établir si les mesures du plan de traitement de R-AG-01, et les mesures sur les agences issues de l'appréciation de décembre 2026, sont en place et fonctionnent.

Périmètre : les 38 agences, les comptes et les postes des agents, les espaces de fichiers, les sauvegardes des serveurs d'agence, les automates de retrait (GAB) ; période : de septembre 2027 à mars 2028.

Critères : la politique de sécurité de la banque ; le plan de traitement (actions A1 à A8, preuves attendues) ; les mesures correspondantes de l'ISO/IEC 27002:2022.

Équipe : Mme EKAMBI et deux auditeurs internes, avec l'appui d'un auditeur technique externe pour les extractions. Aucun membre de l'équipe n'a participé à la mise en œuvre du plan.

Accès : la lettre de mission, signée par le président du comité, donne à l'équipe l'accès à tous les systèmes, documents et personnes nécessaires, y compris chez les

prestataires dans la limite des contrats.

La dernière phrase compte. Sans elle, l'auditeur dépend de la bonne volonté de chacun. Avec elle, un refus d'accès devient un constat, que le comité doit traiter.

6.2.3 La préparation

L'équipe analyse les risques de la mission : où une erreur de conclusion serait la plus grave, où la preuve sera la plus difficile à obtenir. Elle en tire un *programme de travail* : pour chaque critère, le test, la technique, l'échantillon, la preuve attendue.

Réf.	Critère	Test	Preuve attendue
T1	Second facteur sur tous les comptes (A1)	Extraction exhaustive des 1 240 comptes ; essai de connexion sans second facteur	Extraction, procès-verbal d'essai
T2	Cloisonnement par agence (A2)	Essais d'accès d'une agence vers les espaces des autres	Procès-verbal d'essai
T3	Sauvegardes hors ligne testées (A4)	Restauration observée d'un serveur choisi par l'auditeur	Procès-verbal, empreinte des fichiers
T4	Mode dégradé exercé (A5)	Exercice inopiné dans deux agences	Compte rendu, chronométrage
T5	Sensibilisation des agents (A6)	Rapprochement des listes de présence et des effectifs	Listes, fichier du personnel
T6	Journalisation centralisée (A8)	Extraction du collecteur : agences qui envoient des journaux	Extraction datée
T7	Fin de l'administration locale des chefs d'agence	Extraction des groupes locaux des postes	Extraction
T8	Correctifs des GAB	Revue des configurations auprès du prestataire	Configurations

Tableau 6.3. Le programme de travail de la mission

6.3 Collecter et Apprécier la Preuve

6.3.1 Trois techniques, et leurs variantes

Le NIST décrit trois méthodes d'évaluation des mesures de sécurité : *examiner* (des documents, des configurations, des journaux), *interroger* (des personnes), *tester* (faire fonctionner la mesure dans des conditions définies) [47]. Les auditeurs y ajoutent l'*observation* (regarder une opération se faire) et la *ré-exécution* (refaire soi-même un contrôle pour voir s'il donne le même résultat).

6.3.2 La fiabilité de la preuve

Toutes les preuves ne se valent pas. Une preuve est d'autant plus fiable qu'elle est obtenue directement par l'auditeur, qu'elle est produite par un système plutôt que rédigée par une personne, et qu'elle vient d'une source indépendante de l'audité.

Rang	Type de preuve	Exemple dans la mission
1	Obtenue directement par l'auditeur (test, ré-exécution, observation)	Essai de connexion sans second facteur, restauration observée
2	Produite par le système, extraite sous les yeux de l'auditeur	Extraction des comptes, du collecteur de journaux
3	Document de tiers indépendant	Rapport du test d'intrusion A3
4	Document produit par l'audité	Rapport de la RSSI, captures d'écran fournies
5	Déclaration orale	« Toutes les agences sont raccordées »

Tableau 6.4. Une hiérarchie de la fiabilité des preuves

Note

Suffisante, pertinente, fiable. Une preuve doit être *pertinente* (elle porte sur le critère), *fiable* (rang élevé du Tableau 6.4) et *suffisante* (en quantité, pour la conclusion visée). Une déclaration orale peut orienter un test ; elle ne suffit jamais à coter OUI.

6.3.3 Échantillonner

On ne vérifie pas toujours tout. Pour un *contrôle automatisé* (le second facteur, géré par un serveur central), on extrait l'ensemble de la population : 1 240 comptes, sans échantillon. Pour ce qui se fait agence par agence, l'équipe retient un échantillon de huit agences sur trente-huit :

- Ngaoundéré, point d'entrée de l'attaque de 2026 ;
- deux autres agences touchées en 2026 ;
- les trois agences qui traitent le plus d'opérations ;
- deux agences tirées au hasard parmi les autres, dont Kribi.

Définition

Échantillon raisonné : échantillon choisi par l'auditeur selon les risques. Il permet de trouver des défauts là où ils sont probables ; il ne permet pas d'extrapoler un taux à la population. Seul un **échantillon aléatoire**, de taille suffisante, autorise une estimation statistique.

La distinction n'est pas un détail : si trois agences de l'échantillon sur huit présentent un défaut, on ne peut pas en déduire que « 37,5 % des agences » le présentent. On peut seulement dire que le défaut existe, et demander une vérification exhaustive.

6.4 Coter les Tests

6.4.1 Les résultats de terrain

Réf.	Résultat	Cote	Rang de la preuve
T1	1 240 comptes sur 1 240 avec second facteur ; connexion refusée sans lui dans les huit agences	OUI	1 et 2
T2	Tous les essais d'accès entre agences refusés	OUI	1
T3	Trois restaurations réussies, empreintes identiques	OUI	1
T4	Garoua sert en mode dégradé en 40 minutes ; Kribi ne peut pas servir pendant plus de deux heures (procédure introuvable, codes inconnus)	NON	1
T5	Listes de 30 agences, signatures non nominatives ; rapprochement avec les effectifs impossible	NEK	4
T6	31 agences sur 38 envoient des journaux au collecteur	NON	2
T7	Chef d'agence encore administrateur local dans 3 agences sur 8	NON	2
T8	Le prestataire des GAB refuse l'accès aux configurations, en invoquant son contrat	NEK	–

Tableau 6.5. Résultats des tests (mars 2028)

⚖ Lecture auditologique · La mission sur le réseau d'agences

Constatation. Sur huit tests : 3 OUI, 3 NON, 2 NEK.

$\mu = 0{,}375$; $U = 0{,}25$; $H = -(2{\times}0{,}375 \log_2 0{,}375 + 0{,}25 \log_2 0{,}25) \approx 0{,}531 + 0{,}531 + 0{,}500 \approx 1{,}56$ b

Analyse (confiance élevée sur les OUI et les NON). Les trois mesures techniques centrales du plan (T1 à T3) fonctionnent : le résiduel de R-AG-01 sur l'entrée et la propagation est confirmé. Mais le rapport de la RSSI déclarait « tout en place », et trois mesures ne le sont pas. Ce n'est pas un défaut d'honnêteté : la RSSI a reçu des déclarations des agences et de la DSI, et les a transmises. C'est exactement la raison d'être de l'audit : remplacer des déclarations de rang 4 ou 5 par des preuves de rang 1 ou 2.

$\mu = 0{,}375$ · $U = 0{,}25$ · $H = 1{,}56$ **bit**

6.4.2 Le cas du NEK

Les deux NEK ne sont pas de même nature.

- **T5** est un NEK de *preuve insuffisante* : les listes existent, mais ne permettent pas de conclure. L'auditeur recommande une preuve meilleure (émargement nominatif, quiz enregistré) et pourra conclure au prochain passage.
- **T8** est un NEK de *limitation de l'étendue* : on a empêché l'auditeur de voir. C'est en soi un constat, grave, que le rapport porte au comité : quatorze agences ont des GAB sous un système sans correctifs (Chapitre 3), et la banque ne peut pas vérifier ce que fait leur prestataire.

★ Attention

Violation typique. Retirer du rapport un test que l'on n'a pas pu réaliser, pour ne présenter que ce qui a été vérifié.

Règle : une limitation de l'étendue figure dans le rapport, avec sa cause et ce qu'elle empêche de conclure. Le principe de présentation impartiale l'exige : le commanditaire doit savoir ce que l'audit n'a pas pu voir.

6.4.3 Le papier de travail

☑ Papier de travail

Le papier de travail d'un test. Chaque test du programme laisse un papier de travail qui permet à un autre auditeur de refaire le raisonnement :

- la référence du test, le critère, la population et l'échantillon, avec la méthode de sélection ;
- la technique employée et la date ;
- les preuves obtenues, leur rang de fiabilité, et l'endroit où elles sont conservées (extraction, empreinte, procès-verbal) ;
- le résultat et la cote (OUI, NON ou NEK), avec, pour un NEK, sa nature (preuve insuffisante ou limitation) ;
- l'auteur et le réviseur.

6.5 Le Contradictoire et le Rapport

6.5.1 La réunion de clôture

Avant le rapport, l'équipe présente ses constats aux audités : la RSSI, la DSI, la direction du réseau d'agences. C'est le **contradictoire** : l'audité peut contester un fait, apporter

une preuve que l'auditeur n'avait pas, ou expliquer une cause. Un constat qui a survécu au contradictoire est solide ; un constat qui le contourne est fragile.

Scénario Opérationnel · Opération SANAGA. La DSI conteste T6

Faits. À la réunion de clôture, le DSI affirme que les sept agences manquantes « ont été raccordées la semaine dernière ».

Réponse de l'équipe. Mme EKAMBI demande une extraction datée du collecteur, faite devant un auditeur. L'extraction, obtenue le lendemain, montre 38 agences sur 38.

Analyse (confiance élevée). Le constat n'est pas supprimé : pendant la période auditée, sept agences n'étaient pas journalisées, et une attaque y serait passée inaperçue. Le rapport le maintient, et ajoute « corrigé en cours de mission, extraction du 22 mars 2028 ». La correction est une bonne nouvelle ; elle ne réécrit pas le passé.

6.5.2 Le rapport et le suivi

Le rapport présente les objectifs, le périmètre, les critères, les limitations, puis les constats et les conclusions. Chaque constat donne le critère, le fait, la cote et la preuve ; le Chapitre 7 montre comment le développer en observation complète (cause, conséquence, recommandation) et comment tirer une conclusion d'ensemble des cotes. L'audité répond par un plan d'actions daté ; l'audit interne vérifie, à l'échéance, que les actions sont faites, par des preuves du même rang que celles de la mission.

Fiche de risque · R-AG-01 · Après l'audit de mars 2028

Mesures confirmées par l'audit : second facteur (T1), cloisonnement (T2), sauvegardes restaurées (T3).
Mesures non confirmées : mode dégradé (T4, NON à Kribi), sensibilisation (T5, NEK), journalisation (T6, corrigée en cours de mission), administration locale (T7, NON dans 3 agences sur 8).
Résiduel : inchangé à $2 \times 3 = 6$ selon la convention de réduction, car les étapes entrée, propagation et récupération restent couvertes par des mesures prouvées. Mais la récupération repose sur les sauvegardes seules : dans une agence comme Kribi, les guichets resteraient fermés le temps de la restauration.
Nouveau risque à apprécier : compromission d'un GAB (T8), base NEK ; présentation au comité des risques en raison de la limitation de l'étendue.

6.6 Le Cadre Camerounais

Jurisprudence & Droit applicable

Loi n° 2010/012, article 4, point 9 [53] :

« Audit de sécurité : examen méthodique des composantes et des acteurs de la sécurité, de la politique, des mesures, des solutions, des procédures et des moyens mis en oeuvre par une organisation, pour sécuriser son environnement, effectuer des contrôles de conformité, des contrôles d'évaluation de l'adéquation des moyens (organisationnels, techniques, humains, financiers) investis au regard des risques encourus, d'optimisation, de rationalité et de performance. »

Article 13, alinéa 1 :

« Sont soumis à un audit de sécurité obligatoire, les réseaux de communications électroniques et les systèmes d'information, des opérateurs, des autorités de certification et des fournisseurs de services de communications électroniques. »

Article 32, alinéas 1 et 2 :

« (1) Les réseaux de communications électroniques et les systèmes d'information sont soumis à un régime d'audit de sécurité obligatoire et périodique de leurs systèmes de sécurité par l'Agence. (2) L'audit de sécurité et les mesures d'impact de gravité sont effectués chaque année ou lorsque les circonstances l'exigent. »

Portée. La définition légale de l'article 4 couvre à la fois la conformité et l'adéquation des moyens « au regard des risques encourus » : elle correspond à l'approche fondée sur le risque de l'ISO 19011. Les articles 13 et 32 instituent un audit réglementaire annuel, conduit sous l'autorité de l'Agence nationale des technologies de l'information et de la communication. Leur champ exact (quels systèmes, quelles organisations) et leur application à une agence publique comme l'ANPP sont étudiés au Chapitre 10.

6.7 Ce que l'Audit demande à chaque Métier

Application Auditeur en cybersécurité

Préférer la preuve que l'on obtient soi-même

1. Obtenir un mandat écrit qui garantit l'accès, y compris chez les prestataires.
2. Écrire, avant le terrain, la preuve attendue de chaque test.
3. Viser les preuves de rang 1 et 2 ; ne jamais coter OUI sur une déclaration.
4. Distinguer, pour chaque NEK, preuve insuffisante et limitation de l'étendue, et porter la seconde au commanditaire.
5. Maintenir un constat corrigé en cours de mission, en signalant la correction.

Application RSSI

Préparer l'audit, pas le subir

La RSSI aurait évité l'écart entre son rapport et l'audit en demandant, pour chaque action, la preuve prévue au plan (Chapitre 3) plutôt qu'une déclaration. Un RSSI dont les rapports reposent sur des preuves de rang 2 voit l'audit confirmer ses chiffres.

Application Responsable GRC

Faire entrer l'audit dans les contrats

La limitation de T8 vient d'un contrat sans droit d'audit, comme celui de DIGICORE. Le responsable GRC fait inscrire, dans chaque contrat de prestataire qui touche au système d'information, un droit d'accès de l'audit interne et des auditeurs mandatés.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **L'audit** obtient et évalue des preuves au regard de critères ; le constat peut être conforme, non conforme, ou NEK.
- **Sept principes** (ISO 19011) : intégrité, présentation impartiale, conscience professionnelle, confidentialité, indépendance, approche fondée sur la preuve, approche fondée sur le risque.
- **Quatre familles** : interne, contractuel, certification, réglementaire.
- **Le cycle** : mandat, préparation, terrain, contradictoire, rapport, suivi.
- **La preuve** vaut par sa pertinence, sa fiabilité et sa suffisance ; une déclaration n'est jamais suffisante.
- **Un échantillon raisonné** trouve des défauts ; il ne permet pas d'extrapoler un taux.
- **Une limitation de l'étendue** est un constat, porté au commanditaire.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- classer une preuve dans la hiérarchie de fiabilité ;
- rédiger une ligne de programme de travail avec sa preuve attendue ;
- dire ce qu'un échantillon raisonné permet de conclure ;
- distinguer les deux sortes de NEK et traiter chacune.

Exercices

✍ Exercice 6.1. Techniques et preuves ★☆☆

Pour chacun des éléments suivants, indiquez la technique (examiner, interroger, tester, observer, ré-exécuter) et le rang de fiabilité de la preuve (Tableau 6.4).

(a) Le DSI explique que les correctifs sont appliqués chaque mois.

(b) L'auditeur lance lui-même la restauration d'un serveur.

(c) La RSSI remet une capture d'écran de la console de sauvegarde.

(d) L'auditeur assiste à l'ouverture d'une agence en mode dégradé.

(e) L'auditeur extrait la liste des comptes d'administration, devant lui, depuis l'annuaire.

(f) L'auditeur recalcule le délai d'application des correctifs à partir du journal de déploiement.

✍ Exercice 6.2. Une ligne de programme ★★☆

Le comité demande d'ajouter à la mission un test sur les comptes des agents partis : aucun compte d'un agent ayant quitté la banque ne doit rester actif plus de cinq jours après son départ.

(a) Rédigez la ligne du programme de travail : critère, test, population, échantillon éventuel, preuve attendue.

(b) La DRH fournit une liste de 46 départs en 2027 ; l'extraction de l'annuaire montre 4 comptes de partants actifs plus de cinq jours. Cotez le test et justifiez.

(c) La DRH refuse de communiquer les départs du dernier trimestre, « pour des raisons de confidentialité ». Quelle est la nature de ce NEK, et que fait l'auditeur ?

✍ Exercice 6.3. Ce que dit l'échantillon ★★☆

(a) Justifiez chacun des quatre critères de sélection de l'échantillon de huit agences.

(b) Un administrateur lit le résultat de T7 et conclut que « 14 agences environ » gardent l'administration locale. Que répondez-vous ?

(c) Si les huit agences avaient été conformes pour T7, l'auditeur aurait-il pu coter OUI pour les 38 agences ? Proposez la meilleure preuve possible pour ce test.

✍ Exercice 6.4. L'audit contractuel de PHARMACAM ★★★

PHARMACAM exerce, en 2028, son droit d'audit sur LiZbiZ, pour vérifier le plan de traitement du scénario SO1 (Chapitres 4 et 5).

(a) De quelle famille d'audit s'agit-il ? Qui peut le conduire ? AUDIX CONSEIL peut-il s'en charger ? Justifiez.

(b) Rédigez la lettre de mission : objectif, périmètre, critères, accès.

(c) Rédigez un programme de travail de cinq tests, avec la preuve attendue et son rang.

(d) L'éditeur de l'application refuse de montrer la configuration de son accès de maintenance. Comment le rapport le traite-t-il, et quelle conséquence PHARMACAM peut-elle en tirer ?

Note

Pour aller plus loin.

- L'ISO 19011:2018 [30], sur les principes, le programme et la conduite des audits.
- L'ISO/IEC 27007:2020 [38], pour l'audit d'un SMSI.
- Le NIST SP 800-53A [47], sur les méthodes d'évaluation des mesures de sécurité.
- Les normes mondiales d'audit interne de l'IIA [70].

Note

Transition. La mission a produit huit cotes : 3 OUI, 3 NON, 2 NEK. Que conclure ? Le réseau d'agences est-il « sécurisé » ? Pour répondre, il faut décomposer l'objet audité, coter chaque assertion selon plusieurs critères, et appliquer une règle de décision qui tienne compte de l'incertitude. C'est l'objet du Chapitre 7.

7

DÉCOMPOSER, COTER, CONCLURE

« Conclure, ce n'est pas compter les *oui*.
C'est savoir ce qu'ils valent. »

Principe de la méthode

Niveau : *Intermédiaire* • Maîtrise du Chapitre 6

✦ Objectifs du chapitre

- ➢ Décomposer un domaine de sécurité selon le gabarit canonique à huit niveaux, et vérifier la qualité de la décomposition.
- ➢ Rédiger une fiche d'assertion à plusieurs critères, en respectant l'atomicité.
- ➢ Déduire la cote d'un contrôle de celles de ses critères.
- ➢ Calculer μ, U et H par sous-domaine, et localiser l'incertitude.
- ➢ Situer un domaine dans le quadrant conformité × incertitude et appliquer la règle de décision.
- ➢ Rédiger une observation en sept éléments et la conclusion d'un rapport.

Avant de commencer : « Alors, c'est sécurisé ? »

Douala, avril 2028. Mme EKAMBI présente les résultats de la mission sur le réseau d'agences au comité des risques : huit tests, 3 OUI, 3 NON, 2 NEK (Chapitre 6). Un administrateur l'interrompt : « Trois sur huit, c'est 37 %. Les agences sont-elles sécurisées, oui ou non ? »

La question est légitime, la réponse ne peut pas être un pourcentage. Les huit cotes ne portent pas sur la même chose : trois concernent les barrières techniques du scénario R-AG-01, une la capacité à continuer de servir, une le personnel, une un prestataire qui a refusé l'accès. Les additionner, c'est mélanger un pare-feu et une limitation de l'étendue.

Ce chapitre apprend à structurer ce que l'on audite, à coter chaque contrôle selon ses critères, puis à conclure, en disant à la fois ce qui va mal et ce que l'on ne sait pas. La méthode est celle de l'auditologie, commune aux cours du corpus [56], [57].

★ Attention

Violation typique. Résumer un audit par le pourcentage de contrôles conformes.

Règle : une conclusion se donne par sous-domaine, avec trois mesures (conformité, incertitude, dispersion), selon une règle de décision écrite à l'avance. Un taux unique cache où sont les défauts et où est l'ignorance.

7.1 Décomposer

7.1.1 Pourquoi décomposer

Un domaine de sécurité compte des dizaines de contrôles. La mémoire de travail humaine traite environ sept éléments à la fois [54] : au-delà, l'auditeur oublie, recouvre ou mélange. La décomposition découpe l'objet audité en niveaux emboîtés, chacun de taille maîtrisable. Elle a trois usages : vérifier que rien n'échappe au programme, situer chaque cote, et localiser l'incertitude.

7.1.2 Le gabarit canonique

Le programme de l'auditologie propose un **gabarit canonique** à huit niveaux [57].

N°	Niveau	Question	Exemple (réseau d'agences)
1	Domaine	Que soumet-on à l'audit ?	Sécurité du réseau d'agences
2	Sous-domaine	Quels grands ensembles le composent ?	Récupération
3	Processus	Quelles suites d'activités ?	Continuité du service au guichet
4	Activité	Quelles actions élémentaires ?	Servir en mode dégradé
5	Contrôle	Quel dispositif maîtrise l'activité ?	Procédure de mode dégradé, exercée
6	Test	Comment l'auditeur le vérifie-t-il ?	Exercice inopiné, chronométré
7	Preuve	Quel élément le test produit-il ?	Compte rendu signé, chronométrage
8	Trace	Quel enregistrement l'atteste ?	Journal des opérations en mode dégradé

Tableau 7.1. Le gabarit canonique (d'après [57])

Les quatre premiers niveaux disent *ce qui est audité* ; les quatre derniers, *comment on le vérifie*. Le contrôle fait la charnière : c'est l'objet sur lequel l'auditeur se prononce.

7.1.3 Trois conditions de qualité

Condition	Sens	Défaut si elle manque
Exhaustivité	Les éléments d'un niveau couvrent entièrement leur parent	Une partie du domaine n'est pas auditée
Non-redondance	Deux éléments d'un même niveau ne se recouvrent pas ; chacun a un seul parent	Double comptage, conclusions contradictoires
Borne cognitive	Aucun élément n'a plus de sept enfants environ	Grille illisible, éléments oubliés

Tableau 7.2. Les trois conditions d'une bonne décomposition

7.1.4 Le réseau d'agences, décomposé

Scénario Opérationnel · Opération SANAGA. Six sous-domaines

Mme EKAMBI décompose le domaine « sécurité du réseau d'agences » en six sous-domaines. Les quatre premiers suivent les étapes du scénario R-AG-01 (Chapitre 2) ; les deux derniers couvrent ce que le scénario ne prévoyait pas.

Code	Sous-domaine	Contrôles testés	Tests
S1	Entrée (accès, authentification)	Second facteur sur tous les comptes	T1
S2	Propagation (cloisonnement, privilèges)	Cloisonnement par agence ; fin de l'administration locale	T2, T7
S3	Détection	Journalisation centralisée	T6
S4	Récupération	Sauvegardes hors ligne testées ; mode dégradé	T3, T4
S5	Facteur humain	Sensibilisation des agents	T5
S6	Équipements de tiers	Correctifs des GAB	T8

Vérification. Six sous-domaines, sous la borne de sept ; chaque test a un seul parent ; l'ensemble couvre le périmètre de la lettre de mission. L'exhaustivité appelle une réserve : d'autres contrôles existent dans chaque sous-domaine (par exemple les correctifs des postes en S1) ; la mission n'a testé que ceux du plan de traitement. Le rapport doit le dire.

7.2 Coter un Contrôle

7.2.1 La fiche d'assertion

Le gabarit dit *où* se trouve un contrôle. La **fiche d'assertion** dit ce que l'auditeur affirme à son sujet, et ce qui arrive si l'affirmation est fausse.

Attribut	Rôle	Forme
Objectif	Ce que le contrôle doit garantir	À l'infinitif : « S'assurer que… »
Critère	La condition vérifiable qui définit la conformité	Au présent : une condition unique, observable
Question	La question posée pour coter	Interrogative ; réponse OUI, NON ou NEK
Risque	L'état de non-conformité si la réponse est NON	L'antithèse du critère
Conséquence	L'effet sur l'organisation si le risque se réalise	Financier, opérationnel, réglementaire

Tableau 7.3. Les attributs de la fiche d'assertion

Note

Règle d'atomicité. L'objectif, le critère et la question ne contiennent aucun « et » ni « ou ». Toute assertion qui en contient est scindée en autant d'assertions qu'il y a de conditions indépendantes. Ainsi une réponse NON désigne un seul défaut.

7.2.2 Un contrôle, trois critères

Scénario Opérationnel · Opération SANAGA. Fiche d'assertion du contrôle S4.2

Position : domaine « réseau d'agences » → S4 (récupération) → continuité du service au guichet → servir en mode dégradé → contrôle S4.2.

Objectif : s'assurer que chaque agence peut servir ses clients sans le système d'information habituel.

Critère 1 : la procédure de mode dégradé est disponible sur place, sous forme papier. *Question :* la procédure est-elle présente dans l'agence ?
Critère 2 : les codes d'accès au mode dégradé sont connus de la personne qui dirige l'agence le jour du test. *Question :* le responsable présent connaît-il les codes ?
Critère 3 : l'agence sert un premier client en moins d'une heure. *Question :* le premier client a-t-il été servi en moins d'une heure ?

Test, preuve, trace : exercice inopiné dans deux agences de l'échantillon ; compte rendu signé et chronométrage ; journal des opérations en mode dégradé.

Risque : une agence touchée par un incident reste fermée.
Conséquence : perte d'exploitation (190 millions pour neuf agences en 2026, Chapitre 5), atteinte à la réputation.

7.2.3 De la cote des critères à celle du contrôle

Chaque critère reçoit sa propre cote. La cote du contrôle s'en déduit par une règle simple :

- un seul critère NON suffit pour coter le contrôle NON ;
- à défaut, un seul critère NEK donne NEK ;
- le contrôle n'est coté OUI que si tous ses critères le sont.

À Garoua, les trois critères sont OUI. À Kribi, le critère 1 est NON (procédure introuvable), le critère 2 NON (codes inconnus du chef d'agence remplaçant), donc le critère 3 aussi (2 h 15). Un contrôle d'agence se teste agence par agence : S4.2 est NON pour l'échantillon, puisqu'une agence sur deux ne le satisfait pas.

★ Attention

Violation typique. Coter « OUI à 50 % » un contrôle conforme dans une agence et défaillant dans l'autre.

Règle : la cote porte sur le critère, qui est binaire. On cote NON, et le papier de travail précise où le contrôle fonctionne et où il échoue.

7.3 Mesurer et Localiser l'Incertitude

7.3.1 Trois mesures

■ Définition

Pour un ensemble de cotes, on note $p(\text{OUI})$, $p(\text{NON})$ et $p(\text{NEK})$ les parts de chaque réponse [56].

Taux de conformité : $\mu = p(\text{OUI})$.

Taux d'incertitude : $U = p(\text{NEK})$.

Entropie : dispersion des réponses, en bits,

$$H = -\sum_{m \in \{\text{OUI},\text{NON},\text{NEK}\}} p(m)\log_2 p(m), \qquad 0 \le H \le \log_2 3 \approx 1{,}585,$$

avec la convention $0 \log_2 0 = 0$.

Situation	μ	U	H	Lecture
Tout est OUI	1	0	0	Conformité certaine
Tout est NON	0	0	0	Non-conformité certaine
Tout est NEK	0	1	0	**Ignorance unanime**
Réponses également réparties	1/3	1/3	1,585	Dispersion maximale

Tableau 7.4. Les cas limites des trois mesures (d'après [56])

★ **Attention**

Violation typique. Conclure « certitude » parce que l'entropie est nulle.

Règle : une entropie nulle dit seulement que toutes les cotes sont identiques. Si elles sont toutes NEK, on ne sait rien : $H = 0$ et $U = 1$. On ne lit jamais H sans U ni μ.

7.3.2 Par sous-domaine

⚖ **Lecture auditologique · Le réseau d'agences, sous-domaine par sous-domaine**

Code	Sous-domaine	oui/non/nek	μ	U	H
S1	Entrée	1 / 0 / 0	1,00	0,00	0,00
S2	Propagation	1 / 1 / 0	0,50	0,00	1,00
S3	Détection	0 / 1 / 0	0,00	0,00	0,00
S4	Récupération	1 / 1 / 0	0,50	0,00	1,00
S5	Facteur humain	0 / 0 / 1	0,00	1,00	0,00
S6	Équipements de tiers	0 / 0 / 1	0,00	1,00	0,00
Domaine		**3 / 3 / 2**	**0,375**	**0,25**	**1,56**

Constatation. Toute l'incertitude du domaine se concentre dans S5 et S6 : deux cas d'ignorance unanime ($H = 0$, $U = 1$). Les quatre autres sous-domaines sont connus ($U = 0$) : S1 est conforme, S3 non conforme, S2 et S4 partagés.

Analyse (confiance élevée). Lu d'un bloc, le domaine paraît « à 37 % » et en partie inconnu. Décomposé, il dit trois choses distinctes : les barrières techniques du scénario R-AG-01 tiennent (S1, le cloisonnement de S2, les sauvegardes de S4) ; des défauts connus restent à corriger (administration locale, journalisation, mode dégradé) ; et la banque ignore tout de deux sujets, le personnel et les GAB. Ce ne sont pas les mêmes décisions.

$\mu = 0{,}375$ · $U = 0{,}25$ · $H = 1{,}56$ **bit**

Note

Peu de cotes, mesures fragiles. S2 et S4 ne comptent que deux contrôles chacun : $\mu = 0{,}50$ y signifie « un sur deux », pas une proportion stable. À ce niveau, on conclut contrôle par contrôle ; les mesures servent surtout à comparer les sous-domaines et à repérer les NEK.

7.4 Conclure

7.4.1 Le quadrant conformité × incertitude

L'article sur l'incertitude épistémique propose de lire ensemble la conformité et l'incertitude, dans un quadrant à quatre régions [56]. Le cours retient, par convention, un seuil de 0,5 pour μ et de 0,20 pour U ; chaque mission peut fixer les siens, à condition de les écrire dans le plan d'audit.

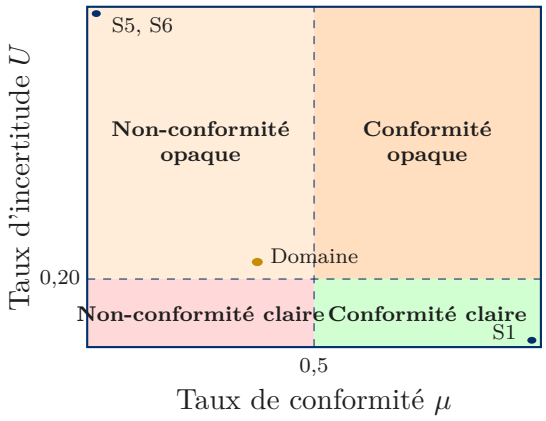


Figure 7.1: Le quadrant diagnostique (d'après l'article sur l'incertitude épistémique ; seuils du cours)

Région	Situation	Action
Conformité claire	Conformité établie, peu d'inconnu	Validation courante
Non-conformité claire	Non-conformité établie, peu d'inconnu	Correctifs
Conformité opaque	Beaucoup de OUI, mais une part importante de NEK	**Alerte prioritaire** : rechercher la preuve avant toute conclusion
Non-conformité opaque	Beaucoup de NON et une part importante de NEK	Rechercher la preuve et engager des premiers correctifs

Tableau 7.5. Les quatre régions et leurs actions (d'après [56])

La conformité opaque est la région la plus dangereuse : une grille binaire la confond avec la conformité claire. Le rapport de la RSSI de février 2028 en donne l'exemple :

huit mesures déclarées « en place », soit une conformité apparente de 100 % ; mais ces OUI reposaient sur des déclarations, qui ne valaient que des NEK tant qu'on ne les avait pas vérifiées.

7.4.2 La règle de décision

Papier de travail

Conclure sur un domaine. L'auditeur ne conclut qu'après avoir consigné, pour chaque domaine et chaque sous-domaine :

1. U **d'abord.** Si $U \geq 0{,}20$, l'ensemble est opaque : aucune conclusion de conformité n'est possible. L'auditeur recherche la preuve, ou conclut *sur l'opacité elle-même.*
2. μ **ensuite.** Si $U < 0{,}20$, l'ensemble est clair : conforme si $\mu \geq 0{,}5$, non conforme sinon.
3. H **pour contrôler.** Une entropie élevée avec U faible signale un désaccord entre OUI et NON : l'ensemble n'est pas homogène. On le décompose avant de conclure.
4. **Les cotes de l'auditeur prévalent.** Les mesures orientent ; la conclusion repose sur les contrôles cotés, preuve à l'appui.

Scénario Opérationnel · Opération SANAGA. La conclusion de Mme EKAMBI

Domaine. $U = 0{,}25 \geq 0{,}20$: le domaine est opaque, en région de non-conformité opaque ($\mu = 0{,}375$). Aucune conclusion de conformité d'ensemble n'est possible ; la mission recherche les preuves manquantes et engage des premiers correctifs.

Sous-domaines.

- S1 : clair et conforme.
- S2 et S4 : clairs, $H = 1$: non homogènes ; conclusion par contrôle : cloisonnement et sauvegardes efficaces, administration locale et mode dégradé non efficaces.
- S3 : clair, non conforme (corrigé en cours de mission).
- S5 et S6 : ignorance unanime ; l'auditeur conclut sur l'opacité. Pour S6, l'opacité vient d'une limitation de l'étendue, portée au comité.

Phrase pour le comité. « Les barrières techniques qui ont été défaillantes en 2026 sont désormais en place et fonctionnent. Trois défauts connus restent à corriger. Et la banque ne sait pas, à ce jour, si ses agents sont formés ni si ses GAB sont protégés : sur ces deux points, nous ne pouvons pas conclure, et nous en donnons les raisons. »

7.4.3 Pas de niveau de maturité pour un domaine opaque

Les directions aiment résumer un domaine par un niveau de 1 à 5. Le corpus propose une conversion du taux de conformité en niveau de maturité : moins de 0,35, niveau 1 ; de 0,35 à 0,55, niveau 2 ; de 0,55 à 0,75, niveau 3 ; de 0,75 à 0,90, niveau 4 ; au-delà, niveau 5. C'est une *convention pédagogique déclarée*, non une norme, et elle a une règle : si $U \geq 0{,}20$, le niveau est *indéterminé*. Le réseau d'agences n'a donc pas de niveau en 2028 ; lui en attribuer un, sur la foi de $\mu = 0{,}375$, ferait croire au comité qu'il connaît un état qu'en partie il ignore.

7.5 Rédiger l'Observation

7.5.1 Sept éléments

Chaque non-conformité significative donne lieu à une observation, de structure invariante.

N°	Élément	Contenu
1	Norme	Le critère, et le texte ou le référentiel d'où il vient
2	Constatation	Le fait établi, chiffré, avec sa preuve et sa cote
3	Risques	Ce qui peut arriver : le risque de la fiche d'assertion et sa conséquence
4	Contradictoire	La réponse de l'audité, datée
5	Analyse	La cause de l'écart et l'interprétation, avec un niveau de confiance
6	Conclusion	La position finale de l'auditeur
7	Recommandations	Ce qu'il faut faire, en traitant la cause

Tableau 7.6. Les sept éléments de l'observation

Scénario Opérationnel · Opération SANAGA. Observation S4.2 · Mode dégradé

1. Norme : plan de traitement de R-AG-01, action A5 (« procédure de guichet en mode dégradé, exercée ») ; ISO/IEC 27002:2022, mesure 5.30 (préparation des TIC pour la continuité d'activité) [41].

2. Constatation : exercice inopiné du 14 mars 2028. Garoua sert un premier client en 40 minutes. À Kribi, la procédure est introuvable, le chef d'agence remplaçant ignore les codes du mode dégradé, et aucun client n'est servi pendant 2 h 15 (compte rendu signé, chronométrage). Cote : NON.

3. Risques : une agence touchée par un incident reste fermée ; perte d'exploitation et atteinte à la réputation.

4. Contradictoire : la direction du réseau d'agences indique, le 20 mars, que la procédure a été diffusée par courriel en mai 2027 et que le chef d'agence titulaire de Kribi était en congé.

5. Analyse (confiance élevée) : la procédure a été diffusée par la messagerie, c'est-à-dire par l'outil qui manquera le jour d'un incident. Elle n'a jamais été intégrée au dossier papier de l'agence, et sa connaissance repose sur une seule personne.

6. Conclusion : le contrôle S4.2 n'est pas efficace pour l'échantillon ; son efficacité dans les 36 autres agences n'est pas établie.

7. Recommandations : placer la procédure et les codes, sous enveloppe scellée, dans le coffre de chaque agence ; former au moins deux personnes par agence ; exercer chaque agence une fois par an, avec chronométrage ; vérification par l'audit interne lors du suivi.

7.5.2 Le nouveau risque

La limitation de l'étendue sur les GAB n'appelle pas d'observation au sens strict : on ne peut pas décrire un écart que l'on n'a pas vu. Elle appelle une appréciation de risque, que le rapport demande au gestionnaire des risques.

Fiche de risque · R-AG-02 · Compromission d'un GAB

Valeur métier : le retrait d'espèces dans les agences.
Biens supports : automates de retrait de 14 agences, sous un système d'exploitation qui ne reçoit plus de correctifs ; contrat de maintenance sans droit d'audit.
Événement redouté : retraits frauduleux, ou indisponibilité des automates.
Vraisemblance : NEK (configuration non vérifiable).
Impact : à apprécier (montant des encaisses, nombre de clients concernés).
Action immédiate : négociation d'un avenant de droit d'audit avec le prestataire ; à défaut, présentation au comité des risques, comme pour DIGICORE (Chapitre 3).

7.6 Ce que la Conclusion demande à chaque Métier

Application Auditeur en cybersécurité

Conclure par sous-domaine

1. Décomposer le domaine avant le terrain, et faire revoir la décomposition.
2. Rédiger une fiche d'assertion atomique pour chaque contrôle.
3. Calculer μ, U et H par sous-domaine, et appliquer la règle de décision écrite dans le plan d'audit.
4. Conclure sur l'opacité quand $U \geq 0{,}20$, au lieu de la taire.
5. Développer chaque non-conformité significative en observation à sept éléments.

Application RSSI

Lire le rapport par sous-domaine

La RSSI ne retient pas « 37 % ». Elle retient que ses barrières techniques tiennent, qu'elle a trois défauts à corriger, et que deux sujets lui échappent : le personnel et les GAB. Son prochain rapport au comité suivra la même décomposition.

Application Responsable GRC

Une même décomposition partout

Si le registre des risques, le plan de traitement et le programme d'audit emploient la même décomposition (ici, les étapes du scénario plus le facteur humain et les tiers), les cotes de l'audit alimentent directement le registre. C'est le dispositif unique du Chapitre 13.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Le gabarit canonique** a huit niveaux : domaine, sous-domaine, processus, activité, contrôle, test, preuve, trace.
- **Une bonne décomposition** est exhaustive, non redondante et respecte la borne de sept éléments environ.
- **La fiche d'assertion** donne objectif, critère, question, risque, conséquence ; elle est atomique.
- **La cote d'un contrôle** : un NON suffit ; à défaut un NEK ; OUI seulement si tous les critères le sont.
- **La règle de décision** : U d'abord, μ ensuite, H pour contrôler, les cotes de l'auditeur prévalent.
- **Une entropie nulle** n'est pas une certitude si $U = 1$.
- **L'observation** a sept éléments, dont le contradictoire et une conclusion explicite.

Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- placer un élément au bon niveau du gabarit ;
- scinder une assertion qui n'est pas atomique ;
- calculer les trois mesures d'un sous-domaine et le situer dans le quadrant ;

➢ rédiger une conclusion qui dit ce qui va mal et ce que l'on ne sait pas.

Exercices

✍ Exercice 7.1. À quel niveau ? ★☆☆

Placez chaque élément au niveau du gabarit canonique qui lui correspond.

(a) L'extraction des groupes d'administration locale, avec son empreinte.

(b) La propagation.

(c) Le retrait des droits d'administration aux chefs d'agence.

(d) L'entrée du journal qui enregistre la modification d'un groupe local.

(e) Comparer les membres des groupes locaux à la liste des administrateurs autorisés.

(f) La gestion des droits sur les postes de travail.

(g) Aucun poste d'agence ne compte d'administrateur local autre que le compte central de la DSI.

✍ Exercice 7.2. Rendre atomique ★★☆

La première version du programme portait la question suivante : « Les chefs d'agence ont-ils perdu leurs droits d'administration et les postes sont-ils gérés par l'outil central ou par un prestataire agréé ? »

(a) Expliquez pourquoi cette question n'admet pas de réponse honnête dans une agence où les droits ont été retirés mais où les postes ne sont gérés par personne.

(b) Scindez-la en questions atomiques.

(c) Rédigez la fiche d'assertion complète du contrôle « fin de l'administration locale » (S2.2), avec deux critères.

✍ Exercice 7.3. Le domaine D de LiZbiZ ★★☆

AUDIX CONSEIL a décomposé le domaine D (contrôle d'accès à l'application intégrée de LiZbiZ) en cinq sous-domaines :

➢ D.1, politique et organisation : 4 / 0 / 0 ;

➢ D.2, cycle de vie des comptes : 1 / 1 / 2 ;

➢ D.3, authentification : 4 / 0 / 0 ;

➢ D.4, comptes à privilèges : 2 / 0 / 2 ;

➢ D.5, journalisation et revue : 2 / 1 / 1.

(nombre de OUI, NON et NEK).

(a) Calculez μ, U et H pour chaque sous-domaine et pour le domaine.

(b) Situez chacun dans le quadrant et appliquez la règle de décision.

(c) Quel niveau de maturité peut-on attribuer au domaine ?

(d) Où portez-vous les tests du second passage, et pourquoi ?

✍ Exercice 7.4. Observation et conclusion ★★★

(a) Rédigez l'observation à sept éléments du test T6 (journalisation : 31 agences sur 38, corrigée le 22 mars 2028, Chapitre 6).

(b) Rédigez le paragraphe de conclusion du rapport consacré à S5 (facteur humain), en concluant sur l'opacité.

(c) Un administrateur demande que le rapport « retire les deux NEK, qui affaiblissent le message ». Répondez-lui en citant les principes de l'audit (Chapitre 6).

● Note

Pour aller plus loin.

➢ L'article *Vers l'auditologie* [57], pour le gabarit canonique et l'observabilité partielle.

➢ L'article sur l'incertitude épistémique [56], pour les trois mesures et le quadrant.

➢ Miller [54], sur la borne de la mémoire de travail.

● Note

Transition. La Partie II est achevée : on sait apprécier, traiter, chiffrer, auditer et conclure. Il reste à connaître les textes auxquels se mesurent risques et audits : la famille des normes ISO/IEC 27000, les autres référentiels et le droit. C'est l'objet de la Partie III, qui s'ouvre avec le Chapitre 8.

partie III

Cadre Normatif et Juridique

© *MaletYon*

8

LA FAMILLE ISO/IEC 27000

« Une norme ne dit pas ce que vous faites.
Elle dit ce que vous devrez prouver. »

Principe du cours

Niveau : *Fondamental* • Maîtrise du Chapitre 3

✦ Objectifs du chapitre

- ➢ Situer les principales normes de la famille ISO/IEC 27000 et leur rôle.
- ➢ Présenter les exigences de l'ISO/IEC 27001:2022, articles 4 à 10, et le cycle de certification.
- ➢ Utiliser l'ISO/IEC 27002:2022 : 93 mesures, quatre thèmes, attributs, et l'écart avec l'édition de 2013.
- ➢ Rédiger une déclaration d'applicabilité et justifier une exclusion.
- ➢ Confronter une déclaration d'applicabilité aux preuves d'audit.
- ➢ Situer les ISO/IEC 27004, 27006 et 27007.

Avant de commencer : le renouvellement

Douala, avril 2028. Le certificat ISO/IEC 27001 de la BANQUE SANAGA[1], obtenu en juin 2025 pour trois ans, arrive à échéance. Le conseil a approuvé l'extension du système de management aux 38 agences ; l'audit de renouvellement de CERTIQUAL AFRIQUE portera donc, pour la première fois, sur toute la banque.

Mme ABENA doit remettre à l'organisme certificateur une pièce maîtresse : la *déclaration d'applicabilité*, qui dit, mesure par mesure, ce que la banque applique et pourquoi. La version de 2025 tenait en quelques pages, sur le seul centre de données. Celle de 2028 doit couvrir les agences, au moment même où l'audit interne vient d'y relever trois non-conformités et deux inconnues (Chapitre 7).

[1] Comme dans tout le cours, la BANQUE SANAGA, l'organisme CERTIQUAL AFRIQUE, les dates et les montants sont fictifs ; les normes citées sont exactes et paraphrasées, leur texte étant protégé.

© MaletYon

Ce chapitre ouvre la Partie III, consacrée au cadre normatif et juridique. Il présente la famille de normes la plus utilisée en sécurité de l'information, puis la manière de rédiger, et de vérifier, une déclaration d'applicabilité.

★ Attention

Violation typique. Rédiger la déclaration d'applicabilité en cochant « mise en œuvre » pour toutes les mesures, à partir des déclarations des services.

Règle : la déclaration d'applicabilité est un document *opposable* : l'organisme certificateur et les auditeurs la confrontent aux preuves. Chaque « mise en œuvre » doit pouvoir être démontrée ; chaque exclusion doit être justifiée par l'appréciation des risques.

8.1 Une Famille de Normes

La famille ISO/IEC 27000 est publiée par le sous-comité 27 du comité technique commun de l'ISO et de la CEI (JTC 1/SC 27). Elle compte des dizaines de documents ; une seule norme est certifiable, l'ISO/IEC 27001.

Norme	Objet	Dans ce cours
ISO/IEC 27000	Vue d'ensemble et vocabulaire [36]	Définitions (propriétaire de risque)
ISO/IEC 27001	Exigences du SMSI ; seule norme certifiable de la famille [40]	Ce chapitre, Chapitre 11
ISO/IEC 27002	Recommandations pour les mesures de sécurité [41]	Ce chapitre
ISO/IEC 27004	Surveillance, mesure, analyse et évaluation [35]	Chapitre 11
ISO/IEC 27005	Gestion des risques [42]	Chapitre 3
ISO/IEC 27006	Exigences pour les organismes qui auditent et certifient les SMSI	Ce chapitre
ISO/IEC 27007	Lignes directrices pour l'audit des SMSI [38]	Chapitres 6 et 11
ISO/IEC 27014	Gouvernance de la sécurité [39]	Chapitre 1

Tableau 8.1. Les principales normes de la famille ISO/IEC 27000

D'autres normes de la famille déclinent les mesures pour un secteur ou un sujet : les services en nuage, la gestion des incidents, la protection de la vie privée. Le Chapitre 15 y revient pour le nuage.

8.2 L'ISO/IEC 27001:2022

8.2.1 Une structure commune

L'ISO/IEC 27001 suit la structure commune à toutes les normes de systèmes de management de l'ISO (qualité, environnement, continuité) : dix articles, dont les sept derniers contiennent les exigences. Une organisation qui a déjà un système de management de la qualité retrouve donc le même plan.

Art.	Titre	Ce que la norme exige, en substance
4	Contexte de l'organisation	Comprendre les enjeux internes et externes, les parties intéressées et leurs exigences ; fixer le périmètre ; établir le SMSI et ses processus
5	Leadership	Engagement de la direction ; politique de sécurité ; rôles, responsabilités et autorités
6	Planification	Actions face aux risques et opportunités : appréciation et traitement des risques, déclaration d'applicabilité ; objectifs de sécurité ; planification des modifications
7	Support	Ressources ; compétences ; sensibilisation ; communication ; informations documentées
8	Fonctionnement	Planifier et maîtriser les opérations ; réaliser les appréciations et les traitements des risques prévus
9	Évaluation des performances	Surveillance et mesure ; audit interne ; revue de direction
10	Amélioration	Amélioration continue ; non-conformités et actions correctives

Tableau 8.2. Les articles 4 à 10 de l'ISO/IEC 27001:2022 (paraphrasés)

Les Chapitres 1 à 7 ont déjà parcouru l'essentiel de ces exigences sans les nommer : le périmètre et les parties intéressées (article 4), le rôle de la direction (article 5), l'appréciation et le traitement des risques (articles 6 et 8), l'audit interne (article 9). La norme ne prescrit pas *comment* faire ; elle dit ce que l'organisation doit faire et pouvoir prouver.

8.2.2 Ce qui a changé en 2022

L'édition de 2022 remplace celle de 2013. Les principaux changements :

- l'annexe A, liste des mesures de référence, est alignée sur la nouvelle ISO/IEC 27002:2022 (93 mesures au lieu de 114) ;
- une exigence nouvelle impose de planifier les modifications du SMSI (article 6.3) ;
- le SMSI doit identifier ses processus et leurs interactions (article 4.4).

Un amendement publié en 2024 demande en outre à l'organisation de déterminer si le changement climatique est un enjeu pertinent pour son système de management. Les

certificats délivrés sur l'édition de 2013 devaient avoir migré au plus tard le 31 octobre 2025. Le certificat de la BANQUE SANAGA, délivré en juin 2025 sur l'édition de 2022, n'était pas concerné.

Note

Le dossier du cours et l'édition 2013. Les normes archivées dans les ressources du cours sont celles de 2013. Le cours enseigne l'édition de 2022 ; les numéros de mesures cités ici sont ceux de 2022. Un étudiant qui consulte un document de 2013 trouvera d'autres numéros (de A.5 à A.18) et quatorze domaines au lieu de quatre thèmes.

8.2.3 Le cycle de certification

Étape	Contenu
Audit initial, étape 1	Revue documentaire et de l'état de préparation : périmètre, politique, appréciation des risques, déclaration d'applicabilité
Audit initial, étape 2	Évaluation de la mise en œuvre et de l'efficacité du SMSI sur le terrain ; décision de certification
Audits de surveillance	Au moins un par an, pendant les trois ans du certificat, sur une partie du SMSI
Audit de renouvellement	Avant l'échéance des trois ans, sur l'ensemble du SMSI

Tableau 8.3. Le cycle de certification

L'organisme certificateur doit lui-même satisfaire aux exigences de l'ISO/IEC 27006, et être accrédité par un organisme d'accréditation. La certification est volontaire : elle ne remplace ni l'audit interne, ni l'audit de sécurité réglementaire (Chapitre 6).

8.3 L'ISO/IEC 27002:2022

8.3.1 93 mesures, quatre thèmes

L'ISO/IEC 27002 n'est pas certifiable : elle donne, pour chaque mesure, un objectif et des recommandations de mise en œuvre [41]. L'édition de 2022 réorganise les mesures en quatre thèmes.

Thème	Mesures	Exemples (intitulés traduits par le cours)
Organisationnelles (5.1 à 5.37)	37	Politiques, rôles, renseignement sur les menaces (5.7), relations avec les fournisseurs (5.19, 5.20), préparation des TIC pour la continuité (5.30)
Liées aux personnes (6.1 à 6.8)	8	Sélection, sensibilisation et formation (6.3), signalement des événements
Physiques (7.1 à 7.14)	14	Périmètres, surveillance de la sécurité physique (7.4), matériels
Technologiques (8.1 à 8.34)	34	Droits d'accès privilégiés (8.2), authentification sécurisée (8.5), vulnérabilités techniques (8.8), sauvegarde (8.13), journalisation (8.15), cloisonnement des réseaux (8.22), codage sécurisé (8.28)

Tableau 8.4. Les quatre thèmes de l'ISO/IEC 27002:2022

Onze mesures sont nouvelles, dont le renseignement sur les menaces (5.7), la sécurité des services en nuage (5.23), la préparation des TIC pour la continuité (5.30), la surveillance de la sécurité physique (7.4), la gestion de la configuration (8.9), la prévention des fuites de données (8.12), les activités de surveillance (8.16), le filtrage web (8.23) et le codage sécurisé (8.28). Les autres mesures de 2013 ont été regroupées ou reformulées.

8.3.2 Les attributs

L'édition de 2022 associe à chaque mesure des **attributs**, qui permettent de trier les mesures selon plusieurs vues :

- le *type de mesure* : préventive, détective, corrective ;
- les *propriétés de sécurité* : confidentialité, intégrité, disponibilité ;
- les *concepts de cybersécurité* : identifier, protéger, détecter, répondre, rétablir (les fonctions historiques du cadre du NIST, Chapitre 1) ;
- les *capacités opérationnelles* (gestion des identités, continuité, gestion des fournisseurs, etc.) ;
- les *domaines de sécurité* : gouvernance et écosystème, protection, défense, résilience.

Note

À quoi servent les attributs ? À vérifier l'équilibre d'un dispositif. Les mesures de la BANQUE SANAGA en 2025 étaient presque toutes *préventives* ; les mesures *détectives* (journalisation, surveillance) et *correctives* (sauvegardes, mode dégradé) manquaient en agence. Trier la déclaration d'applicabilité par type de mesure l'aurait

montré. C'est aussi ce que faisaient apparaître les étapes du scénario (Chapitre 2).

8.4 La Déclaration d'Applicabilité

8.4.1 Ce qu'elle contient

Définition

Déclaration d'applicabilité (DdA) : document exigé par l'ISO/IEC 27001 (article 6.1.3) qui recense les mesures nécessaires au traitement des risques, justifie leur inclusion, indique si elles sont mises en œuvre, et justifie l'exclusion de toute mesure de l'annexe A [40].

La déclaration fait le pont entre l'appréciation des risques (Chapitre 3) et la liste des mesures. Une mesure y figure parce qu'un risque l'exige, ou parce qu'une obligation légale ou contractuelle l'impose. Une mesure en est exclue parce qu'aucun risque ni aucune obligation ne la rend nécessaire, et non parce qu'elle est difficile.

8.4.2 Un extrait

Scénario Opérationnel · Opération SANAGA. La déclaration d'applicabilité de 2028 (extrait)

Mesure	Intitulé (traduit)	Incl.	Justification	Mise en œuvre
5.20	Sécurité dans les accords avec les fournisseurs	Oui	R-DC-02, R-AG-02	Oui
5.30	Préparation des TIC pour la continuité	Oui	R-AG-01, récupération	Oui
6.3	Sensibilisation et formation	Oui	R-AG-01, entrée	Oui
8.2	Droits d'accès privilégiés	Oui	R-AG-01, propagation	Oui
8.5	Authentification sécurisée	Oui	R-AG-01, entrée	Oui
8.8	Gestion des vulnérabilités techniques	Oui	R-AG-01, R-AG-02	Oui
8.13	Sauvegarde des informations	Oui	R-AG-01, récupération	Oui
8.15	Journalisation	Oui	R-DC-03, loi n° 2010/012, art. 29	Oui
8.22	Cloisonnement des réseaux	Oui	R-AG-01, propagation	Oui
8.28	Codage sécurisé	Non	« Pas de développement interne : le système central est un progiciel »	–

La première version remise par les directions, en avril 2028, porte « Oui » dans la colonne « mise en œuvre » pour les neuf mesures incluses.

8.4.3 Confronter la déclaration aux preuves

La RSSI a appris la leçon de février : avant d'envoyer la déclaration, elle la confronte aux résultats de l'audit de mars 2028 (Chapitres 6 et 7).

⚖ Lecture auditologique · Les neuf « mise en œuvre » face aux preuves

Constatation.

- OUI : 8.5 (second facteur, T1), 8.13 (sauvegardes, T3), 8.22 (cloisonnement, T2) ;
- NON : 5.30 (mode dégradé, T4), 8.2 (administration locale, T7), 8.15 (journalisation incomplète pendant la période, T6) ;
- NEK : 6.3 (sensibilisation, T5), 5.20 (le contrat des GAB n'a pas de droit d'audit, T8), 8.8 (vulnérabilités : GAB non vérifiés, postes non testés).

3 OUI, 3 NON, 3 NEK :

$$\mu = U = \tfrac{1}{3} \; ; \quad H = \log_2 3 \approx 1{,}585 \text{ bit.}$$

Analyse (confiance élevée). La déclaration affirmait neuf mesures sur neuf ; les preuves en confirment trois. La dispersion est maximale : tout ce que l'on peut dire de cette déclaration, c'est qu'elle ne renseigne pas sur l'état réel. La version envoyée à CERTIQUAL AFRIQUE est corrigée : « partielle » pour 5.30, 8.2 et 8.15, avec le plan d'actions ; « à vérifier » pour 6.3, 5.20 et 8.8, avec la date de la vérification prévue.

$\mu = 0{,}33$ · $U = 0{,}33$ · $H = 1{,}58$ **bit**

8.4.4 L'exclusion de 8.28

L'exclusion du codage sécurisé paraît solide : la banque n'écrit pas son système central. Mais la DSI développe, depuis 2026, les interfaces entre le système central, l'application de paiement et le portail en ligne. L'exclusion est donc contredite par un fait : sa base est NON. La mesure est réintégrée, limitée aux développements d'interfaces.

☑ Papier de travail

Vérifier une exclusion. Le papier de travail qui examine une exclusion de la déclaration d'applicabilité vérifie :

- que la justification renvoie à l'appréciation des risques (aucun risque ne rend la mesure nécessaire), et non à une difficulté de mise en œuvre ;

- qu'aucune obligation légale ou contractuelle n'impose la mesure ;
- que les faits invoqués sont exacts (ici : existe-t-il vraiment aucun développement interne ?) ;
- que l'exclusion est approuvée par la direction, et datée.

8.5 Mesurer et Auditer le SMSI

Deux normes de la famille accompagnent le fonctionnement du SMSI. L'ISO/IEC 27004 aide à construire des indicateurs qui répondent à l'exigence de surveillance et de mesure de l'article 9.1 [35]. L'ISO/IEC 27007 adapte à l'audit d'un SMSI les lignes directrices générales de l'ISO 19011 [38]. Le Chapitre 11 met en œuvre l'une et l'autre : les indicateurs de la RSSI, puis l'audit interne du SMSI élargi et la préparation de la revue de direction.

Note

La norme et la loi. L'article 26 de la loi n° 2010/012 impose aux exploitants des systèmes d'information de se doter de « systèmes normalisés » de gestion des risques (Chapitre 3) [53]. Un SMSI conforme à l'ISO/IEC 27001 en est une forme reconnue internationalement ; la loi n'en fait pas une obligation, et le certificat ne dispense pas de l'audit de sécurité réglementaire des articles 13 et 32. Le Chapitre 10 précise l'articulation.

8.6 Ce que la Norme demande à chaque Métier

Application Consultant en mise en œuvre de SMSI

Une déclaration défendable

1. Partir de l'appréciation des risques, pas de la liste de l'annexe A.
2. Pour chaque mesure incluse, citer le risque ou l'obligation qui l'exige.
3. Pour chaque « mise en œuvre », désigner la preuve qui le démontre.
4. Justifier chaque exclusion par le risque, et en vérifier les faits.

Application Auditeur en cybersécurité

Lire la déclaration comme un ensemble d'assertions

Chaque ligne « mise en œuvre » est une assertion de l'audité ; l'auditeur de certification la teste, comme Mme EKAMBI a testé le plan de traitement. Il prélève en priorité les mesures nouvelles de 2022, les exclusions, et les mesures qui portent les risques les plus élevés.

Application RSSI

Ne rien déclarer que l'on ne peut prouver

La RSSI préfère une déclaration honnête, avec des « partielle » et des « à vérifier », à une déclaration parfaite qui ne résisterait pas à l'étape 2 de l'audit. Un organisme certificateur pardonne une mesure en cours ; il ne pardonne pas une déclaration fausse.

Application Responsable GRC

Relier la déclaration au registre

La colonne « justification » de la déclaration renvoie aux références du registre des risques (R-AG-01, R-DC-02…). Le responsable GRC vérifie que tout risque intolérable a ses mesures dans la déclaration, et que toute mesure de la déclaration a un risque ou une obligation.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **La famille ISO/IEC 27000** compte une seule norme certifiable, l'ISO/IEC 27001 ; les autres l'outillent.
- **L'ISO/IEC 27001:2022** suit la structure commune des systèmes de management : articles 4 à 10, du contexte à l'amélioration.
- **L'ISO/IEC 27002:2022** compte 93 mesures en quatre thèmes (37 organisationnelles, 8 liées aux personnes, 14 physiques, 34 technologiques), avec des attributs.
- **La déclaration d'applicabilité** relie les risques aux mesures ; chaque « mise en œuvre » se prouve, chaque exclusion se justifie par le risque.
- **Confrontée aux preuves**, la déclaration de la BANQUE SANAGA passe de 9 sur 9 à 3 OUI, 3 NON, 3 NEK.
- **La certification** est volontaire et triennale ; elle ne remplace ni l'audit interne, ni l'audit réglementaire.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- dire dans quel article de l'ISO/IEC 27001 se trouve une exigence ;
- placer une mesure dans son thème et lui associer des attributs ;
- rédiger une ligne de déclaration d'applicabilité avec sa justification ;

➢ contester une exclusion par les faits.

Exercices

✍ Exercice 8.1. Quel article ? ★☆☆

Indiquez l'article de l'ISO/IEC 27001:2022 (4 à 10) dont relève chacune des activités suivantes.

(a) Le conseil approuve l'extension du périmètre aux agences.

(b) La RSSI rédige la déclaration d'applicabilité.

(c) L'audit interne conduit la mission de mars 2028.

(d) La DSI planifie le remplacement du collecteur de journaux sans interrompre la journalisation.

(e) La direction du réseau d'agences corrige le mode dégradé de Kribi après l'observation S4.2.

(f) La RSSI organise la formation de deux personnes par agence.

✍ Exercice 8.2. Thèmes et attributs ★★☆

Pour chacune des mesures suivantes, donnez son thème et son type (préventive, détective, corrective), puis dites à quelle étape du scénario R-AG-01 elle se rattache.

(a) 8.5, authentification sécurisée.

(b) 8.15, journalisation.

(c) 8.13, sauvegarde des informations.

(d) 6.3, sensibilisation et formation.

(e) 8.22, cloisonnement des réseaux.

(f) 5.30, préparation des TIC pour la continuité.

Que montre la répartition par type de mesure ?

✍ Exercice 8.3. Quatre exclusions ★★☆

Une banque de la sous-région exclut de sa déclaration d'applicabilité les mesures suivantes. Pour chacune, dites si l'exclusion est recevable, et justifiez.

(a) 5.23 (services en nuage) : « Nous n'utilisons aucun service en nuage. » La messagerie est hébergée chez un fournisseur en nuage.

(b) 7.4 (surveillance de la sécurité physique) : « Trop coûteux pour les petites agences. »

(c) 8.28 (codage sécurisé) : « Aucun développement ; tous les logiciels sont des progiciels, paramétrés par l'éditeur. » L'inventaire le confirme.

(d) 8.12 (prévention des fuites de données) : « Mesure couverte par la politique de classification. »

✍ Exercice 8.4. La déclaration de LiZbiZ ★★★

LiZbiZ veut s'engager vers la certification ISO/IEC 27001 pour rassurer PHARMACAM (Chapitres 4 à 6).

(a) Proposez un périmètre défendable, en tenant compte des dépendances (éditeur, transporteurs, centres de données).

(b) Rédigez six lignes de déclaration d'applicabilité pour les mesures qui traitent le scénario SO1, avec leur justification.

(c) L'audit contractuel de PHARMACAM a donné : comptes par défaut supprimés (OUI), services chiffrés (OUI), filtrage entre centres (NON), second facteur de l'éditeur (NEK, accès refusé), restauration observée (OUI), plan de réponse (NON). Remplissez la colonne « mise en œuvre », calculez μ, U et H, et dites si LiZbiZ peut demander l'audit initial.

(d) Quelle mesure de l'ISO/IEC 27002 traite la cause du NEK, et que doit faire LiZbiZ avant l'étape 2 ?

Note

Pour aller plus loin.

- L'ISO/IEC 27001:2022 [40], articles 4 à 10 et annexe A.
- L'ISO/IEC 27002:2022 [41], pour les recommandations de mise en œuvre de chaque mesure.
- L'ISO/IEC 27000 [36], pour le vocabulaire.

Note

Transition. L'ISO/IEC 27001 n'est pas le seul référentiel. La banque doit aussi répondre au superviseur, et ses partenaires parlent parfois NIST ou CIS. Comment passer d'un référentiel à l'autre sans tout refaire ? C'est l'objet du Chapitre 9.

9

LES AUTRES RÉFÉRENTIELS ET LEURS CORRESPONDANCES

« Tester une fois,
rendre compte autant de fois qu'il le faut. »

Principe du cours

Niveau : *Fondamental* • Maîtrise du Chapitre 8

✦ Objectifs du chapitre

- ➢ Présenter le cadre de cybersécurité du NIST (CSF 2.0), le catalogue NIST SP 800-53, les CIS Controls et PCI DSS.
- ➢ Situer les rapports d'assurance SOC 2 et ISAE 3402, et COBIT 2019.
- ➢ Construire une table de correspondance entre référentiels, et en connaître les pièges.
- ➢ Bâtir une base commune de contrôles, testée une fois et projetée sur plusieurs référentiels.
- ➢ Choisir les référentiels d'une organisation.

Avant de commencer : trois audits pour un seul système

Yaoundé, mars 2027. L'ANPP[1], agence publique de paiement, finance la modernisation de ses systèmes avec l'appui d'un bailleur de fonds international. La convention de financement exige un « profil de cybersécurité selon le cadre du NIST, version 2.0 », actuel et cible. La Chambre des comptes, par la voix du magistrat vérificateur M. NJOYA, prépare son contrôle des paiements et de leurs systèmes. Et l'audit de sécurité prévu par la loi n° 2010/012 pourrait s'appliquer à l'agence (Chapitre 10).

M. ESSOMBA, directeur général, refuse d'organiser trois chantiers : « Nos serveurs sont les mêmes pour tout le monde. Je veux un seul travail, et trois rapports. »

[1] L'ANPP, ses dirigeants, le bailleur, les dates et les montants sont fictifs ; les référentiels cités sont exacts.

Ce chapitre présente les principaux référentiels qui coexistent avec l'ISO/IEC 27001, puis la technique qui permet d'en satisfaire plusieurs à la fois : la table de correspondance et la base commune de contrôles.

★ Attention

Violation typique. Conclure qu'une organisation est conforme au cadre du NIST parce qu'elle est certifiée ISO/IEC 27001, au motif qu'une table de correspondance relie les deux.

Règle : une correspondance dit que deux exigences portent sur le même sujet, pas qu'elles disent la même chose. La conformité se démontre référentiel par référentiel, à partir des preuves.

9.1 Le Cadre de Cybersécurité du NIST

9.1.1 Six fonctions, vingt-deux catégories

Le cadre de cybersécurité du NIST (CSF), dans sa version 2.0 de 2024, organise la gestion des risques cyber en six fonctions, déclinées en 22 catégories et 106 sous-catégories [60]. Le Chapitre 1 a présenté la fonction *Gouverner* ; voici l'ensemble.

Fonction	Catégories (intitulés traduits par le cours)
Gouverner (GV)	Contexte organisationnel (OC) ; stratégie de gestion des risques (RM) ; rôles, responsabilités et autorités (RR) ; politique (PO) ; supervision (OV) ; risques de la chaîne d'approvisionnement (SC)
Identifier (ID)	Gestion des actifs (AM) ; appréciation des risques (RA) ; amélioration (IM)
Protéger (PR)	Identités, authentification et contrôle d'accès (AA) ; sensibilisation et formation (AT) ; sécurité des données (DS) ; sécurité des plateformes (PS) ; résilience de l'infrastructure (IR)
Détecter (DE)	Surveillance continue (CM) ; analyse des événements indésirables (AE)
Répondre (RS)	Gestion des incidents (MA) ; analyse (AN) ; communication (CO) ; atténuation (MI)
Rétablir (RC)	Exécution du plan de rétablissement (RP) ; communication (CO)

Tableau 9.1. Les fonctions et catégories du NIST CSF 2.0

9.1.2 Profils et niveaux

Le CSF ne fixe pas d'exigences ; il donne un langage. Une organisation décrit son *profil actuel* (ce qu'elle fait, sous-catégorie par sous-catégorie) et son *profil cible* (ce qu'elle vise),

puis comble l'écart. Elle peut aussi caractériser la rigueur de sa gestion des risques par l'un des quatre *niveaux de mise en œuvre* : partiel, informé par le risque, reproductible, adaptatif.

Note

Pourquoi les bailleurs aiment le CSF. Il est gratuit, lisible par une direction, et ne suppose pas de certification. Un profil actuel et un profil cible donnent au bailleur une feuille de route qu'il peut suivre d'une année sur l'autre. C'est aussi sa limite : un profil est une auto-description ; il ne vaut que par les preuves qui l'appuient.

9.2 Catalogues de Mesures

9.2.1 NIST SP 800-53

Le catalogue NIST SP 800-53, révision 5, compte plus d'un millier de mesures et d'améliorations, réparties en vingt familles (contrôle d'accès, audit et responsabilité, réponse aux incidents, etc.) [46]. Il est obligatoire pour les systèmes fédéraux américains et sert ailleurs de réservoir de mesures détaillées. Son compagnon, le SP 800-53A, décrit la manière d'évaluer chaque mesure (Chapitre 6).

9.2.2 Les CIS Controls

Les CIS Controls, version 8, publiés par le Center for Internet Security, retiennent 18 contrôles et 153 mesures, classés par ordre de priorité [5]. Leur originalité est de définir trois *groupes de mise en œuvre* : le premier (IG1) réunit 56 mesures, présentées comme l'hygiène de base que toute organisation devrait appliquer ; les groupes 2 et 3 ajoutent des mesures pour les organisations plus exposées ou plus outillées.

N°	Contrôle (traduit)	N°	Contrôle (traduit)
1	Inventaire des actifs matériels	10	Défenses contre les maliciels
2	Inventaire des logiciels	11	Restauration des données
3	Protection des données	12	Gestion de l'infrastructure réseau
4	Configuration sécurisée	13	Surveillance et défense du réseau
5	Gestion des comptes	14	Sensibilisation et formation
6	Gestion du contrôle d'accès	15	Gestion des prestataires
7	Gestion continue des vulnérabilités	16	Sécurité des applications
8	Gestion des journaux	17	Réponse aux incidents
9	Protection de la messagerie et du navigateur	18	Tests d'intrusion

Tableau 9.2. Les 18 CIS Controls (version 8)

Note

Un point de départ pour les petites organisations. Pour une entreprise comme LiZbiZ, qui n'a ni RSSI ni audit interne, le groupe IG1 des CIS Controls est un objectif réaliste et vérifiable avant toute certification. Le Chapitre 12 s'appuie sur les guides de configuration du même organisme.

9.2.3 PCI DSS

La norme PCI DSS, version 4.0, est imposée par les réseaux de cartes de paiement à toute organisation qui stocke, traite ou transmet des données de cartes [63]. Elle est contractuelle, détaillée et vérifiée par des évaluateurs agréés. Elle ne concerne pas l'ANPP, qui paie par virement ; elle concerne la BANQUE SANAGA pour son activité monétique, sur un périmètre (l'environnement des données de cartes) distinct de celui de son SMSI.

9.3 Rapports d'Assurance et Gouvernance

9.3.1 SOC 2 et ISAE 3402

Quand une organisation confie une activité à un prestataire, elle ne peut pas toujours l'auditer elle-même. Elle peut alors demander un **rapport d'assurance** établi par un auditeur indépendant sur les contrôles du prestataire.

Rapport	Cadre	Contenu
ISAE 3402	Norme internationale d'assurance [22]	Contrôles d'un prestataire qui affectent l'information financière de ses clients
SOC 2	Critères de services de confiance de l'AICPA [3]	Sécurité, disponibilité, intégrité des traitements, confidentialité, vie privée

Tableau 9.3. Deux rapports d'assurance sur les prestataires

Chacun existe en deux types : le *type 1* porte sur la conception des contrôles à une date ; le *type 2* sur leur efficacité pendant une période, généralement de six à douze mois. Seul le type 2 dit si les contrôles ont fonctionné.

Scénario Opérationnel · Opération SANAGA. Une issue pour DIGICORE

Faits. DIGICORE refuse l'avenant qui donnerait à la banque un droit d'audit (Chapitre 3).

Analyse (confiance moyenne). Un prestataire qui sert plusieurs banques refuse souvent d'être audité par chacune. La banque peut exiger, à la place, un rapport d'assurance de type 2 par an, établi par un auditeur indépendant, sur les contrôles

qui la concernent. La base NEK de R-DC-02 deviendrait alors une base OUI ou NON, sans que la banque entre chez le prestataire.

9.3.2 COBIT 2019

COBIT 2019, de l'ISACA, est un cadre de gouvernance et de gestion de l'informatique, qui compte quarante objectifs [27]. Il n'est pas spécifique à la sécurité : il la situe dans l'ensemble du pilotage du système d'information. Le cours GCI (MSN-2S3-MSI03) l'étudie en détail ; NRAC n'en retient que la distinction entre gouvernance et gestion (Chapitre 1).

9.4 Les Tables de Correspondance

9.4.1 Ce qu'est une correspondance

Définition

Table de correspondance : tableau qui relie les exigences d'un référentiel à celles d'un autre, en indiquant, pour chaque lien, s'il est complet ou partiel. Elle sert à réutiliser un travail fait pour un référentiel au profit d'un autre.

Papier de travail

Construire une correspondance fiable. Le papier de travail qui établit ou utilise une table de correspondance vérifie :

- la **source** de chaque lien : publication officielle (le NIST et le CIS publient des correspondances), travail interne, ou fournisseur ;
- la **nature** du lien : complet (les deux exigences ont le même contenu) ou partiel (l'une couvre une partie de l'autre) ;
- le **sens** du lien : satisfaire A peut suffire pour B sans que l'inverse soit vrai ;
- la **multiplicité** : une exigence peut correspondre à plusieurs autres, et réciproquement ;
- la **version** de chaque référentiel : une table ISO/IEC 27002:2013 ne vaut pas pour l'édition de 2022.

9.4.2 La base commune de l'ANPP

Le responsable de la sécurité de l'ANPP construit une **base commune de contrôles** : une liste de contrôles propres à l'agence, chacun relié aux référentiels qui l'exigent.

Réf.	Contrôle de l'ANPP	ISO/IEC 27002	CSF 2.0	CIS v8
B1	Inventaire des postes et serveurs	5.9	ID.AM	1
B2	Désactivation des comptes au départ	5.18	PR.AA	5
B3	Authentification multifacteur	8.5	PR.AA	6
B4	Journalisation et revue	8.15	DE.CM	8
B5	Sauvegardes testées	8.13	PR.DS, RC.RP	11
B6	Application des correctifs	8.8	ID.RA	7
B7	Sensibilisation des agents	6.3	PR.AT	14
B8	Sécurité des prestataires	5.19, 5.20	GV.SC	15
B9	Réponse aux incidents	5.24, 5.26	RS.MA	17
B10	Test d'intrusion annuel	(partiel)	ID.IM	18

Tableau 9.4. La base commune de l'ANPP (correspondances établies par le cours)

Trois remarques. B5 correspond à deux catégories du CSF : la sauvegarde protège les données et sert au rétablissement. B10 n'a pas de mesure dédiée dans l'ISO/IEC 27002 ; le test d'intrusion n'y apparaît que comme un moyen parmi d'autres, d'où la mention « partiel ». Enfin, la base ne couvre pas tout : plusieurs catégories du CSF (le contexte organisationnel, la politique, la communication) n'ont pas de contrôle dans cette première version.

9.4.3 Tester une fois, rendre compte trois fois

⚖ Lecture auditologique · La base commune de l'ANPP, évaluée en 2027

Constatation. L'équipe de l'ANPP, appuyée par un cabinet, teste une fois les dix contrôles :

- OUI : B1, B5, B9 (exercice de 2026), B10 (rapport de 2027) ;
- NON : B2 (quatre agents payés après leur départ, comptes encore actifs ; aucune procédure écrite), B3 (pas de second facteur), B7 (aucune sensibilisation depuis 2023) ;
- NEK : B4 (journaux « aux archives », non produits), B6 (aucun relevé des correctifs), B8 (contrats sans clause de sécurité, aucun rapport des prestataires).

4 OUI, 3 NON, 3 NEK :

$\mu = 0{,}40$; $U = 0{,}30$; $H = -(0{,}4 \log_2 0{,}4 + 2 \times 0{,}3 \log_2 0{,}3) \approx 0{,}529 + 0{,}521 + 0{,}521 \approx 1{,}57$ bit.

Projection sur le CSF (par fonction) : Gouverner 0/0/1 (B8) ; Identifier 2/0/1

(B1, B10 ; B6) ; Protéger 1/3/0 (B5 ; B2, B3, B7) ; Détecter 0/0/1 (B4) ; Répondre 1/0/0 (B9) ; Rétablir 1/0/0 (B5).

Analyse (confiance moyenne). La même série de tests donne trois lectures. Pour le bailleur, le profil actuel est faible en *Protéger* (des défauts établis) et inconnu en *Gouverner* et *Détecter* : le niveau de mise en œuvre est au mieux « partiel », et l'ANPP vise « reproductible ». Pour la Chambre des comptes, B2 rejoint le constat des quatre agents payés après leur départ : le défaut de désactivation est aussi un défaut de contrôle des paiements. Pour l'audit réglementaire, les mêmes preuves serviront, référentiel par référentiel.

$\mu = 0{,}40$ · $U = 0{,}30$ · $H = 1{,}57$ **bit**

★ Attention

Violation typique. Reporter une cote sur un référentiel par la seule table, alors que le lien est partiel.

Règle : un OUI ne se transporte que par un lien complet. Par un lien partiel, le OUI devient au mieux un NEK sur l'autre référentiel, jusqu'à ce que la partie non couverte soit testée.

9.5 Choisir ses Référentiels

On ne choisit pas un référentiel pour sa réputation, mais pour ce qu'il oblige ou permet.

Critère	Question à se poser
Obligation	La loi, le superviseur ou un contrat impose-t-il un référentiel (PCI DSS, exigence d'un bailleur, audit réglementaire) ?
Reconnaissance	Les clients ou partenaires attendent-ils une certification (ISO/IEC 27001) ou un rapport (SOC 2, ISAE 3402) ?
Taille et maturité	L'organisation peut-elle faire vivre un SMSI, ou doit-elle commencer par une hygiène de base (CIS IG1) ?
Langage	Faut-il parler à une direction et à un bailleur (CSF) ou à des techniciens (SP 800-53, guides de configuration) ?
Coût de la preuve	Combien coûte la démonstration de conformité, et peut-elle être mutualisée (base commune) ?

Tableau 9.5. Critères de choix d'un référentiel

Scénario Opérationnel · Trois organisations, trois choix

BANQUE SANAGA. ISO/IEC 27001 certifiée, sur toute la banque ; PCI DSS pour la monétique ; exigences du superviseur (Chapitre 10) ; rapports ISAE 3402 demandés aux prestataires.

LiZbiZ. CIS Controls IG1 d'abord, comme socle vérifiable ; ISO/IEC 27001 ensuite, si PHARMACAM l'exige au renouvellement suivant.

ANPP. Une base commune ISO/IEC 27002, projetée sur le CSF pour le bailleur et sur les textes pour la Chambre des comptes et l'audit réglementaire.

9.6 Ce que les Référentiels demandent à chaque Métier

Application Responsable GRC

Une base, plusieurs rapports

1. Recenser les référentiels imposés et attendus.
2. Construire une base commune de contrôles, chacun relié aux référentiels par des liens qualifiés (complet, partiel).
3. Tester chaque contrôle une fois, avec des preuves réutilisables.
4. Produire les rapports par projection, en signalant les liens partiels.

Application Auditeur en cybersécurité

Ne pas auditer la table

L'auditeur à qui l'on présente une table de correspondance vérifie sa source, sa version et la nature des liens. Il refuse de reporter une conformité par un lien partiel, et prélève des contrôles dans les zones que la base ne couvre pas.

Application Gestionnaire des risques cyber

Le référentiel ne remplace pas le risque

Un référentiel donne des mesures ; il ne dit pas lesquelles comptent le plus pour l'organisation. Le gestionnaire des risques vérifie que les contrôles de la base traitent les scénarios du registre, et pas seulement les cases des référentiels.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

➢ **NIST CSF 2.0** : six fonctions, 22 catégories ; un langage, des profils et des niveaux, pas d'exigences.

- **Catalogues** : NIST SP 800-53 (détaillé), CIS Controls (18 contrôles priorisés, groupe IG1 pour l'hygiène de base), PCI DSS (cartes de paiement, contractuel).
- **Rapports d'assurance** : ISAE 3402 et SOC 2 ; seul le type 2 dit si les contrôles ont fonctionné.
- **Une correspondance** relie des sujets, pas des contenus ; elle a une source, une nature, un sens et une version.
- **Une base commune** se teste une fois et se projette sur plusieurs référentiels ; un OUI ne se transporte que par un lien complet.

Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- placer une pratique dans une fonction du CSF ;
- dire ce qu'apporte un rapport de type 2 par rapport au type 1 ;
- construire une ligne de base commune avec trois référentiels ;
- refuser une conformité déduite d'un lien partiel.

Exercices

Exercice 9.1. Quelle fonction du CSF ? ★☆☆

Placez chaque pratique dans une fonction du NIST CSF 2.0, et, si possible, dans une catégorie.

(a) Le conseil fixe l'appétence au risque cyber.

(b) La DSI tient l'inventaire des postes des agences.

(c) Les agents suivent une formation à l'hameçonnage.

(d) Le collecteur de journaux déclenche une alerte sur une connexion inhabituelle.

(e) La cellule de crise décide d'isoler les agences touchées.

(f) Les agences rouvrent après restauration des postes.

(g) La banque exige un rapport de type 2 de DIGICORE.

Exercice 9.2. Correspondances partielles ★★☆

(a) Pour chacun des contrôles B2, B4 et B10 de l'ANPP, dites si le lien avec la mesure ISO/IEC 27002 indiquée est complet ou partiel, et pourquoi.

(b) Un consultant affirme que l'ANPP, étant « conforme à 60 % de l'ISO/IEC 27002 », est « au niveau 2 du CSF ». Relevez les deux erreurs de

raisonnement.

(c) B10 est OUI. Quelle cote reporter sur l'ISO/IEC 27002, et pourquoi ?

✍ Exercice 9.3. L'hygiène de base de LiZbiZ ★★☆

(a) Justifiez le choix du groupe IG1 des CIS Controls pour LiZbiZ, à l'aide des critères du Tableau 9.5.

(b) Reliez chacun des constats de l'audit des quatre centres (comptes par défaut, services en clair, flux non autorisés, sauvegardes non restaurées) à un contrôle CIS.

(c) PHARMACAM demande « une certification ». Que répondez-vous à M. ETEME : CIS, ISO/IEC 27001 ou rapport SOC 2 ? Justifiez.

✍ Exercice 9.4. Trois rapports pour l'ANPP ★★★

À partir des résultats de la base commune (4/3/3) :

(a) Calculez μ, U et H pour la fonction *Protéger* et pour la fonction *Identifier*, et appliquez la règle de décision du Chapitre 7.

(b) Rédigez, en dix lignes, la partie « profil actuel et profil cible » destinée au bailleur.

(c) Rédigez, en cinq lignes, la note destinée à M. NJOYA sur le contrôle B2, en reliant le défaut de sécurité au défaut de paiement.

(d) Proposez trois contrôles à ajouter à la base pour couvrir les catégories du CSF qu'elle ignore, avec leur correspondance ISO/IEC 27002.

Note

Pour aller plus loin.

- Le NIST CSF 2.0 [60] et ses références informatives.
- Les CIS Controls, version 8 [5].
- La norme ISAE 3402 [22] et les critères de services de confiance de l'AICPA [3].

Note

Transition. Les référentiels sont volontaires ou contractuels. La loi, elle, s'impose : quelles organisations doivent être auditées, par qui, avec quelles garanties pour l'auditeur et l'audité ? Le Chapitre 10 présente le cadre juridique camerounais et la déontologie de l'auditeur.

10

LE CADRE CAMEROUNAIS ET AFRICAIN, LA DÉONTOLOGIE

« L'auditeur constate un écart au critère.
Le juge, seul, qualifie l'infraction. »

Règle de prudence

Niveau : *Fondamental* • Maîtrise du Chapitre 6

✦ Objectifs du chapitre

- ➢ Distinguer, dans un texte juridique, ce qui est vérifié de ce qui reste à vérifier, et ne citer que le premier.
- ➢ Identifier les obligations d'audit et de sécurité de la loi n° 2010/012, et le rôle de l'ANTIC.
- ➢ Situer le règlement COBAC R-2016/04, la Convention de Malabo et la loi sur les données personnelles.
- ➢ Faire de la loi une source de critères d'audit.
- ➢ Appliquer les principes déontologiques de l'auditeur et reconnaître les menaces sur son indépendance.
- ➢ Rédiger un constat sans qualifier juridiquement les faits.

Avant de commencer : trois lettres

Trois lettres, la même semaine de 2028[1].

À Yaoundé, M. ESSOMBA reçoit de l'Agence nationale des technologies de l'information et de la communication (ANTIC) l'annonce d'un audit de sécurité de l'ANPP. Il se demande si son agence y est vraiment soumise, et ce qu'il doit remettre.

À Douala, M. ETEME écrit à AUDIX CONSEIL : la synthèse destinée à PHARMACAM « pourrait être formulée plus positivement », d'autant que le renouvellement du

[1] Les organisations, les personnes, les dates et les montants des cas sont fictifs ; les textes cités sont exacts, avec le degré de vérification indiqué.

© MaletYon

contrat de LiZbiZ, et donc la suite des missions d'AUDIX, en dépend.

À la BANQUE SANAGA enfin, la DSI propose au chef de mission de CERTIQUAL AFRIQUE, la veille de l'étape 2, un « petit-déjeuner de travail » dans un grand hôtel.

Ce chapitre présente les textes qui encadrent la sécurité et son audit au Cameroun et en Afrique, puis les règles de déontologie qui protègent l'auditeur et la valeur de son travail.

★ Attention

Règle du chapitre. Un texte de loi n'est cité entre guillemets que s'il a été lu dans sa version officielle. Les autres dispositions sont présentées sans citation, avec la mention « à vérifier ». Un auditeur applique la même règle dans ses rapports : une citation inexacte ruine la crédibilité de tout le reste.

10.1 Panorama des Textes

Texte	Assujettis	Ce qu'il impose	Vérification
Loi n° 2010/012 (cybersécurité et cybercriminalité)	Opérateurs, exploitants de SI, autorités de certification, organismes publics	Mesures de sécurité, gestion des risques, conservation des journaux, audit de sécurité	Texte officiel lu
Règlement COBAC R-2016/04	Établissements de crédit de la CEMAC	Système de contrôle interne, dont le risque opérationnel	Art. 1 et 2 relevés, à collationner
Convention de Malabo (Union africaine, 2014)	États parties	Cadres nationaux de cybersécurité et de protection des données	Statut camerounais à vérifier
Loi n° 2024/017 (données personnelles)	Responsables de traitement	Protection des données, y compris pendant l'audit	À vérifier au Journal officiel
Droit OHADA des sociétés	Sociétés commerciales	Commissaire aux comptes, comité d'audit	Présenté, à vérifier

Tableau 10.1. Les textes et leur degré de vérification dans ce cours

10.2 La Loi sur la Cybersécurité

10.2.1 L'audit de sécurité et l'ANTIC

Le Chapitre 6 a cité la définition légale de l'audit de sécurité (article 4, point 9) et le régime d'audit obligatoire et périodique (articles 13 et 32) [53]. La loi confie à l'ANTIC, désignée comme « l'Agence », une mission de contrôle de ces audits.

⚖ Jurisprudence & Droit applicable

Loi n° 2010/012, article 7, alinéa 2 (extrait) : l'Agence a notamment pour mission *« de s'assurer de la régularité, de l'effectivité des audits de sécurité des systèmes d'information suivant les normes en la matière, des organismes publics et des autorités de certification »*.

Portée. Deux points. La loi renvoie aux *normes* : un audit de sécurité légal se conduit selon les normes et référentiels des Chapitres 6 et 8. Et elle vise expressément les *organismes publics*, ce qui concerne l'ANPP.

10.2.2 L'ANPP est-elle soumise ?

🔍 Scénario Opérationnel · Opération ANPP. Lire le texte avant de conclure

Constatations.

- L'article 7, alinéa 2, charge l'Agence de s'assurer de la régularité des audits de sécurité des organismes publics.
- L'article 13, alinéa 1, soumet à l'audit obligatoire « les réseaux de communications électroniques et les systèmes d'information, des opérateurs, des autorités de certification et des fournisseurs de services de communications électroniques ».
- Les conditions et modalités sont renvoyées à des textes d'application.

Analyse (confiance faible sur la portée de l'article 13, élevée sur l'article 7). La ponctuation de l'article 13 admet deux lectures : soit tous les systèmes d'information sont visés, soit seulement ceux des opérateurs, autorités et fournisseurs. L'article 7 tranche en partie pour l'ANPP : ses audits de sécurité relèvent du contrôle de l'Agence en tant qu'organisme public. La réponse sûre à M. ESSOMBA est donc : l'audit annoncé s'inscrit dans la mission légale de l'ANTIC ; ses modalités se lisent dans les textes d'application en vigueur, que l'ANPP doit demander. Un auditeur ne tranche pas seul une ambiguïté de texte : il la signale.

10.2.3 Des obligations qui deviennent des critères

Plusieurs articles imposent aux exploitants des systèmes d'information des obligations qui deviennent, pour l'auditeur, des critères opposables. Le tableau les résume d'après le texte officiel ; seul l'article 29, alinéa 1, a été cité textuellement (Chapitre 3).

Art.	Obligation (résumé du texte officiel)	Critère d'audit
26 (1)	Prendre les mesures techniques et administratives de sécurité ; se doter de systèmes normalisés de gestion continue des risques	Un processus de gestion des risques existe et fonctionne
26 (2) et (3)	Mettre en place des mécanismes de sécurité (disponibilité, intégrité, authentification, non-répudiation, confidentialité, sécurité physique), approuvés et visés par l'Agence	Les mécanismes existent ; le visa de l'Agence est au dossier
29 (1)	Conserver les données de connexion et de trafic pendant dix ans	La politique de conservation couvre dix ans
29 (2)	Installer des mécanismes de surveillance du contrôle d'accès aux données	Les accès aux données sont journalisés et surveillés
30 (1)	Évaluer et réviser les systèmes de sécurité selon l'évolution des technologies	Une revue périodique est tracée

Tableau 10.2. Obligations de la loi n° 2010/012 et critères d'audit

⚖ Lecture auditologique · L'ANPP face à la loi

Constatation. À partir de la base commune du Chapitre 9, l'équipe de l'ANPP cote les cinq obligations :

- 26 (1) : NON : aucun registre des risques, aucune appréciation formalisée ;
- 26 (2) et (3) : NEK : des mécanismes existent, mais personne ne sait s'ils ont été soumis au visa de l'Agence ;
- 29 (1) : NEK : les journaux sont « aux archives », leur durée de conservation n'est pas connue ;
- 29 (2) : NON : les comptes des agents partis restent actifs, et aucune surveillance des accès n'est en place ;
- 30 (1) : NON : aucune revue de sécurité depuis 2023.

0 OUI, 3 NON, 2 NEK : $\mu = 0$; $U = 0{,}40$; $H = -(0{,}6\log_2 0{,}6 + 0{,}4\log_2 0{,}4) \approx 0{,}97$ bit.

Analyse (confiance moyenne). Non-conformité opaque : aucune obligation n'est démontrée. Les deux NEK se lèvent à peu de frais (une demande à l'ANTIC sur le visa, une extraction des archives de journaux) ; l'ANPP a intérêt à le faire *avant* l'audit, pour que l'Agence constate des écarts connus et traités plutôt qu'une ignorance.

$\mu = 0{,}00$ · $U = 0{,}40$ · $H = 0{,}97$ **bit**

10.2.4 Le secret, et l'obstruction

Jurisprudence & Droit applicable

Loi n° 2010/012, article 14 : *« Le personnel de l'Agence et les experts commis en vue d'accomplir des opérations d'audit sont astreints au secret professionnel. »*

Article 61, alinéa 1 : *« Sont punis d'un emprisonnement de trois (03) mois à trois (03) ans et d'une amende de 20.000 (vingt mille) à 100.000 (cent mille) F CFA, les personnels de l'Agence et les experts des personnes morales chargés des audits qui révèlent sans autorisation, des informations confidentielles dont ils ont eu connaissance à l'occasion d'un audit de sécurité. »*

Article 61, alinéa 3 (paraphrasé) : la loi punit aussi celui qui fait obstacle aux audits de sécurité ou refuse de fournir les informations ou documents qui s'y rapportent.

Portée. La loi protège l'audit dans les deux sens : elle punit l'auditeur qui divulgue, et l'audité qui fait obstruction. Dans un audit de sécurité légal, le refus du prestataire des GAB (Chapitre 6) ne serait pas seulement une limitation de l'étendue : ce serait un fait à consigner, que l'Agence apprécierait.

10.3 La Réglementation Bancaire

Les établissements de crédit de la CEMAC sont soumis au règlement COBAC R-2016/04 relatif au contrôle interne [8].

Jurisprudence & Droit applicable

Règlement COBAC R-2016/04, articles 1 et 2 (texte relevé sur une base réglementaire en ligne, à collationner avec la version du Secrétariat général de la COBAC) :

Article 1 : *« Le présent règlement fixe les exigences minimales relatives au système de contrôle interne que les établissements assujettis doivent mettre en œuvre. »*

Article 2, risque opérationnel : *« risque de pertes résultant de l'inadéquation ou de la défaillance des processus internes, des personnes et des systèmes, ou d'évènements externes. »*

Portée. Une attaque par rançongiciel est un risque opérationnel au sens du règlement : défaillance des systèmes et des personnes, provoquée par un événement externe. Le rapport demandé par la COBAC après l'incident de septembre 2026 relève donc du contrôle interne de la banque, et non d'une simple information technique.

Le règlement donne le cadre ; il ne dit pas comment évaluer une mesure de sécurité. Pour le rapport au superviseur, la banque s'appuie sur ses propres critères

(ISO/IEC 27002, plan de traitement) et sur les résultats de son audit interne. Les exigences précises du règlement sur les systèmes d'information, au-delà des deux articles relevés, sont à lire dans le texte collationné.

10.4 Le Cadre Africain et les Données Personnelles

10.4.1 La Convention de Malabo

La Convention de l'Union africaine sur la cybersécurité et la protection des données à caractère personnel a été adoptée à Malabo en 2014 [12]. Elle invite les États parties à se doter d'un cadre national de cybersécurité, d'une protection des données personnelles et d'une répression de la cybercriminalité. Elle est entrée en vigueur en 2023, après avoir réuni le nombre de ratifications requis. L'état de sa signature et de sa ratification par le Cameroun est *à vérifier* ; le cours ne tire donc d'elle aucune obligation directe pour les organisations camerounaises. Elle reste une référence pour lire la loi nationale et pour les coopérations régionales.

10.4.2 Les données personnelles pendant l'audit

La loi n° 2024/017 relative à la protection des données à caractère personnel est étudiée dans l'UE MSN-2S3-JUR01 ; son texte reste à vérifier au Journal officiel. Pour l'auditeur, une règle de prudence suffit : lorsqu'il extrait des données personnelles (fichiers du personnel, bénéficiaires de paiements, clients), il ne prélève que ce que le test exige, les protège pendant la mission, et les détruit au terme de la conservation du dossier. L'audit de protection des données lui-même relève de l'UE MSN-2S4-SEC02.

10.5 La Déontologie de l'Auditeur

10.5.1 Cinq principes

Les normes mondiales d'audit interne de l'IIA regroupent l'éthique de l'auditeur en cinq principes [70] ; les codes de l'ISACA et des organismes de certification en reprennent l'esprit.

Principe	En audit de cybersécurité
Intégrité	Ne rien affirmer que la preuve ne soutient pas ; ne rien retirer sous la pression
Objectivité	Juger sans conflit d'intérêts ni préjugé ; ne pas auditer son propre travail
Compétence	N'accepter que les missions que l'on sait conduire, ou se faire assister (auditeur technique)
Conscience professionnelle	Le soin qu'exigent les enjeux : tests suffisants, papiers de travail complets
Confidentialité	Protéger les failles constatées et les données consultées ; ne rien utiliser à des fins personnelles

Tableau 10.3. Les principes déontologiques (d'après les normes de l'IIA, 2024)

10.5.2 Les menaces sur l'indépendance

Le cadre conceptuel du code de déontologie de l'IESBA distingue cinq menaces qui peuvent compromettre l'objectivité d'un professionnel [24]. Les cas du cours en offrent une illustration chacun.

Menace	Exemple du cours	Sauvegarde
Intérêt personnel	AUDIX dépend du contrat de LiZbiZ avec PHARMACAM pour ses missions futures	Refuser toute modification non justifiée ; déclarer la dépendance ; revue par un associé
Autorévision	Animer l'étude EBIOS que l'on auditera ensuite (Chapitre 4)	Refuser l'une des deux missions
Représentation	Défendre l'audité devant son client ou son superviseur	Ne s'exprimer que sur les constats ; renvoyer à l'audité
Familiarité	Auditer pendant des années la même équipe, devenue proche	Rotation des chefs de mission
Intimidation	Une direction qui menace de retirer la mission si un constat est maintenu	Remonter au commanditaire ; maintenir le constat

Tableau 10.4. Les cinq menaces et leurs sauvegardes (d'après le code de l'IESBA)

Scénario Opérationnel · Trois lettres, trois réponses

À M. ETEME. M. BEYALA répond que la synthèse reprend les constats tels qu'ils ont survécu au contradictoire ; il peut en améliorer la clarté, mais non le sens. Il signale à son associé la dépendance de son cabinet envers ce contrat (intérêt personnel, intimidation).

À la DSI de la BANQUE SANAGA. Le chef de mission de CERTIQUAL AFRIQUE décline l'invitation, et les règles de son organisme l'y obligent : un avantage offert par l'audité, même modeste, crée une apparence de dépendance. Le refus figure au dossier.

À M. ESSOMBA. Les auditeurs de l'ANTIC sont astreints au secret (article 14) ; l'ANPP, de son côté, doit fournir les documents demandés (article 61, alinéa 3). La relation n'est ni hostile ni complaisante : elle est encadrée.

10.5.3 Constater n'est pas qualifier

★ Attention

Violation typique. Écrire dans un rapport « la DSI a dissimulé l'absence de journalisation » ou « l'ANPP viole la loi ».

Règle : l'auditeur constate un écart à un critère, preuve à l'appui : « pendant la période auditée, 7 agences sur 38 n'envoyaient pas de journaux au collecteur ; le rapport de la RSSI de février 2028 les déclarait raccordées ». L'intention (dissimuler) et la qualification juridique (violation, infraction) ne se constatent pas : la première relève d'une enquête, la seconde du juge ou de l'autorité compétente.

10.5.4 Une obligation de moyens

L'auditeur contractuel s'engage à conduire ses travaux selon les normes qu'il déclare dans sa lettre de mission. Il n'est pas garant de l'absence de faille : son engagement est, en règle générale, une obligation de moyens. Sa responsabilité peut être recherchée s'il n'a pas appliqué ces normes. D'où l'importance des papiers de travail (Chapitre 6), qui montrent ce qu'il a fait, et des NEK documentés, qui montrent ce qu'il n'a pas pu établir : ils le protègent autant qu'ils informent le commanditaire.

10.6 Ce que la Loi et la Déontologie demandent à chaque Métier

Application Auditeur en cybersécurité

Protéger la mission

1. Établir si la mission relève d'un régime légal, et en tirer les obligations de forme, de secret et de destinataire.
2. Ne citer que des textes lus dans leur version officielle.
3. Identifier, avant la mission, les menaces sur son indépendance, et les sauvegardes.
4. Constater sans qualifier ; maintenir les constats sous la pression, et consigner la pression.

Application RSSI

Préparer l'audit légal

Établir si l'organisation est assujettie, rassembler les pièces des articles 26, 29 et 30 (appréciation des risques, mécanismes et visa, conservation, revues), lever à l'avance les NEK qui peuvent l'être, et désigner l'interlocuteur des auditeurs : l'obstruction est une infraction.

Application Responsable GRC

Un registre des obligations

Chaque article qui crée une obligation devient une ligne d'un registre des obligations, reliée aux contrôles de la base commune (Chapitre 9) et à sa preuve. Le Chapitre 13 montre comment le tenir.

Application Consultant en mise en œuvre de SMSI

Conseiller sans auditer

Le consultant qui a construit le SMSI ne participe pas à son audit, ni à celui de l'organisme certificateur pour le compte de ce dernier. S'il est sollicité, il le refuse ou le déclare.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Ne citer que le vérifié** : chaque texte a son degré de vérification, et le rapport le dit.
- **La loi n° 2010/012** institue l'audit de sécurité, confie à l'ANTIC le contrôle des audits des organismes publics et des autorités de certification, et fournit des critères (articles 26, 29, 30).
- **Elle protège l'audit dans les deux sens** : secret de l'auditeur (articles 14 et 61), sanction de l'obstruction.
- **Le règlement COBAC R-2016/04** fait du risque informatique un risque opérationnel du contrôle interne.
- **La Convention de Malabo** encadre l'action des États ; son statut au Cameroun est à vérifier.
- **Cinq principes, cinq menaces** : intégrité, objectivité, compétence, conscience professionnelle, confidentialité ; intérêt personnel, autorévision, représentation, familiarité, intimidation.
- **Constater n'est pas qualifier.**

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- dire quel texte s'applique à une situation, et avec quel degré de certitude ;
- transformer un article de loi en critère d'audit ;
- nommer la menace sur l'indépendance dans une situation donnée, et la sauve-

garde ;

➢ récrire une phrase de rapport qui qualifie au lieu de constater.

Exercices

✍ Exercice 10.1. Quel texte ? ★☆☆

Pour chaque situation, indiquez le texte principal applicable et son degré de vérification dans le cours.

(a) La BANQUE SANAGA doit rendre compte au superviseur de l'incident de septembre 2026.

(b) Les journaux du pare-feu sont effacés au bout de trente jours.

(c) Un auditeur de l'ANTIC parle à un journaliste d'une faille de l'ANPP.

(d) Le prestataire des GAB refuse de remettre ses configurations lors d'un audit de sécurité légal.

(e) L'auditeur extrait le fichier du personnel de l'ANPP pour un rapprochement.

(f) Un étudiant affirme que la Convention de Malabo oblige LiZbiZ à notifier ses incidents.

✍ Exercice 10.2. Menaces sur l'indépendance ★★☆

Nommez la menace et proposez une sauvegarde.

(a) Mme EKAMBI audite le plan de traitement qu'elle a aidé à rédiger en 2026.

(b) Le même chef de mission de CERTIQUAL AFRIQUE audite la banque depuis six ans.

(c) Un cabinet d'audit propose à LiZbiZ, pendant sa mission, de vendre l'outil qui corrigerait les constats.

(d) Le directeur général d'une agence publique fait savoir au magistrat qu'il « en parlera au ministre » si un constat est maintenu.

(e) Un auditeur témoigne devant la COBAC en faveur de la banque qu'il a auditée.

✍ Exercice 10.3. Constater, pas qualifier ★★☆

Récrivez chacune des phrases suivantes sous la forme d'un constat, preuve à l'appui, sans qualification juridique ni jugement d'intention.

(a) « L'ANPP viole l'article 29 de la loi. »

(b) « Le responsable informatique de LiZbiZ a laissé des portes ouvertes aux fraudeurs. »

(c) « La banque a menti au certificateur dans sa déclaration d'applicabilité. »

(d) « Les quatre agents payés après leur départ ont détourné des fonds publics. »

✍ Exercice 10.4. Préparer l'audit de l'ANTIC ★★★

M. ESSOMBA vous confie la préparation de l'audit annoncé.

(a) Rédigez la note qui répond à sa question « sommes-nous soumis ? », en distinguant ce que le texte établit et ce qui reste à vérifier.

(b) Proposez, pour chacun des deux NEK du Tableau 10.2 appliqué à l'ANPP, l'action qui le lève avant l'audit, et recalculez μ, U et H si les deux deviennent NON. La situation est-elle meilleure ? Justifiez.

(c) Listez les pièces à remettre aux auditeurs, et les précautions à prendre pour les données personnelles qu'elles contiennent.

(d) Que doit faire l'ANPP si un prestataire refuse de communiquer un document demandé par l'Agence ?

● Note

Pour aller plus loin.

- La loi n° 2010/012 [53], dans son texte officiel, et ses textes d'application.
- Le règlement COBAC R-2016/04 [8], dans la version du Secrétariat général de la COBAC.
- La Convention de Malabo [12].
- Les normes mondiales d'audit interne [70] et le code de l'IESBA [24].

● Note

Transition. La Partie III a posé les normes, les référentiels et le droit. La Partie IV passe à la pratique : mettre en œuvre et auditer un SMSI sur toute la BANQUE SANAGA, auditer la technique, faire vivre la GRC. Elle s'ouvre avec le Chapitre 11.

partie IV

Pratique : SMSI, Audit Technique et GRC

© MaletYon

11

METTRE EN ŒUVRE ET AUDITER UN SMSI

> « Un système de management qui ne se mesure pas
> ne se gère pas ; qui ne s'audite pas ne se croit pas. »
>
> Principe du cours

Niveau : *Intermédiaire* • Maîtrise du Chapitre 8, du Chapitre 7

✦ Objectifs du chapitre

- ➢ Conduire la mise en œuvre d'un SMSI comme un projet, de la décision de la direction à l'audit de certification.
- ➢ Définir un périmètre défendable et en justifier les exclusions.
- ➢ Identifier les informations documentées qu'exige l'ISO/IEC 27001.
- ➢ Construire des indicateurs selon l'ISO/IEC 27004, et coter leur fiabilité.
- ➢ Conduire l'audit interne du SMSI et préparer la revue de direction.
- ➢ Qualifier une non-conformité majeure ou mineure, et en tirer les conséquences pour la certification.

Avant de commencer : « Majeure ou mineure ? »

Douala, 16 juin 2028, réunion de clôture de l'étape 2 de l'audit de renouvellement[1]. Le chef de mission de CERTIQUAL AFRIQUE lit ses constats. Au troisième, la RSSI se raidit : « La banque n'a pas apprécié le risque des automates de retrait de quatorze agences, alors que l'audit interne l'avait signalé en avril. Je qualifie cette non-conformité de *majeure*. »

Le directeur général demande ce que cela change. Tout : le certificat de 2025 expire dans dix jours, et l'organisme ne peut pas le renouveler tant que la non-conformité majeure n'est pas corrigée et sa correction vérifiée. Pendant ce temps, la banque n'aura plus de certificat.

[1] Comme dans tout le cours, la BANQUE SANAGA, CERTIQUAL AFRIQUE, les dates et les montants sont fictifs ; les normes citées sont exactes et paraphrasées.

© MaletYon

Ce chapitre ouvre la Partie IV, consacrée à la pratique. Il suit l'extension du SMSI de la BANQUE SANAGA à toute la banque, de la décision du conseil à l'audit de certification, et explique pourquoi un seul constat a suffi à interrompre la certification.

★ Attention

Violation typique. Traiter l'audit de certification comme un examen à préparer, en mettant à jour les documents dans les semaines qui précèdent, au lieu de faire fonctionner le système toute l'année.

Règle : l'organisme certificateur n'évalue pas des documents ; il évalue un système qui fonctionne, par ses traces. Une exigence qui n'a pas de trace sur la période n'est pas satisfaite, même si le document existe.

11.1 Mettre en Œuvre : un Projet, puis un Système

11.1.1 Les étapes

L'ISO/IEC 27001 décrit des exigences, pas un projet. Dans la pratique, la mise en œuvre d'un SMSI suit pourtant un ordre presque toujours le même, parce que chaque étape a besoin de la précédente.

N°	Étape	Article	BANQUE SANAGA
1	Décision de la direction, moyens	5	Conseil, octobre 2027
2	Contexte, parties intéressées, périmètre	4	Décembre 2026, revu en 2027
3	Politique et objectifs de sécurité	5.2, 6.2	Politique révisée novembre 2027
4	Appréciation et traitement des risques, déclaration d'applicabilité	6.1, 8.2, 8.3	Décembre 2026 à avril 2028
5	Compétences, sensibilisation, documentation	7	2027–2028
6	Exploitation des mesures	8.1	2027–2028
7	Surveillance, audit interne, revue de direction	9	Mars à mai 2028
8	Non-conformités et améliorations	10	Continu

Tableau 11.1. Les étapes de la mise en œuvre d'un SMSI

Une fois les étapes franchies, le projet devient un système : les étapes 4 à 8 se répètent chaque année, et à chaque changement important. C'est ce que l'organisme certificateur vient vérifier.

11.1.2 Un périmètre défendable

Le prologue a montré un périmètre de complaisance. L'ISO/IEC 27001 demande de fixer le périmètre en tenant compte des enjeux, des exigences des parties intéressées, et des interfaces et dépendances avec ce qui reste en dehors [40].

Scénario Opérationnel · Opération SANAGA. Le périmètre de 2028

Rédaction approuvée par le conseil. « Le système de management de la sécurité de l'information couvre les activités bancaires de la BANQUE SANAGA : siège, centre de données principal de Douala, site de secours de Bonabéri, et 38 agences, avec leurs postes, leurs réseaux, la messagerie et les accès des prestataires. L'activité monétique est exclue : elle relève d'un programme de conformité PCI DSS distinct ; ses interfaces avec le système central sont incluses. »

Analyse (confiance élevée). L'exclusion de la monétique est défendable pour trois raisons : elle est couverte par un autre dispositif, nommé ; les interfaces, par lesquelles une attaque passerait de l'une à l'autre, sont dans le périmètre ; et la décision est approuvée par l'instance qui répond des risques. C'est l'inverse de 2025, où les agences avaient été exclues sans dispositif de remplacement, sans maîtrise des interfaces et sans décision du conseil.

11.1.3 Les informations documentées

Papier de travail

Ce que la norme exige d'écrire. Le dossier du SMSI contient au moins les informations documentées que l'ISO/IEC 27001 exige expressément :

- le périmètre (4.3) et la politique de sécurité (5.2) ;
- le processus d'appréciation des risques (6.1.2) et ses résultats (8.2) ; le processus de traitement (6.1.3), la déclaration d'applicabilité et le plan de traitement, et ses résultats (8.3) ;
- les objectifs de sécurité (6.2) ;
- les preuves de compétence (7.2) ;
- les informations nécessaires à la maîtrise des processus (8.1) ;
- les résultats de la surveillance et de la mesure (9.1) ;
- le programme et les résultats des audits internes (9.2) ;
- les résultats des revues de direction (9.3) ;
- les non-conformités, les actions menées et leurs résultats (10.2).

Tout le reste est laissé au jugement de l'organisation (7.5) : écrire ce qui est nécessaire à l'efficacité, pas davantage.

11.2 Mesurer : les Indicateurs du SMSI

11.2.1 Deux familles de mesures

L'article 9.1 demande de déterminer ce qui doit être surveillé et mesuré, comment, quand, par qui, et comment les résultats sont analysés. L'ISO/IEC 27004 aide à construire ces mesures [35]. Elle distingue deux familles :

- les **mesures de mise en œuvre** : la mesure est-elle en place, et à quel degré ? (part des comptes avec second facteur) ;
- les **mesures d'efficacité** : la mesure produit-elle l'effet attendu ? (part des agents qui cliquent lors d'une campagne d'hameçonnage simulé).

Un tableau de bord fait seulement de mesures de mise en œuvre dit que l'on travaille ; il ne dit pas si l'on est protégé.

11.2.2 Les six indicateurs de la RSSI

Réf.	Indicateur	Famille	Source	Cible	Mai 2028
I1	Comptes avec second facteur	M. œ.	Extraction de l'annuaire	100 %	100 %
I2	Délai médian d'application des correctifs critiques	Eff.	Outil de déploiement	15 j	9 j
I3	Restaurations trimestrielles réussies	Eff.	Procès-verbaux	100 %	100 %
I4	Agences qui envoient des journaux	M. œ.	Collecteur, quotidien	100 %	100 %
I5	Agences ayant exercé le mode dégradé dans l'année	M. œ.	Déclarations des agences	100 %	79 %
I6	Agents qui cliquent lors d'une campagne simulée	Eff.	Plateforme de campagne	< 5 %	11 %

Tableau 11.2. Le tableau de bord du SMSI (M. œ. : mise en œuvre ; Eff. : efficacité)

11.2.3 Un indicateur vaut ce que vaut sa source

Lecture auditologique · La fiabilité du tableau de bord

Constatation. Mme EKAMBI cote la fiabilité de chaque indicateur, c'est-à-dire la capacité de sa source à mesurer ce que dit sa définition :

- OUI : I1, I3, I4, I6 (sources automatiques ou procès-verbaux signés) ;
- NON : I2 : l'outil de déploiement ne couvre que les serveurs ; les postes des agences, mis à jour à part, n'entrent pas dans le calcul, alors que la définition parle de « tous les systèmes » ;
- NEK : I5 : les agences déclarent leurs exercices, sans compte rendu ni chronométrage (cf. Kribi, Chapitre 7).

4 OUI, 1 NON, 1 NEK : $\mu \approx 0{,}67$; $U \approx 0{,}17$;

$$H = -\left(\tfrac{2}{3}\log_2\tfrac{2}{3} + 2 \times \tfrac{1}{6}\log_2\tfrac{1}{6}\right) \approx 0{,}390 + 0{,}862 \approx 1{,}25 \text{ bit.}$$

Analyse (confiance élevée). Les deux indicateurs les plus rassurants en apparence posent problème : I2 est bon parce qu'il mesure un sous-ensemble ; I5, à 79 %, repose sur des déclarations. Un indicateur dont la source est déclarative est un NEK, quelle que soit sa valeur. Le plus utile du tableau est I6, à 11 % : c'est une mauvaise nouvelle, mais une mesure fiable d'efficacité.

$\mu = 0{,}67$ · $U = 0{,}17$ · $H = 1{,}25$ **bit**

Note

La fiche d'un indicateur. Chaque indicateur se décrit par : l'objectif de sécurité qu'il sert ; sa définition et sa formule ; sa source et son mode de collecte ; sa fréquence ; sa cible et ses seuils d'alerte ; son responsable ; et la cote de fiabilité de sa source. C'est la fiche d'assertion (Chapitre 7) appliquée à une mesure.

11.3 Auditer le SMSI

11.3.1 Deux objets

L'audit interne exigé par l'article 9.2 porte sur deux objets : le *système de management* (les articles 4 à 10 : le périmètre est-il tenu, les risques appréciés, les objectifs suivis, les non-conformités traitées ?) et les *mesures* de la déclaration d'applicabilité. L'ISO/IEC 27007 donne les lignes directrices de cet audit [38]. La mission de mars 2028 sur les agences (Chapitre 6) portait sur des mesures ; il manquait l'audit du système lui-même.

Scénario Opérationnel · Opération SANAGA. L'audit interne du SMSI, mai 2028

Programme. L'audit interne examine, pour chaque article de 4 à 10, une ou deux exigences, avec la preuve de leur fonctionnement sur la période : approbation du périmètre (4.3), revue de la politique (5.2), appréciation des risques à jour (6.1.2, 8.2), suivi des objectifs (6.2), preuves de compétence (7.2), indicateurs (9.1), traitement des non-conformités de l'audit de mars (10.2).

Constat principal. L'appréciation des risques n'a pas été mise à jour après l'audit de mars : le risque R-AG-02 (compromission d'un GAB), signalé le 20 avril, n'a ni cote, ni propriétaire, ni décision. La RSSI l'attendait « pour la prochaine revue annuelle ».

Analyse (confiance élevée). Le défaut est de même nature qu'en 2025 : une partie du périmètre comporte un risque connu qui n'a pas été apprécié. Le rapport de l'audit interne le porte en tête, avec une échéance avant l'étape 2.

11.3.2 La revue de direction

L'article 9.3 fait de la revue de direction le moment où la direction regarde le SMSI dans son ensemble et décide. La norme en fixe les éléments d'entrée : l'état des actions décidées lors des revues précédentes ; les changements des enjeux et des attentes des parties intéressées ; les retours sur la performance (non-conformités et actions correctives, résultats de la surveillance, des audits, atteinte des objectifs) ; les retours des parties intéressées ; les résultats de l'appréciation des risques et l'état du plan de traitement ; les opportunités d'amélioration [40].

Note

La revue de direction de la BANQUE SANAGA. Elle se tient le 30 mai 2028, présidée par M. FOTSO. Le dossier comprend le tableau de bord (Tableau 11.2) et le rapport de l'audit de mars. Il ne comprend pas le rapport de l'audit interne du SMSI, remis le 2 juin. La revue décide des moyens pour le mode dégradé et la sensibilisation, mais ne dit rien de R-AG-02 : personne ne le lui a présenté.

11.4 L'Audit de Certification et ses Constats

11.4.1 Majeure, mineure

Définition

Non-conformité majeure : non-conformité qui affecte la capacité du système de management à atteindre les résultats escomptés ; par exemple une exigence qui n'est pas appliquée du tout, ou un défaut répété, ou un doute sérieux sur la maîtrise d'un risque [33].

Non-conformité mineure : non-conformité qui n'affecte pas cette capacité : un défaut ponctuel, isolé, dans un système qui fonctionne par ailleurs.

Piste de progrès : constat qui n'est pas une non-conformité, mais une occasion d'améliorer.

Les conséquences diffèrent. Une non-conformité *mineure* donne lieu à un plan d'actions que l'organisme accepte, et dont il vérifie l'effet au prochain audit. Une non-conformité *majeure* suspend la décision de certification : l'organisme attend la correction et la preuve de son efficacité, dans le délai fixé par ses règles, et peut organiser un audit complémentaire.

11.4.2 Les constats de CERTIQUAL AFRIQUE

N°	Constat	Exig.	Qualification
1	Le risque des GAB de 14 agences, connu depuis avril, n'a pas été apprécié ni traité	6.1.2, 8.2	**Majeure** : exigence non appliquée à une partie du périmètre, défaut déjà connu
2	Mode dégradé non exercé de façon vérifiable dans 8 agences sur 38	Annexe A, 5.30	Mineure : plan d'actions engagé
3	La revue de direction n'a pas examiné les résultats de l'audit interne	9.3	Mineure : revue tenue, élément d'entrée manquant
4	L'indicateur des correctifs ne couvre pas les postes des agences	9.1	Mineure
5	Exercice de réponse aux incidents non réalisé depuis 2026	Annexe A, 5.24	Piste de progrès : planifié pour juillet
6	La mesure 8.28 réintégrée n'a pas encore de procédure	Annexe A, 8.28	Piste de progrès

Tableau 11.3. Les constats de l'étape 2 (juin 2028)

Scénario Opérationnel · Opération SANAGA. Pourquoi « majeure »

Analyse (confiance élevée). Le constat 1 n'est pas grave par son objet seul (quatorze agences, un équipement) : il l'est parce qu'il montre que le *processus* d'appréciation des risques ne fonctionne pas comme la norme l'exige. Un risque connu a attendu deux mois sans décision, et ni l'audit interne, ni la revue de direction n'ont pu le faire remonter à temps. C'est exactement le mécanisme de 2025 : le système laisse une zone sans appréciation. Les constats 2 à 4, eux, sont des défauts dans un système qui, par ailleurs, les a détectés.

11.4.3 Ce qui suit

La banque apprécie R-AG-02 en juillet, obtient du prestataire des GAB un avenant de droit d'audit, et fait vérifier la correction par l'organisme. CERTIQUAL AFRIQUE accepte la correction le 25 août et renouvelle le certificat en septembre 2028. Entre la fin du certificat de 2025 et le nouveau, la banque est restée trois mois sans certificat : il a fallu l'expliquer à deux correspondants étrangers et à un client institutionnel.

Fiche de risque · R-AG-02 · Compromission d'un GAB (appréciée en juillet 2028)

Propriétaire : le directeur du réseau d'agences.
Vraisemblance : 3 (système sans correctifs, exposé dans les agences). Base : configurations obtenues grâce à l'avenant (OUI).

Impact : 3 (retraits frauduleux plafonnés par les encaisses ; indisponibilité). Base : OUI.
Criticité : 9, intolérable : remplacement du système des 14 GAB programmé avant la fin de 2028 ; en attendant, cloisonnement des GAB sur un réseau dédié et surveillance des retraits atypiques.

Note

La norme et la loi. L'article 30 de la loi n° 2010/012 demande aux exploitants d'évaluer et de réviser leurs systèmes de sécurité selon l'évolution des technologies (Chapitre 10) [53]. La revue de direction et l'audit interne du SMSI en sont la forme normalisée : leurs comptes rendus sont les pièces qu'un audit réglementaire demandera.

11.5 Ce que le SMSI demande à chaque Métier

Application Consultant en mise en œuvre de SMSI

Faire fonctionner, pas seulement documenter

1. Conduire la mise en œuvre dans l'ordre des étapes, en commençant par la décision de la direction et le périmètre.
2. Rédiger un périmètre qui nomme ses exclusions et inclut ses interfaces.
3. Mettre en place, dès le début, l'appréciation des risques en continu : un risque nouveau est apprécié quand il apparaît, pas à la revue annuelle.
4. Laisser au moins un cycle complet (audit interne, revue de direction, actions) avant l'audit de certification.

Application Auditeur en cybersécurité

Qualifier par le système, pas par l'objet
Une non-conformité est majeure quand elle révèle que le système ne fonctionne pas, pas quand son objet impressionne. L'auditeur justifie sa qualification par l'exigence concernée et par ce que le défaut dit du processus.

Application RSSI

Un indicateur fiable vaut mieux qu'un bon indicateur
La RSSI corrige I2 (inclure les postes), remplace la source de I5 par des comptes rendus chronométrés, et présente I6 à la direction sans l'enjoliver : 11 % de clics est un chiffre utile parce qu'il est vrai.

Application Responsable GRC

Relier les constats d'audit au registre

Tout constat d'audit qui révèle un risque nouveau entre dans le registre dans la semaine, avec un propriétaire et une échéance d'appréciation. Le défaut de la banque en 2028 tenait à un délai, pas à une ignorance.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Un SMSI** se met en œuvre comme un projet, puis vit comme un système dont les étapes se répètent.
- **Un périmètre défendable** nomme ses exclusions, inclut ses interfaces et est approuvé par l'instance qui répond des risques.
- **Les indicateurs** sont de mise en œuvre ou d'efficacité ; un indicateur vaut ce que vaut sa source.
- **L'audit interne** porte sur le système (articles 4 à 10) et sur les mesures ; la revue de direction décide à partir de ses résultats.
- **Majeure ou mineure** : la qualification dépend de ce que le défaut dit de la capacité du système, non de son objet.
- **Une majeure** suspend la certification : à la BANQUE SANAGA, trois mois sans certificat.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- rédiger un périmètre avec une exclusion défendable ;
- distinguer un indicateur de mise en œuvre d'un indicateur d'efficacité, et coter sa fiabilité ;
- composer l'ordre du jour d'une revue de direction ;
- qualifier un constat et justifier la qualification.

Exercices

✍ Exercice 11.1. Exigé ou non ? ★☆☆

Dites si chacun des documents suivants est une information documentée expressément exigée par l'ISO/IEC 27001, et citez l'article le cas échéant.

(a) La déclaration d'applicabilité.

(b) Une charte d'usage de la messagerie.

(c) Le compte rendu de la revue de direction.

(d) Les attestations de formation des administrateurs.

(e) Un schéma de l'architecture réseau.

(f) La liste des non-conformités et des actions menées.

✍ Exercice 11.2. Construire un indicateur ★★☆

(a) Classez en mise en œuvre ou efficacité : part des agences dont le partage est cloisonné ; nombre de tentatives d'accès entre agences bloquées par mois ; délai moyen de détection d'un incident ; part des contrats de prestataires comportant une clause de sécurité.

(b) Rédigez la fiche complète d'un indicateur d'efficacité pour la mesure 5.30 (mode dégradé), avec sa source et sa cote de fiabilité.

(c) Corrigez la définition ou la source de I2 pour qu'il devienne OUI.

✍ Exercice 11.3. Qualifier ★★☆

Qualifiez chacun des constats suivants (majeure, mineure, piste de progrès) et justifiez par ce qu'il dit du système.

(a) Aucun audit interne du SMSI n'a été conduit depuis la certification initiale.

(b) Sur 25 comptes de partants prélevés, un est resté actif huit jours au lieu de cinq ; les 24 autres sont conformes.

(c) La politique de sécurité n'a pas été revue depuis trois ans, alors que la procédure prévoit une revue annuelle ; elle reste pertinente.

(d) Les objectifs de sécurité de 2028 ne sont pas mesurables (« renforcer la sécurité »).

(e) Le tableau de bord pourrait comporter un indicateur sur les fournisseurs.

✍ Exercice 11.4. Le SMSI de LiZbiZ ★★★

LiZbiZ décide d'engager un SMSI en vue d'une certification fin 2029 (Chapitre 8, Exercice 8.4).

(a) Établissez le calendrier des huit étapes du Tableau 11.1, en laissant un cycle complet avant l'audit initial.

(b) Proposez quatre indicateurs (deux de mise en œuvre, deux d'efficacité) qui couvrent le scénario SO1, avec leur source.

(c) LiZbiZ n'a pas d'audit interne. Qui peut conduire l'audit interne du SMSI, et à quelles conditions d'indépendance (Chapitre 10) ?

(d) Rédigez l'ordre du jour de la première revue de direction, en couvrant tous les éléments d'entrée exigés.

Note

Pour aller plus loin.

- L'ISO/IEC 27001:2022 [40], articles 4.3, 9 et 10.
- L'ISO/IEC 27004:2016 [35], sur les mesures.
- L'ISO/IEC 27007:2020 [38], sur l'audit d'un SMSI.
- L'ISO/IEC 17021-1:2015 [33], sur les exigences applicables aux organismes de certification.

Note

Transition. L'audit d'un SMSI vérifie le système et ses mesures, souvent à partir de documents et d'extractions. Il faut parfois aller plus loin, jusqu'à la configuration des serveurs, la segmentation du réseau, les comptes et les vulnérabilités. C'est l'audit technique, objet du Chapitre 12.

12

L'AUDIT TECHNIQUE DE SÉCURITÉ

« La politique dit ce qui est permis.
La configuration dit ce qui est possible. »

Principe du cours

Niveau : *Intermédiaire* • Maîtrise du Chapitre 11

✦ Objectifs du chapitre

- ➢ Distinguer audit de configuration, scan de vulnérabilités et test d'intrusion, et encadrer juridiquement un test technique.
- ➢ Travailler sur des exports figés et en garantir l'intégrité et l'exhaustivité.
- ➢ Auditer une configuration au regard d'une référence (CIS Benchmarks, configuration interne).
- ➢ Auditer la segmentation par la comparaison des flux autorisés et observés.
- ➢ Auditer les comptes et la journalisation.
- ➢ Auditer la gestion des vulnérabilités et prioriser leur correction.
- ➢ Comparer deux passages d'audit par centre, sans moyenne trompeuse.

Avant de commencer : ce qui est écrit est-il configuré ?

Douala, octobre 2028. Deux ans plus tôt, AUDIX CONSEIL avait audité l'infrastructure des quatre centres de données de LiZbiZ[1] : la politique interdisait les protocoles d'administration en clair, imposait le changement des mots de passe par défaut et séparait les postes des serveurs ; deux centres sur quatre ne l'appliquaient pratiquement pas. Depuis, LiZbiZ a conduit le plan de traitement de son scénario de rançongiciel (Chapitre 3), et l'audit contractuel de PHARMACAM a encore relevé un filtrage défaillant entre centres (Chapitre 6).

M. ETEME demande un second passage. M. BEYALA accepte : auditer n'est pas conseiller, et son cabinet n'a pas conduit le plan. Mais il pose deux conditions : travailler

[1] LiZbiZ, AUDIX CONSEIL, PHARMACAM, les dates et les montants sont fictifs ; les référentiels et les textes cités sont exacts.

sur des exports figés des configurations, et obtenir une autorisation écrite avant tout test sur les réseaux.

Ce chapitre présente l'audit technique de sécurité : ce qu'il vérifie, ce qui le distingue d'un test d'intrusion, et comment il produit des preuves qui tiennent.

★ Attention

Violation typique. Conclure qu'un centre est « durci » parce que la politique de durcissement existe et que l'équipe déclare l'avoir appliquée.

Règle : seule la configuration réelle, extraite et figée, établit l'état d'un équipement. L'auditeur la compare à une référence écrite ; l'écart est le constat.

12.1 Trois Activités Techniques

Activité	Question	Méthode	Limite
Audit de configuration	Les équipements sont-ils configurés selon la référence ?	Lecture d'exports, comparaison	Ne dit pas ce qu'un attaquant ferait des écarts
Scan de vulnérabilités	Quelles faiblesses connues présentent les systèmes ?	Outil, de préférence authentifié	Faux positifs ; ne voit que le connu
Test d'intrusion	Un attaquant peut-il atteindre tel objectif ?	Exploitation contrôlée	Un chemin trouvé ne dit rien des autres

Tableau 12.1. Trois activités techniques

L'audit technique combine en général les deux premières ; il peut s'appuyer sur un test d'intrusion, conduit par d'autres (UE MSN-2S3-SEC03), comme preuve d'efficacité. Ce qui le distingue d'un test d'intrusion, c'est son objet : l'audit vérifie l'*ensemble* des critères d'un périmètre et conclut sur leur conformité ; le test d'intrusion cherche *un* chemin vers un objectif et conclut sur son existence.

12.1.1 Le droit de tester

⚖ Jurisprudence & Droit applicable

Loi n° 2010/012, article 69 [53] : *« Est puni d'un emprisonnement de cinq (05) à dix (10) ans et d'une amende de 10.000.000 (dix millions) à 100.000.000 (cent millions) F CFA ou de l'une de ces deux peines seulement, celui qui accède sans droit, et en violation des mesures de sécurité, à l'ensemble ou à une partie d'un réseau de communications électroniques, d'un système d'information ou d'un équipement*

terminal, afin d'obtenir des informations ou des données, en relation avec un système d'information connecté à un autre système d'information. »

Article 70 (résumé) : est puni celui qui provoque, par saturation, l'attaque d'une ressource de réseau ou d'un système d'information, dans le but d'empêcher la réalisation des services attendus.

Portée. L'autorisation écrite du responsable du système donne à l'auditeur le droit d'accéder : sans elle, un scan ou une tentative de connexion peut tomber sous l'article 69. Les tests de charge et de déni de service, qui pourraient produire l'effet visé par l'article 70, sont exclus, sauf autorisation expresse et environnement dédié. Pour le centre de Garoua, hébergé par un prestataire local, l'accord écrit de l'hébergeur s'ajoute à celui de LiZbiZ.

Papier de travail

La note d'autorisation d'un test technique. Elle précise : le signataire habilité (et l'hébergeur, pour un système hébergé) ; le périmètre (adresses, systèmes inclus et exclus) ; les méthodes permises et interdites ; les fenêtres de test ; un contact joignable et une procédure d'arrêt immédiat ; la confidentialité, la conservation et la destruction des résultats (articles 14 et 61, Chapitre 10).

12.2 Travailler sur des Exports Figés

12.2.1 Pourquoi figer

L'auditeur ne travaille pas sur les équipements en production : il travaille sur des **exports figés**, c'est-à-dire des copies des configurations, des listes de comptes et des règles de filtrage, extraites à une date donnée, sous ses yeux ou selon une procédure écrite, et scellées par une empreinte.

- **Sécurité** : l'audit ne risque pas de perturber la production.
- **Reproductibilité** : un autre auditeur peut refaire l'analyse sur les mêmes fichiers et vérifier les constats.
- **Opposabilité** : l'empreinte établit que le fichier analysé est celui qui a été extrait, à la date dite.

Papier de travail

Le dossier d'exports. Pour chaque export, le papier de travail indique : l'équipement (nom, adresse, rôle, centre) ; la commande ou la fonction d'export employée ; la date et l'heure ; la personne qui a extrait et le témoin ; l'empreinte cryptographique (par exemple SHA-256) calculée au moment de la remise ; le lieu de conservation. L'auditeur recalcule l'empreinte avant chaque analyse.

12.2.2 L'exhaustivité

Un export figé est fiable sur ce qu'il contient ; il ne dit rien de ce qui manque. L'auditeur rapproche donc la liste des exports de l'inventaire des équipements. Un équipement présent dans l'inventaire et absent des exports est un NEK ; un équipement présent dans les exports et absent de l'inventaire est un constat sur l'inventaire.

Scénario Opérationnel · Opération LIZBIZ. La remise du 2 octobre 2028

Faits. La DSI remet 61 exports (pare-feu, commutateurs, serveurs, annuaire), avec leurs empreintes SHA-256. L'inventaire compte 64 équipements. Les trois manquants sont les serveurs de Garoua gérés par l'hébergeur, qui n'a pas encore fourni ses exports, et un commutateur de Bafoussam « en panne ».

Analyse (confiance élevée). Les constats sur 61 équipements peuvent être établis ; pour les trois autres, l'audit cotera NEK et le dira. Le commutateur « en panne » mérite une vérification sur place : un équipement que l'on ne peut pas exporter mais qui reste branché est un équipement que personne ne surveille.

12.3 Auditer la Configuration

12.3.1 Une référence écrite

Auditer une configuration, c'est la comparer à une référence. Deux sources sont courantes :

- les **CIS Benchmarks**, guides de configuration élaborés par consensus pour des centaines de produits (systèmes d'exploitation, équipements réseau, bases de données), avec deux profils : le niveau 1, applicable presque partout, et le niveau 2, plus strict [6] ;
- la **configuration de référence interne**, qui adapte ces guides au contexte et que la politique de l'organisation rend obligatoire.

La seconde est le critère opposable ; la première sert à la construire, et à juger si elle est suffisante.

12.3.2 Lire un export

Ligne de l'export (simplifiée)	Référence	Sous-domaine	Cote
`line vty 0 4 / transport input telnet ssh`	Administration en SSH seulement	IN.3	NON
`snmp-server community public RO`	Aucune communauté par défaut	IN.2	NON
`username admin secret 9 $9$...`	Compte nominatif, mot de passe haché	IN.2	OUI
`logging host 10.20.0.15`	Journaux vers le collecteur central	IN.5	OUI
`ntp server 10.20.0.1`	Horloge synchronisée	IN.5	OUI

Tableau 12.2. Extrait de l'export d'un commutateur de Bafoussam

Deux lignes suffisent à établir deux non-conformités : Telnet reste accepté pour l'administration, et une communauté SNMP par défaut permet de lire la configuration à quiconque atteint l'équipement. La synchronisation de l'horloge, souvent négligée, est une condition de la journalisation : des journaux mal datés ne permettent pas de reconstituer un incident.

12.4 Auditer la Segmentation

La segmentation se vérifie en comparant deux matrices : celle des flux que la politique autorise entre zones, et celle des flux que les règles des pare-feu laissent réellement passer. L'écart est le constat.

De \ vers	DMZ	Applicatif	Utilisateurs	Autres centres
Internet	443	–	–	–
DMZ	–	8443	–	–
Utilisateurs	443	8443	–	–
Administration	22	22	22	22
Applicatif	–	–	–	1433 (réplication)
Maintenance éditeur	–	**toutes (observé)**	–	**toutes (observé)**

Tableau 12.3. Matrice de flux du centre de Garoua : ports autorisés, et en gras les flux observés non autorisés

Scénario Opérationnel · Opération LIZBIZ. Une règle de trop

Constatation. L'export du pare-feu de Garoua contient une règle qui autorise tout trafic depuis l'adresse de maintenance de l'éditeur vers toutes les zones du centre et vers les autres centres. Elle a été créée en 2027, « temporairement », lors d'une mise à jour de l'application.

Analyse (confiance élevée). La règle annule la segmentation pour l'accès qui sert de point d'entrée au scénario SO1 (Chapitre 4) : un attaquant qui compromettrait l'accès de maintenance atteindrait d'emblée les quatre centres. C'est la cause du NON relevé par PHARMACAM sur le filtrage entre centres. Une règle « temporaire » sans date d'expiration est une règle permanente.

12.5 Auditer les Comptes et la Journalisation

12.5.1 Les comptes

L'audit des comptes rapproche trois listes : les comptes présents dans les exports (annuaire, équipements, bases de données), les personnes et les services autorisés, et les dernières connexions. Il recherche quatre catégories :

- les **comptes par défaut** encore actifs (IN.2) ;
- les **comptes orphelins**, sans titulaire (départs) ;
- les **comptes dormants**, sans connexion depuis longtemps ;
- les **comptes partagés** ou génériques, qui empêchent d'imputer une action.

Les comptes de service, utilisés par les applications, méritent une attention particulière : ils ont souvent des droits étendus, des mots de passe qui ne changent jamais, et personne n'en est propriétaire.

12.5.2 La journalisation

Pour la journalisation (IN.5), l'auditeur vérifie quatre choses : que chaque équipement envoie ses journaux au collecteur (rapprochement avec l'inventaire) ; que les horloges sont synchronisées ; que la durée de conservation respecte la politique et la loi (article 29, Chapitre 10) ; et que quelqu'un lit ou exploite les journaux, par des alertes ou une revue. Des journaux collectés et jamais lus ne détectent rien.

12.6 Auditer la Gestion des Vulnérabilités

12.6.1 Le processus avant le scan

L'auditeur n'audite pas seulement le résultat d'un scan ; il audite le processus de gestion des vulnérabilités (ISO/IEC 27002, mesure 8.8) : les sources de veille, la fréquence des scans, le délai de correction fixé par la politique selon la gravité, et le suivi des exceptions. Un scan *authentifié*, qui se connecte aux systèmes avec un compte de lecture,

voit les versions réellement installées ; un scan non authentifié devine à partir des services exposés, avec plus de faux positifs.

12.6.2 Prioriser

Le système de cotation CVSS, dans sa version 4.0, attribue à chaque vulnérabilité un score de gravité de 0 à 10 [16]. Le score seul ne suffit pas à prioriser : il décrit la vulnérabilité, pas l'organisation. Trois questions s'ajoutent : la vulnérabilité est-elle exploitée activement (l'agence américaine CISA publie un catalogue des vulnérabilités exploitées connues) ? Le système est-il exposé (Internet, accès de maintenance) ? Que porte-t-il (valeur métier, Chapitre 2) ?

Réf.	Système	CVSS	Exploitée ?	Exposition
V1	Serveur de maintenance à distance (Garoua)	8,1	Oui	Accès de l'éditeur
V2	Base de données de l'application (Douala)	9,0	Non	Interne, zone applicative
V3	Portail de suivi des transporteurs	7,5	Oui	Internet
V4	Imprimantes des agences	9,8	Non	Réseau des agences
V5	Serveur de fichiers de Yaoundé	6,5	Oui	Interne
V6	Commutateurs de Bafoussam (Telnet)	7,0	Non	Réseau d'administration

Tableau 12.4. Six vulnérabilités relevées (scores et indications d'exploitation fictifs)

Trié par score CVSS, le tableau place V4 (des imprimantes) en tête. Trié par risque, il place V1 et V3 en tête : exploitées activement, exposées, et sur le chemin du scénario SO1 pour V1. V4 vient bien plus loin : une imprimante d'agence n'est pas une valeur métier, et elle n'est pas exposée à Internet.

12.7 Deux Passages, Quatre Centres

Lecture auditologique · L'infrastructure de LiZbiZ, 2026 et 2028

Centre	IN.1	IN.2	IN.3	IN.4	IN.5	2028	2026
Douala	OUI	OUI	OUI	OUI	OUI	5/0/0	4/1/0
Yaoundé	OUI	OUI	OUI	NON	OUI	4/1/0	4/1/0
Garoua	NON	OUI	OUI	NEK	OUI	3/1/1	0/4/1
Bafoussam	NON	OUI	NON	OUI	NEK	2/2/1	0/3/2
Ensemble						**14/4/2**	**8/9/3**

Constatation. En 2028 : $\mu = 0{,}70$; $U = 0{,}10$;

$$H = -(0{,}7\log_2 0{,}7 + 0{,}2\log_2 0{,}2 + 0{,}1\log_2 0{,}1) \approx 0{,}360 + 0{,}464 + 0{,}332 \approx 1{,}16 \text{ bit.}$$

En 2026 : $\mu = 0{,}40$; $U = 0{,}15$; $H \approx 1{,}46$ bit.

Analyse (confiance élevée). L'ensemble passe de la non-conformité claire à la conformité claire, et l'incertitude baisse. Mais la moyenne cache deux choses : Yaoundé régresse sur les correctifs (deux correctifs critiques en retard), et Garoua comme Bafoussam gardent un défaut de segmentation, le même que celui qui ouvre le scénario SO1. Les NEK viennent des exports manquants (hébergeur de Garoua, commutateur de Bafoussam). Le rapport conclut centre par centre, et place la règle de maintenance de Garoua en tête des recommandations.

$\mu = 0{,}70$ · $U = 0{,}10$ · $H = 1{,}16$ **bit**

Fiche de risque · SO1 · Rançongiciel par l'accès de maintenance (octobre 2028)

Phase « rentrer » : second facteur de l'éditeur prouvé (avenant signé en 2028) ; mais V1, vulnérabilité exploitée, sur le serveur de maintenance de Garoua.
Phase « trouver » : la règle « tout vers tout » depuis l'adresse de maintenance annule la segmentation ; Telnet persiste sur deux commutateurs de Bafoussam.
Phase « exploiter » : sauvegardes hors ligne restaurées (Chapitre 6).
Cotation : vraisemblance V3 maintenue, tant que V1 et la règle de Garoua ne sont pas corrigées ; gravité ramenée de G4 à G3 par la récupération prouvée ; criticité $3 \times 3 = 9$, toujours intolérable.
Priorité : corriger V1 et supprimer la règle de maintenance de Garoua sous huit jours, puis vérifier par un nouvel export.

12.8 Ce que l'Audit Technique demande à chaque Métier

Application Auditeur en cybersécurité

Lire un export

1. Vérifier l'empreinte, la date et l'équipement de chaque export.
2. Rapprocher les exports de l'inventaire, et coter NEK ce qui manque.
3. Comparer chaque configuration à la référence écrite, ligne par ligne.
4. Comparer les flux observés aux flux autorisés.
5. Prioriser les vulnérabilités par le risque, pas par le seul score.
6. Conclure par centre, avant toute agrégation.

Application RSSI

Préparer l'audit technique

Fournir la matrice des flux autorisés et la configuration de référence ; faire signer l'autorisation, avec l'accord des hébergeurs ; prévenir les équipes de surveillance ; produire les exports avec leur empreinte ; supprimer les règles « temporaires » à leur échéance.

Application Gestionnaire des risques cyber

Relier les constats aux scénarios

Chaque constat technique se rattache à une phase d'un scénario. La règle de Garoua n'est pas un défaut de configuration parmi d'autres : elle annule la phase « trouver » de SO1. C'est ce rattachement qui fixe la priorité.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Audit de configuration, scan, test d'intrusion** : trois activités, trois questions ; l'audit conclut sur un ensemble de critères.
- **Le droit de tester** vient d'une autorisation écrite ; sans elle, l'article 69 de la loi n° 2010/012 menace l'auditeur.
- **Les exports figés** rendent l'audit sûr, reproductible et opposable ; leur exhaustivité se vérifie contre l'inventaire.
- **Une configuration** se compare à une référence écrite ; une segmentation, à la matrice des flux autorisés.
- **Les vulnérabilités** se priorisent par l'exploitation, l'exposition et la valeur métier, pas par le seul score CVSS.
- **Quatre centres** : on conclut centre par centre ; la moyenne de LiZbiZ progresse, mais le défaut qui ouvre SO1 demeure.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- dire ce qui distingue un audit technique d'un test d'intrusion ;
- constituer un dossier d'exports figés ;
- lire une ligne d'export et la coter au regard d'une référence ;
- prioriser des vulnérabilités en justifiant l'ordre.

Exercices

✍ Exercice 12.1. Quelle activité, quelle autorisation ? ★☆☆

Pour chacune des demandes suivantes, dites s'il s'agit d'un audit de configuration, d'un scan de vulnérabilités ou d'un test d'intrusion, et qui doit signer l'autorisation.

(a) Vérifier que les pare-feu des quatre centres appliquent la matrice de flux.

(b) Savoir si un attaquant parti du portail des transporteurs peut atteindre la base de facturation.

(c) Recenser les versions vulnérables des serveurs de Garoua, hébergés par un prestataire.

(d) Vérifier qu'aucun commutateur n'accepte Telnet.

(e) Mesurer la résistance du portail à un afflux massif de requêtes.

✍ Exercice 12.2. Lire un export ★★☆

L'export d'un serveur Linux de Yaoundé contient, entre autres, les lignes suivantes (simplifiées) : `PermitRootLogin yes` ; `PasswordAuthentication yes` ; `Protocol 2` ; un compte `backup` sans connexion depuis 400 jours ; aucune ligne d'envoi des journaux vers le collecteur.

(a) Pour chaque élément, donnez le sous-domaine (IN.1 à IN.5), la référence attendue et la cote.

(b) Lequel de ces écarts touche directement la phase « rentrer » du scénario SO1 ?

(c) La DSI affirme que le serveur a été corrigé la veille. Que faites-vous ?

✍ Exercice 12.3. Comparer les flux ★★☆

La politique de la BANQUE SANAGA n'autorise, depuis le réseau des agences vers le centre de données, que le port 8443 (application de guichet) et le port 53 (résolution de noms) vers deux serveurs désignés. L'export du pare-feu montre en outre : le port 445 vers le serveur de fichiers du siège ; le port 3389 vers tous les serveurs ; le port 8443 vers l'application de guichet.

(a) Construisez la matrice et relevez les flux non autorisés.

(b) Pour chacun, décrivez le risque en vous appuyant sur le scénario R-AG-01.

(c) Proposez la recommandation et la preuve de sa mise en œuvre.

✍ Exercice 12.4. Prioriser six vulnérabilités ★★★

(a) Classez V1 à V6 (Tableau 12.4) par ordre de priorité de correction, et justifiez chaque rang par l'exploitation, l'exposition et la valeur métier.

(b) La politique de LiZbiZ fixe un délai de correction de 15 jours pour un score supérieur à 9, et de 30 jours au-delà de 7. Montrez qu'elle conduit à un mauvais ordre, et proposez une règle meilleure.

(c) Le second passage cote IN.4 NON à Yaoundé. Rédigez l'observation en sept éléments (Chapitre 7).

(d) Calculez μ, U et H de Garoua et de Bafoussam en 2028, et dites ce que la décomposition par centre apporte par rapport à l'ensemble.

● Note

Pour aller plus loin.

➢ Les CIS Benchmarks [6], pour les références de configuration.

➢ La spécification CVSS 4.0 [16].

➢ Le NIST SP 800-53A [47], pour les méthodes d'évaluation.

● Note

Transition. Les audits produisent des constats ; la gestion des risques produit des scénarios ; la conformité produit des obligations. Il reste à les faire vivre ensemble, au quotidien, dans un dispositif unique. C'est la GRC en pratique, objet du Chapitre 13.

13

LA GRC EN PRATIQUE

« Quatre rapports qui ne se parlent pas
valent moins qu'un tableau qui les relie. »

Principe du cours

Niveau : *Intermédiaire* • Maîtrise du Chapitre 11

✦ Objectifs du chapitre

- ➢ Relier risques, obligations, contrôles et preuves dans un dispositif unique.
- ➢ Tenir un registre des risques et un registre des obligations.
- ➢ Construire une matrice risques-contrôles, et y repérer les risques sans contrôle et les contrôles sans risque.
- ➢ Distinguer indicateurs de risque et indicateurs de performance, et fixer des seuils.
- ➢ Concevoir le tableau de bord GRC d'une instance de gouvernance, y compris ce que l'on ignore.
- ➢ Organiser le contrôle continu de la conformité, et en connaître les limites.

Avant de commencer : quatre rapports

Douala, janvier 2029. Le comité des risques du conseil de la BANQUE SANAGA[1] reçoit, pour la même séance, quatre documents : le tableau de bord de la RSSI, le rapport annuel de l'audit interne, le rapport de CERTIQUAL AFRIQUE et une lettre de la COBAC. Chacun est juste, et aucun ne parle la langue des autres. Le tableau de bord dit « 100 % des comptes avec second facteur » ; l'audit interne, « trois non-conformités sur les agences » ; CERTIQUAL, « une majeure levée » ; la COBAC demande « l'état des mesures prises depuis l'incident de 2026 ».

Le président du comité pose une seule question : « Où en sommes-nous ? » M. ATANGANA, responsable GRC nommé en octobre 2028 et rattaché au directeur des risques,

[1] Comme dans tout le cours, la BANQUE SANAGA, ses dirigeants, ses prestataires, les dates et les montants sont fictifs ; les textes cités sont exacts.

© MaletYon

a trois mois pour qu'une page y réponde.

Ce chapitre montre comment faire vivre la gouvernance, le risque et la conformité dans un seul dispositif : des registres reliés, une matrice, des indicateurs, un tableau de bord, et des contrôles qui se vérifient seuls.

★ Attention

Violation typique. Présenter à la gouvernance des rapports juxtaposés (sécurité, audit, conformité, certification), chacun avec ses références et ses échelles.

Règle : un même référentiel relie risques, obligations, contrôles et preuves. Chaque rapport est une vue de ce référentiel, et le tableau de bord de la gouvernance les réunit.

13.1 Un Dispositif Unique

Le Chapitre 1 a défini la GRC comme un seul dispositif, avec un référentiel commun. En pratique, ce référentiel tient en quatre objets et leurs liens.

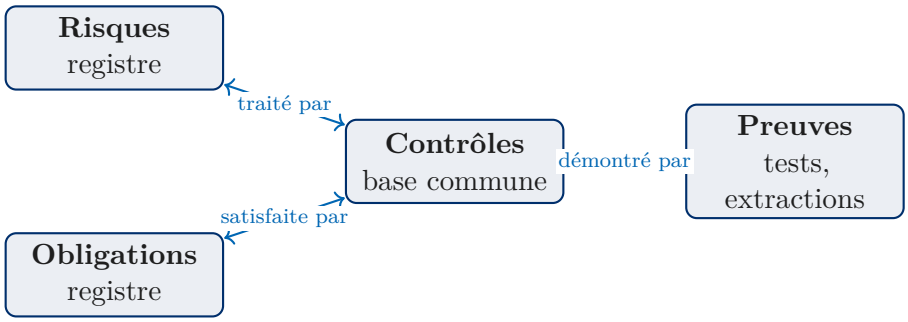


Figure 13.1: Le référentiel commun de la GRC

Chaque objet a son propriétaire : le risque, un directeur métier ; l'obligation, la fonction conformité ou juridique ; le contrôle, son exploitant ; la preuve, celui qui l'a produite et celui qui l'a évaluée. Les liens sont le travail propre du responsable GRC : c'est par eux qu'un constat d'audit change la cote d'un risque, ou qu'une nouvelle loi crée un contrôle.

13.2 Les Deux Registres

13.2.1 Le registre des risques

Le registre des risques reprend, pour chaque risque, les rubriques des chapitres précédents : scénario, propriétaire, cotes inhérente et résiduelle avec leur base de preuve (Chapitre 2), décision de traitement ou d'acceptation (Chapitre 3), date de revue.

Réf.	Risque	Propriétaire	Rés.	Décision, revue
R-AG-01	Rançongiciel en agence	Dir. réseau d'agences	6	Traité ; revue juin 2029
R-AG-02	Compromission d'un GAB	Dir. réseau d'agences	9	Remplacement en cours ; revue mars 2029
R-DC-02	Défaillance de DIGICORE	Dir. des opérations	6 (NEK)	Accepté en l'état des connaissances ; rapport attendu
R-DC-03	Intrusion par Internet	DSI	8	Traité ; revue juin 2029
R-DC-06	Déni de service des services en ligne	Dir. canaux numériques	9	Protection contractualisée ; test en mars

Tableau 13.1. Extrait du registre des risques (janvier 2029)

13.2.2 Le registre des obligations

Définition

Registre des obligations : liste des exigences qui s'imposent à l'organisation (lois, règlements, contrats, normes auxquelles elle s'engage), avec, pour chacune, sa source, son contenu résumé, les contrôles qui la satisfont, la preuve et son statut.

Réf.	Source	Exigence (résumée)	Statut
O1	Loi n° 2010/012, art. 26 (1)	Gestion continue des risques	OUI
O2	Loi n° 2010/012, art. 26 (2)–(3)	Mécanismes de sécurité visés par l'Agence	NEK
O3	Loi n° 2010/012, art. 29 (1)	Conservation dix ans des données de connexion	NON
O4	Loi n° 2010/012, art. 29 (2)	Surveillance des accès aux données	OUI
O5	Loi n° 2010/012, art. 30 (1)	Revue périodique des systèmes de sécurité	OUI
O6	Règlement COBAC R-2016/04	Contrôle interne couvrant le risque opérationnel	OUI
O7	PCI DSS (monétique)	Évaluation annuelle de conformité	NEK
O8	ISO/IEC 27001 (certificat)	Maintien du SMSI certifié	OUI
O9	Contrat DIGICORE	Rapport d'assurance annuel de type 2	NON
O10	Avenant du prestataire des GAB	Droit d'audit de la banque	OUI
O11	Loi n° 2024/017 (à vérifier)	Obligations sur les données personnelles	NEK
O12	Contrats des correspondants bancaires	Questionnaire de sécurité annuel	OUI

Tableau 13.2. Le registre des obligations (janvier 2029)

⚖ Lecture auditologique · L'état des obligations

Constatation. 7 OUI, 2 NON, 3 NEK sur 12 :

$$\mu \approx 0{,}58\,; \quad U = 0{,}25\,; \quad H = -\left(\tfrac{7}{12}\log_2\tfrac{7}{12} + \tfrac{2}{12}\log_2\tfrac{2}{12} + \tfrac{3}{12}\log_2\tfrac{3}{12}\right) \approx 0{,}454{+}0{,}431{+}0{,}500 \approx 1{,}38 \text{ bit.}$$

Analyse (confiance élevée). Conformité opaque : la banque satisfait la majorité de ses obligations, mais un quart d'entre elles est dans l'inconnu. Les trois NEK n'ont pas la même cause : O2 est une pièce à retrouver ; O7 attend le rapport de l'évaluateur de la monétique ; O11 dépend d'un texte que la banque n'a pas encore analysé. Les deux NON sont connus et datés : O3 tient à la capacité de stockage (deux ans au lieu de dix), O9 au retard de DIGICORE, qui n'a pas remis son rapport à l'échéance de décembre 2028.

$\mu = 0{,}58$ · $U = 0{,}25$ · $H = 1{,}38$ **bit**

13.3 La Matrice Risques-Contrôles

13.3.1 Croiser

Définition

Matrice risques-contrôles : tableau qui croise les contrôles de la base commune et les risques du registre, en indiquant quel contrôle traite quel risque, et avec la dernière cote de chaque contrôle.

Réf.	Contrôle	AG-01	AG-02	DC-02	DC-03	DC-06	Cote
C1	Second facteur	×			×		OUI
C2	Cloisonnement	×	×				OUI
C3	Sauvegardes testées	×		×			OUI
C4	Mode dégradé	×	×	×		×	NON
C5	Journalisation	×	×		×		OUI
C6	Correctifs	×	×		×		NEK
C7	Sensibilisation	×			×		NON
C8	Assurance des prestataires		×	×			NON
C9	Revue mensuelle des règles de pare-feu						OUI

Tableau 13.3. Matrice risques-contrôles (extrait)

13.3.2 Lire la matrice

La matrice se lit dans trois directions.

- **Par ligne** : les contrôles qui traitent beaucoup de risques sont des *contrôles clés* ; C4 (mode dégradé) en traite quatre, et il est NON : c'est la priorité du plan.
- **Par colonne** : un risque dont tous les contrôles sont NON ou NEK n'est pas maîtrisé. R-DC-06 n'a qu'un contrôle, C4, coté NON : la protection contre le déni de service, contractualisée avec le fournisseur d'accès, n'est pas encore un contrôle de la base ; il faut l'y inscrire et la tester.
- **Les lignes vides** : C9 ne traite aucun risque du registre. Soit il est inutile, soit un risque manque. C'est le second cas : la règle « temporaire » de LiZbiZ (Chapitre 12) a montré le risque d'une règle de filtrage qui survit à son besoin ; le registre de la banque doit le porter.

Papier de travail

Tenir la matrice. Le responsable GRC vérifie, à chaque mise à jour :

- que chaque risque au-delà de l'appétence a au moins un contrôle coté OUI par étape de son scénario ;
- que chaque contrôle est relié à au moins un risque ou une obligation ;

- que la cote de chaque contrôle vient du dernier test, avec sa date et sa source (audit, contrôle automatisé, autoévaluation) ;
- qu'un constat d'audit modifie la cote dans la semaine, et la cote du risque à la revue suivante.

13.4 Les Indicateurs de Risque

13.4.1 Risque ou performance

Les indicateurs du SMSI (Chapitre 11) mesurent la mise en œuvre et l'efficacité des mesures. Un **indicateur de risque** mesure autre chose : un signal qui annonce que l'exposition change, souvent avant l'incident. Il se lit avec des seuils, qui déclenchent une action.

Réf.	Indicateur de risque	Vert	Orange	Rouge	Risque suivi
K1	Agents qui cliquent lors d'une campagne simulée	< 5 %	5 à 10 %	> 10 %	R-AG-01
K2	Vulnérabilités exploitées non corrigées après 7 jours	0	1 à 2	≥ 3	R-AG-01, R-DC-03
K3	Règles de filtrage temporaires échues	0	1	≥ 2	R-AG-01, R-DC-03
K4	Prestataires critiques sans rapport d'assurance à jour	0	1	≥ 2	R-DC-02, R-AG-02
K5	Tentatives de connexion refusées sur l'accès distant (par semaine, écart à la moyenne)	< 2 fois	2 à 5 fois	> 5 fois	R-DC-03

Tableau 13.4. Les indicateurs de risque et leurs seuils

Note

Ce que déclenche un seuil. Un indicateur au rouge ne change pas la cote du risque à lui seul : il déclenche la revue du risque par son propriétaire, sans attendre la date prévue (Chapitre 3). En janvier 2029, K1 est au rouge (11 %) et K4 à l'orange (DIGICORE) : les revues de R-AG-01 et de R-DC-02 sont avancées.

13.5 Le Tableau de Bord GRC

13.5.1 Une page pour la gouvernance

Le tableau de bord du comité des risques n'est pas celui de la RSSI. Il ne détaille pas les mesures ; il répond à trois questions : où sont les risques qui dépassent l'appétence ? Respectons-nous nos obligations ? Que savons-nous, et que ne savons-nous pas ?

Scénario Opérationnel · Opération SANAGA. La page de M. ATANGANA, avril 2029

1. Risques au-delà de l'appétence : R-AG-02 (GAB, 9 ; remplacement à 60 %, fin prévue en juin) ; R-DC-06 (déni de service, 9 ; test de la protection en mars, réussi : proposition de passer à 6).

2. Obligations : 7 satisfaites sur 12 ; deux non satisfaites (O3, conservation, budget de stockage demandé ; O9, DIGICORE, relance et pénalité contractuelle) ; trois inconnues (O2, O7, O11), avec une date pour chacune.

3. Contrôles clés : C4 (mode dégradé) non conforme, plan à fin juin ; C6 (correctifs) inconnu, test de l'audit interne en mai.

4. Indicateurs de risque : K1 au rouge (11 %) ; K4 à l'orange.

5. Ce que nous ne savons pas : $U = 0{,}25$ sur les obligations ; contrôles C6 et sensibilisation à vérifier ; base NEK de la vraisemblance de R-DC-02.

6. Décisions demandées au comité : budget de stockage (O3) ; position sur DIGICORE si le rapport n'est pas remis en juin (changement de prestataire) ; validation de la nouvelle cote de R-DC-06.

La rubrique 5 est la plus rare dans les tableaux de bord, et la plus utile. Un comité qui ne voit que des chiffres rassurants ne sait pas sur quoi ils reposent ; un comité qui voit l'incertitude sait où porter l'effort et ce qu'il accepte d'ignorer.

13.6 Le Contrôle Continu de la Conformité

13.6.1 Des contrôles qui se vérifient seuls

Certains contrôles peuvent être testés automatiquement, chaque jour, par une extraction comparée à une règle : la part des comptes avec second facteur (C1), la part des agences qui envoient des journaux (C5), les règles de filtrage échues (C9, K3). C'est le **contrôle continu de la conformité** : une alerte part dès qu'une extraction s'écarte de la règle, au lieu d'attendre l'audit suivant.

Scénario Opérationnel · Opération SANAGA. Trois tests quotidiens

Depuis février 2029, trois scripts tournent chaque nuit : extraction de l'annuaire (comptes sans second facteur), extraction du collecteur (agences silencieuses depuis plus de 24 heures), extraction des pare-feu (règles dont la date d'expiration est passée). Leurs résultats alimentent directement la cote de C1, C5 et C9 dans la matrice.

Le 14 mars, le test de C5 signale une agence silencieuse depuis trente heures : un commutateur remplacé n'avait pas reçu la configuration de référence. L'écart est corrigé le jour même. En 2028, le même défaut avait attendu l'audit pour être

découvert (Chapitre 6).

13.6.2 Les limites

★ Attention

Violation typique. Tenir pour OUI un contrôle parce que le test automatique ne signale rien.

Règle : un test automatique est lui-même un contrôle, qui doit être validé : voit-il toute la population (exhaustivité) ? Sa règle est-elle juste (exactitude) ? Fonctionne-t-il encore (un script arrêté ne signale rien) ? L'audit interne teste les tests, au moins une fois par an. Un script qui ne tourne plus transforme un OUI en NEK sans que personne ne le voie.

Le contrôle continu de la conformité porte sur les contrôles ; l'audit continu, qui porte sur les données et les transactions pour y détecter les anomalies, est présenté au Chapitre 15.

● Note

La loi et le continu. L'article 26 de la loi n° 2010/012 demande aux exploitants de gérer *continûment* les risques de sécurité (Chapitre 3) [53]. Le dispositif décrit dans ce chapitre (registres reliés, indicateurs à seuils, tests quotidiens) est une manière concrète de donner un contenu à cet adverbe.

13.7 Ce que la GRC demande à chaque Métier

Application Responsable GRC

Tenir les liens

1. Tenir le registre des obligations, avec la fonction juridique, et le relier aux contrôles.
2. Tenir la matrice risques-contrôles à jour de chaque test et de chaque constat.
3. Repérer les risques sans contrôle et les contrôles sans risque.
4. Fixer avec les propriétaires les indicateurs de risque et leurs seuils.
5. Produire une page pour la gouvernance, avec une rubrique « ce que nous ne savons pas ».

Application RSSI

Alimenter le référentiel

La RSSI ne tient plus son propre tableau à part : ses indicateurs et ses tests alimentent la matrice. Elle automatise les tests qui peuvent l'être, et demande à

l'audit interne de valider ses scripts.

Application Auditeur en cybersécurité

Auditer le dispositif, et s'en servir

L'auditeur peut s'appuyer sur la matrice et sur les tests automatiques pour cibler sa mission, à condition de les avoir validés. Il audite aussi le dispositif lui-même : les liens sont-ils justes, les cotes à jour, les seuils suivis ?

Application Gestionnaire des risques cyber

Réagir aux seuils

Un indicateur au rouge déclenche la revue du risque par son propriétaire. Le gestionnaire des risques organise cette revue dans le mois, et en inscrit la décision au registre.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Un référentiel commun** : risques, obligations, contrôles, preuves, et leurs liens.
- **Deux registres** : les risques (avec propriétaires et décisions) et les obligations (avec source et statut).
- **La matrice risques-contrôles** révèle les contrôles clés, les risques sans contrôle et les contrôles sans risque.
- **Les indicateurs de risque** annoncent un changement d'exposition ; leurs seuils déclenchent une revue.
- **Le tableau de bord de la gouvernance** tient en une page, et dit ce que l'on ne sait pas.
- **Le contrôle continu** détecte les écarts au jour le jour ; les tests automatiques sont eux-mêmes des contrôles à valider.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- rédiger une ligne du registre des obligations à partir d'un article de loi ;
- lire une matrice risques-contrôles dans ses trois directions ;
- définir un indicateur de risque et ses seuils ;
- dire pourquoi un test automatique silencieux n'est pas une preuve.

Exercices

✍ Exercice 13.1. Classer ★☆☆

Dites si chacun des éléments suivants est un risque, une obligation, un contrôle, une preuve, un indicateur de performance ou un indicateur de risque.

(a) Conserver dix ans les données de connexion.

(b) La part des comptes avec second facteur.

(c) Le procès-verbal de restauration du 12 février.

(d) Une défaillance prolongée de DIGICORE.

(e) Le nombre de vulnérabilités exploitées non corrigées après sept jours.

(f) La revue mensuelle des règles de pare-feu.

✍ Exercice 13.2. Compléter la matrice ★★☆

(a) Ajoutez à la matrice (Tableau 13.3) le contrôle « protection contre le déni de service chez le fournisseur d'accès » et le risque « règle de filtrage temporaire maintenue ». Reliez-les.

(b) Pour chaque risque, dites s'il a au moins un contrôle OUI. Lesquels ne sont pas maîtrisés ?

(c) Calculez μ, U et H des neuf contrôles du tableau, puis celles des seuls contrôles qui traitent R-AG-01. Que montre la comparaison ?

✍ Exercice 13.3. Des indicateurs pour les prestataires ★★☆

(a) Proposez deux indicateurs de risque pour R-DC-02 (DIGICORE), avec leurs seuils et leur source.

(b) Proposez un indicateur de risque pour R-AG-02 (GAB) une fois le remplacement achevé.

(c) Dites, pour chacun, ce que déclenche le passage au rouge, et qui décide.

✍ Exercice 13.4. La page de l'ANPP ★★★

À partir des Chapitres 9 et 10, préparez le tableau de bord GRC d'une page destiné au conseil d'administration de l'ANPP.

(a) Construisez le registre des obligations (au moins six lignes), avec leur statut.

(b) Calculez μ, U et H de ce registre et situez-le dans le quadrant.

(c) Rédigez les six rubriques de la page, sur le modèle de celle de M. ATANGANA, dont la rubrique « ce que nous ne savons pas ».

(d) Proposez deux tests automatiques quotidiens réalistes pour l'ANPP, et dites comment l'audit les validera.

Note

Pour aller plus loin.

- L'ISO 31000 [31], pour l'intégration de la gestion des risques dans la gouvernance.
- Le cadre COSO de gestion des risques [10], pour l'appétence et les indicateurs.
- Le NIST CSF 2.0 [60], fonction *Gouverner*, catégorie de supervision.

Note

Transition. Les chapitres de la Partie IV ont traité la pratique par morceaux : le SMSI, l'audit technique, la GRC. Le Chapitre 14 les assemble dans trois cas complets, de l'incident au rapport.

14

ÉTUDES DE CAS INTÉGRATRICES

> « Une méthode se juge à la fin d'une histoire,
> pas au début d'un chapitre. »
>
> Principe du cours

Niveau : *Expert* • Maîtrise du Chapitre 12, du Chapitre 13

✦ Objectifs du chapitre

- ➢ Retracer, pour chacun des trois cas, le chemin de l'incident ou du constat initial jusqu'au rapport final.
- ➢ Relier gouvernance, appréciation et quantification des risques, audit, référentiels et droit dans une même mission.
- ➢ Lire l'évolution d'un dispositif dans le temps par les trois mesures μ, U et H.
- ➢ Reconnaître et éviter les erreurs typiques de l'auditeur et du gestionnaire des risques.
- ➢ Préparer l'épreuve de synthèse du cours.

Avant de commencer : trois histoires, une méthode

Les treize chapitres précédents ont suivi trois organisations, chapitre après chapitre[1]. La BANQUE SANAGA a été compromise malgré son certificat, puis a reconstruit sa sécurité et sa gouvernance. LiZbiZ a découvert des fraudes, puis a dû convaincre un client exigeant. L'ANPP, organisme public, a dû répondre à la fois à un bailleur, à la Chambre des comptes et à l'ANTIC.

Ce chapitre ne présente aucune notion nouvelle. Il rassemble chaque histoire en un seul fil, montre ce que chaque méthode y a apporté, en tire les erreurs à ne pas commettre, puis propose trois études de cas complètes. C'est le chapitre à relire avant l'épreuve de synthèse.

[1] Comme dans tout le cours, les organisations, les personnes, les dates et les montants sont fictifs ; les méthodes, les normes et les textes cités sont exacts.

14.1 Une Méthode en Dix Questions

Toutes les missions du cours, quel que soit leur objet, répondent aux mêmes dix questions, dans cet ordre.

N°	Question	Outil	Chap.
1	Qui décide, qui répond, qui vérifie ?	RACI, trois lignes	1
2	Quel est le périmètre, et qu'en exclut-on ?	Périmètre défendable	11
3	Quels scénarios, avec quelle base de preuve ?	Fiche de risque, EBIOS	2, 4
4	Combien cela coûterait-il ?	FAIR, Monte-Carlo	5
5	Que décide-t-on, et qui accepte le reste ?	Plan, critères d'acceptation	3
6	Quels textes s'imposent, lesquels sont choisis ?	Registre des obligations	9, 10
7	Les mesures sont-elles en place et efficaces ?	Audit, exports figés	6, 12
8	Que peut-on conclure, et que ne sait-on pas ?	Décomposition, μ, U, H	7
9	Le système se corrige-t-il seul ?	Audit interne, revue de direction	11
10	Une seule vue pour la gouvernance ?	Matrice, tableau de bord	13

Tableau 14.1. La méthode du cours en dix questions

14.2 BANQUE SANAGA : du Rançongiciel au Certificat

14.2.1 Le fil

Date	Événement	Chap.
Juin 2025	Certificat sur le seul centre de données	0
Sept. 2026	Rançongiciel par l'agence de Ngaoundéré : 180 postes, 9 agences, 410 M FCFA	0
Oct. 2026	« Qui a décidé du périmètre ? » : gouvernance 2/4/2	1
Nov. 2026	R-AG-01 coté 16 puis 12 ; registre 2025 revu : 6/2/4	2
Déc. 2026	Critères d'acceptation, plan A1–A8 (193 M)	3
Mars 2027	Quantification : 165 M par an, puis 19 après traitement	5
Sept. 2027	Suivi du plan : 5/2/3	3
Mars 2028	Audit des agences : 3/3/2 ; Kribi, GAB	6, 7
Avr. 2028	Déclaration d'applicabilité confrontée aux preuves : 3/3/3	8
Juin 2028	Étape 2 : une majeure (GAB non appréciés)	11
Sept. 2028	Certificat renouvelé sur toute la banque	11
Avr. 2029	Page GRC du comité : obligations 7/2/3	13

Tableau 14.2. La BANQUE SANAGA, de 2025 à 2029

14.2.2 Ce que les mesures racontent

⚖ Lecture auditologique · Le risque R-AG-01 et la connaissance qu'on en a

Constatation. La criticité résiduelle de R-AG-01 passe de 12 (2025) à 9 (mars 2027), puis à 6 (septembre 2027), confirmé par l'audit de mars 2028. Sur la même période, les évaluations successives donnent :

- agences, prologue : $\mu = 0{,}20$, $U = 0{,}40$;
- agences, audit de mars 2028 : $\mu = 0{,}375$, $U = 0{,}25$;
- obligations, avril 2029 : $\mu \approx 0{,}58$, $U = 0{,}25$.

Analyse (confiance moyenne : les ensembles mesurés ne sont pas identiques). Le risque technique a baissé plus vite que l'incertitude. Les barrières techniques ont été posées et prouvées en dix-huit mois ; la part d'inconnu, elle, est restée autour d'un quart, parce qu'elle s'est déplacée : des agences vers le personnel, puis vers les prestataires et les textes. La banque n'a pas cessé d'ignorer ; elle a appris *où* elle ignorait.

14.2.3 Ce que le cas enseigne

- Un certificat ne protège que son périmètre ; le périmètre est une décision du conseil.
- Les défaillances de 2025 et de 2028 ont la même forme : un risque connu, ou connaissable, laissé sans appréciation sur une partie du périmètre.
- Les mesures techniques se corrigent vite ; les mesures humaines et les relations avec les prestataires, lentement.

14.3 LiZbiZ : de la Fraude au Client Exigeant

14.3.1 Le fil

Date	Événement	Chap.
2026	Écart de stock de 186 M FCFA ; fraude TRANSLOG (112,7 M) ; registre R1–R8 (cours ACSI)	2
2026	Audit des quatre centres : 8/9/3	12
2026–2027	Base de preuve du registre : 4/1/3 ; R8 recoté à 12	2
Janv. 2027	PHARMACAM exige une analyse ; étude EBIOS animée par Mme NKENG ; SO1 à 12	4
2027	Quantification simple de SO1 : 100 M par an	5
2028	Audit contractuel de PHARMACAM ; déclaration d'applicabilité 3/2/1	6, 8
Oct. 2028	Second passage technique : 14/4/2 ; règle de maintenance de Garoua	12
2029	Engagement d'un SMSI, certification visée fin 2029	11

Tableau 14.3. LiZbiZ, de 2026 à 2029

14.3.2 Ce que le cas enseigne

- Une petite organisation n'a ni RSSI ni audit interne : elle compense par la séparation des rôles qu'elle peut tenir (contrôleuse interne, auditeur externe indépendant) et par une hygiène de base vérifiable.
- Les fraudes internes et les attaques externes exploitent les mêmes faiblesses ; EBIOS les met sur le même plan.
- Le client est un régulateur de fait : ses clauses (analyse, droit d'audit) font avancer la sécurité plus vite que la loi.
- Le défaut qui ouvre le scénario principal peut survivre à tous les plans s'il est « temporaire » : la règle de Garoua l'a montré.

14.4 ANPP : un Organisme Public sous Trois Regards

14.4.1 Le fil

Date	Événement	Chap.
2026	Chambre des comptes : 40 paiements contrôlés, 29 OUI, 6 NON, 5 NEK ; quatre agents payés après leur départ (cours ACSI)	9
Mars 2027	Un bailleur exige un profil NIST CSF ; base commune B1–B10 : 4/3/3	9
2028	L'ANTIC annonce un audit de sécurité ; obligations légales : 0/3/2	10
2028–2029	Tableau de bord GRC pour le conseil d'administration	13

Tableau 14.4. L'ANPP, de 2026 à 2029

Lecture auditologique · Les paiements de l'ANPP

Constatation. 29 OUI, 6 NON, 5 NEK sur 40 paiements : $\mu \approx 0{,}73$; $U = 0{,}125$;

$H = -(0{,}725 \log_2 0{,}725 + 0{,}15 \log_2 0{,}15 + 0{,}125 \log_2 0{,}125) \approx 0{,}336 + 0{,}411 + 0{,}375 \approx 1{,}12$ bit.

Analyse (confiance moyenne). Lu seul, le contrôle des paiements paraît plutôt conforme. Rapproché de la base commune (B2 : comptes des partants actifs, NON) et des obligations légales (0/3/2), il change de sens : les quatre agents payés après leur départ sont le symptôme financier d'un défaut de sécurité. Le même défaut apparaît dans trois rapports, à trois destinataires ; il n'appelle qu'une correction.

$\mu = 0{,}725$ · $U = 0{,}125$ · $H = 1{,}12$ **bit**

14.4.2 Ce que le cas enseigne

- Un organisme public répond à plusieurs autorités, avec des textes parfois ambigus ; l'auditeur signale l'ambiguïté au lieu de la trancher.
- Une base commune de contrôles, testée une fois, évite trois chantiers et révèle les défauts communs.
- La sécurité et la régularité financière se rejoignent dans les contrôles d'accès.

14.5 Dix Erreurs à ne pas Commettre

N°	Erreur	Où le cours l'a montrée	Chap.
1	Prendre un certificat pour une preuve de sécurité	Hall de la BANQUE SANAGA	0
2	Lire un risque absent du registre comme un risque faible	Registre 2025	0
3	Laisser une décision de risque sous l'instance qui en répond	Périmètre signé par le seul DG	1
4	Coter une vraisemblance sur un silence non surveillé	« Jamais attaqués »	2
5	Réduire un risque par une mesure non testée	Cloisonnement de mars 2027	2
6	Présenter un chiffre unique au lieu d'une distribution	143,5 M	5
7	Coter OUI sur une déclaration	Rapport « tout est en place »	6
8	Taire une limitation de l'étendue	GAB, prestataire	6
9	Résumer un audit par un pourcentage	« 37 % »	7
10	Reporter une conformité par un lien partiel	« Conforme ISO, donc NIST »	9

Tableau 14.5. Les dix erreurs typiques

Toutes ont la même racine : confondre ce que l'on sait et ce que l'on suppose. Le cours n'a enseigné qu'une seule discipline, sous plusieurs noms : dire, à chaque étape, ce qui est établi, ce qui est contredit, et ce que l'on ignore.

14.6 Préparer l'Épreuve de Synthèse

L'épreuve de synthèse prend la forme d'une étude de cas, sur le modèle des trois études ci-dessous : un dossier (faits, extraits de documents, résultats de tests) et des questions qui suivent la méthode en dix questions. Le barème détaillé, la durée et les documents autorisés sont fixés par l'enseignant et communiqués avec le calendrier de l'UE.

Papier de travail

Répondre à une étude de cas.

- Lire tout le dossier avant de répondre ; repérer les acteurs, le périmètre et ce qui est demandé.
- Séparer, pour chaque réponse, la constatation (le fait, la preuve) de l'analyse (l'interprétation, avec un niveau de confiance).
- Poser les calculs : cotes, criticités, μ, U et H, avec les valeurs intermédiaires.
- Nommer ce que l'on ne sait pas, et dire comment le savoir.

- ➢ Citer les normes et les textes avec leur degré de vérification ; ne jamais inventer un numéro d'article.
- ➢ Conclure par une décision, et dire qui la prend.

14.7 Le Parcours de chaque Métier

Application RSSI

De Mme ABENA en 2026 à Mme ABENA en 2029

Elle a obtenu le droit d'être entendue par le comité, cessé d'administrer ce qu'elle surveille, remplacé ses déclarations par des preuves, et présenté un indicateur défavorable (11 % de clics) sans l'enjoliver.

Application Auditeur en cybersécurité

Mme EKAMBI, M. BEYALA, CERTIQUAL AFRIQUE

Trois auditeurs, trois postures, une même règle : la preuve que l'on obtient soi-même, la limitation que l'on déclare, le constat que l'on maintient sous la pression, l'indépendance que l'on protège.

Application Gestionnaire des risques cyber

Du registre au scénario

Il est passé d'une liste cotée sans preuve à des scénarios décomposés, reliés aux attaquants et à l'écosystème, chiffrés en francs CFA, avec une base de preuve pour chaque cote.

Application Responsable GRC

M. ATANGANA

Il a relié quatre rapports en une page, et fait apparaître ce que le comité ignorait. Son outil principal n'est pas un logiciel : ce sont les liens entre risques, obligations, contrôles et preuves.

Application Consultant en mise en œuvre de SMSI

Le consultant de 2025, et celui de LiZbiZ

Le premier a livré un certificat sur un périmètre commode ; celui que LiZbiZ retiendra devra livrer un processus qui fonctionne sans lui, et un périmètre qui inclut ses interfaces.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Dix questions** structurent toute mission : rôles, périmètre, scénarios, chiffrage, décisions, textes, preuves, conclusion, amélioration, vue d'ensemble.
- **BANQUE SANAGA** : le risque baisse vite, l'inconnu se déplace ; les échecs de 2025 et de 2028 ont la même forme.
- **LiZbiZ** : fraude et attaque exploitent les mêmes faiblesses ; le client fait avancer la sécurité.
- **ANPP** : un même défaut d'accès apparaît dans trois rapports ; une base commune le corrige une fois.
- **Dix erreurs**, une racine : confondre ce que l'on sait et ce que l'on suppose.

Exercices

✍ Étude de cas 14.1. La réponse à la COBAC ★★★

En janvier 2029, la COBAC demande à la BANQUE SANAGA « l'état des mesures prises depuis l'incident de septembre 2026 ».

(a) Identifiez le cadre de la demande et le degré de vérification du texte (Chapitre 10).

(b) Rédigez le plan de la réponse, en suivant la méthode en dix questions.

(c) Rédigez la partie « risque » de la réponse : évolution de la criticité de R-AG-01, avec la base de preuve de chaque étape, et la quantification avant et après traitement.

(d) Rédigez la partie « ce que la banque ne sait pas encore », et le calendrier pour le savoir.

(e) Qui signe la réponse, et pourquoi ?

✍ Étude de cas 14.2. Le dossier de renouvellement de PHARMACAM ★★★

PHARMACAM demande à LiZbiZ, pour le renouvellement de janvier 2030, un dossier de sécurité.

(a) Listez les pièces du dossier, en distinguant ce qui est prouvé et ce qui est déclaré.

(b) Retracez l'évolution du scénario SO1 de 2027 à 2028 (criticité, phases couvertes, preuves).

(c) Comparez les deux passages de l'audit technique (8/9/3 et 14/4/2) centre par

centre, et rédigez le paragraphe qui les présente à PHARMACAM sans moyenne trompeuse.

(d) Quelle décision recommandez-vous à M. ETEME sur la certification ISO/IEC 27001, et à quelle échéance ?

✍ Étude de cas 14.3. Un défaut, trois rapports ★★★

À l'ANPP, le défaut de désactivation des comptes des agents partis apparaît dans trois travaux : le contrôle des paiements de la Chambre des comptes, la base commune (B2), et les obligations légales (article 29, alinéa 2).

(a) Montrez, pour chacun des trois destinataires (M. NJOYA, le bailleur, l'ANTIC), ce que le défaut signifie dans sa langue.

(b) Rédigez une seule recommandation, avec sa preuve de mise en œuvre, qui réponde aux trois.

(c) Proposez le test automatique qui permettra de vérifier chaque nuit que le défaut ne revient pas, et dites comment l'audit le validera.

(d) Recalculez μ, U et H de la base commune si B2 devient OUI et si B4 et B6 sont établis (OUI et NON).

● Note

Transition. Les trois cas reposent sur des systèmes que leurs propriétaires détiennent. Les risques qui viennent sont ailleurs : chez les prestataires et dans le nuage, dans l'intelligence artificielle, dans l'audit qui devient continu. La Partie V les aborde au Chapitre 15.

partie V

Défis Avancés

© *MaletYon*

15

RISQUES ÉMERGENTS ET NOUVEAUX OBJETS D'AUDIT

« On peut externaliser un service.
On n'externalise jamais la responsabilité. »

Principe du cours

Niveau : *Expert* • Maîtrise du Chapitre 14

✦ Objectifs du chapitre

- ➢ Gérer et auditer les risques liés aux tiers et à la chaîne d'approvisionnement.
- ➢ Auditer un service en nuage selon le partage des responsabilités.
- ➢ Situer les risques des systèmes d'intelligence artificielle, et les cadres qui les encadrent (ISO/IEC 42001, NIST AI RMF).
- ➢ Concevoir un dispositif d'audit continu, et en connaître les limites.
- ➢ Appliquer à ces nouveaux objets la cote OUI / NON / NEK et les trois mesures.

Avant de commencer : la sécurité qui n'est plus chez soi

Douala, 2029. La BANQUE SANAGA[1] a reconstruit sa sécurité sur ce qu'elle détient : ses postes, ses réseaux, ses agences. Mais une part croissante de son système d'information n'est plus chez elle. Le centre de données est hébergé par DIGICORE ; la messagerie migre en 2029 vers un service en nuage, NUAGEPRO ; un modèle d'intelligence artificielle, acheté à l'éditeur FRAUDSCAN, analyse désormais chaque virement. Et des agents ont pris l'habitude de coller des extraits de dossiers de clients dans un assistant d'IA générative public, « pour rédiger plus vite ».

La RSSI résume la situation au comité : « Nous savons auditer nos systèmes. Nous ne savons pas encore auditer ceux des autres, ni ceux qui apprennent. »

Ce chapitre ouvre la Partie V. Il présente trois objets d'audit qui transforment le

[1] Comme dans tout le cours, les organisations, les prestataires (DIGICORE, NUAGEPRO, FRAUDSCAN), les personnes, les dates et les montants sont fictifs ; les normes et les cadres cités sont exacts.

métier : les tiers et le nuage, l'intelligence artificielle, et l'audit lui-même, qui devient continu.

★ Attention

Violation typique. Considérer qu'un risque confié à un prestataire sort du registre de l'organisation.

Règle : le risque reste celui de l'organisation ; seule l'exécution de certaines mesures change de main. Le registre porte le risque, le contrat porte les obligations du prestataire, et la preuve doit revenir à l'organisation.

15.1 Les Tiers et la Chaîne d'Approvisionnement

15.1.1 Un risque qui vient de l'extérieur

Le Chapitre 4 a montré qu'un attaquant ciblé passe souvent par un partenaire moins protégé. Les tiers posent trois questions distinctes : un prestataire peut *servir de porte d'entrée* (l'accès de maintenance de LiZbiZ) ; il peut *défaillir* (DIGICORE) ; et il peut lui-même dépendre d'autres prestataires, que l'organisation ne connaît pas (les sous-traitants de rang deux).

L'ISO/IEC 27002:2022 consacre cinq mesures à ces sujets : la politique de sécurité dans les relations avec les fournisseurs (5.19), la sécurité dans les accords (5.20), la chaîne d'approvisionnement des TIC (5.21), la surveillance et la revue des services des fournisseurs (5.22), et la sécurité des services en nuage (5.23) [41].

15.1.2 Le cycle de vie d'un tiers

Étape	Ce que l'organisation fait, et ce qu'elle garde comme preuve
Sélection	Classe le tiers selon sa criticité (dépendance, pénétration : Chapitre 4) ; évalue sa maturité par un questionnaire et des attestations
Contrat	Inscrit les exigences de sécurité, la notification des incidents, le droit d'audit ou le rapport d'assurance, la réversibilité, l'accord préalable sur la sous-traitance
Exploitation	Suit les indicateurs de service et de sécurité, reçoit les rapports d'assurance, exerce son droit d'audit ; met à jour la criticité
Sortie	Récupère les données, révoque les accès, obtient la preuve de destruction

Tableau 15.1. Le cycle de vie d'un tiers

⚖ Lecture auditologique · Les neuf prestataires critiques de la BANQUE SANAGA

Constatation. En mars 2029, M. ATANGANA cote, pour chacun des neuf prestataires classés critiques, l'existence d'une preuve récente que ses mesures fonctionnent (rapport d'assurance de type 2, audit exercé, ou certification couvrant le service) :

- OUI : le prestataire des GAB (audit exercé grâce à l'avenant), le fournisseur d'accès (test de la protection contre le déni de service), l'éditeur du système central (rapport de type 2), NUAGEPRO (certification ISO/IEC 27001 et rapport de type 2 couvrant la messagerie) ;
- NON : DIGICORE (rapport annuel non remis) ;
- NEK : FRAUDSCAN, le prestataire de la monétique, l'imprimeur des chéquiers et le transporteur de fonds (aucune preuve demandée à ce jour).

4 OUI, 1 NON, 4 NEK :

$$\mu = U \approx 0{,}44 \ ; \quad H = -\left(2 \times \tfrac{4}{9}\log_2 \tfrac{4}{9} + \tfrac{1}{9}\log_2 \tfrac{1}{9}\right) \approx 1{,}040 + 0{,}352 \approx 1{,}39 \text{ bit.}$$

Analyse (confiance élevée). La banque connaît bien ses prestataires « historiques », ceux de l'incident de 2026 et de l'audit de 2028. Les quatre NEK sont des prestataires que personne n'a regardés sous l'angle de la sécurité, parce qu'ils ne sont pas « informatiques ». Le transporteur de fonds et l'imprimeur des chéquiers ont pourtant accès à des informations sensibles. C'est le périmètre de complaisance du prologue, déplacé vers l'écosystème.

$\mu = 0{,}44$ · $U = 0{,}44$ · $H = 1{,}39$ **bit**

15.2 Auditer un Service en Nuage

15.2.1 La responsabilité partagée

Dans un service en nuage, les mesures de sécurité se répartissent entre le fournisseur et le client, selon le modèle de service. Le fournisseur répond de ce qu'il exploite ; le client, de ce qu'il configure et de ce qu'il y met.

Couche	Infrastructure (IaaS)	Plateforme (PaaS)	Logiciel (SaaS)
Centre de données, matériel	Fournisseur	Fournisseur	Fournisseur
Système d'exploitation	Client	Fournisseur	Fournisseur
Application	Client	Client	Fournisseur
Configuration du service	Client	Client	Client
Identités et accès des utilisateurs	Client	Client	Client
Données	Client	Client	Client

Tableau 15.2. Le partage des responsabilités (schéma général ; chaque contrat le précise)

Deux lignes restent toujours au client : les identités et les données. Une messagerie en nuage parfaitement sécurisée par son fournisseur reste vulnérable si les comptes des agents n'ont pas de second facteur, ou si un agent partage un dossier de clients avec tout Internet.

15.2.2 Les référentiels du nuage

L'ISO/IEC 27017 complète l'ISO/IEC 27002 par des recommandations propres aux services en nuage, pour le fournisseur comme pour le client [34] ; l'ISO/IEC 27018 traite de la protection des données personnelles dans le nuage public [37]. Pour l'auditeur, la preuve vient le plus souvent des rapports d'assurance du fournisseur (type 2) et de ses certifications : il vérifie qu'ils couvrent bien le service utilisé, la période, et le centre de données qui héberge les données.

Scénario Opérationnel · Opération SANAGA. La messagerie dans le nuage

Faits. La messagerie migre vers NUAGEPRO en mai 2029. NUAGEPRO fournit une certification ISO/IEC 27001 et un rapport de type 2.

Analyse (confiance moyenne). Ces pièces couvrent la part du fournisseur. La part de la banque se vérifie autrement : second facteur sur tous les comptes (une extraction de la console d'administration du service) ; règles de partage externe désactivées ; journaux d'accès récupérés dans le collecteur de la banque ; localisation des données et conditions de leur transfert, à examiner au regard de la loi n° 2024/017 (à vérifier). Le « rapport du fournisseur » ne remplace aucune de ces quatre preuves.

Note

La loi et les tiers. L'article 26, alinéa 1, de la loi n° 2010/012 vise les risques liés aux services offerts « directement ou indirectement » (Chapitre 3) [53]. Analyse (lecture du cours) : confier un service à un prestataire ne fait pas sortir ses risques du champ de l'obligation de l'exploitant.

15.3 L'Intelligence Artificielle

15.3.1 Des risques nouveaux

Un système d'intelligence artificielle est un logiciel dont le comportement est appris à partir de données plutôt qu'entièrement programmé. Il ajoute aux risques classiques des risques propres :

- **la fuite de données** : ce que l'on confie à un assistant public peut être conservé, réutilisé, ou exposé ;
- **la manipulation** : des données d'entraînement empoisonnées, ou des instructions cachées dans un document soumis à un assistant, peuvent détourner le système ;

- **l'erreur opaque** : un modèle peut se tromper sans que l'on sache pourquoi, et ses performances peuvent se dégrader quand les données changent ;
- **le biais** : un modèle peut traiter différemment des catégories de personnes, ce qui pose des questions de droit et de réputation.

15.3.2 Deux cadres

	ISO/IEC 42001:2023	NIST AI RMF 1.0 (2023)
Nature	Système de management de l'IA, certifiable [43]	Cadre volontaire de gestion des risques [59]
Structure	Même structure que l'ISO/IEC 27001 (articles 4 à 10), avec une annexe de mesures	Quatre fonctions : gouverner, cartographier, mesurer, gérer
Apport	S'intègre au SMSI existant	Décrit les caractéristiques d'une IA digne de confiance : valide et fiable, sûre, sécurisée et résiliente, responsable et transparente, explicable, respectueuse de la vie privée, équitable

Tableau 15.3. Deux cadres pour l'IA

15.3.3 Deux usages à la BANQUE SANAGA

Scénario Opérationnel · Opération SANAGA. Un modèle acheté, un assistant toléré

Le modèle de FRAUDSCAN. Il attribue à chaque virement un score de risque ; au-delà d'un seuil, le virement est bloqué pour vérification. Questions de l'auditeur : sur quelles données le modèle a-t-il été entraîné ? Qui a validé le seuil, et sur quels essais ? Comment la banque sait-elle, mois après mois, que le taux de fraudes manquées ne se dégrade pas ? Que peut-elle expliquer à un client dont le virement est bloqué, ou au superviseur ? À ce jour, la banque ne peut répondre qu'à la deuxième question : les trois autres sont NEK.

L'assistant public. Une revue des journaux de navigation montre que 47 agents ont soumis des textes à un assistant d'IA générative public en un mois, dont certains contenaient des noms et des numéros de compte de clients. Aucune règle ne l'interdisait, aucune ne l'encadrait.

Analyse (confiance élevée). Le premier usage est un risque de *tiers* et de *modèle* : il relève à la fois du cycle de vie des prestataires et d'une surveillance des performances. Le second est un risque de *fuite*, créé par un usage non déclaré : il appelle une règle d'usage, une solution autorisée, et une sensibilisation. Ni l'un ni l'autre ne figurait

au registre.

Fiche de risque · R-IA-01 · Fuite de données de clients par un assistant public

Valeur métier : la confidentialité des données des clients.
Bien support : navigateurs des agents, assistant public non contractualisé.
Événement redouté : divulgation de données de clients à un tiers sans contrat ; manquement possible aux obligations de protection des données (loi n° 2024/017, à vérifier).
Vraisemblance : 4 (usage constaté, 47 agents en un mois). Base : journaux de navigation (OUI).
Impact : 3 (atteinte à la confidentialité, réputation, risque réglementaire). Base : appréciation du DPD (OUI).
Traitement : règle d'usage de l'IA approuvée par le comité de sécurité ; blocage de l'assistant public ; mise à disposition d'un assistant contractualisé, sans conservation des données ; sensibilisation ciblée.
Propriétaire : le directeur des opérations, avec le DPD.

15.4 L'Audit Continu

15.4.1 De l'échantillon à la population

Le Chapitre 13 a présenté le contrôle continu de la *conformité* : des tests automatiques sur les contrôles. L'**audit continu** va plus loin : il analyse les *données* et les *transactions* elles-mêmes, sur toute la population et de manière répétée, pour y détecter les anomalies. Là où la Chambre des comptes examinait 40 paiements de l'ANPP, l'audit continu les examine tous, chaque mois.

Scénario Opérationnel · Opération ANPP. Tous les paiements, chaque mois

Le test. Chaque mois, un programme rapproche les paiements du fichier des agents en activité et signale tout paiement à une personne absente de ce fichier à la date du paiement. Le programme appartient à l'audit interne de l'ANPP, qui le fait tourner sur une copie des données.

Juin 2029. Le test signale 37 exceptions. Après examen : 29 sont justifiées (départs enregistrés avec retard, rappels de salaire dus), 6 sont des paiements indus, et 2 restent sans explication, les dossiers n'ayant pas été retrouvés.

Lecture auditologique · Les 37 exceptions de juin 2029

Constatation. 29 justifiées (OUI), 6 indues (NON), 2 sans explication (NEK) :

$$\mu \approx 0{,}78 \ ; \quad U \approx 0{,}05 \ ; \quad H \approx 0{,}276 + 0{,}426 + 0{,}228 \approx 0{,}93 \text{ bit.}$$

Analyse (confiance moyenne). La plupart des exceptions sont des faux positifs, et c'est normal : un test exhaustif signale tout ce qui s'écarte de la règle, y compris ce qui s'explique. Les six paiements indus sont des constats établis sur toute la population, plus solides que ceux qu'un échantillon de 40 aurait pu fournir. Les deux NEK sont l'objet même de l'audit : ce sont les cas où l'explication manque.

$\mu = 0{,}78$ · $U = 0{,}05$ · $H = 0{,}93$ **bit**

15.4.2 Les conditions et les limites

Papier de travail

Mettre en place un test d'audit continu. Le papier de travail décrit :

- la règle testée et son critère (texte, procédure) ;
- les sources de données, leur exhaustivité et leur qualité (le fichier des agents est-il à jour ? les paiements sont-ils tous extraits ?) ;
- le programme, sa version, et sa validation (essai sur des cas connus) ;
- la fréquence, le seuil d'exception et le circuit de traitement des exceptions ;
- qui détient le programme : l'audit interne, et non la direction auditée, pour préserver l'indépendance.

★ Attention

Violation typique. Confier le test d'audit continu à la direction qui exécute les paiements, puis lire l'absence d'exception comme une preuve.

Règle : un test d'audit continu ne vaut que par l'exhaustivité de ses données et l'indépendance de celui qui le fait tourner. Le même programme, géré par la direction, est un contrôle de premier ou de deuxième niveau (Chapitre 1), utile, mais qui ne remplace pas l'audit. Et trop d'exceptions non traitées finissent par ne plus être lues.

15.5 Ce que les Nouveaux Objets demandent à chaque Métier

Application Responsable GRC

Un registre des tiers

Tenir la liste des prestataires critiques, leur criticité, la preuve attendue de chacun et son statut. Y faire entrer ceux qui ne sont pas « informatiques », mais touchent à l'information.

Application Auditeur en cybersécurité

Lire un rapport d'assurance

Vérifier que le rapport de type 2 couvre le service utilisé, la période et le lieu des données ; repérer les mesures que le fournisseur attend du client (souvent listées dans le rapport) et les tester chez le client. Pour l'IA, demander les preuves d'entraînement, de validation et de surveillance du modèle.

Application RSSI

Encadrer les usages avant de les interdire

Un usage non déclaré de l'IA révèle un besoin. La RSSI propose une règle d'usage, une solution autorisée et une sensibilisation ; le blocage seul déplace l'usage ailleurs.

Application Gestionnaire des risques cyber

Faire entrer l'IA dans le registre

Chaque système d'IA en usage est inventorié, avec son propriétaire, ses données, son fournisseur et ses scénarios de risque : fuite, manipulation, erreur, biais.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Les tiers** sont une porte d'entrée, un risque de défaillance et une chaîne ; le risque reste celui de l'organisation.
- **Le cycle de vie d'un tiers** : sélection, contrat, exploitation, sortie, avec une preuve à chaque étape.
- **Dans le nuage**, les identités et les données restent toujours au client ; le rapport du fournisseur ne couvre que sa part.
- **L'IA** ajoute fuite, manipulation, erreur opaque et biais ; ISO/IEC 42001 et le NIST AI RMF l'encadrent.
- **L'audit continu** examine toute la population ; il vaut par l'exhaustivité des données et l'indépendance de son exploitant.

Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- répartir une mesure entre fournisseur et client pour un service donné ;
- dire ce qu'un rapport d'assurance prouve et ce qu'il laisse au client ;
- apprécier un usage de l'IA sous forme de fiche de risque ;
- concevoir un test d'audit continu et ses conditions de validité.

Exercices

Exercice 15.1. Qui en répond ? ★☆☆

La messagerie de la BANQUE SANAGA est un service en nuage de type logiciel (SaaS). Pour chacune des tâches suivantes, dites si elle revient à NUAGEPRO ou à la banque.

(a) Appliquer les correctifs du système d'exploitation des serveurs.

(b) Activer le second facteur pour les agents.

(c) Désactiver le partage externe des documents.

(d) Protéger physiquement le centre de données.

(e) Désactiver le compte d'un agent parti.

(f) Conserver les journaux d'accès selon la loi.

Exercice 15.2. Le contrat de FRAUDSCAN ★★☆

(a) Rédigez cinq clauses de sécurité pour le contrat du modèle de détection de fraude, en couvrant les quatre étapes du cycle de vie d'un tiers.

(b) Ajoutez deux clauses propres à l'IA (données d'entraînement, surveillance des performances).

(c) Quelles preuves la banque devra-t-elle obtenir chaque année pour lever les trois NEK du modèle ?

Exercice 15.3. L'IA chez LiZbiZ ★★☆

LiZbiZ envisage un modèle qui optimise les tournées de livraison à partir des données de suivi des expéditions et des adresses des clients.

(a) Identifiez deux scénarios de risque propres à l'IA, et rédigez la fiche de l'un d'eux.

(b) Placez les actions de LiZbiZ dans les quatre fonctions du NIST AI RMF.

(c) PHARMACAM demande si ce modèle « est conforme à l'ISO/IEC 42001 ». Que

répondez-vous ?

✍ Exercice 15.4. Un audit continu des ajustements de stock ★★★

Le cours ACSI a établi que 148 millions FCFA d'ajustements de stock, dont 71 % en fin de mois, avaient été enregistrés sous le compte de M. FOUDA à Douala.

(a) Concevez un test d'audit continu qui aurait signalé ces ajustements : règle, données, seuils, fréquence.

(b) Rédigez le papier de travail de mise en place (exhaustivité, validation, indépendance).

(c) Lors du premier mois, le test signale 120 exceptions. Comment éviter que les exceptions ne soient plus lues, sans perdre les vraies anomalies ?

(d) Un mois, 80 exceptions sont justifiées, 15 confirmées comme anormales, 5 sans explication. Calculez μ, U et H, et dites ce que chaque catégorie appelle.

Note

Pour aller plus loin.

- L'ISO/IEC 27002:2022 [41], mesures 5.19 à 5.23.
- L'ISO/IEC 27017 [34] et l'ISO/IEC 27018 [37].
- L'ISO/IEC 42001:2023 [43] et le NIST AI RMF [59].

Note

Transition. Tiers opaques, modèles qui apprennent, populations entières analysées : à chaque fois, la question de l'auditeur est la même : que sait-on, et que ne sait-on pas ? La Partie VI, consacrée à la recherche, montre comment l'auditologie fait de cette question un objet de mesure. C'est le Chapitre 16.

partie VI

Recherche : Mesurer ce que l'on ne Sait pas

© *MaletYon*

16

MESURER CE QUE L'ON NE SAIT PAS

« Distinguer ce que l'on sait,
ce que l'on a déposé, et ce qui reste à prouver. »

Règle du chapitre

Niveau : *Recherche* • Maîtrise du Chapitre 7

✦ Objectifs du chapitre

- ➢ Présenter l'auditologie : son objet, ses six axiomes, ses cinq piliers et sa méthode (article A0).
- ➢ Approfondir l'instrument OUI / NON / NEK et ses métriques (article A1), et les appliquer au risque et à l'audit cyber.
- ➢ Décomposer l'entropie en ignorance et en désaccord, et comparer deux cycles par la divergence de Kullback-Leibler.
- ➢ Comprendre l'usage stratégique de NEK et ses limites.
- ➢ Distinguer ce qui est établi, ce qui est déposé et ce qui est en préparation.
- ➢ Formuler un sujet de projet ou de mémoire falsifiable.

Avant de commencer : que vaut ce que nous avons mesuré ?

Depuis le prologue, le cours a calculé des dizaines de valeurs de μ, U et H : sur les contrôles d'une banque, la base de preuve d'un registre, les critères d'un écosystème, les obligations d'un organisme public. Il a répété une règle : on ne lit jamais une mesure seule, et l'on dit toujours ce que l'on ignore.

Ce dernier chapitre change de point de vue. Il ne demande plus « que conclure sur la BANQUE SANAGA ? », mais « d'où viennent ces mesures, que valent-elles, et que reste-t-il à établir ? ». Il présente le programme de recherche dont le cours est l'application, l'*auditologie*, en distinguant soigneusement ce qui est publié, ce qui est en préparation, et ce qui n'est encore qu'une question.

© *MaletYon*

★ Attention

Règle du chapitre. Une affirmation de recherche se cite avec son statut : établie (théorème, résultat reproduit), déposée (prépublication non encore évaluée par les pairs), en préparation (non publiée), ou question ouverte. Le cours applique à son propre fondement l'exigence qu'il fait à l'auditeur : séparer ce que l'on sait de ce que l'on suppose.

16.1 L'Auditologie

16.1.1 L'objet

L'article A0 part d'un constat : l'audit des systèmes d'information dispose de méthodes et de référentiels, mais d'aucun socle axiomatique ni d'aucun espace de mesure unifié pour son objet central, la réduction de l'incertitude [57].

■ Définition

Mission auditologique (A0) : quintuplet $\mathcal{M} = \langle \mathcal{S}, \mathcal{A}, \mathcal{I}, \mathcal{G}, \mathcal{T} \rangle$, où $\mathcal{S}$ est le système audité, $\mathcal{A}$ l'architecture cognitive de l'auditeur, $\mathcal{I}$ le canal d'information par lequel les preuves parviennent à l'auditeur, $\mathcal{G}$ la structure stratégique de l'interaction entre auditeur, audité et tiers, et $\mathcal{T}$ la trajectoire du système au fil des missions.

Auditologie : science appliquée de la réduction de l'incertitude sur les missions auditologiques.

	Composante	Dans la mission de Mme EKAMBI (mars 2028)
$\mathcal{S}$	Système audité	Les 38 agences, leurs postes, réseaux, agents, et les prestataires qui y interviennent
$\mathcal{A}$	Architecture cognitive	L'équipe d'audit, sa décomposition en six sous-domaines, ses huit tests
$\mathcal{I}$	Canal d'information	Extractions, essais, exercices ; et ce qui ne passe pas : les configurations des GAB
$\mathcal{G}$	Structure stratégique	Comité des risques, RSSI, DSI, direction du réseau d'agences, prestataire des GAB
$\mathcal{T}$	Trajectoire	Prologue (2026), mission de 2028, suivi

Tableau 16.1. Une mission du cours comme mission auditologique

16.1.2 Six axiomes

L'article A0 pose six axiomes, dont le cours a appliqué les conséquences depuis le prologue. Les énoncés sont ceux de l'article.

Axiome 1 (Observabilité partielle)**.** Pour tout système audité $\mathcal{S}$ non dégénéré, l'auditeur n'a accès qu'à un sous-ensemble strict des états pertinents de $\mathcal{S}$, et ce sous-ensemble est lui-même partiellement opaque.

Axiome 2 (Cognition limitée des agents)**.** L'auditeur et l'audité sont des agents cognitivement limités, au sens de Simon, de Miller et de Kahneman [49], [54], [66].

Axiome 3 (Mesurabilité de l'incertitude épistémique)**.** L'incertitude épistémique de $\mathcal{A}$ concernant des propositions spécifiques sur $\mathcal{S}$ admet une mesure quantitative, définissable par l'entropie informationnelle et ses généralisations.

Axiome 4 (Interaction stratégique)**.** L'auditeur et l'audité ont des fonctions d'utilité distinctes, et leurs actions sont, en général, mieux modélisées comme des mouvements dans un jeu à information imparfaite et asymétrique.

Axiome 5 (Individuation temporelle)**.** Le système audité $\mathcal{S}$ évolue dans le temps, et sa trajectoire est dépendante du chemin : l'état à la mission $n+1$ dépend de l'état à n et des interventions déclenchées par cette mission antérieure.

Axiome 6 (Opposabilité)**.** Toute conclusion produite par une mission auditologique doit, en principe, pouvoir être défendue devant un tiers disposant de l'autorité légitime pour la contester.

Axiome	Où le cours l'a rencontré
Observabilité partielle	Le certificat ne voit que son périmètre (prologue) ; les GAB que l'on ne peut pas voir (Chapitre 6)
Cognition limitée	La borne de sept et la décomposition (Chapitre 7)
Mesurabilité	μ, U, H dans chaque chapitre
Interaction stratégique	Les pressions sur l'auditeur (Chapitre 10) ; l'attaquant qui s'adapte (Chapitre 2)
Individuation temporelle	Les passages successifs de LiZbiZ (Chapitre 12) ; la correction qui ne réécrit pas le passé (Chapitre 6)
Opposabilité	Le papier de travail, la preuve de rang 1, la citation vérifiée

Tableau 16.2. Les axiomes dans le cours

A0 en tire quatre conséquences, que le cours a mises en pratique : un instrument d'audit doit comporter une modalité explicite de connaissance insuffisante (NEK) ; un espace d'audit non trivial doit être décomposé en respectant la borne cognitive ; les conclusions ne se testent que par l'observation longitudinale ; et l'audit fait lui-même partie de la trajectoire du système qu'il observe.

16.1.3 Cinq piliers et une méthode

Les axiomes disent ce qu'est une mission ; cinq piliers théoriques permettent de la modéliser : la cognition limitée, la théorie de l'information [50], [65], la théorie des jeux, les systèmes dynamiques [62] et l'ontologie critique-réaliste [4]. L'auditologie se veut une science du design [19] : elle construit des artefacts (instruments, métriques, grilles) et les évalue dans leur environnement. Elle adopte enfin le falsificationnisme de Lakatos [51] : un noyau dur (axiomes et piliers) et une ceinture protectrice d'hypothèses et de prédictions testables, qui peuvent être réfutées.

16.2 L'Instrument et ses Métriques

16.2.1 Quatre conditions pour nek

L'article A1 formalise l'instrument trichotomique [56]. Pour chaque question q, l'espace des réponses est $\Omega_q = \{\text{OUI}, \text{NON}, \text{NEK}\}$, et A1 précise quatre conditions qui distinguent un NEK légitime d'un mauvais usage.

Condition (A1)	Sens	Dans le cours
C1. Spécificité de l'objet	NEK porte sur l'objet précis de la question	Questions atomiques (Chapitre 7)
C2. Asymétrie d'accès	L'information existe, mais le répondant n'y a pas accès	Le visa de l'Agence, les configurations des GAB
C3. Non-report	Si l'on peut vérifier dans le délai, on répond	Les NEK levés avant l'audit de l'ANTIC (Chapitre 10)
C4. Neutralité	Aucun barème ne rend NEK équivalent à OUI ou à NON	Pas de « demi-point »

Tableau 16.3. Les conditions de la réponse NEK (d'après A1)

16.2.2 Décomposer l'entropie

L'entropie trichotomique mêle deux sources de dispersion : l'ignorance, et le désaccord entre ce que l'on sait. La propriété de groupement de l'entropie [65] les sépare exactement. En notant $H_b(x) = -x \log_2 x - (1-x)\log_2(1-x)$ l'entropie binaire :

$$H \;=\; H_b(U) \;+\; (1-U)\, H_b\!\left(\frac{\mu}{1-U}\right).$$

Le premier terme est la part de l'ignorance ; le second, pondéré par la part de ce qui est connu, est la part du désaccord entre OUI et NON.

⚖ Lecture auditologique · Ignorance ou désaccord ? Cinq mesures du cours

Ensemble	O/N/K	U	$H_b(U)$	Désacc.	H	Ignor.
Agences, prologue	2/4/4	0,40	0,97	0,55	1,52	64 %
Registre 2025 (Chap. 2)	6/2/4	0,33	0,92	0,54	1,46	63 %
Déclaration d'applicabilité (Chap. 8)	3/3/3	0,33	0,92	0,67	1,58	58 %
Mission de mars 2028 (Chap. 6)	3/3/2	0,25	0,81	0,75	1,56	52 %
Infrastructure LiZbiZ 2028 (Chap. 12)	14/4/2	0,10	0,47	0,69	1,16	41 %

Constatation. Les cinq ensembles ont une entropie proche de 1,5 bit, sauf le dernier ; mais la part de l'ignorance décroît de 64 % à 41 % à mesure que le cours avance dans le temps et que les preuves s'accumulent.

Analyse (confiance élevée sur le calcul, faible sur la tendance : les ensembles mesurés ne sont pas identiques). Une même entropie peut appeler deux actions opposées : chercher la preuve quand l'ignorance domine, chercher la cause du désaccord quand elle ne domine plus. La décomposition rend quantitative la règle « H élevé, U faible » du Chapitre 7.

16.2.3 Comparer deux cycles

L'article A1 propose de comparer deux cycles par la **divergence de Kullback-Leibler** [50], calculée dans le sens du temps :

$$D_{\mathrm{KL}}\left(p^{(t+1)} \,\middle\|\, p^{(t)}\right) = \sum_{m} p^{(t+1)}(m) \log_2 \frac{p^{(t+1)}(m)}{p^{(t)}(m)}.$$

Elle vaut zéro si la distribution n'a pas changé. Elle exige que toute modalité observée au cycle $t+1$ l'ait été au cycle t.

🔍 Scénario Opérationnel · Opération LIZBIZ. L'infrastructure entre 2026 et 2028

Calcul. En 2026 : (0,40 ; 0,45 ; 0,15) ; en 2028 : (0,70 ; 0,20 ; 0,10).

$$D_{\mathrm{KL}} = 0{,}7 \log_2 \tfrac{0{,}7}{0{,}4} + 0{,}2 \log_2 \tfrac{0{,}2}{0{,}45} + 0{,}1 \log_2 \tfrac{0{,}1}{0{,}15} \approx 0{,}565 - 0{,}234 - 0{,}059 \approx 0{,}27 \text{ bit}.$$

Analyse (confiance moyenne). Le changement est net, porté surtout par le passage de NON à OUI. Mais A0 rappelle que deux cycles ne distinguent pas encore une

amélioration réelle d'un artefact de mesure : les exports de 2028 ne couvrent pas exactement les mêmes équipements qu'en 2026. C'est l'objet des travaux sur la trajectoire (Section 16.4).

16.3 L'Usage Stratégique de nek

Un NEK est *authentique* s'il traduit une vraie limite de connaissance ; il est *stratégique* si le répondant sait, mais évite les conséquences d'une réponse nette. Pour une réponse isolée, les deux sont indiscernables. A1 propose de les distinguer sur le *profil* d'un répondant : l'ignorance authentique ne dépend pas, en moyenne, de l'enjeu de la question ; l'ignorance stratégique se concentre sur les questions à fort enjeu [56].

Pour chaque question q, un score d'enjeu $s_q \in [0,1]$ est fixé *avant* la collecte par des experts indépendants. Pour chaque répondant r, A1 estime un modèle logistique

$$\log \frac{\Pr[\text{NEK}_{r,q}=1]}{1-\Pr[\text{NEK}_{r,q}=1]} \;=\; \alpha_r + \beta_r\, s_q + \gamma_r^{\top}\mathbf{z}_q,$$

où $\mathbf{z}_q$ contient des variables de contrôle, et définit l'indice d'usage stratégique $\text{SUI}_r = \hat{\beta}_r$.

Scénario Opérationnel · Un atelier de cotation des risques

Lors d'un atelier de cotation, un directeur répond NEK à toutes les questions qui portent sur son propre périmètre et dont l'enjeu est élevé (acceptation d'un risque intolérable, défaut d'un prestataire qu'il a choisi), et répond nettement partout ailleurs. Le profil est celui que l'indice cherche à détecter ; il ne suffit pas à le calculer : il faut des scores d'enjeu fixés à l'avance par d'autres, et assez de questions par répondant.

★ Attention

Trois réserves d'A1, à ne jamais oublier.

1. Un indice positif signale une corrélation entre NEK et enjeu, qui peut avoir d'autres causes (questions plus difficiles, accès plus restreint).
2. Le score d'enjeu doit être fixé hors des répondants ; sinon, l'indice n'est pas identifié.
3. L'indice décrit une population, *pas* une faute individuelle : il n'établit pas l'intention et ne fonde aucune sanction (Chapitre 10, « constater n'est pas qualifier »).

16.4 Établi, Déposé, en Préparation

16.4.1 Les travaux en préparation

Quatre articles prolongent le programme. Ils ne sont pas publiés ; le cours les présente d'après leur objet, sans en citer de résultat comme acquis.

- **La trajectoire (A2)** : un score d'amélioration entre cycles, un descripteur topologique des trajectoires et une chaîne de Markov sur les niveaux de maturité, pour distinguer une amélioration réelle d'un artefact de mesure.
- **Le signalement stratégique (A3)** : l'interaction entre auditeur et audité comme un jeu de signalement, où NEK est un signal ; extension à l'audit de sécurité face à un attaquant.
- **La décomposition (A4)** : la justification formelle du gabarit canonique à huit niveaux, sous une borne cognitive et des conditions d'exhaustivité et de non-redondance.
- **L'instrument (A5)** : un outil logiciel qui génère les grilles à partir du gabarit et calcule les mesures en continu.

Élément	Statut	Ce qui reste à faire
Entropie, divergence, groupement	Établi (théorie de l'information)	·
Programme de l'auditologie (A0)	Prépublication HAL, 2026	Discussion par la communauté ; tests des prédictions
Instrument, métriques, indice d'usage stratégique (A1)	Prépublication HAL, 2026	Expérience comparant instruments binaire et trichotomique
A2, A3, A4, A5	En préparation	Dépôt, puis validation
Applications de ce cours au risque cyber (base de preuve des registres, couplage avec FAIR)	Questions ouvertes	Formulation et test (sujets ci-dessous)
Cas SANAGA, LiZbiZ, ANPP	Fictifs, pédagogiques	Ils illustrent ; ils ne prouvent rien

Tableau 16.4. Le statut de ce que le cours a présenté

16.4.2 Questions ouvertes pour le risque cyber

Ce cours a appliqué l'instrument à des objets que les articles ne traitent pas directement. Ces applications ouvrent des questions, que le cours ne tranche pas.

- **La base de preuve des registres** : coter OUI / NON / NEK la base de chaque cote d'un registre des risques (Chapitre 2) améliore-t-il les décisions de traitement ? Les registres dont U est élevé sont-ils suivis de plus d'incidents imprévus ?

- **Le couplage avec la quantification** : comment combiner la distribution des pertes de FAIR (incertitude aléatoire, sous hypothèses) et la cote des hypothèses (incertitude épistémique), au-delà de l'analyse de sensibilité du Chapitre 5 ?
- **L'écosystème** : la concentration des NEK sur la maturité et la confiance des parties prenantes (Chapitre 4) est-elle générale ? Que devient le niveau de menace quand on la prend en compte ?
- **Les tests automatiques** : un contrôle continu silencieux (Chapitre 13) doit-il voir sa cote se dégrader en NEK avec le temps, et à quel rythme ?

16.5 Formuler un Sujet de Recherche

Papier de travail

Un sujet de mémoire falsifiable. Un sujet recevable précise :

- la **question**, en une phrase, et l'axiome ou le pilier auquel elle se rattache ;
- une **hypothèse** énoncée de sorte que des données puissent la réfuter (« les registres dont $U \geq 0{,}30$ sont suivis de plus d'incidents non prévus que les autres ») ;
- les **données** : lesquelles, chez qui, avec quelle autorisation et quelle protection des personnes et des organisations (Chapitre 10) ;
- la **méthode** de mesure et de comparaison ;
- ce qui **réfuterait** l'hypothèse, écrit avant la collecte ;
- la **limite** principale, et la manière dont on la contrôle.

Note

Pourquoi le statut compte. L'auditologie s'applique à elle-même ce qu'elle demande aux auditeurs. Un cours qui présenterait comme acquis des travaux en préparation ferait exactement ce qu'il reproche au registre de 2025 : afficher une cote sans base. Un étudiant qui reprend ces travaux dans un mémoire cite les prépublications comme telles, et ne leur attribue que ce qu'elles contiennent.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **L'auditologie** étudie la réduction de l'incertitude sur une mission $\langle \mathcal{S}, \mathcal{A}, \mathcal{I}, \mathcal{G}, \mathcal{T} \rangle$, sous six axiomes.
- **L'instrument** OUI / NON / NEK suppose quatre conditions ; ses mesures se

lisent ensemble.

- **L'entropie se décompose** exactement en ignorance et en désaccord ; les deux appellent des actions différentes.
- **La divergence** compare deux cycles, sans distinguer encore progrès réel et artefact de mesure.
- **L'usage stratégique de nek** se lit sur un profil, avec trois réserves ; il ne fonde aucune sanction.
- **Tout n'a pas le même statut** : établi, déposé, en préparation, question ouverte.

Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- énoncer les six axiomes et dire où le cours les a appliqués ;
- décomposer une entropie et dire quelle action elle appelle ;
- calculer une divergence entre deux cycles et en dire la limite ;
- formuler une hypothèse de recherche réfutable.

Exercices

Exercice 16.1. Quel axiome ? ★☆☆

Associez chaque situation à l'axiome de A0 qu'elle illustre le mieux.

(a) Le prestataire des GAB refuse l'accès aux configurations.

(b) Une grille de 25 questions sans décomposition produit des oublis.

(c) La DSI corrige la journalisation pendant la mission ; le constat est maintenu pour la période.

(d) Un directeur répond NEK sur les questions qui engagent sa responsabilité.

(e) Chaque cote est accompagnée de la preuve qui permet de la défendre devant le comité ou le superviseur.

Exercice 16.2. Décomposer ★★☆

(a) Décomposez l'entropie de la base commune de l'ANPP (4/3/3, Chapitre 9) et du registre des obligations de la BANQUE SANAGA (7/2/3, Chapitre 13).

(b) Pour chacun, dites si l'action prioritaire est de chercher la preuve ou de chercher la cause d'un désaccord.

(c) Montrez, à partir de la formule, qu'une ignorance unanime donne $H = 0$.

✍ Exercice 16.3. Deux cycles ★★☆

(a) Calculez la divergence entre les agences de la BANQUE SANAGA au prologue (2/4/4) et lors de la mission de mars 2028 (3/3/2).

(b) Comparez-la à celle de l'infrastructure de LiZbiZ (0,27 bit).

(c) Pourquoi ces deux divergences ne sont-elles pas directement comparables ? Citez au moins deux raisons.

✍ Exercice 16.4. Un sujet de mémoire ★★★

Choisissez l'une des questions ouvertes de la Section 16.4 et rédigez un projet de sujet de mémoire d'une page, selon la procédure de la Section 16.5 : question, hypothèse réfutable, données et autorisations, méthode, condition de réfutation, limite principale. Dites quels travaux vous citez, et avec quel statut.

● Note

Pour aller plus loin.

- L'article *Vers l'auditologie* [57].
- L'article sur l'incertitude épistémique [56].
- Shannon [65] et Kullback et Leibler [50], pour les mesures.
- Lakatos [51] et Hevner et collègues [19], pour la méthode.

● Note

Pour conclure le cours. Le prologue s'ouvrait sur un certificat accroché au mur et des guichets fermés. Tout ce qui a suivi revient à une seule exigence : savoir ce que l'on sait, savoir ce que l'on ignore, et le dire à ceux qui décident. Les normes, les méthodes de risque, les audits et le droit en sont les instruments ; la mesure de l'inconnu en est la discipline.

A

GLOSSAIRE

Ce glossaire reprend, sous une forme abrégée, les définitions données dans les chapitres. Le numéro renvoie au chapitre où le terme est défini et illustré ; c'est là qu'il faut lire la définition complète.

Acceptation du risque Décision argumentée, prise par l'instance qui en a l'autorité, de ne pas traiter davantage un risque résiduel, pour une durée et à des conditions données (Ch. 3).

Appétence au risque Niveau de risque qu'une organisation accepte pour atteindre ses objectifs ; fixée par l'organe de direction (Ch. 1, 2).

Attributs de mesure Étiquettes associées à chaque mesure de l'ISO/IEC 27002:2022 (type, propriétés, concepts, capacités, domaines), qui permettent de trier les mesures (Ch. 8).

Audit Processus méthodique, indépendant et documenté, qui obtient des preuves et les évalue au regard de critères (Ch. 6).

Audit continu Analyse répétée de toute une population de données ou de transactions pour y détecter les anomalies (Ch. 15).

Auditologie Science appliquée de la réduction de l'incertitude sur les missions auditologiques (A0 ; Ch. 16).

Base commune de contrôles Liste de contrôles propres à l'organisation, chacun relié aux référentiels qui l'exigent ; testée une fois, projetée sur plusieurs référentiels (Ch. 9).

Base de preuve Ce sur quoi repose une cote : mesures internes, données externes, avis motivé, ou rien ; elle se cote elle-même OUI, NON ou NEK (Ch. 2).

Bien support Composant sur lequel repose une valeur métier : matériel, logiciel, réseau, personne, prestataire (Ch. 2).

Certificat Attestation, par un organisme tiers accrédité, qu'un système de management satisfait une norme, sur un périmètre et pour une durée donnés (Ch. 0).

Conclusion d'audit Résultat de l'audit, tiré de l'ensemble des constats, au regard des objectifs de la mission (Ch. 6).

© *MaletYon*

Conformité Satisfaction prouvée d'une exigence (norme, loi, contrat, politique) (Ch. 0, 1).

Constat d'audit Résultat de l'évaluation des preuves au regard des critères : conforme, non conforme, ou NEK (Ch. 6).

Contradictoire Présentation des constats à l'audité, qui peut contester un fait, apporter une preuve ou expliquer une cause (Ch. 6).

Contrôle continu de la conformité Test automatique et répété d'un contrôle par une extraction comparée à une règle (Ch. 13).

Couple SR/OV Association d'une source de risque et d'un objectif visé, dans EBIOS Risk Manager (Ch. 4).

Criticité Produit vraisemblance × impact, de 1 à 16 ; elle classe, elle ne décide pas (Ch. 2).

Critère d'audit Exigence de référence : norme, politique, loi, contrat, plan (Ch. 6).

Critères d'acceptation Règles, fixées à l'avance, qui disent quel résiduel peut être accepté, par qui, à quelles conditions (Ch. 3).

Déclaration d'applicabilité Document exigé par l'ISO/IEC 27001 qui recense les mesures nécessaires, justifie leur inclusion et l'exclusion des autres, et indique leur mise en œuvre (Ch. 8).

Divergence de Kullback-Leibler Mesure du changement de la distribution des réponses entre deux cycles (Ch. 16).

Échantillon raisonné Échantillon choisi selon les risques ; il trouve des défauts, il ne permet pas d'extrapoler un taux (Ch. 6).

Entropie Dispersion des réponses OUI, NON, NEK, en bits, de 0 à $\log_2 3$; elle se décompose en ignorance et désaccord (Ch. 7, 16).

Estimation calibrée Minimum, valeur la plus probable et maximum, choisis pour encadrer la vraie valeur avec une confiance d'environ 90 % (Ch. 5).

Événement redouté Atteinte à une valeur métier, exprimée du point de vue de l'organisation (Ch. 2).

Export figé Copie d'une configuration ou d'une liste, extraite à une date et scellée par une empreinte (Ch. 12).

FAIR Modèle de quantification du risque d'information : fréquence des événements de perte et ampleur des pertes (Ch. 5).

Fiche d'assertion Description d'un contrôle par son objectif, son critère, sa question, son risque et sa conséquence (Ch. 7).

Gabarit canonique Décomposition à huit niveaux : domaine, sous-domaine, processus, activité, contrôle, test, preuve, trace (A0 ; Ch. 7).

Gestion des risques Activités coordonnées pour identifier, analyser, évaluer, traiter et suivre les risques (Ch. 1, 3).

Gouvernance de la sécurité Responsabilités et pratiques par lesquelles l'organe de direction fixe les objectifs, le niveau de risque acceptable, les rôles, et surveille les résultats (Ch. 1).

GRC Gouvernance, risque et conformité pilotés comme un seul dispositif, avec un référentiel commun (Ch. 1, 13).

Incertitude aléatoire Part de l'incertitude qui tient au hasard des événements ; elle se décrit, elle ne se réduit pas (Ch. 2).

Incertitude épistémique Part de l'incertitude qui tient à ce que l'on ne sait pas ; elle se réduit par des preuves (Ch. 2).

Indicateur de risque Signal qui annonce un changement d'exposition, lu avec des seuils qui déclenchent une revue (Ch. 13).

Matrice RACI Tableau des rôles : réalise, répond, consulté, informé ; un seul A par activité (Ch. 1).

Matrice risques-contrôles Tableau qui croise contrôles et risques, avec la dernière cote de chaque contrôle (Ch. 13).

Menace Cause potentielle d'un incident (Ch. 2).

Mission auditologique Quintuplet $\langle \mathcal{S}, \mathcal{A}, \mathcal{I}, \mathcal{G}, \mathcal{T} \rangle$ (A0 ; Ch. 16).

Modèle des trois lignes Répartition des rôles entre organe de gouvernance, première ligne, deuxième ligne et audit interne (IIA, 2020 ; Ch. 1).

nek Réponse « connaissance insuffisante » : ni OUI, ni NON ; quatre conditions la rendent légitime (A1 ; Ch. 0, 16).

Non-conformité majeure Non-conformité qui affecte la capacité du système de management à atteindre ses résultats (Ch. 11).

Non-conformité mineure Non-conformité qui n'affecte pas cette capacité (Ch. 11).

Objectif visé Ce que la source de risque cherche à obtenir (Ch. 2, 4).

Organe de direction Personne ou groupe qui répond en dernier ressort de l'organisation : le conseil d'administration (Ch. 1).

Périmètre de complaisance Périmètre choisi pour faciliter la certification plutôt que pour couvrir les risques (Ch. 0).

Piste de progrès Constat qui n'est pas une non-conformité, mais une occasion d'améliorer (Ch. 11).

Preuve d'audit Information vérifiable et pertinente au regard des critères ; sa fiabilité se classe en cinq rangs (Ch. 6).

Propriétaire de risque Personne qui a la responsabilité et l'autorité de gérer un risque (Ch. 1).

Rapport d'assurance Rapport d'un auditeur indépendant sur les contrôles d'un prestataire (ISAE 3402, SOC 2) ; seul le type 2 dit s'ils ont fonctionné (Ch. 9).

Registre des obligations Liste des exigences qui s'imposent à l'organisation, avec leur source, leurs contrôles, leur preuve et leur statut (Ch. 13).

Risque Effet de l'incertitude sur les objectifs (ISO 31000 ; Ch. 2).

Risque cyber Risque dont la source est une action sur les systèmes ou les données, et dont les conséquences touchent les activités (Ch. 2).

Risque inhérent Niveau du risque avant les mesures (Ch. 2).

Risque résiduel Niveau du risque compte tenu des seules mesures dont l'efficacité est établie (Ch. 2).

Scénario opérationnel Suite d'actions élémentaires (connaître, rentrer, trouver, exploiter) qui réalise un scénario stratégique (Ch. 4).

Scénario stratégique Chemin d'attaque de haut niveau, d'un couple SR/OV à un événement redouté, éventuellement par l'écosystème (Ch. 4).

Sécurité effective Capacité réelle de l'organisation à résister aux attaques et à s'en relever (Ch. 0).

Simulation de Monte-Carlo Tirage d'un grand nombre d'années selon les estimations, pour obtenir la distribution des pertes (Ch. 5).

SMSI Système de management de la sécurité de l'information : politiques, processus, rôles et contrôles sur un périmètre, en amélioration continue (Ch. 0, 11).

Source de risque Élément, personne ou groupe susceptible d'engendrer le risque (Ch. 2).

Table de correspondance Tableau qui relie les exigences de deux référentiels, en qualifiant chaque lien (Ch. 9).

Taux de conformité (μ) Part des réponses OUI (Ch. 0, 7).

Taux d'incertitude (U) Part des réponses NEK (Ch. 0, 7).

Valeur métier Activité, processus ou information qui a de la valeur pour l'organisation (Ch. 2).

Vulnérabilité Faiblesse d'un bien support qu'une menace peut exploiter (Ch. 2).

B

RÉFÉRENTIEL DES OUTILS

Les outils ci-dessous sont des exemples courants, cités pour situer les tâches du cours. Aucun n'est imposé ; aucun ne remplace la méthode. Les versions et les licences sont à vérifier avant usage.

★ Attention

Règle. Tout outil qui interroge un réseau ou un système (scan, test d'accès, test d'intrusion) ne s'emploie qu'avec une autorisation écrite du responsable du système, et de l'hébergeur s'il y a lieu (Chapitre 12, loi n° 2010/012, article 69).

Gestion et quantification des risques

Tâche	Outils	Chap.
Registre, matrice, critères	Tableur partagé, à défaut d'un outil GRC	2, 13
Étude EBIOS Risk Manager	Modèle de tableur mis à disposition par l'ANSSI ; outils labellisés par l'ANSSI	4
Simulation de Monte-Carlo	Python (bibliothèque numpy) ou tableur ; le générateur `fair_sanaga_C05.py` de NDAP SUKULU	5
Mesures μ, U, H, D_{KL}	Tableur, Python	7, 16

Audit et audit technique

© *MaletYon*

Tâche	Outils	Chap.
Sceller un export	Calcul d'empreinte SHA-256 (`sha256sum`, `Get-FileHash`)	12
Comparer à une référence	Guides CIS Benchmarks et outil d'évaluation associé ; scripts de comparaison	12
Inventaire des services	Scanner de ports (par exemple Nmap)	12
Vulnérabilités	Scanner authentifié (par exemple Greenbone OpenVAS) ; calculateur CVSS du FIRST	12
Comptes et journaux	Extractions de l'annuaire et du collecteur de journaux ; tableur pour les rapprochements	6, 12
Audit continu	Scripts de rapprochement planifiés, détenus par l'audit	15

NDAP SUKULU

Les fiches d'auto-évaluation et les ateliers du cours sont accessibles sur NDAP SUKULU, sous le code MSN-2S3-SEC08. Ils s'appuient sur des pièces et des exports figés fictifs, générés pour le cours : aucun test n'y porte sur un système réel.

C

MODÈLES DE DOCUMENTS OPÉRATIONNELS

Cette annexe rassemble les rubriques des documents que le cours a construits. Chaque modèle renvoie au chapitre où il est expliqué et illustré.

Vue d'ensemble

N°	Document	Usage	Chap.
M1	Fiche de risque	Décrire, coter et décider un risque	2
M2	Décision d'acceptation	Accepter un résiduel selon les critères	3
M3	Ligne de plan de traitement	Planifier une action et sa preuve	3
M4	Ligne de déclaration d'applicabilité	Justifier une mesure	8
M5	Lettre de mission	Fixer objectifs, périmètre, critères, accès	6
M6	Note d'autorisation de test	Encadrer un test technique	12
M7	Papier de travail d'un test	Rendre un test refaisable	6
M8	Fiche d'assertion	Définir un contrôle et sa cote	7
M9	Observation en sept éléments	Rédiger une non-conformité	7
M10	Fiche d'indicateur	Définir un indicateur et sa fiabilité	11
M11	Page GRC de la gouvernance	Une page pour décider	13

M1. Fiche de risque

© MaletYon

Rubrique	Contenu attendu
Référence et intitulé	Code unique (R-XX-nn), scénario en une ligne
Valeur métier, biens supports	Ce que l'on protège, ce par quoi on est attaqué
Source de risque, objectif visé	Qui, pour quoi faire
Événement redouté	L'atteinte, du point de vue de l'organisation
Vraisemblance et impact	Cotes de 1 à 4, avec la base de preuve de chacune (OUI, NON, NEK)
Mesures existantes	Par étape du scénario, avec la preuve de leur test
Résiduel	Criticité selon la convention de réduction
Propriétaire, décision, revue	Qui répond, ce qui est décidé, quand on revoit

M2 et M3. Décision d'acceptation, plan de traitement

Rubrique	Contenu attendu
Décision d'acceptation	Risque, propriétaire, résiduel et base de preuve, mesures en place, décision (« accepté » ou « accepté en l'état des connaissances »), conditions, durée, date de revue, signatures
Ligne de plan	Action, risque et étape visés, responsable nommé, échéance, coût, preuve attendue, effet attendu sur la cote

M4. Ligne de déclaration d'applicabilité

Mesure (numéro et intitulé de l'ISO/IEC 27002:2022) ; incluse ou exclue ; justification (risque du registre ou obligation) ; mise en œuvre (oui, partielle, à vérifier) avec la référence de la preuve ; pour une exclusion, les faits vérifiés et l'approbation datée.

M5 et M6. Lettre de mission, note d'autorisation

Document	Rubriques
Lettre de mission	Commanditaire ; objectif ; périmètre et période ; critères ; équipe et indépendance ; accès aux systèmes, documents, personnes et prestataires ; destinataires du rapport
Note d'autorisation	Signataire habilité et accord de l'hébergeur ; périmètre inclus et exclu ; méthodes permises et interdites ; fenêtres ; contact et procédure d'arrêt ; confidentialité et destruction des résultats

M7. Papier de travail d'un test

Référence du test et critère ; population, échantillon et méthode de sélection ; technique et date ; preuves obtenues, rang de fiabilité et lieu de conservation (avec empreinte pour un export) ; résultat et cote, avec, pour un NEK, sa nature (preuve insuffisante ou limitation de l'étendue) ; auteur et réviseur.

M8 et M9. Fiche d'assertion, observation

Document	Rubriques
Fiche d'assertion	Position dans le gabarit ; objectif ; un critère et une question par condition (atomicité) ; test, preuve, trace ; risque ; conséquence
Observation	1. Norme ; 2. Constatation chiffrée, preuve et cote ; 3. Risques ; 4. Contradictoire daté ; 5. Analyse et confiance ; 6. Conclusion ; 7. Recommandations qui traitent la cause

M10 et M11. Indicateur, page GRC

Document	Rubriques
Fiche d'indicateur	Objectif servi ; famille (mise en œuvre, efficacité, risque) ; définition et formule ; source et collecte ; fréquence ; cible et seuils ; responsable ; cote de fiabilité de la source
Page GRC	1. Risques au-delà de l'appétence ; 2. Obligations ; 3. Contrôles clés ; 4. Indicateurs de risque ; 5. Ce que nous ne savons pas ; 6. Décisions demandées

D

TEXTES ET NORMES DE RÉFÉRENCE

Cette annexe rassemble les textes cités dans le cours, avec leur degré de vérification. Seuls les extraits lus dans leur version officielle sont reproduits entre guillemets (Chapitre 10).

Degré de vérification

Texte	Degré de vérification	Chapitres
Loi n° 2010/012 (cybersécurité)	Texte officiel lu ; extraits cités	1, 3, 6, 10, 12
Règlement COBAC R-2016/04	Art. 1 et 2 relevés, à collationner	1, 10
Convention de Malabo (2014)	Présentée ; statut camerounais à vérifier	10
Loi n° 2024/017 (données personnelles)	À vérifier au Journal officiel	1, 10, 15
Droit OHADA des sociétés	Présenté, à vérifier	10

Loi n° 2010/012 relative à la cybersécurité et à la cybercriminalité

Jurisprudence & Droit applicable

Article 4, point 9 : *« Audit de sécurité : examen méthodique des composantes et des acteurs de la sécurité, de la politique, des mesures, des solutions, des procédures et des moyens mis en oeuvre par une organisation, pour sécuriser son environnement, effectuer des contrôles de conformité, des contrôles d'évaluation de l'adéquation des moyens (organisationnels, techniques, humains, financiers) investis au regard des risques encourus, d'optimisation, de rationalité et de performance. »*

Article 7, alinéa 2 (extrait) : l'Agence a notamment pour mission *« de s'assurer de la régularité, de l'effectivité des audits de sécurité des systèmes d'information suivant les normes en la matière, des organismes publics et des autorités de certification ».*

Article 13, alinéa 1 : *« Sont soumis à un audit de sécurité obligatoire, les réseaux de communications électroniques et les systèmes d'information, des opérateurs, des autorités de certification et des fournisseurs de services de communications*

© MaletYon

électroniques. »

Article 14 : *« Le personnel de l'Agence et les experts commis en vue d'accomplir des opérations d'audit sont astreints au secret professionnel. »*

Article 26, alinéa 1 : *« Les exploitants des systèmes d'information prennent toutes les mesures techniques et administratives afin de garantir la sécurité des services offerts. A cet effet, ils se dotent de systèmes normalisés leur permettant d'identifier, d'évaluer, de traiter et de gérer continûment les risques liés à la sécurité des systèmes d'information dans le cadre des services offerts directement ou indirectement. »*

Article 29, alinéa 1 : *« Les exploitants des systèmes d'information ont l'obligation de conserver les données de connexion et de trafic de leurs systèmes d'information pendant une période de dix (10) ans. »*

Article 32, alinéas 1 à 3 : *« (1) Les réseaux de communications électroniques et les systèmes d'information sont soumis à un régime d'audit de sécurité obligatoire et périodique de leurs systèmes de sécurité par l'Agence. (2) L'audit de sécurité et les mesures d'impact de gravité sont effectués chaque année ou lorsque les circonstances l'exigent. (3) Les rapports d'audit sont confidentiels et adressés au Ministre chargé des Télécommunications. »*

Article 61, alinéa 1 : *« Sont punis d'un emprisonnement de trois (03) mois à trois (03) ans et d'une amende de 20.000 (vingt mille) à 100.000 (cent mille) F CFA, les personnels de l'Agence et les experts des personnes morales chargés des audits qui révèlent sans autorisation, des informations confidentielles dont ils ont eu connaissance à l'occasion d'un audit de sécurité. »*

Article 69 : *« Est puni d'un emprisonnement de cinq (05) à dix (10) ans et d'une amende de 10.000.000 (dix millions) à 100.000.000 (cent millions) F CFA ou de l'une de ces deux peines seulement, celui qui accède sans droit, et en violation des mesures de sécurité, à l'ensemble ou à une partie d'un réseau de communications électroniques, d'un système d'information ou d'un équipement terminal, afin d'obtenir des informations ou des données, en relation avec un système d'information connecté à un autre système d'information. »*

Résumés (texte officiel lu, non cité) : article 26, alinéas 2 et 3 (mécanismes de sécurité visés par l'Agence) ; article 29, alinéa 2 (surveillance des accès aux données) ; article 30, alinéa 1 (évaluation et révision des systèmes de sécurité) ; article 61, alinéa 3 (obstacle aux audits) ; article 70 (attaque par saturation).

Règlement COBAC R-2016/04

⚖ Jurisprudence & Droit applicable

Texte relevé sur une base réglementaire en ligne, à collationner avec la version du Secrétariat général de la COBAC :

Article 1 : *« Le présent règlement fixe les exigences minimales relatives au système de contrôle interne que les établissements assujettis doivent mettre en œuvre. »*

Article 2, risque opérationnel : *« risque de pertes résultant de l'inadéquation ou de la défaillance des processus internes, des personnes et des systèmes, ou d'évènements externes. »*

Normes et cadres

Norme ou cadre	Statut dans le cours	Chap.
ISO 31000:2018	Paraphrasée	2, 3
ISO/IEC 27000:2018	Paraphrasée ; édition vérifiée	1
ISO/IEC 27001:2022 et amendement 1:2024	Paraphrasée ; éditions vérifiées	8, 11
ISO/IEC 27002:2022	Paraphrasée ; édition vérifiée ; répartition des mesures à confirmer	8
ISO/IEC 27004, 27005, 27007, 27014, 27017, 27018	Paraphrasées	1 à 15
ISO 19011:2018, ISO/IEC 17021-1:2015	Paraphrasées	6, 11
ISO/IEC 42001:2023, NIST AI RMF	Présentés	15
EBIOS Risk Manager (ANSSI)	Ateliers vérifiés sur le site de l'ANSSI ; quatre détails à confirmer dans le guide	4
Open FAIR (O-RT 3.0.1, O-RA 2.0.1)	Versions vérifiées	5
NIST CSF 2.0, SP 800-30, 800-53, 800-53A	Présentés	1, 9
CIS Controls v8, CIS Benchmarks, PCI DSS v4.0, CVSS v4.0	Présentés	9, 12

E

BIBLIOGRAPHIE COMMENTÉE

Pour chaque partie, quelques lectures, avec ce qu'elles apportent. Les références complètes figurent dans la bibliographie du livre. Les textes de l'auteur sont des prépublications ; les travaux en préparation ne sont pas cités.

Pour commencer

- **Le programme de l'auditologie** [57] : objet, axiomes, piliers et méthode ; à lire après le prologue, et à relire avec le Chapitre 16.
- **L'instrument trichotomique** [56] : la réponse NEK, ses conditions, les mesures et l'indice d'usage stratégique.

Partie I · Fondements

- L'IIA, le modèle des trois lignes [69] : la répartition des rôles, en une dizaine de pages.
- L'ISO/IEC 27014 [39] et la fonction *Gouverner* du NIST CSF 2.0 [60] : la gouvernance de la sécurité.
- L'ISO 31000 [31] : le vocabulaire du risque.
- Cox, sur les matrices de risque [14] : ce que les couleurs cachent.

Partie II · Méthodes

- L'ISO/IEC 27005:2022 [42] : le processus appliqué à la sécurité de l'information.
- Le guide EBIOS Risk Manager de l'ANSSI [2] et ses fiches méthodes : la méthode et ses ateliers.
- Freund et Jones [17] : l'exposé de référence de FAIR ; Hubbard et Seiersen [20] : le calibrage des experts.
- L'ISO 19011 [30] et le NIST SP 800-53A [47] : les principes de l'audit et les méthodes d'évaluation.

Partie III · Cadre normatif et juridique

- L'ISO/IEC 27001:2022 [40] et l'ISO/IEC 27002:2022 [41] : à lire ensemble, l'une pour les exigences, l'autre pour les mesures.
- Les CIS Controls [5] : une hygiène de base priorisée.

- La loi n° 2010/012 [53], dans son texte officiel, et le règlement COBAC R-2016/04 [8].
- Les normes de l'IIA [70] et le code de l'IESBA [24] : la déontologie.

Partie IV · Pratique

- L'ISO/IEC 27007 [38] et l'ISO/IEC 27004 [35] : auditer et mesurer un SMSI.
- Les CIS Benchmarks [6] et la spécification CVSS 4.0 [16] : l'audit technique.

Parties V et VI · Défis avancés et recherche

- L'ISO/IEC 42001 [43] et le NIST AI RMF [59] : les cadres de l'IA.
- L'ISO/IEC 27017 [34] : la sécurité du nuage.
- Shannon [65], Kullback et Leibler [50], Lakatos [51] : les fondements des mesures et de la méthode.

F

CONTACTS ET RESSOURCES

Les adresses ci-dessous sont celles des sites institutionnels à la date de rédaction ; elles peuvent changer et sont à vérifier avant usage.

Autorités et institutions camerounaises et régionales

Institution	Rôle dans le cours	Site
ANTIC	Régulation de la sécurité électronique, audits de sécurité (loi n° 2010/012)	`www.antic.cm`
MINPOSTEL	Destinataire des rapports d'audit de sécurité (art. 32)	`www.minpostel.gov.cm`
COBAC (Secrétariat général)	Contrôle interne des établissements de crédit de la CEMAC	`www.sgcobac.org`
Chambre des comptes de la Cour suprême	Contrôle juridictionnel des comptes publics	·
Union africaine	Convention de Malabo	`au.int`

Organisations normatives et professionnelles

Organisation	Ressources	Site
ISO	Normes ISO et ISO/IEC	`www.iso.org`
ANSSI (France)	EBIOS Risk Manager, fiches méthodes	`cyber.gouv.fr`
NIST	CSF 2.0, SP 800-30, 800-53, AI RMF	`www.nist.gov`
The Open Group	Normes Open FAIR	`www.opengroup.org`
Center for Internet Security	CIS Controls, CIS Benchmarks	`www.cisecurity.org`
FIRST	Spécification et calculateur CVSS	`www.first.org`
IIA	Normes mondiales d'audit interne, modèle des trois lignes	`www.theiia.org`
ISACA	COBIT, ITAF, certifications	`www.isaca.org`

© *MaletYon*

Recherche

Les articles A0 (`hal-05701007`) et A1 (`hal-05701270`) sont déposés sur l'archive ouverte HAL (`hal.science`). Les travaux en préparation y seront déposés à leur tour.

NDAP SUKULU

Les fiches d'auto-évaluation et les ateliers du cours sont disponibles sur NDAP SUKULU, sous le code MSN-2S3-SEC08. NDAP SUKULU est une propriété de MaletYon, mise à la disposition des étudiants et des praticiens souhaitant se perfectionner : `maletyon@proton.me`.

RÉFÉRENCES BIBLIOGRAPHIQUES

[1] *Acte uniforme relatif au droit des sociétés commerciales et du groupement d'intérêt économique (révisé)*, Journal officiel de l'OHADA, numéro spécial du 4 février 2014, 30 jan. 2014.

[2] Agence nationale de la sécurité des systèmes d'information, *EBIOS Risk Manager – Le guide*, Publié le 9 octobre 2018 ; version 1.5 de mars 2024, ANSSI, Paris, 2018.

[3] American Institute of Certified Public Accountants, *Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy*, AICPA, 2017.

[4] R. Bhaskar, *A Realist Theory of Science*. Leeds : Leeds Books, 1975.

[5] Center for Internet Security, *CIS Critical Security Controls, Version 8*, Révision 8.1 publiée en 2024, CIS, East Greenbush, NY, 2021.

[6] Center for Internet Security. « CIS Benchmarks. » Guides de configuration par produit, profils de niveau 1 et 2. (2026), adresse : https://www.cisecurity.org/cis-benchmarks (visité le 06/11/2026).

[7] Comité d'harmonisation de l'audit interne (CHAI), *Guide d'audit des systèmes d'information*, Version 1.0, Guide élaboré par un groupe de travail interministériel ; copie dans le dossier Normes, juin 2014.

[8] Commission bancaire de l'Afrique centrale, *Règlement COBAC R-2016/04 relatif au contrôle interne dans les établissements de crédit et les holdings financières*, Secrétariat général de la COBAC, 2016. adresse : http://www.sgcobac.org.

[9] Committee of Sponsoring Organizations of the Treadway Commission, *Le management des risques de l'entreprise : cadre de référence, synthèse*, Version française du résumé de l'édition 2004, COSO, 2004.

[10] Committee of Sponsoring Organizations of the Treadway Commission, *Enterprise Risk Management: Integrating with Strategy and Performance*, COSO, 2017.

[11] Committee of Sponsoring Organizations of the Treadway Commission (COSO), *Internal control – integrated framework*, COSO, 2013.

[12] *Convention de l'Union africaine sur la cybersécurité et la protection des données à caractère personnel*, Adoptée à Malabo ; entrée en vigueur en 2023. État de signature et de ratification par le Cameroun à vérifier, 27 juin 2014.

[13] COSO et Association of Certified Fraud Examiners (ACFE), *Fraude : guide de gestion du risque de fraude – synthèse*, Traduction française de la synthèse ; copie dans le dossier Normes, COSO, ACFE, déc. 2016.

[14] L. A. Cox, « What's Wrong with Risk Matrices? » *Risk Analysis*, t. 28, nº 2, p. 497-512, 2008.

[15] D. R. Cressey, *Other People's Money: A Study in the Social Psychology of Embezzlement*. Glencoe (Illinois) : Free Press, 1953.

[16] Forum of Incident Response and Security Teams, *Common Vulnerability Scoring System, Version 4.0: Specification Document*, FIRST, 2023.

[17] J. Freund et J. Jones, *Measuring and Managing Information Risk: A FAIR Approach*. Oxford : Butterworth-Heinemann, 2015.

[18] J. C. Harsanyi, « Games with Incomplete Information Played by "Bayesian" Players. Part I–III, » *Management Science*, t. 14, nº 3, 5, 7, p. 159-182, 320-334, 486-502, 1967.

[19] A. R. Hevner, S. T. March, J. Park et S. Ram, « Design Science in Information Systems Research, » *MIS Quarterly*, t. 28, nº 1, p. 75-105, 2004.

[20] D. W. Hubbard et R. Seiersen, *How to Measure Anything in Cybersecurity Risk*. Hoboken : Wiley, 2016.

[21] Initiative de Développement de l'INTOSAI, *Audit de conformité : manuel de mise en œuvre des ISSAI, version 1*, IDI, Oslo, 2021.

[22] International Auditing and Assurance Standards Board, *ISAE 3402: Assurance Reports on Controls at a Service Organization*, IFAC, 2011.

[23] International Auditing and Assurance Standards Board, *ISA 315 (Revised 2019): Identifying and Assessing the Risks of Material Misstatement*, IFAC, 2019.

[24] International Ethics Standards Board for Accountants, *Handbook of the International Code of Ethics for Professional Accountants*, IFAC, New York, 2023.

[25] INTOSAI, *GUID 5100 : Lignes directrices sur la vérification des systèmes d'information*, Organisation internationale des institutions supérieures de contrôle des finances publiques, 2019.

[26] ISACA, *COBIT 2019 Framework: Governance and Management Objectives*, ISACA, Schaumburg, IL, 2018.

[27] ISACA, *COBIT 2019 Framework: Introduction and Methodology*, ISACA, Schaumburg, IL, 2018.

[28] ISACA, *ITAF: A Professional Practices Framework for IS Audit/Assurance, 4th edition*, ISACA, Schaumburg, IL, 2020.

[29] ISO, *ISO 22301:2019 – Security and resilience – Business continuity management systems – Requirements*, Genève : ISO, 2019.

[30] *ISO 19011:2018 – Lignes directrices pour l'audit des systèmes de management*, Troisième édition ; l'édition de 2011 comptait six principes, celle de 2018 en compte sept, Organisation internationale de normalisation, 2018.

[31] *ISO 31000:2018 – Management du risque – Lignes directrices*, Organisation internationale de normalisation, 2018.

[32] ISO/IEC, *ISO/IEC 27037:2012 – Information technology – Security techniques – Guidelines for identification, collection, acquisition and preservation of digital evidence*, Genève : ISO, 2012.

[33] ISO/IEC, *ISO/IEC 17021-1:2015 – Conformity assessment – Requirements for bodies providing audit and certification of management systems – Part 1: Requirements*, Genève : ISO, 2015.

[34] ISO/IEC, *ISO/IEC 27017:2015 – Information technology – Security techniques – Code of practice for information security controls based on ISO/IEC 27002 for cloud services*, Genève : ISO, 2015.

[35] ISO/IEC, *ISO/IEC 27004:2016 – Information technology – Security techniques – Information security management – Monitoring, measurement, analysis and evaluation*, Genève : ISO, 2016.

[36] ISO/IEC, *ISO/IEC 27000:2018 – Technologies de l'information – Techniques de sécurité – Systèmes de management de la sécurité de l'information – Vue d'ensemble et vocabulaire*, Genève : Organisation internationale de normalisation, 2018.

[37] ISO/IEC, *ISO/IEC 27018:2019 – Information technology – Security techniques – Code of practice for protection of personally identifiable information (PII) in public clouds acting as PII processors*, Genève : ISO, 2019.

[38] ISO/IEC, *ISO/IEC 27007:2020 – Information security, cybersecurity and privacy protection – Guidelines for information security management systems auditing*, Genève : ISO, 2020.

[39] ISO/IEC, *ISO/IEC 27014:2020 – Sécurité de l'information, cybersécurité et protection de la vie privée – Gouvernance de la sécurité de l'information*, Genève : Organisation internationale de normalisation, 2020.

[40] ISO/IEC, *ISO/IEC 27001:2022 – Information security, cybersecurity and privacy protection – Information security management systems – Requirements*, Genève : ISO, 2022.

[41] ISO/IEC, *ISO/IEC 27002:2022 – Information security, cybersecurity and privacy protection – Information security controls*, Genève : ISO, 2022.

[42] ISO/IEC, *ISO/IEC 27005:2022 – Sécurité de l'information, cybersécurité et protection de la vie privée – Préconisations pour la gestion des risques liés à la sécurité de l'information*, Genève : Organisation internationale de normalisation, 2022.

[43] ISO/IEC, *ISO/IEC 42001:2023 – Information technology – Artificial intelligence – Management system*, Genève : ISO, 2023.

[44] *ISO/IEC 27005:2018 – Technologies de l'information – Techniques de sécurité – Gestion des risques liés à la sécurité de l'information*, Édition présente dans le dossier Normes ; remplacée par l'édition de 2022, ISO/IEC, 2018.

[45] IT Governance Institute, *COBIT 4.1 : cadre de référence, objectifs de contrôle, guide de management, modèles de maturité*, IT Governance Institute, 2007.

[46] Joint Task Force, « Security and Privacy Controls for Information Systems and Organizations, » National Institute of Standards et Technology, Special Publication 800-53, Revision 5, 2020.

[47] Joint Task Force, « Assessing Security and Privacy Controls in Information Systems and Organizations, » National Institute of Standards et Technology, Special Publication 800-53A, Revision 5, 2022.

[48] Joint Task Force Transformation Initiative, « Guide for Conducting Risk Assessments, » National Institute of Standards et Technology, Special Publication 800-30, Revision 1, 2012.

[49] D. Kahneman, *Thinking, Fast and Slow*. Farrar, Straus et Giroux, 2011.

[50] S. Kullback et R. A. Leibler, « On Information and Sufficiency, » *The Annals of Mathematical Statistics*, t. 22, n° 1, p. 79-86, 1951.

[51] I. Lakatos, « Falsification and the Methodology of Scientific Research Programmes, » in *Criticism and the Growth of Knowledge*, I. Lakatos et A. Musgrave, éd., Cambridge University Press, 1970, p. 91-196.

[52] B. Latour, *Reassembling the Social: An Introduction to Actor-Network-Theory*. Oxford University Press, 2005.

[53] *Loi n° 2010/012 du 21 décembre 2010 relative à la cybersécurité et la cybercriminalité au Cameroun*, Version anglaise officielle : Law No. 2010/012 of 21 December 2010 relating to cybersecurity and cybercriminality in Cameroon, 21 déc. 2010.

[54] G. A. Miller, « The Magical Number Seven, Plus or Minus Two: Some Limits on Our Capacity for Processing Information, » *Psychological Review*, t. 63, n° 2, p. 81-97, 1956.

[55] Ministère des Finances du Cameroun, *Régime financier de l'État et des autres entités publiques*, Collection « Les essentiels de la réforme », présentation de la loi n° 2018/012 du 11 juillet 2018, MINFI, Yaoundé, 2023.

[56] T. E. Minka Mi Nguidjoï. « Modelling epistemic uncertainty in information systems audit: A trichotomous response instrument and its information-theoretic properties. » Prépublication, licence CC BY-NC 4.0. HAL : hal-05701270. (22 juill. 2026), adresse : https://hal.science/hal-05701270.

[57] T. E. Minka Mi Nguidjoï. « Vers l'auditologie : un agenda de recherche en science du design pour une science appliquée de la réduction de l'incertitude dans l'audit des systèmes d'information. » Prépublication, licence CC BY-NC 4.0. HAL : hal-05701007. (22 juill. 2026), adresse : https://hal.science/hal-05701007.

[58] J. F. Nash, « Non-Cooperative Games, » *Annals of Mathematics*, t. 54, n° 2, p. 286-295, 1951.

[59] National Institute of Standards and Technology, « Artificial Intelligence Risk Management Framework (AI RMF 1.0), » NIST, NIST AI 100-1, 2023.

[60] National Institute of Standards and Technology, « The NIST Cybersecurity Framework (CSF) 2.0, » National Institute of Standards et Technology, Cybersecurity White Paper NIST CSWP 29, 2024.

[61] J. von Neumann et O. Morgenstern, *Theory of Games and Economic Behavior*. Princeton University Press, 1944.

[62] J. R. Norris, *Markov Chains*. Cambridge University Press, 1998.

[63] PCI Security Standards Council, *Payment Card Industry Data Security Standard (PCI DSS), Version 4.0*, PCI SSC, 2022.

[64] *Sarbanes-Oxley Act of 2002, Public Law 107-204*, 116 Stat. 745, États-Unis, 30 juill. 2002.

[65] C. E. Shannon, « A Mathematical Theory of Communication, » *Bell System Technical Journal*, t. 27, n° 3–4, p. 379-423, 623-656, 1948.

[66] H. A. Simon, *Models of Man: Social and Rational*. John Wiley & Sons, 1957.

[67] G. Simondon, *Du mode d'existence des objets techniques*. Paris : Aubier, 1958.

[68] The Institute of Internal Auditors, *Cadre de référence international des pratiques professionnelles de l'audit interne (CRIPP), édition 2017 : Normes et Code de déontologie*, IIA, 2017.

[69] The Institute of Internal Auditors, *The IIA's Three Lines Model: An Update of the Three Lines of Defense*, IIA, 2020.

[70] The Institute of Internal Auditors, *Global Internal Audit Standards*, IIA, Lake Mary, FL, 2024.

[71] The Open Group. « Open FAIR Body of Knowledge: Risk Taxonomy (O-RT) Standard, version 3.0.1, and Risk Analysis (O-RA) Standard, version 2.0.1. » Page du programme de certification, consultée pour les versions en vigueur. (2026), adresse : https://www.opengroup.org/certifications/openfair (visité le 05/11/2026).

[72] U.S. Securities and Exchange Commission, *In the Matter of Knight Capital Americas LLC: Order Instituting Administrative and Cease-and-Desist Proceedings*, Securities Exchange Act Release No. 70694, File No. 3-15570, 16 oct. 2013.

[73] UNESCO, *Recommandation sur l'éthique de l'intelligence artificielle*, Organisation des Nations unies pour l'éducation, la science et la culture, Paris, 2021.

INDEX

Acceptation du risque, 61
acceptation du risque, 61
Appétence au risque, 25, 41
appétence au risque, 25, 41
attributs, 131
attributs de mesure, 131
Audit, 98
audit, 98
audit continu, 218
Auditologie, 226
auditologie, 226

base commune de contrôles, 143
base de preuve, 43
Bien support, 37
bien support, 37

Certificat, 6
certificat, 6
Conclusion d'audit, 98
conclusion d'audit, 98
Conformité, 6
conformité, 6
Constat d'audit, 98
constat d'audit, 98
contradictoire, 104
contrôle continu de la conformité, 195
Couple SR/OV, 72
couple SR/OV, 72
Criticité, 40
criticité, 40
Critère d'audit, 98
critère d'audit, 98
critères d'acceptation, 56
Critères d'acceptation du risque, 56

Direction, 22
direction, 22
divergence de Kullback-Leibler, 229

Déclaration d'applicabilité, 132
déclaration d'applicabilité, 132

Entropie, 115
entropie, 9, 115
estimation calibrée, 86
estimations calibrées, 86
export figé, 179
exports figés, 179

FAIR, 85
fiche d'assertion, 114

gabarit canonique, 112
Gestion des risques, 21
gestion des risques, 21
Gouvernance de la sécurité, 21
gouvernance de la sécurité, 21
Gouvernance, risque et conformité, 21
GRC, 21

Incertitude aléatoire, 42
incertitude aléatoire, 42
Incertitude épistémique, 42
incertitude épistémique, 42
indicateur de risque, 194

Matrice RACI, 27
matrice RACI, 27
Matrice risques-contrôles, 193
matrice risques-contrôles, 193
Menace, 37
menace, 37
Mission auditologique, 226
mission auditologique, 226
modèle des trois lignes, 24

Non-conformité majeure, 171
non-conformité majeure, 171
Non-conformité mineure, 171

non-conformité mineure, 171

Objectif visé, 37
objectif visé, 37
Organe de direction, 22
organe de direction, 22

Piste de progrès, 171
piste de progrès, 171
Preuve d'audit, 98
preuve d'audit, 98
Propriétaire de risque, 25
propriétaire de risque, 25
Périmètre de complaisance, 7
périmètre de complaisance, 7

rapport d'assurance, 142
Registre des obligations, 191
registre des obligations, 191
Risque, 36
risque, 36
Risque (au sens de FAIR), 85
Risque cyber, 36
risque cyber, 36
Risque inhérent, 41
risque inhérent, 41
Risque résiduel, 41
risque résiduel, 41

Scénario, 37
scénario de risque, 37
Scénario opérationnel, 76
scénario opérationnel, 76
Scénario stratégique, 74
scénario stratégique, 74
simulation de Monte-Carlo, 88
SMSI, 6
Source de risque, 37
source de risque, 37
Système de management de la sécurité de l'information, 6
Sécurité effective, 6
sécurité effective, 6

Table de correspondance, 143
table de correspondance, 143
Taux d'incertitude, 115
taux d'incertitude, 9, 115
Taux de conformité, 115
taux de conformité, 9, 115

Valeur métier, 37
valeur métier, 37
Vulnérabilité, 37
vulnérabilité, 37

Échantillon raisonné, 102
Événement redouté, 37
échantillon aléatoire, 102
échantillonnage, 102
événement redouté, 37

À propos de ce cours

Un certificat n'est pas une preuve de sécurité, et une analyse de risque sans preuve n'est qu'une opinion chiffrée. Ce cours enseigne à appliquer les normes, à gérer les risques et à auditer la cybersécurité, en disant toujours ce que l'on sait, comment on le sait, et ce que l'on ignore.

Il progresse en six parties, précédées d'un prologue : la gouvernance et le risque, les méthodes (ISO/IEC 27005, EBIOS Risk Manager, FAIR, audit), le cadre normatif et juridique, la pratique (SMSI, audit technique, GRC, études de cas), les défis avancés et la recherche en auditologie.

Il s'adresse aux étudiants du Master Professionnel en Sécurité des Systèmes Numériques et aux professionnels qui exercent comme RSSI, auditeurs en cybersécurité, gestionnaires des risques cyber ou responsables GRC.

MINKA MI NGUIDJOÏ Thierry Emmanuel

CISA · CISM · CGEIT · CRISC · CDPSE · ISO 27001 · ISO 22301 · ISO 9001

Chercheur au laboratoire d'Ingénierie Mathématiques et des Systèmes d'Information

Chercheur | Cryptologue | Auditeur Senior | Expert Judiciaire | GRC & Sécurité de l'Information